MODULE 00 · EXAM STRATEGY - ALL DOMAINS

AWS Certified DevOps Engineer – Professional

DOP-C02. How this course works, what the exam really tests, and how to get the most from the next nine hours.

DOMAIN All six EXAM WEIGHT 100% MODULE 0 of 34

admin@sthithapragna.com

This exam rarely asks what a service **does**. It asks you to **choose** between options that all work, using one detail in the question.

admin@sthithapragna.com

The exam, in facts

ITEM	DETAIL
Questions	75: 65 scored, 10 unscored that you cannot identify
Time	180 minutes, about 2.4 minutes per question
Types	Multiple choice, and multiple response: choose two or three
Score	Scaled 100 to 1,000; 750 to pass; compensatory across domains
Guessing	No penalty: never leave a question blank

ON THE EXAM

Compensatory scoring means a weaker domain can be offset by stronger ones. Every question counts the same.

Six domains, and where they are taught

DOMAIN	WEIGHT	MODULES	WORKED SCENARIOS
1 SDLC Automation	22%	2 to 8	32
2 Configuration Management and IaC	17%	9 to 13	24
3 Resilient Cloud Solutions	15%	14 to 16	22
4 Monitoring and Logging	15%	17 to 20	24
5 Incident and Event Response	14%	21 to 23	20
6 Security and Compliance	17%	24 to 27	24

ON THE EXAM

Domain 1 is the largest, and its pipeline ideas return in every other domain.

The shape of the course

01

Module 1

The mental model: how one change flows through AWS.

02

Modules 2 to 27

The six domains, each with worked scenarios.

03

Modules 28 to 30

Exam skills: confusion pairs, question writing, what changed.

04

Modules 31 to 34

Four practice exams, 80 questions.

ON THE EXAM

Watch in order. Later modules assume vocabulary and patterns from earlier ones.

How every teaching module is built

PART	WHAT IT DOES
The mental model	One idea that organises everything in the module
Teaching slides	Services and features, with dates where they changed
Tiebreakers	The one question that separates two similar options
Worked scenarios	Exam-style questions, every option explained
Five-line summary	What to remember, in five sentences

ON THE EXAM

The tiebreakers are the most exam-relevant slides in the course. They reappear together in module 28.

How to use the worked scenarios

- When 'Pause and decide' appears, **pause the video** and commit to an answer.
- The walkthrough explains why the right answer wins, and why **each wrong option** fails.
- After a miss, ask: was it a **knowledge** error, or a **reading** error?
- Knowledge errors: rewatch the teaching slides. Reading errors: find the detail you missed.

> ON THE EXAM
>
> Recognising the right answer is easy. Choosing it before you see it is the skill the exam tests.

The catalogue has moved

- The exam guide predates many changes. Retired services can still appear as options.
- Slides titled **The catalogue has moved** flag each change where it comes up, with its date.
- On the exam, answer in the **guide's terms**. At work, use today's services.
- Module 30 lists every change in one place.

> ON THE EXAM
>
> Verified against AWS documentation, September 2026. Check retirement dates the week you sit the exam.

The practice exams

FEATURE	DETAIL
Papers	Four, of 20 questions each, all new
Weighting	Across all 80 questions, matching the domain weights
Multiple response	17 questions, about the real exam's rate
After each question	A pause, then a full worked solution
Scoring	By domain, with the module to revisit for each miss

ON THE EXAM

Score each paper by domain, not only in total. A domain weak on two papers is your priority.

A study plan that works

- Two or three modules a day completes the teaching in about two weeks.
- Take practice exam 1 after module 30, and score it by domain.
- Revisit weak domains, then take the next paper. Leave days between papers.
- The night before: rewatch Confusion Pairs and The Revision Gap.

> ON THE EXAM
>
> If you score 16 out of 20 or more consistently, you are ready to book.

Before you start

- The exam is aimed at engineers with hands-on experience operating AWS.
- You should already know core services such as EC2, S3, IAM and VPC at associate level.
- No lab account is required, but trying features yourself makes them stick.
- This course is not affiliated with or endorsed by Amazon Web Services.

> ON THE EXAM
>
> Where AWS documentation is unclear, or has moved on since the guide, the course says so.

Module 0 in five lines

- The exam tests decisions between working options, decided by one planted detail.
- Six domains, taught in modules 2 to 27, with 160 worked scenarios.
- Pause at every scenario; name each miss as knowledge or reading.
- Answer in the guide's terms; module 30 tracks what has changed.
- Four practice exams at the end. Score by domain; book at 16 or more.

> ON THE EXAM
>
> Next, module 1: how a release flows through AWS, the mental model for everything that follows.

MODULE 01 · EXAM STRATEGY - ALL DOMAINS

How a Release Flows Through AWS

One change, followed from a laptop to production and back out again. Every question on this exam is a moment somewhere on that journey.

DOMAIN All six EXAM WEIGHT 100% MODULE 1 of 34

admin@sthithapragna.com

Every DOP question is a moment in the life of **one change**. Find the moment, and the answer narrows itself.

The loop

01
Commit
A change lands in Git and something notices.

02
Build
Compile, package, scan. One immutable artifact.

03
Test
Prove it at the right stage, cheaply first.

04
Deploy
Move traffic to it without an outage.

05
Observe
Metrics, logs, traces and events.

06
Respond
Roll back, remediate, or scale. Automatically.

ON THE EXAM

Respond feeds back into Commit. The exam rewards loops that close themselves without a human.

Where the six domains sit on the loop

DOMAIN	WEIGHT	WHERE IT LIVES
D1 SDLC Automation	22%	Commit, build, test, deploy
D2 Configuration and IaC	17%	Underneath everything: how it all gets created
D3 Resilient Cloud Solutions	15%	Around deploy: surviving load and failure
D4 Monitoring and Logging	15%	Observe
D5 Incident and Event Response	14%	Respond
D6 Security and Compliance	17%	Across every stage, and every account

ON THE EXAM

Domain 1 is the single largest domain, but Domains 2 and 6 together outweigh it. Neither sits at one point on the loop.

The exam's real vocabulary

- **Lambda appears in 43% of questions.** Almost never as the topic. It is the glue between services.
- **EventBridge appears in 29%.** Event, rule, target is the most common shape on the paper.
- CloudWatch 26%, IAM 22%, CloudFormation 20%, Organizations 19%, CodePipeline 18%.
- **One question in five is multiple response.** Choose two, or choose three, with no partial credit.

> ON THE EXAM
>
> We used a bank of several hundred practice questions only to measure emphasis. No question from it appears in this course.

Three shapes that answer most questions

- **Event, rule, target.** Something happens, EventBridge matches it, a target acts: SNS, Lambda, an SSM runbook, a pipeline.
- **The managed feature beats the custom code.** If a service has a built-in switch, the Lambda-and-cron option is the distractor.
- **A role in the target, and a key the target can use.** Every cross-account failure is one or the other.

> ON THE EXAM
>
> Learn to recognise these three shapes and you will pre-sort most options before you have read them fully.

Where the pipeline lives

Log archive
Org CloudTrail, Config
Write once

Git provider
Via CodeConnections
Webhook starts the run

Security tooling
Delegated administrator
GuardDuty, Security Hub

Dev account
Deploy role to assume
First target

Tooling account
CodePipeline and CodeBuild
Artifact bucket and ECR
Customer managed KMS key
Builds happen here, and only here.

Staging account
Deploy role to assume
Tests at scale

Production
Deploy role to assume
Approval or alarms gate

ON THE EXAM

A 'central shared services account' in a question means the centre of this diagram.

Commit: how the loop starts

- Code lives in Git: GitHub, GitLab, Bitbucket, Azure DevOps, or CodeCommit.
- **CodeConnections** links an external provider to AWS. It used to be called CodeStar Connections.
- A **push to main** usually starts the release pipeline. A **pull request** usually starts a test-only build.
- Polling a repository on a timer is the legacy answer. Webhooks and events are the current one.

> ON THE EXAM
>
> CodeConnections was renamed from CodeStar Connections. The CodeStar service itself was discontinued in July 2024.

Build: one artifact, built once

- **CodeBuild** runs the build in a fresh, disposable container, driven by a buildspec file.
- The output is **one immutable artifact**: a zip in S3, an image in ECR, a package in CodeArtifact.
- That same artifact is promoted through dev, staging and production. It is never rebuilt per environment.
- Secrets never sit in the buildspec in plain text. They come from Secrets Manager or Parameter Store.

> ON THE EXAM
>
> Build once, promote many. An option that rebuilds for production has quietly broken the guarantee that you tested what you ship.

Reading a buildspec

```
1  version: 0.2
2  env:
3    secrets-manager:
4      NPM_TOKEN: prod/build/npm:token
5  phases:
6    install:
7      commands: [npm ci]
8    build:
9      commands: [npm test, npm run build]
10 artifacts:
11   files: ['dist/**/*', 'appspec.yml']
```

3-4 The secret is fetched at run time. The file holds only its name.

9 A failing test returns a non-zero exit code, and the build fails.

ON THE EXAM

The build fails because a command exits non-zero. That single rule is how tests gate a pipeline.

Mutable or immutable?

MUTABLE, OR IN-PLACE

Change the servers you have

- Same instances, new code copied on
- Cheap: no extra capacity
- Drift accumulates over time
- Rollback means redeploying the old version

IMMUTABLE

Replace the servers entirely

- New instances or tasks from a new image
- Costs extra capacity while both exist
- Every server is identical to its image
- Rollback means sending traffic back

THE TIEBREAKER

Fastest, safest rollback points to immutable. Lowest cost with no spare capacity points to in-place.

The deployment strategies, in one table

STRATEGY	WHAT HAPPENS	CAPACITY DURING	ROLLBACK
All at once	Every target updated together	Outage possible	Slow redeploy
Rolling	Batches updated in turn	Reduced	Slow redeploy
Rolling, extra batch	New batch first, then roll	Full	Slow redeploy
Immutable	New fleet, then swap	Double, briefly	Fast
Blue/green	New environment, move traffic	Double	Fastest
Canary	Small slice first, then the rest	Double	Fast, little exposure
Linear	Equal steps on a timer	Double	Fast, little exposure

ON THE EXAM

Canary and linear are traffic-shifting flavours of blue/green. Module 07 covers which platforms offer which.

Observe: four kinds of signal

- **Metrics** say something is wrong. CloudWatch, with alarms on thresholds or anomalies.
- **Logs** say what happened. CloudWatch Logs, queried with Logs Insights or Athena.
- **Traces** say where, across services. X-Ray and OpenTelemetry.
- **Events** say something changed. CloudTrail, AWS Health, service events on EventBridge.

> ON THE EXAM
>
> Match the signal to the question: 'which service is slow' wants traces; 'who changed it' wants CloudTrail.

The loop closing itself

01
Deploy
New version takes a slice of traffic.

02
Alarm
5xx errors breach the threshold.

03
Stop
The deployment tool halts the rollout.

04
Revert
Traffic returns to the last good version.

05
Notify
An event tells the team what happened.

ON THE EXAM

Nobody clicked anything. That is the design the exam is looking for.

Respond: when it is not a deployment

- An **EventBridge rule** matches the event and invokes a target.
- Targets that fix things: an **SSM Automation runbook**, a Lambda function, a Step Functions workflow.
- **AWS Config** detects a resource out of policy and can remediate it automatically.
- A person reading an email and running a script is the answer the exam wants you to replace.

> ON THE EXAM
>
> Known problem, known fix: automate it with a runbook. Unknown problem: better signals and a human.

Every station is itself infrastructure

- Pipelines, alarms, rules and accounts are defined as code: CloudFormation, CDK or SAM.
- **StackSets** and **Control Tower** stamp the same baseline into every account and Region.
- Systems Manager keeps the servers themselves in their desired state, and patched.
- Console clicks create drift. The exam treats manual change as the root cause, not the fix.

> ON THE EXAM
>
> If a question describes the same thing being set up by hand in many accounts, the answer is a template deployed at scale.

ALL DOMAINS / ACROSS EVERYTHING

Security at every station

- Each stage runs under its **own role** with only the permissions that stage needs.
- Artifacts crossing accounts are encrypted with a **customer managed KMS key** the targets can use.
- Images and dependencies are **scanned** before they are promoted, not after.
- Guardrails such as **SCPs** and **CloudFormation Hooks** stop bad changes before they exist.

> ON THE EXAM
>
> Preventive beats detective when the question says 'ensure' or 'prevent'. Detective fits 'identify' or 'report'.

Lambda as glue, or Lambda as a trap?

THE RIGHT ANSWER

Connecting what nothing else connects

- A rule target that transforms or decides
- A custom resource, or a lifecycle hook
- Only where no native integration exists
- Short, event-driven, stateless

THE DISTRACTOR

Rebuilding a feature that exists

- A scheduled Lambda polls for a condition
- Custom code does a service's own job
- More to write, test and maintain
- Loses on LEAST operational overhead

THE TIEBREAKER

Before choosing a Lambda option, ask: does the service already have a switch for this? If yes, choose the switch.

The qualifier decides between working answers

WHEN THE QUESTION SAYS	IT IS REALLY ASKING FOR
LEAST operational overhead	The most managed option, even if it costs more
MOST operationally efficient	Fewest moving parts to run and maintain
MOST cost-effective	Cheapest that still meets every stated requirement
LEAST development effort	Configuration over code
Ensure, prevent	A preventive control, applied before the change

ON THE EXAM

On a professional exam several options usually work. The qualifier is what separates them. Module 29 goes deeper.

A warning before we start: the catalogue has moved

IN THE EXAM GUIDE	WHAT HAPPENED
AWS OpsWorks	End of life, May 2024. Systems Manager replaces it
AWS CodeStar	Discontinued, July 2024
AWS Copilot CLI	End of support, June 2026
AWS Proton	End of support, 7 October 2026
AWS App Runner	Closed to new customers, April 2026
CodeDeploy for ECS blue/green	Still valid, but ECS now does it natively

THE RULE

Answer from the exam guide, and know the reality. Module 30 covers every gap with dates.

A team deploys a web application to EC2 instances behind an Application Load Balancer, using a pipeline with a CodeDeploy deployment stage. Last week a release with a bug reached every instance.

Customers saw errors for 40 minutes until an engineer noticed a dashboard and manually redeployed the previous revision. The team wants bad releases reversed automatically, with the least operational overhead.

What should the team do?

A. EventBridge rule on the ALB error alarm invokes a Lambda function that redeploys the previous revision

B. CloudWatch alarm on ALB 5xx errors attached to the deployment group, with automatic rollback enabled

C. Manual approval action before the production stage

D. More unit tests in CodeBuild, so the bug fails the build

◆ PAUSE AND DECIDE

What should the team do?

A. EventBridge rule and Lambda redeploy

It would work, but it rebuilds with custom code a rollback CodeDeploy already offers. Loses on least overhead.

B. Alarm on the deployment group, automatic rollback

CodeDeploy stops the deployment when the alarm fires and returns to the last good revision. A setting, not a system.

C. Manual approval before production

A human cannot see a runtime bug by approving a stage. And the requirement was automatic.

D. More unit tests

Worth doing, but it moves the problem to the build station. It reverses nothing once a bug does escape.

THE SIGNAL

Place it on the loop first: this is respond, fed by observe. Then pick the native switch over the Lambda.

A company runs its pipeline in a central tooling account. Artifacts go to an S3 bucket encrypted with the default AWS managed key for S3.

A new deploy stage assumes a role in the production account. The build succeeds, but the production deployment fails with an access denied error when it reads the artifact. The bucket policy already grants the production role s3:GetObject.

What will fix the deployment?

A Move the pipeline into the production account so that no cross-account access is needed

B Disable default encryption on the artifact bucket

C Encrypt artifacts with a customer managed KMS key whose key policy allows the production role to decrypt

D Add s3:GetObject for the production role to the pipeline's own service role

◆ PAUSE AND DECIDE

What will fix the deployment?

A **Move the pipeline into production**

Abandons the central tooling account and puts build rights inside production. It fixes the error by breaking the design.

B **Disable default encryption**

Amazon S3 encrypts every new object regardless. And weakening protection is never the intended fix.

C **Customer managed KMS key the role can use**

The bucket already allowed the read. The key did not. An AWS managed key's policy cannot be edited to admit another account.

D **Permission on the pipeline's own role**

The wrong principal. The production role is doing the read, and it already has S3 permission.

THE SIGNAL

S3 permission present, still access denied, bucket encrypted: the key is the problem. Remember shape three.

Where the course goes from here

- **Modules 2 to 8:** the loop's first half. Pipelines, builds, tests, artifacts, deployment.
- **Modules 9 to 13:** underneath. CloudFormation, CDK, accounts, fleets.
- **Modules 14 to 23:** surviving, watching and responding.
- **Modules 24 to 27:** security across it all. Then confusion pairs, exam technique and four practice papers.

> ON THE EXAM
>
> Every scenario from here on: place it on the loop, spot the shape, then read the qualifier.

MODULE 02 · DOMAIN 1 - SDLC AUTOMATION

Pipeline Anatomy

How CodePipeline starts, what it runs, how it queues, and how it decides to stop, skip or roll back a stage.

DOMAIN 1 of 6 EXAM WEIGHT 22% MODULE 2 of 34

admin@sthithapragna.com

A pipeline is a conveyor belt for **revisions**. Most questions are really asking what happens when two revisions are on the belt at once.

Pipeline, stage, action, artifact

01
Pipeline
The whole release process, one per service or repo.

02
Stage
A named step. One execution at a time, unless PARALLEL.

03
Action
The work: build, test, deploy, approve, invoke.

04
Artifact
Files passed between actions, stored in S3.

05
Variable
Values passed between actions, such as a commit ID.

ON THE EXAM

Actions with the same run order inside a stage run in parallel. Different run orders run in sequence.

Action categories, and what plugs into each

CATEGORY	COMMON PROVIDERS
Source	CodeConnections (GitHub, GitLab, Bitbucket), CodeCommit, S3, ECR
Build	CodeBuild, Commands, ECRBuildAndPublish
Test	CodeBuild, Device Farm, third-party tools
Deploy	CodeDeploy, ECS, CloudFormation, Elastic Beanstalk, S3, Lambda, EC2
Approval	Manual approval
Invoke	Lambda, Step Functions, another CodePipeline pipeline

ON THE EXAM

If a scenario needs a step no provider covers, the answer is usually an Invoke action or CodeBuild running a script.

V1 or V2?

V2 TYPE

The current pipeline

- Git triggers with branch, tag and path filters
- QUEUED and PARALLEL execution modes
- Pipeline-level variables, stage conditions
- $0.002 per action-execution minute

V1 TYPE

The original pipeline

- Starts on any change to one branch
- SUPERSEDED mode only
- No stage conditions or pipeline variables
- $1 per active pipeline per month

THE TIEBREAKER

If a scenario needs any feature in the left column, the first step is converting the pipeline to V2.

How each source starts a pipeline

SOURCE	CHANGE DETECTION
GitHub, GitLab, Bitbucket	Webhook through CodeConnections. V2 triggers can filter it
CodeCommit	EventBridge rule on the repository
S3 object	EventBridge, with the bucket versioned and events recorded
ECR image	EventBridge rule on the image push
Anything else	Manual start, EventBridge schedule, or StartPipelineExecution

ON THE EXAM

Periodic polling is the legacy option for every source. Event-based detection is the answer the exam expects.

A V2 trigger, read line by line

```
1  "triggers": [{
2    "providerType": "CodeStarSourceConnection",
3    "gitConfiguration": {
4      "sourceActionName": "Source",
5      "push": [
6        { "branches":  { "includes": ["main"] },
7          "filePaths": { "includes": ["services/payments/**"] } },
8        { "tags": { "includes": ["v*"], "excludes": ["v*-rc*"] } }
9      ],
10     "pullRequest": [
11       { "events": ["OPEN", "UPDATED"], "branches": { "includes": ["main"] } }
12     ] } }]
```

6-7 One filter: main AND a path under payments. Both must match.

8 A second filter: release tags, excluding release candidates. Either filter starts a run.

ON THE EXAM

Filters are OR'd with each other. Conditions inside one filter are AND'd. Excludes always beat includes.

Trigger behaviour worth knowing

- A **push** run uses the commit on the branch pushed to. A **pull request** run uses the commit on the source branch.
- Adding any trigger **disables the default** change detection on the action's branch.
- A new branch's **first push** does not match a file-path filter: there is no list of changed files yet.
- Merging a pull request can start **two runs** if push and pull request filters overlap.
- Triggers exist only for **connection-based** sources. CodeCommit and S3 filter through EventBridge rules instead.

> ON THE EXAM
>
> A monorepo where one change starts every service's pipeline is solved by file-path filters, not by custom code.

Three execution modes

MODE	WHEN A NEWER RUN ARRIVES	USE IT WHEN
SUPERSEDED	The older run finishes its stage, then the newer one replaces it	Only the latest change matters
QUEUED	The newer run waits its turn; every run completes in order	Every change must deploy, in order
PARALLEL	Runs travel independently; stages are not locked	Fast, isolated feedback, such as pull requests

ON THE EXAM

SUPERSEDED is the default, and it can skip revisions entirely. That is a feature until a skipped commit carried a migration.

Picking the mode from the wording

CHOOSE QUEUED WHEN

Order and completeness matter

- Each deployment must finish before the next
- Every merged commit must reach production
- Infrastructure changes build on one another
- Typical for a main-branch release pipeline

CHOOSE PARALLEL WHEN

Speed of feedback matters

- Results for every pull request, quickly
- Runs target separate, isolated environments
- No shared state between runs
- Typical for a pull request pipeline

THE TIEBREAKER

Two pipelines, two modes: PARALLEL for pull requests, QUEUED for main. SUPERSEDED when 'only the latest' is stated.

Variables: passing values, not files

- **Source variables:** CommitId, BranchName, AuthorDate, and more, from the source action.
- **Action output variables** live in a **namespace** and are referenced as #{Namespace.Name}.
- CodeBuild **exports** variables from its buildspec for later actions to use.
- **Pipeline-level variables** (V2) take a value when the run starts, with a default.

> ON THE EXAM
>
> Artifacts carry files. Variables carry small values such as an image tag or a commit ID. Do not zip a single string.

An image tag, from build to deploy

```
1  # buildspec.yml
2  env:
3    exported-variables: [IMAGE_TAG]
4  phases:
5    build:
6      commands:
7        - export IMAGE_TAG=$(echo $CODEBUILD_RESOLVED_SOURCE_VERSION | cut -c1-8)
8
9  # later action, configuration field in the pipeline
10 "ImageTag": "#{BuildVariables.IMAGE_TAG}"
```

3 Declares which environment variable leaves the build.

10 BuildVariables is the namespace given to the build action.

ON THE EXAM

No namespace on the build action, no way to reference its variables. That is the usual reason the value arrives empty.

Manual approval

- Pauses the run. Can notify an **SNS topic** and include a **URL** for reviewers to check.
- Approvers need **codepipeline:PutApprovalResult** on that pipeline. Comments are recorded.
- Default timeout **7 days**. Now configurable per action, **5 minutes to 60 days**.
- It proves someone agreed. It cannot detect a runtime fault that has not happened yet.

> ON THE EXAM
>
> Change control or sign-off: approval action. Automatic protection from bad releases: alarms and rollback.

Stage conditions: three moments, several results

CONDITION	CHECKED	POSSIBLE RESULTS
Entry	Before the stage starts	Fail, or Skip
On Failure	When the stage has failed	Roll back, or Retry
On Success	After the stage has succeeded	Roll back, or Fail

ON THE EXAM

Each condition holds a set of rules. If any rule fails, the condition fails and its result engages.

The rules a condition can use

RULE	IT CHECKS	TYPICAL USE
`CloudWatchAlarm`	Is an alarm in ALARM?	Block or roll back on bad health
`DeploymentWindow`	Is now inside a cron window?	Only deploy in business hours
`VariableCheck`	Does a variable match?	Skip a stage for some branches
`LambdaInvoke`	Does a function return success?	Any custom check
`CodeBuild`	Does a build succeed?	Integration tests after deploy
`Commands`	Do shell commands exit zero?	A quick smoke test

ON THE EXAM

Only VariableCheck and LambdaInvoke can drive a Skip result. CodeBuild and Commands rules arrived in March 2025.

A health check after deploy, without code

```
"name": "Production",
"actions": [ ... ],
"onSuccess": {
  "conditions": [{
    "result": "ROLLBACK",
    "rules": [{
      "name": "ErrorRateAfterDeploy",
      "ruleTypeId": { "category": "Rule", "owner": "AWS",
                      "provider": "CloudWatchAlarm", "version": "1" },
      "configuration": { "AlarmName": "prod-5xx-rate", "WaitTime": "30" }
    }] }] }
```

5 If the rule fails, return the stage to the last successful execution.

10 If the alarm is firing when checked, allow 30 minutes for it to clear first.

ON THE EXAM

WaitTime is a grace period for an alarm already firing, not a watch window. If the alarm is OK, the rule passes at once.

Rollback and retry

- **Stage rollback** re-runs the stage with the source revisions of its last successful execution.
- Rollback only reaches executions from the **current pipeline structure**. Edit the pipeline, lose the history.
- **Retry** re-runs the failed actions, or the whole failed stage, on the same revision.
- Rollback redeploys an older artifact. It does **not** revert your Git history.

> ON THE EXAM
>
> Transient failure, same code: retry. Bad code that deployed: roll back, then fix forward in Git.

Two rollbacks at two levels

INSIDE THE DEPLOY ACTION

CodeDeploy or ECS rollback

- Alarm fires during the traffic shift
- Traffic returns within the same deployment
- Configured on the deployment group or service
- Catches problems while traffic is moving

AROUND THE STAGE

CodePipeline stage rollback

- Evaluated when the stage completes
- Re-runs the stage with the last good revision
- Configured as a stage condition
- Catches a system unhealthy once it lands

THE TIEBREAKER

Problem while traffic is moving: deployment-level rollback. Unhealthy once the stage completes: a stage condition.

Invoking custom work

- A **Lambda invoke** action must call **PutJobSuccessResult** or **PutJobFailureResult**.
- With no reply after **20 minutes**, the action times out and fails, even if the function succeeded.
- A **Step Functions** invoke action suits longer, multi-step work. Default timeout 7 days.
- The **Commands** action runs shell commands on managed compute without a CodeBuild project.

> ON THE EXAM
>
> A Lambda action 'stuck in progress' with a successful function log is almost always a missing job-result call.

Watching the pipeline itself

- Pipeline, stage and action **state changes** are sent to EventBridge automatically.
- A rule on FAILED can notify **SNS**, open an OpsCenter item, or start a runbook.
- **Notification rules** in the console send the same events to SNS or chat channels.
- CloudTrail records who **changed** or started a pipeline. It is not how you watch runs.

> ON THE EXAM
>
> 'Notify the team when any production deployment fails' is an EventBridge rule on the pipeline state change event.

A company deploys database schema changes and application code through a V2 pipeline on its main branch. Developers merge several times an hour.

Last week a newer run overtook an older one, so the older commit's migration never ran and the next release failed. The company requires every merged commit to be deployed, in order, with each deployment finishing before the next begins.

What should the company change?

A Set the pipeline's execution mode to PARALLEL

B Disable the transition into the deploy stage during business hours

C Set the pipeline's execution mode to QUEUED

D Keep SUPERSEDED mode and add a manual approval before deployment

◆ PAUSE AND DECIDE

What should the company change?

A PARALLEL

Runs would no longer be skipped, but they would deploy concurrently and out of order. Exactly what a migration cannot tolerate.

B Disable the transition by day

Queues nothing and orders nothing. It just delays the same problem until evening.

C QUEUED

Newer runs wait their turn, every run completes, and they complete in order. One setting.

D SUPERSEDED plus approval

The approver cannot stop a waiting run from superseding an older one. The mode is the cause.

THE SIGNAL

'Every commit', 'in order', 'finish before the next': three phrases, one mode.

A team keeps two services, payments and search, in one GitHub repository connected through CodeConnections. Each service has its own V2 pipeline.

Every commit starts both pipelines, even when only one service changed, which wastes action minutes and causes needless production deployments. The team wants each pipeline to run only for its own service's changes, with the least effort.

What should the team do?

A Add a push trigger to each pipeline with a file-path filter for that service's folder

B Route the GitHub webhook to a Lambda function that inspects changed files and starts the right pipeline

C Split the repository into one repository per service

D Add an entry condition with a VariableCheck rule that skips the deploy stage when the service is unchanged

◆ PAUSE AND DECIDE

What should the team do?

A File-path filter per pipeline

The run never starts for the other service's changes. No code, no wasted minutes, no deployment.

B Webhook to a Lambda router

Works, but rebuilds in custom code what V2 triggers already do. The Lambda trap from module 1.

C Split the repository

Solves it by restructuring the codebase. Far more effort than a trigger filter.

D VariableCheck skip on deploy

The run still starts, still builds, still costs minutes. It hides the waste rather than removing it.

THE SIGNAL

Monorepo, one pipeline per service, needless runs: file-path filters on V2 triggers.

During a recent incident, production was already degraded when a scheduled release started. The new deployment made diagnosis harder and extended the outage.

A CloudWatch alarm named prod-health already tracks production. The company wants the pipeline to refuse to start the production stage whenever that alarm is in ALARM, with the least operational overhead.

What should a DevOps engineer configure?

A. A Lambda invoke action at the start of the stage that checks the alarm

B. A manual approval before production, with reviewers told to check the dashboard

C. EventBridge rules that disable the stage transition on ALARM and re-enable it on OK

D. An entry condition on the production stage with a CloudWatchAlarm rule and a Fail result

◆ PAUSE AND DECIDE

What should a DevOps engineer configure?

A **Lambda check action**

Works, but it is code to write, permission, and maintain, including the job-result calls. A built-in rule does this.

B **Manual approval**

Relies on a person noticing, and blocks every release, healthy or not. Not automatic.

C **EventBridge toggling the transition**

Clever and genuinely workable, but two rules and a race between them. More moving parts than needed.

D **Entry condition, CloudWatchAlarm rule, Fail**

Exactly this feature's purpose: check health before entry, refuse if unhealthy. Pure configuration.

THE SIGNAL

'Refuse to start the stage when' describes an entry condition. The alarm already exists, so it is one rule.

A pipeline stage runs a Lambda invoke action that performs a smoke test against staging. The function's logs show it completes successfully in about four seconds.

Even so, the action stays In Progress for about 20 minutes and then fails with a timeout. The function's own timeout is set to 60 seconds.

What is the most likely cause?

A The function cannot read the input artifact from the artifact bucket

B The function never calls PutJobSuccessResult, so CodePipeline receives no result

C The function's 60-second timeout is too short for a smoke test

D The pipeline is in QUEUED mode, so the action waits for an earlier run

◆ PAUSE AND DECIDE

What is the most likely cause?

A Cannot read the artifact

The function would log an access error and fail, not finish successfully in four seconds.

B No PutJobSuccessResult call

The function finishes, but CodePipeline hears nothing. After 20 minutes without a reply the action times out.

C Function timeout too short

It finished in four seconds. A 60-second limit was never reached.

D QUEUED mode

Queued runs wait at the stage entrance, not inside a running action.

THE SIGNAL

Function succeeds, action hangs, then times out at 20 minutes: the job result was never reported.

Module 2 in five lines

- V2 for triggers, execution modes, variables and stage conditions.
- SUPERSEDED skips, QUEUED orders, PARALLEL isolates.
- Events start pipelines. Polling is the legacy answer. Path filters tame monorepos.
- Entry, On Failure, On Success: health gates and automatic stage rollback without code.
- Lambda invoke actions must report a job result, or they time out at 20 minutes.

> ON THE EXAM
>
> Next, module 3: inside the build action itself. CodeBuild, the buildspec, and where secrets and caches come from.

MODULE 03 · DOMAIN 1 - SDLC AUTOMATION

CodeBuild in Depth

The buildspec, what runs when a phase fails, where secrets come from, how builds reach private networks, and how to make them fast.

DOMAIN 1 of 6 EXAM WEIGHT 22% MODULE 3 of 34

admin@sthithapragna.com

A build is a **clean room** that exists for minutes. Everything it needs must be brought in. Everything worth keeping must be carried out.

The life of one build

01
Queued
Waits for capacity.

02
Provisioning
Container starts from the build image.

03
Download source
Git clone or S3 fetch.

04
Your four phases
Install, pre-build, build, post-build.

05
Upload artifacts
Always attempted, even after a failed build.

06
Finalizing
Logs flushed, container destroyed.

ON THE EXAM

Only the middle box is yours. Queue and provisioning time are what Lambda compute and reserved fleets reduce.

What belongs in each phase

PHASE	TYPICAL WORK
`install`	Choose runtime versions. Install tools the image lacks.
`pre_build`	Sign in to ECR. Fetch dependencies. Lint.
`build`	Compile, run unit tests, build the image.
`post_build`	Push the image, package, notify.

> ON THE EXAM
>
> The phases are conventions until something fails. Then the phase a command lives in decides what happens next.

When a phase fails, by default

- A failure in **install** or **pre_build** ends the build. Nothing after it runs.
- A failure in **build** still runs **post_build**. Then artifacts upload is attempted.
- A **finally** block runs even when a command in its phase fails.
- **on-failure** overrides the default: ABORT, CONTINUE, or RETRY with a count and a pattern.

> ON THE EXAM
>
> RETRY variants are recent and run on EC2 compute only. On Lambda compute and reserved capacity, on-failure is ignored.

The post_build trap

```
1  phases:
2    build:
3      commands:
4        - npm test
5        - docker build -t $REPO:latest .
6    post_build:
7      commands:
8        - docker push $REPO:latest
9
10 # the fix: only push from a build that is still succeeding
11       - '[ "$CODEBUILD_BUILD_SUCCEEDING" = "1" ] && docker push $REPO:latest'
```

4, 8 Tests fail, the build phase fails, and post_build still runs the push.

11 CODEBUILD_BUILD_SUCCEEDING is 1 while the build is healthy, 0 once it has failed.

ON THE EXAM

A failed build that still published an image is almost always a push in post_build with no guard.

Getting values into the clean room

SOURCE	BUILDSPEC KEY	SUITABLE FOR SECRETS?
Plain variables	env: variables	No. Visible in the console and API
Parameter Store	env: parameter-store	Yes, as a SecureString
Secrets Manager	env: secrets-manager	Yes, with rotation
Project settings	Type PARAMETER_STORE or SECRETS_MANAGER	Yes, same stores
Built-in	CODEBUILD_* variables	Metadata such as build ID and commit

ON THE EXAM

A secret in a plain environment variable is exposed to anyone who can view the project. That option is always wrong.

Who the build is, and what it may touch

- Every build runs as the project's **service role**, not as the person who started it.
- Reading a secret needs the fetch permission **and** kms:Decrypt if a customer managed key encrypts it.
- Pushing to ECR needs ecr:GetAuthorizationToken plus the layer and image upload actions.
- Reaching another account means assuming a role there from inside the build.

> ON THE EXAM
>
> Access denied inside a build: fix the service role, or a key policy. Never the developer's own permissions.

Default network, or your VPC?

DEFAULT

AWS-managed network

- Internet access works out of the box
- Cannot reach private resources in your VPC
- Right for most builds
- Nothing to configure

VPC CONFIGURATION

ENIs in your subnets

- Reaches private RDS, caches, internal APIs
- Loses internet unless routed through NAT
- Needs private subnets and security groups
- Public subnets do not give it internet

THE TIEBREAKER

Build in a VPC cannot download packages: the subnets need a NAT gateway route, or VPC endpoints for AWS services.

Choosing compute

COMPUTE	STRENGTH	LIMITS
EC2, on demand	Everything works: Docker, root, caching	Queue and provisioning time
Lambda	Starts in seconds, billed per second	15 min, no Docker, no root, no cache
Reserved capacity fleet	Warm hosts, no provisioning wait	You pay while it is idle
Arm (Graviton)	Lower cost for compatible builds	Tools must support Arm
GPU	Machine learning and graphics builds	Higher cost

ON THE EXAM

Needs Docker, root or caching: EC2. Short, simple, frequent builds: Lambda. Consistent speed at scale: a reserved fleet.

Caching: four kinds

CACHE	WHERE IT LIVES	BEST FOR
S3	A bucket, shared by every host	Dependencies, infrequent builds
Local: source	On the build host	Large Git repositories
Local: Docker layer	On the build host	Image builds. Needs privileged mode
Local: custom	On the build host	Directories you name in the buildspec

ON THE EXAM

Local cache is best effort and host-bound: great for frequent builds, useless for rare ones. S3 cache always persists.

Building container images

- **Privileged mode** must be on for the Docker daemon to build images.
- Sign in to ECR in pre_build with a short-lived token from the service role.
- Tag with the commit or build ID, not only **latest**. Deployments should name an exact image.
- Lambda compute cannot build images at all. Windows cannot use privileged mode.

> ON THE EXAM
>
> 'Cannot connect to the Docker daemon' in the build log: privileged mode is off.

Carrying things out: artifacts

- One **primary** artifact, plus named **secondary artifacts** for separate outputs.
- **base-directory** sets the root; **discard-paths** flattens folder structure.
- Artifacts are encrypted with the project's KMS key. A customer managed key is needed for cross-account use.
- Inside CodePipeline, output goes to the pipeline's artifact store, not the project's own setting.

> ON THE EXAM
>
> One build, several separately deployable outputs: secondary artifacts. Not several projects, and not a Lambda to split a zip.

Carrying things out: test reports

- A **reports** section sends results to a **report group**, viewable per test with trends.
- Test formats include JUnit XML, Cucumber, NUnit, TestNG and Visual Studio TRX.
- Coverage formats include JaCoCo, Cobertura, Clover, SimpleCov and LCOV.
- Reports are still published when tests fail. That is when you need them.

> ON THE EXAM
>
> 'See which tests failed without reading logs' or 'track coverage over time': a report group, not a custom parser.

Starting builds without a pipeline: webhooks

- A project can have its own **webhook** on GitHub, GitLab or Bitbucket, and report status back.
- **Filter groups** decide which events build. Groups are OR'd; filters inside a group are AND'd.
- Every group needs an **EVENT** filter: PUSH, PULL_REQUEST_CREATED, PULL_REQUEST_MERGED, and more.
- Others: HEAD_REF, BASE_REF, FILE_PATH, COMMIT_MESSAGE, and **ACTOR_ACCOUNT_ID**.

> ON THE EXAM
>
> Pull request validation that reports a pass or fail to the pull request: a CodeBuild webhook. No pipeline needed.

Two filter groups

```
1 [
2   [ { "type": "EVENT",    "pattern": "PULL_REQUEST_CREATED, PULL_REQUEST_UPDATED" },
3     { "type": "BASE_REF", "pattern": "^refs/heads/main$" },
4     { "type": "ACTOR_ACCOUNT_ID", "pattern": "^(1001|1002|1003)$" } ],
5
6   [ { "type": "EVENT",    "pattern": "PUSH" },
7     { "type": "HEAD_REF", "pattern": "^refs/heads/main$" } ]
8 ]
```

2-4 Group 1: a pull request into main, AND opened by one of three maintainers.

6-7 Group 2: any push to main. Either group starts a build.

ON THE EXAM

On a public repository, anyone can open a pull request, and the build runs their code with your service role.

Webhook on CodeBuild, or trigger on CodePipeline?

CODEBUILD WEBHOOK

One build, status back to Git

- Validate a pull request before merge
- Pass or fail shown on the pull request
- No stages, no deployment
- Fastest feedback for developers

CODEPIPELINE TRIGGER

A full release

- Build, test, approve, deploy
- Artifacts promoted across stages
- Execution modes and stage conditions
- What runs after the merge

THE TIEBREAKER

Before merge: CodeBuild webhook, or a PARALLEL pull request pipeline. After merge: the release pipeline.

Batch builds: one definition, many builds

TYPE	WHAT IT DOES	EXAMPLE
Build list	Runs listed builds in parallel	Build for three platforms at once
Build matrix	Every combination of variables	Three runtimes by two operating systems
Build graph	Builds with dependencies between them	Libraries first, then services
Build fanout	Splits one test suite across builds	Shard 2,000 tests over ten builds

ON THE EXAM

'Test on several runtime versions from one project' is a build matrix. 'Tests take too long to run' can be fanout.

Runners: keep the workflow, change the compute

- CodeBuild can host **GitHub Actions**, GitLab and Buildkite runners.
- The workflow file stays in the repository. The job runs on CodeBuild, under its service role.
- GitHub jobs arrive through the **WORKFLOW_JOB_QUEUED** webhook event.
- No long-lived AWS access keys stored in the Git provider's secrets.

> ON THE EXAM
>
> 'Keep existing GitHub Actions workflows but run them in AWS with IAM, not stored keys': CodeBuild-hosted runners.

Watching and debugging builds

- Logs go to **CloudWatch Logs**, to **S3**, or both. Secret values are masked.
- Build and phase **state changes** go to EventBridge, like pipeline events.
- **Session Manager** can pause a running build so you can shell in and look around.
- Build timeout runs from 5 minutes to 36 hours. Queued builds have a separate timeout.

> ON THE EXAM
>
> Notify on failed builds: EventBridge. Interactive debugging of a failing build: Session Manager, not SSH keys.

> A buildspec runs unit tests and docker build in the build phase, then docker push with the latest tag in post_build. An ECS service deploys whatever image is tagged latest.
>
> Yesterday a build failed its unit tests, but a new image was still pushed and deployed, causing an outage. The team wants the smallest change that stops failed builds from publishing images.

What should the team change?

A. Move the docker push command into the install phase

B. Set on-failure: CONTINUE on the build phase

C. Add a finally block to the build phase that runs docker push

D. In post_build, push only when CODEBUILD_BUILD_SUCCEEDING equals 1

◆ PAUSE AND DECIDE

What should the team change?

A **Push in install**

Install runs before the image even exists. There would be nothing to push.

B **on-failure: CONTINUE**

Makes it worse: every later phase runs regardless. That is already why the push happened.

C **finally block pushes**

A finally block runs even when a command fails. It guarantees the broken push.

D **Guard on CODEBUILD_BUILD_SUCCEEDING**

The variable is 0 once the build has failed, so the push is skipped. One line.

THE SIGNAL

Build failed, image still published: post_build runs after a failed build phase. Guard it.

> An open-source project has a public GitHub repository. A CodeBuild webhook builds every pull request. The project's service role can read a Secrets Manager secret used to publish documentation.
>
> The security team is concerned that anyone can open a pull request containing code that prints the secret. Pull requests from the five maintainers must still be built automatically.

What should the DevOps engineer do?

A. Add an ACTOR_ACCOUNT_ID filter matching the maintainers' account IDs to the pull request filter group

B. Move the secret into a plaintext environment variable so CodeBuild masks it in logs

C. Run the build in private subnets with no route to the internet

D. Turn off CloudWatch Logs for the project so printed values are not stored

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A ACTOR_ACCOUNT_ID filter

Untrusted pull requests never start a build, so their code never runs with the role. Maintainers still build.

B Plaintext variable

Backwards. Plain variables are visible to anyone who can view the project, and are not masked.

C No internet route

The attacker's code still runs and can still read the secret. It also breaks dependency downloads.

D Turn off logs

The code could send the secret elsewhere. Hiding the evidence is not a control.

THE SIGNAL

Untrusted code with a trusted role: stop the build from starting, rather than limiting what it can do once running.

A team adds a VPC configuration to a CodeBuild project so integration tests can reach a private Amazon RDS database. The project uses two public subnets that route to an internet gateway.

Now the install phase times out while downloading npm packages. The database connection itself works.

How should the team fix the build?

A Enable privileged mode on the project

B Change the compute type to a larger size

C Use private subnets whose route table sends internet traffic through a NAT gateway

D Turn on auto-assign public IPv4 addresses for the two public subnets

◆ PAUSE AND DECIDE

How should the team fix the build?

A **Privileged mode**

Enables the Docker daemon. Nothing to do with network routing.

B **Larger compute**

A timeout here is a missing route, not a slow machine.

C **Private subnets via NAT**

Build interfaces never get public addresses, so internet traffic must leave through NAT. The database stays reachable.

D **Auto-assign public IPs**

The tempting fix, but CodeBuild's network interfaces do not receive public addresses. It changes nothing.

THE SIGNAL

VPC build, internet timeout, public subnets: the classic. CodeBuild in a VPC reaches the internet only through NAT.

> To cut queue and start-up time, a team moved all of its CodeBuild projects to Lambda compute. Short test builds are now much faster.
>
> However, every project that builds a container image now fails. The team wants image builds working again while keeping start-up time low.

What should the team do?

A Increase the memory allocated to the Lambda compute for the image projects

B Move only the image projects to EC2 compute on a reserved capacity fleet

C Enable privileged mode on the Lambda compute image projects

D Enable a local Docker layer cache on the Lambda compute image projects

◆ PAUSE AND DECIDE

What should the team do?

A More Lambda memory

Lambda compute cannot run Docker at any size. Memory is not the constraint.

B Image projects to a reserved EC2 fleet

EC2 compute supports Docker. Warm reserved hosts remove the provisioning wait. Test builds stay on Lambda.

C Privileged mode on Lambda

Not supported on Lambda compute. The setting that fixes Docker on EC2 does not exist here.

D Docker layer cache on Lambda

Lambda compute supports no caching, and a cache cannot help a build that cannot run Docker.

THE SIGNAL

Lambda compute fails at Docker, root tools, caching and anything over 15 minutes. Split the workload, do not abandon Lambda.

Module 3 in five lines

- A failed build phase still runs post_build. Guard pushes with CODEBUILD_BUILD_SUCCEEDING.
- Secrets come from Parameter Store or Secrets Manager, fetched by the service role, never plaintext.
- VPC builds reach the internet only through NAT. Public subnets do not help.
- Lambda compute is fast but has no Docker, root, cache, or builds over 15 minutes.
- Filter groups: OR between groups, AND within. ACTOR_ACCOUNT_ID protects public repositories.

> ON THE EXAM
>
> Next, module 4: testing in the pipeline. Which tests run where, how they gate a release, and how to test at scale.

MODULE 04 · DOMAIN 1 - SDLC AUTOMATION

Testing in the Pipeline

Which tests run at which stage, how a test actually stops a release, and how to test security, load, resilience and production itself.

DOMAIN 1 of 6 EXAM WEIGHT 22% MODULE 4 of 34

admin@sthithapragna.com

A test only protects a pipeline if its failure **stops the pipeline**. Everything else is a report nobody reads.

Which tests run where

STAGE	TESTS	WHY HERE
Pull request	Lint, unit, SAST, secrets scan	Seconds to run; fix before merge
Build	Unit, coverage, dependency and image scans	Every artifact checked once
Staging	Integration, API, UI, load, dynamic scans	Needs a running, realistic system
Production	Smoke tests, synthetic canaries, alarms	Proves the real thing is healthy

ON THE EXAM

Cheap and fast tests run first. A slow test placed before a fast one wastes every failing run's time.

How a failing test stops a release

01
Test runner
One test fails. The runner exits non-zero.

02
Command
CodeBuild sees the non-zero exit code.

03
Phase and build
The phase fails, so the build fails.

04
Action and stage
The pipeline action fails, then the stage.

05
Release halted
Later stages never start.

ON THE EXAM

Every link is an exit code. Break any one of them and a failing test becomes invisible to the pipeline.

Three ways to swallow an exit code

```
1  # 1. Explicitly ignored
2  - npm test || true
3
4  # 2. Lost in a pipe: tee succeeds, so the line succeeds
5  - pytest | tee results.txt
6
7  # 3. Run in the background, never waited for
8  - ./integration-tests.sh &
9
10 # Fix for 2: run under bash (env: shell: bash), then fail the pipe on any failure
11 - set -o pipefail && pytest | tee results.txt
```

5 A pipe's exit status is the last command's. tee always succeeds.

11 pipefail is a bash option: the pipe returns the first failing command's status.

ON THE EXAM

'Tests fail but the build passes' is a diagnosis question. Look for a pipe, an || true, or a background job.

Where a test can sit in CodePipeline

MECHANISM	BEHAVIOUR ON FAILURE	GOOD FOR
CodeBuild test action	Fails the stage	Unit, integration, load tests
Parallel test actions	Same run order, any failure fails the stage	Independent suites at once
Device Farm action	Fails the stage	Mobile apps on real devices
CodeBuild or Commands rule	Condition fails: roll back or block entry	Tests after a deploy
Lambda or Step Functions invoke	Reports job failure	Custom checks

ON THE EXAM

Independent suites taking too long in sequence: give them the same run order so they run in parallel.

Integration tests need somewhere to run

- Create a **short-lived test environment** from the same IaC templates, test it, tear it down.
- Tests against private databases need the CodeBuild project in the **VPC**, as in module 3.
- Test credentials come from Secrets Manager. Test data should be seeded, not copied from production.
- A shared, long-lived test environment drifts, and tests start failing for reasons unrelated to the change.

> ON THE EXAM
>
> Environment per pull request, from IaC, destroyed afterwards: consistent, isolated, and you only pay while testing.

Testing user interfaces and mobile apps

- **AWS Device Farm** runs automated tests on real phones and tablets, many models at once.
- It plugs into CodePipeline as a test action, and scales with the number of devices you choose.
- Browser tests can run headless inside CodeBuild with Selenium or Playwright.
- A fleet of EC2 instances running emulators is the high-overhead distractor.

> ON THE EXAM
>
> Many device types, scaling test load, least management: Device Farm. Emulators on EC2 or ECS lose on overhead.

Security testing, by type

TYPE	WHAT IT FINDS	AWS OPTION
SAST	Flaws in your own source code	Inspector code security, Q Developer review
SCA	Vulnerable third-party dependencies	Inspector code security and image scanning
IaC scanning	Misconfigured templates	Inspector, cfn-guard or cfn-lint in the build
Image scanning	Vulnerable OS and language packages	ECR basic or enhanced scanning
DAST	Flaws in the running application	Third-party tools against staging

ON THE EXAM

Static scans need only code, so they run early. Dynamic scans need a running system, so they run in staging.

The catalogue has moved: code review

OLDER MATERIAL SAYS	WHAT HAPPENED	USE INSTEAD
CodeGuru Reviewer	Closed to new customers, November 2025	Amazon Q Developer code review
CodeGuru Security	Discontinued, 20 November 2025	Inspector code security
Inspector: EC2, ECR, Lambda only	Code security added, June 2025	SAST, SCA, IaC via GitHub, GitLab

THE RULE

If an exam option names CodeGuru for automated code review, it reflects the guide. Choose it on the guide's terms.

ECR basic or enhanced scanning?

ENHANCED

Through Amazon Inspector

- OS and programming language packages
- Scan on push, and continuous rescans
- An EventBridge event per finding
- Findings flow to Security Hub. Paid

BASIC

Built into Amazon ECR

- Operating system packages only
- Scan on push, or manual
- One summary event per scan
- Free. Clair engine now deprecated

THE TIEBREAKER

'Newly published vulnerabilities in images already deployed' needs continuous rescanning, which only enhanced offers.

Turning a scan into a gate

- Scan on push is **asynchronous**. A pipeline that pushes then deploys can outrun the scan.
- Gate with a build step that **waits for the scan**, reads the findings, and exits non-zero on critical ones.
- Or scan inside the build, before the image is ever pushed.
- For images already deployed, an **EventBridge rule** on new critical findings notifies or remediates.

> ON THE EXAM
>
> A scan that only reports is a detective control. A scan whose result sets an exit code is a gate.

Load and performance testing

- Run in **staging**, sized like production, never against production during business hours.
- Scale staging **up before** the test and **back down after**, as pipeline steps. Pay only while testing.
- Generate load from CodeBuild, or the **Distributed Load Testing on AWS** solution for large scale.
- Fail the stage on a threshold: latency, error rate, or throughput below a target.

> ON THE EXAM
>
> Load test fails because staging scales too slowly: raise its minimum capacity before the test, restore it after.

Resilience testing

- **AWS Fault Injection Service** runs experiments: stop instances, add latency, throttle APIs.
- **Stop conditions** are CloudWatch alarms that halt an experiment if harm goes too far.
- Run experiments in staging from the pipeline, and check the system recovers without people.
- **Resilience Hub** assesses an application against RTO and RPO targets, and can run in the pipeline.

> ON THE EXAM
>
> 'Verify the application tolerates the loss of an Availability Zone before release': an FIS experiment in staging.

Testing in production, safely

- **CloudWatch Synthetics canaries** run scripted journeys or API calls on a schedule, from outside.
- A canary's failures feed an **alarm**, and the alarm can drive a rollback.
- Blue/green deployments can test the new version on a **test listener** before any real traffic.
- A canary deployment and a Synthetics canary are different things with the same name.

> ON THE EXAM
>
> 'Continuously verify a user journey works, with the least development effort': a Synthetics canary and an alarm.

> A pipeline's CodeBuild test action runs this command so that results are both shown in the log and saved to a file: pytest | tee test-results.txt.
>
> Last week several tests failed, yet the test action succeeded and the release was deployed to production. The buildspec has no on-failure settings.

What is the most likely cause, and fix?

A. The build timeout is too short; increase it so pytest can finish

B. Tests should run in post_build; move the command there

C. The pipeline needs a manual approval after the test action

D. The pipe returns tee's exit status; enable pipefail so pytest's failure propagates

◆ PAUSE AND DECIDE

What is the most likely cause, and fix?

A Longer timeout

A timeout would fail the build, not pass it. And the tests did run: they failed.

B Move to post_build

Same command, same pipe, same swallowed exit code. The phase is not the problem.

C Manual approval

Adds a human to catch what an exit code should have caught. Treats the symptom.

D pipefail

A pipe reports its last command's status, and tee succeeded. pipefail reports pytest's failure.

THE SIGNAL

Tests failed, build passed: something swallowed the exit code. A pipe is the usual culprit.

A company requires that no container image with critical vulnerabilities is ever deployed. ECR enhanced scanning with scan on push is enabled.

The pipeline builds and pushes the image, then deploys it to ECS in the next stage. Twice, an image was deployed before its scan finished and was later found to contain a critical vulnerability.

Which solution meets the requirement with the LEAST operational overhead?

A. Add a step after the push that waits for the image scan to complete and fails when critical findings exist

B. Switch the registry to basic scanning so that scans finish faster

C. Add a manual approval so the security team reviews findings before each deployment

D. Enable continuous scanning on the repository

◆ PAUSE AND DECIDE

Which solution meets the requirement with the LEAST operational overhead?

A Wait for the scan, fail on critical

Turns an asynchronous report into a synchronous gate. The deploy cannot start until the verdict exists.

B Basic scanning

Still asynchronous, and it misses language package vulnerabilities. Weaker and no gate.

C Manual approval

Would work, but adds a person to every release. The opposite of least overhead.

D Continuous scanning

Finds new vulnerabilities later. It does not stop the first deployment racing the first scan.

THE SIGNAL

Deployed before the scan finished: the scan is asynchronous. Make the pipeline wait for its verdict.

> An online retailer deploys to production several times a day. Twice last month, the checkout journey broke after a deployment, and customers reported it before the team noticed.
>
> The team wants the checkout journey exercised every five minutes, from outside the application, with automatic alerts when it fails. It wants the least development effort.

What should the team implement?

A. A Lambda function on an EventBridge schedule that runs a Selenium script and publishes a custom metric

B. A Device Farm test run triggered every five minutes

C. X-Ray tracing on the checkout service, with sampling set to 100%

D. A CloudWatch Synthetics canary scripting the checkout journey, with a CloudWatch alarm on its failures

◆ PAUSE AND DECIDE

What should the team implement?

A Scheduled Lambda with Selenium

Rebuilds a canary by hand: packaging a browser, scheduling, metrics. Real development effort.

B Device Farm every five minutes

Built for pre-release testing on devices, not for continuous production monitoring.

C X-Ray at 100%

Only sees requests customers make. It never exercises the journey itself.

D Synthetics canary with an alarm

Exactly its purpose: a scripted journey, on a schedule, from outside, with metrics for alarms.

THE SIGNAL

Scripted journey, on a schedule, from outside, with alerting: that sentence describes a Synthetics canary.

A pipeline load-tests a staging ECS service before production. Staging normally runs 2 tasks with target tracking scaling. Production runs up to 20 tasks at peak.

The load test keeps failing its latency threshold because staging scales out too slowly for the sudden test load. The team wants a realistic test at the lowest cost.

What should the team do?

A Run the staging service at 20 tasks permanently

B Add pipeline steps that raise staging's minimum task count to 20 before the test and restore it afterwards

C Run the load test against production during off-peak hours

D Relax the latency threshold until the test passes

◆ PAUSE AND DECIDE

What should the team do?

A 20 tasks permanently

Realistic, but pays for production-sized staging around the clock. Not lowest cost.

B Scale up before, restore after

Production-sized only while testing, then back to 2. Realistic and cheap.

C Test production off-peak

Risks real customers and real data. Never the intended answer for load testing.

D Relax the threshold

Makes the gate pass by removing it. The test no longer protects anything.

THE SIGNAL

Realistic capacity, but only while testing: change the capacity as pipeline steps on either side of the test.

Module 4 in five lines

- Cheap tests first. Static scans early; integration, load and dynamic scans in staging.
- Exit codes are the gate. Pipes, || true and background jobs break the chain.
- Short-lived test environments from IaC. Device Farm for many devices.
- CodeGuru is gone: Inspector code security and Q Developer review replace it.
- Asynchronous scans need a waiting step to become gates. Synthetics canaries watch production.

> ON THE EXAM
>
> Next, module 5: artifacts and images. S3, CodeArtifact, ECR, and building golden images with Image Builder.

MODULE 05 · DOMAIN 1 - SDLC AUTOMATION

Artifacts and Images

Where build output lives: S3 artifact stores, CodeArtifact packages, ECR images, and golden AMIs from EC2 Image Builder.

DOMAIN 1 of 6 EXAM WEIGHT 22% MODULE 5 of 34

admin@sthithapragna.com

An artifact store answers three questions: **who can fetch it**, **how long it lives**, and **whether it can change**.

admin@sthithapragna.com

Four kinds of artifact, four homes

ARTIFACT	HOME	CONSUMED BY
Pipeline hand-offs	S3 artifact store	The next pipeline action
Libraries and packages	CodeArtifact	Other builds, through npm, pip, Maven
Container images	Amazon ECR	ECS, EKS, Lambda, App Runner
Machine images	AMIs, from EC2 Image Builder	Launch templates and Auto Scaling

ON THE EXAM

'Packaged code must be an upstream source for future builds' means CodeArtifact. An S3 bucket is not a package repository.

The pipeline's S3 artifact store

- One artifact bucket per Region the pipeline acts in. The console can create it for you.
- Encrypted by default with the AWS managed key for S3.
- Cross-account actions need a **customer managed key**, as in module 1.
- Artifacts accumulate forever unless an **S3 Lifecycle** rule expires old ones.

> ON THE EXAM
>
> Artifact bucket growing without limit: an S3 Lifecycle expiration rule. No Lambda clean-up job.

A CodeArtifact domain

pypi-store
External connection: PyPI
Caches public packages

npm-store
External connection: npmjs
Caches public packages

team-web
Upstream: shared, npm-store
What developers point at

Domain: acme
One KMS key for everything
Domain policy: which accounts
Deduplicated storage
Assets stored once, shared by every repository.

team-data
Upstream: shared, pypi-store
Another team's view

shared
Internal libraries
Published by CI only

ON THE EXAM

Teams point at one repository. Upstreams make internal and public packages appear together.

CodeArtifact rules worth knowing

- Formats: npm, PyPI, Maven, NuGet, Swift, Ruby, Cargo, and generic.
- A repository can have several **upstreams**, searched in order, but at most one **external connection**.
- Package versions fetched from upstream are **retained**, so builds survive a public package being deleted.
- Publishing a new version emits an **EventBridge** event that can start downstream pipelines.

> ON THE EXAM
>
> Rebuild every consumer when a shared library publishes a new version: EventBridge on the CodeArtifact event.

Reaching CodeArtifact

- Clients use a temporary **authorisation token**: up to 12 hours, 12 by default after login.
- Getting a token needs codeartifact:GetAuthorizationToken **and** sts:GetServiceBearerToken.
- Other accounts are admitted by the **domain policy** and the **repository policy**.
- From a VPC with no internet: interface endpoints **codeartifact.api** and **codeartifact.repositories**, plus an **S3 gateway endpoint** for assets.

> ON THE EXAM
>
> Private build reaches CodeArtifact metadata but not packages: the S3 gateway endpoint is missing. Python and Swift skip it.

Dependency confusion, and how to stop it

- An attacker publishes a **public** package with your internal package's name and a higher version.
- A resolver that merges internal and public sources may pick the attacker's version.
- **Package origin controls** set, per package, whether new versions may be published directly and whether they may arrive from upstream.
- **Package groups** apply those controls by pattern, such as every package in your npm scope.

> ON THE EXAM
>
> Internal names must never be satisfied from a public registry: block upstream for that package group.

ECR fundamentals

- One private registry per account and Region, containing repositories of images.
- A **tag** is a movable label. A **digest** is the image's content hash and never changes.
- **Tag immutability** stops a tag being overwritten. Since July 2025, **exclusion patterns** can exempt tags such as latest.
- Encryption with AES-256 by default, or a KMS key chosen when the repository is created.

> ON THE EXAM
>
> 'Guarantee a deployed tag always means the same image': tag immutability, or deploy by digest.

An ECR lifecycle policy

```
1  { "rules": [
2    { "rulePriority": 1,
3      "description": "Untagged images older than 7 days",
4      "selection": { "tagStatus": "untagged",
5        "countType": "sinceImagePushed", "countUnit": "days", "countNumber": 7 },
6      "action": { "type": "expire" } },
7    { "rulePriority": 2,
8      "description": "Keep the 30 most recent release images",
9      "selection": { "tagStatus": "tagged", "tagPatternList": ["v*"],
10       "countType": "imageCountMoreThan", "countNumber": 30 },
11     "action": { "type": "expire" } } ] }
```

4-5 By age: untagged images expire a week after push.

9-10 By count: beyond 30 v-tagged images, the oldest expire.

ON THE EXAM

Rules only ever select images to expire. Lower rulePriority is evaluated first. Preview a policy before applying it.

Getting images into other Regions and accounts

MECHANISM	WHAT MOVES	BEST FOR
Replication	Every new matching push	DR; Regions running everything
ECR-to-ECR cache	Only images actually pulled	Many Regions, few images each
Public pull cache	Docker Hub, GHCR, Quay images	Rate limits; scanning
Cross-account pull	Nothing: a policy grants it	Several accounts, one registry

ON THE EXAM

Replication copies new pushes only, never existing images. Pull through cache fetches on first pull.

Repository creation templates

- ECR creates repositories for you during **pull through cache**, **replication** and **create on push**.
- A template, matched by prefix, sets their **KMS key**, tag immutability, lifecycle policy, repository policy and tags.
- Templates apply only when a repository is **created**. Existing repositories keep their settings.
- Encryption cannot be changed later, so a non-compliant repository must be deleted and recreated.

> ON THE EXAM
>
> Automatically created repositories must use a specific KMS key: a repository creation template for that prefix.

Proving where an image came from

- **ECR managed signing** (November 2025) signs images automatically on push, using AWS Signer.
- Signatures are stored beside the image as OCI referrers. Notation can sign client-side instead.
- Verification happens at deploy time, for example by an admission controller on EKS.
- For Lambda zip packages, **code signing** with AWS Signer blocks unsigned code from deploying.

> ON THE EXAM
>
> Only run images or code from trusted sources, with least effort: managed signing plus verification at deploy.

A golden AMI pipeline with EC2 Image Builder

01

Recipe

Base image plus build components: hardening, agents.

02

Build and test

Test components prove the image works.

03

Scan

Amazon Inspector checks for vulnerabilities.

04

Distribute

Copy to Regions, share with accounts, update launch templates.

05

Retire

Lifecycle policies deprecate and delete old images.

ON THE EXAM

Scheduled weekly, or whenever the base image updates. The same service builds container images too.

Bake it in, or bootstrap at launch?

BAKE

Everything in the AMI

- Instances start ready, in seconds
- Every instance identical to the image
- Changes need a new image
- Best for fast scale-out

BOOTSTRAP

Configure at launch

- User data or scripts install software
- Flexible, no rebuild to change
- Slow, and fails when repositories do
- Instances can drift apart

THE TIEBREAKER

Scale-out is too slow because instances install software at boot: bake a golden AMI. Keep only config at launch.

A company publishes internal npm packages under its @acme scope to a CodeArtifact repository. That repository has an upstream repository with an external connection to the public npm registry.

A security review finds that anyone could publish a public package named @acme/auth-utils with a higher version, and builds might resolve it. Public packages must remain available.

Which solution prevents this with the LEAST operational overhead?

A. Remove the external connection so that no public packages can be fetched

B. Pin exact versions of every dependency in each project's lock file

C. Create a package group for the @acme scope with origin controls that block upstream versions

D. Move the internal packages into a separate CodeArtifact domain

◆ PAUSE AND DECIDE

Which solution prevents this with the LEAST operational overhead?

A **Remove the external connection**

Stops the attack by breaking every public dependency. Violates the stated requirement.

B **Pin every version**

Helps existing dependencies, but every new or updated dependency is exposed again. Ongoing effort.

C **Package group blocking upstream**

Internal names can only come from direct publishing. Public packages still flow. One configuration.

D **Separate domain**

Projects still need both sources merged, so the confusion simply moves. A migration for nothing.

THE SIGNAL

Internal name, public impostor: package origin controls, applied by pattern with a package group.

A company pushes several hundred container images to Amazon ECR in us-east-1. It runs workloads in six other Regions, but each Region runs only a handful of those images.

The company wants in-Region image pulls for faster start-up, with the lowest storage cost and the least operational overhead.

What should the company configure?

A ECR-to-ECR pull through cache rules in each of the six Regions, with us-east-1 as upstream

B Registry replication from us-east-1 to all six Regions

C A pipeline step that copies each new image to all six Regions

D Point every Region's workloads at the us-east-1 repositories directly

◆ PAUSE AND DECIDE

What should the company configure?

A ECR-to-ECR pull through cache

Each Region stores only the images it actually pulls, then pulls them locally. Managed sync.

B Replication to all six

In-Region and managed, but stores every image in every Region. Six times the storage for images never run.

C Pipeline copy step

Same storage problem as replication, plus custom work to maintain.

D Pull from us-east-1

No extra storage, but every pull is cross-Region. Fails the in-Region requirement.

THE SIGNAL

Many Regions, few images each: pull through cache. Every Region needs everything: replication.

A company patches its EC2 Auto Scaling fleets by hand once a month. The fleets run in three accounts and two Regions, and scale-out is slow because instances install agents at boot.

The company wants a hardened image rebuilt weekly with the latest patches, scanned for vulnerabilities, made available in every account and Region, with launch templates updated automatically.

Which solution meets these requirements with the LEAST operational overhead?

A. A scheduled Lambda function that runs Systems Manager Automation to patch and share an AMI

B. Packer in a weekly CodeBuild project, with scripts that copy and share the AMI

C. Launch template user data that installs agents and applies patches at every boot

D. An EC2 Image Builder pipeline on a weekly schedule, with Inspector scanning and distribution settings for accounts, Regions and launch templates

◆ PAUSE AND DECIDE

Which solution meets these requirements with the LEAST operational overhead?

A Lambda plus Automation

Workable, but hand-builds scheduling, scanning and distribution that Image Builder includes.

B Packer on CodeBuild

A real pattern, but the copying, sharing and template updates are scripts you maintain.

C Patch at every boot

Makes scale-out slower still, and instances drift. The opposite of a golden image.

D Image Builder pipeline

Schedule, build, test, scan, distribute and update launch templates are all built in.

THE SIGNAL

Build, scan, distribute across accounts and Regions, update launch templates: every word is an Image Builder feature.

> An auditor requires that release tags in an ECR repository, such as v2.4.1, can never be overwritten. The team's pipeline also moves a staging tag to each new build.
>
> When the team enabled tag immutability, the pipeline started failing because the staging tag could no longer be moved.

What should the team do with the LEAST effort?

A Disable tag immutability and review release tags in a monthly audit

B Move staging images into a separate repository that has mutable tags

C Keep tag immutability and add an exclusion pattern for the staging tag

D Stop using tags and change every deployment to reference image digests

◆ PAUSE AND DECIDE

What should the team do with the LEAST effort?

A **Disable, audit monthly**

Replaces a preventive control with a detective one. The auditor asked for 'never'.

B **Separate repository**

Works, but duplicates images, policies and pipeline logic across two repositories.

C **Exclusion pattern for staging**

Release tags stay immutable; the one moving tag is exempt. A single setting since July 2025.

D **Digests everywhere**

Good practice, but a change to every deployment. Far from least effort.

THE SIGNAL

Most tags must be fixed, one or two must move: immutability with exclusion patterns.

Module 5 in five lines

- S3 for pipeline hand-offs, CodeArtifact for packages, ECR for images, Image Builder for AMIs.
- CodeArtifact: upstreams in order, one external connection, origin controls stop dependency confusion.
- ECR lifecycle rules only expire. Replication copies all new pushes; pull through cache copies what is pulled.
- Repository creation templates set KMS keys and policies on repositories ECR creates for you.
- Bake golden AMIs for fast scale-out. Image Builder schedules, scans and distributes them.

ON THE EXAM

Next, module 6: CodeDeploy on EC2 and on-premises servers. Agents, the appspec, deployment configurations and rollback.

MODULE 06 · DOMAIN 1 - SDLC AUTOMATION

CodeDeploy on EC2 and On-Premises

The agent, the appspec and its hooks, deployment configurations, Auto Scaling, blue/green on EC2, and rolling back.

DOMAIN 1 of 6 EXAM WEIGHT 22% MODULE 6 of 34

admin@sthithapragna.com

CodeDeploy on servers is a **script runner** with a **traffic switch**. You write the scripts; it decides when, where, and how many at a time.

The moving parts

PART	WHAT IT IS
Application	A name that groups everything for one piece of software
Deployment group	Targets, config, load balancer, alarms, rollback settings
Deployment configuration	How many instances may be out of service at once
Revision	A zip or tar bundle in S3, or a GitHub commit, with an appspec
Agent	Software on each instance that polls CodeDeploy and runs the scripts

ON THE EXAM

Targets are chosen by EC2 tags, on-premises tags, or Auto Scaling group names in the deployment group.

The agent, and the two identities

- The **agent** polls CodeDeploy for work. No inbound ports are opened on the instance.
- The **instance profile** lets the agent download the revision from S3.
- The **service role** lets CodeDeploy call Auto Scaling and Elastic Load Balancing for you.
- On-premises servers are registered with an IAM identity and tagged, then run the same agent.

> ON THE EXAM
>
> Install and update the agent fleet-wide with Systems Manager, rather than baking scripts into every launch.

An appspec for a server

```yaml
version: 0.0
os: linux
files:
  - source: /build
    destination: /var/www/app
hooks:
  ApplicationStop:
    - location: scripts/stop.sh
  BeforeInstall:
    - location: scripts/clear-cache.sh
  ValidateService:
    - location: scripts/health-check.sh
```

9 Runs before files are copied: the place to clear a cache.

11 A non-zero exit fails this instance's deployment.

ON THE EXAM

The appspec lives at the root of the revision bundle. Its hooks are just scripts, judged by their exit codes.

Lifecycle events, in order, with a load balancer

EVENT	SCRIPT FROM	TYPICAL USE
BeforeBlockTraffic, BlockTraffic, AfterBlockTraffic	Previous revision	Drain from the load balancer
ApplicationStop	Previous revision	Stop the old version gracefully
DownloadBundle, BeforeInstall	New revision	Fetch; clear old files, back up
Install, AfterInstall	New revision	Copy files; configure, set permissions
ApplicationStart, ValidateService	New revision	Start; health check
BeforeAllowTraffic, AllowTraffic, AfterAllowTraffic	New revision	Warm up; rejoin; confirm

ON THE EXAM

DownloadBundle, Install, BlockTraffic and AllowTraffic are CodeDeploy's own steps. You cannot attach scripts to them.

The previous-revision trap

- ApplicationStop, BeforeBlockTraffic and AfterBlockTraffic run scripts from the **last successful** revision.
- So a broken stop script, once deployed, breaks **every later deployment**, including the fix.
- Fixing the script in the new revision does not help: its stop script is not the one that runs.
- Deploy with **ignoreApplicationStopFailures**, and the fixed revision becomes the new last successful one.

> ON THE EXAM
>
> Every deployment now fails at ApplicationStop, even the fix: ignore application stop failures for one deployment.

Three more deployment settings

- **fileExistsBehavior**: what to do when a file exists that the last deployment did not put there.
- DISALLOW, the default, fails the deployment. OVERWRITE replaces the file. RETAIN keeps it.
- Each hook script has a **timeout**, one hour at most, set in the appspec.
- **runas** sets which operating system user runs a script.

> ON THE EXAM
>
> Deployment fails because files already exist, often after a manual hotfix: set the file-exists behaviour to OVERWRITE.

Deployment configurations

CONFIGURATION	HOW MANY AT ONCE	TRADE-OFF
`AllAtOnce`	Every instance together	Fastest; an outage if it fails
`HalfAtATime`	Up to half the fleet	Middle ground; half your capacity gone
`OneAtATime`	One instance	Safest; slowest on a large fleet
`Custom: HOST_COUNT`	Keep at least N instances healthy	Exact numbers
`Custom: FLEET_PERCENT`	Keep at least N% healthy	Scales with fleet size

ON THE EXAM

Minimum healthy hosts is what must stay up. The rest is how many CodeDeploy may take down at once.

Doing the arithmetic

- 20 instances, FLEET_PERCENT 75: at least 15 stay healthy, so up to **5** update at once.
- 20 instances, HalfAtATime: 10 stay healthy, and the other 10 carry no traffic.
- 'At least 75% available, as fast as possible' is FLEET_PERCENT 75, not 25.
- OneAtATime also keeps 75% available, but takes twenty rounds instead of four.

> ON THE EXAM
>
> Read the percentage as what stays up. A distractor offering 25% is counting the ones that go down.

Zonal deployments

- A **zonal configuration** deploys to one Availability Zone at a time. EC2 and on-premises only.
- **Monitor duration** waits after each zone before starting the next.
- **First zone monitor duration** can set a longer bake for the first zone.
- **Minimum healthy hosts per zone** works alongside the fleet-wide minimum.

> ON THE EXAM
>
> 'One Availability Zone at a time, with a bake period before the next': a zonal configuration, not separate deployment groups.

In-place or blue/green, on EC2?

BLUE/GREEN

A new fleet, then switch traffic

- Copies the Auto Scaling group, or uses instances you provide
- Full capacity throughout
- Rollback moves traffic back: fast
- Old fleet terminated after a wait you set

IN-PLACE

Update the instances you have

- No extra instances, no extra cost
- Capacity reduced while batches update
- Rollback is another full deployment: slow
- Works on-premises; blue/green does not

THE TIEBREAKER

Fastest rollback, full capacity: blue/green. On-premises servers, or no spare capacity: in-place.

CodeDeploy and Auto Scaling

- A **launch lifecycle hook** holds each new instance until CodeDeploy installs the last successful revision.
- Scale-out **during** a deployment gets the older revision, then an automatic **follow-on deployment** updates it.
- If new instances keep failing their deployment, they are terminated and replaced, in a loop.
- **Termination hooks** run your stop scripts before scale-in terminates an instance.

> ON THE EXAM
>
> Graceful shutdown on scale-in, using the existing CodeDeploy setup: enable termination hooks on the deployment group.

Rolling back

- Automatic rollback triggers on a **failed deployment**, on an **alarm**, or both.
- Alarms are attached to the deployment group; a firing alarm stops the deployment.
- A rollback is a **new deployment** of the last good revision, with a new deployment ID.
- A single deployment can **override** the group's alarm configuration.

> ON THE EXAM
>
> Roll back automatically when application errors rise: an alarm on the deployment group plus rollback on alarm.

Watching deployments

- **Triggers** send deployment and instance events to SNS. EventBridge receives state changes too.
- The agent writes a deployment log on each instance with every script's output.
- Ship those logs to CloudWatch Logs with the CloudWatch agent, and query them with Logs Insights.
- Connecting to each failed instance to read its log does not scale.

> ON THE EXAM
>
> 'Find which lifecycle event failed across many instances, efficiently': agent logs in CloudWatch, queried with Logs Insights.

> Revision 41 of an application deployed successfully, but its stop.sh script references a file that revision 41 also removed. Revision 42 corrects stop.sh.
>
> Every deployment of revision 42 fails at the ApplicationStop event on every instance, and so does an attempt to redeploy revision 40.

How should the DevOps engineer get revision 42 deployed?

A. Edit stop.sh in revision 42 so that it exits 0 when the file is missing

B. Create a deployment of revision 42 with ignoreApplicationStopFailures set to true

C. Reinstall the CodeDeploy agent on every instance

D. Change the deployment configuration to OneAtATime

◆ PAUSE AND DECIDE

How should the DevOps engineer get revision 42 deployed?

A Fix stop.sh in revision 42

The trap. ApplicationStop runs revision 41's script, the last successful one. Revision 42's is never used here.

B ignoreApplicationStopFailures

Skips the broken stop step once. Revision 42 then becomes the last successful revision.

C Reinstall the agent

The agent is working correctly. It is running exactly the script it is meant to run.

D OneAtATime

Changes how many fail at once, not whether they fail.

THE SIGNAL

Even a redeploy of an older revision fails at ApplicationStop: the last successful revision's stop script is broken.

> A company runs 18 EC2 instances across three Availability Zones. After a release once failed in every zone at the same time, it wants deployments to go one Availability Zone at a time.
>
> The first zone must bake for 60 minutes before the next zone starts, and each zone must keep at least 2 healthy instances throughout.

Which solution meets these requirements with the LEAST operational overhead?

A. A custom deployment configuration with a zonal configuration: first-zone monitor duration 60 minutes, minimum 2 healthy hosts per zone

B. The CodeDeployDefault.OneAtATime deployment configuration

C. Three deployment groups, one per zone, run in sequence by the pipeline with a wait action between them

D. The HalfAtATime deployment configuration with a CloudWatch alarm for rollback

◆ PAUSE AND DECIDE

Which solution meets these requirements with the LEAST operational overhead?

A Zonal configuration

Zone by zone, first-zone bake, per-zone minimum: every requirement is a field in one configuration.

B OneAtATime

Ignores zones entirely, and has no bake period between them.

C Three deployment groups

The workaround from before zonal configuration. Works, but triples groups and pipeline logic.

D HalfAtATime plus alarm

Half the fleet can span every zone at once: the exact failure the company wants to avoid.

THE SIGNAL

Zone at a time, bake between zones: zonal configuration. Separate groups per zone is the old workaround.

A worker application runs on an Auto Scaling group whose instances are deployed with CodeDeploy. The application processes long-running jobs.

When the group scales in, instances are terminated while jobs are still running, and the jobs are lost. The team already has a stop script that finishes the current job and exits cleanly.

What is the MOST operationally efficient way to run the stop script before scale-in?

A. Add an Auto Scaling lifecycle hook, an EventBridge rule, and a Lambda function that runs the script with Run Command

B. Increase the load balancer's deregistration delay to one hour

C. Enable termination hooks on the CodeDeploy deployment group, and run the script at ApplicationStop

D. Add a shutdown script to the instances' user data

◆ PAUSE AND DECIDE

What is the MOST operationally efficient way to run the stop script before scale-in?

A. Hook, rule, Lambda, Run Command

Works, but builds by hand what CodeDeploy termination hooks already provide.

B. Longer deregistration delay

Only drains load balancer connections. A worker's in-process job is not a connection.

C. Termination hooks, ApplicationStop

CodeDeploy runs a termination deployment before the instance is terminated, calling the existing script.

D. User data shutdown script

User data runs at launch, not at termination. The script would never run at the right moment.

THE SIGNAL

Graceful scale-in for an application already deployed with CodeDeploy: termination hooks.

> A web application runs on an Auto Scaling group behind an Application Load Balancer. CodeDeploy performs in-place deployments with automatic rollback on alarms.
>
> When a bad release is detected, rollback takes around 25 minutes, and users see errors throughout. The company wants the fastest possible rollback and full capacity during deployments.

What should the DevOps engineer change?

A. Switch the deployment configuration to OneAtATime

B. Add more CloudWatch alarms so that rollback starts sooner

C. Increase the Auto Scaling group's desired capacity during deployments

D. Use a blue/green deployment that copies the Auto Scaling group, keeping the original instances for a wait period

◆ PAUSE AND DECIDE

What should the DevOps engineer change?

A OneAtATime

Limits exposure, but makes both deployment and in-place rollback slower still.

B More alarms

Detection was not the slow part. The in-place redeployment was.

C More capacity

Helps capacity, but rollback is still a full in-place redeployment.

D Blue/green, keep the original fleet

Rollback just moves the load balancer back to instances still running the old version.

THE SIGNAL

Rollback too slow on in-place: the rollback is a redeployment. Blue/green makes it a traffic switch.

Module 6 in five lines

- Instance profile fetches the bundle; service role manages Auto Scaling and load balancers.
- Stop and block-traffic scripts run from the last successful revision. ignoreApplicationStopFailures is the escape.
- Minimum healthy hosts is what stays up. Zonal configurations go one Availability Zone at a time.
- Launch hooks install on new instances; termination hooks shut down gracefully on scale-in.
- In-place rollback is a redeployment. Blue/green rollback is a traffic switch.

> ON THE EXAM
>
> Next, module 7: containers and serverless. ECS rolling, circuit breaker, native blue/green, Lambda traffic shifting, SAM and Beanstalk.

MODULE 07 · DOMAIN 1 - SDLC AUTOMATION

Containers and Serverless Deployment

ECS rolling updates and native blue/green, CodeDeploy for ECS, Lambda traffic shifting with SAM, Elastic Beanstalk policies, and EKS.

DOMAIN 1 of 6 EXAM WEIGHT 22% MODULE 7 of 34

admin@sthithapragna.com

On every platform in this module, a deployment is a decision about **where traffic goes**. The platform only changes what traffic is pointed at.

Who moves the traffic, on each platform

PLATFORM	ROLLING	BLUE/GREEN, CANARY, LINEAR
Amazon ECS	ECS itself	ECS natively (2025), or CodeDeploy
AWS Lambda	Not applicable	CodeDeploy through an alias; SAM configures it
Elastic Beanstalk	Beanstalk policies	Immutable, traffic splitting, or a URL swap
Amazon EKS	Kubernetes Deployments	Progressive delivery tools in the cluster

ON THE EXAM

CodeDeploy is optional for ECS now, but it is still the engine behind Lambda traffic shifting, including through SAM.

ECS rolling updates: two numbers

- **minimumHealthyPercent**: the floor of running tasks, as a percentage of desired count.
- **maximumPercent**: the ceiling of running tasks during the deployment.
- 100 and 200: never below full strength, but needs room for twice the tasks.
- 50 and 100: no extra room needed, but runs at half strength during the update.

> ON THE EXAM
>
> 'Unable to place a task' during deployments on a full cluster: lower minimumHealthyPercent, or add capacity.

Two ways a rolling update notices trouble

DEPLOYMENT CIRCUIT BREAKER

Tasks that will not run

- Tasks fail to start, or fail health checks
- Counts failures against a threshold
- With rollback on: returns to the last completed deployment
- Blind to a task that runs but misbehaves

DEPLOYMENT ALARMS

Tasks that run badly

- CloudWatch alarms named on the service
- Error rate, latency, any metric you choose
- With rollback on: returns to the last completed deployment
- Catches the bug the circuit breaker cannot see

THE TIEBREAKER

Tasks crash-loop: circuit breaker. Tasks healthy but errors rise: deployment alarms. Many services want both.

ECS native blue/green, stage by stage

01

Scale up green

New tasks start. Blue still takes 100% of production.

02

Test traffic

A test listener sends test requests to green.

03

Production shift

All at once, linear steps, or a canary slice.

04

Bake

Both run. Alarms watch. Rollback is instant.

05

Clean up

Blue scales to zero. Green is production.

ON THE EXAM

Rollback before clean-up just moves traffic back to blue tasks that are still running. No new tasks start.

Lifecycle hooks: where you can intervene

STAGE	STATE AT THAT MOMENT	TYPICAL HOOK
PRE_SCALE_UP	Green not started	Check dependencies are ready
POST_SCALE_UP	Green running, no traffic	Smoke-test green directly
POST_TEST_TRAFFIC_SHIFT	Green has all test traffic	Run the test suite via the test listener
PRE_PRODUCTION_TRAFFIC_SHIFT	Before each production step	Check metrics before the next slice
POST_PRODUCTION_TRAFFIC_SHIFT	Green has all production traffic	Final validation before bake

ON THE EXAM

A Lambda hook returns SUCCEEDED, FAILED to roll back, or IN_PROGRESS to be asked again in 30 seconds. PAUSE waits for you.

Linear, canary and bake time on ECS

- **Linear**: a step percentage and a bake time between steps. **Canary**: one slice, a bake, then the rest.
- **Bake time**, up to 24 hours, keeps blue running after the final shift for instant rollback.
- Works with an Application Load Balancer, a Network Load Balancer, or ECS Service Connect.
- The deployment controller can now be changed after the service is created.

> ON THE EXAM
>
> AWS now recommends ECS-native strategies for new deployments. CodeDeploy for ECS remains supported and examinable.

ECS native, or CodeDeploy for ECS?

ECS NATIVE

Built into the service

- No CodeDeploy application or group
- ALB, NLB or Service Connect
- Hooks at more stages, plus PAUSE
- Recommended for new services

CODEDEPLOY

The long-established route

- Deployment controller CODE_DEPLOY
- Appspec names the task definition
- Predefined ECS canary and linear configs
- The exam guide's world; still valid

THE RULE

If an option uses CodeDeploy blue/green for ECS, it is still a correct design. Choose between options on the qualifier.

A CodeDeploy appspec for ECS

```
version: 0.0
Resources:
  - TargetService:
      Type: AWS::ECS::Service
      Properties:
        TaskDefinition: "arn:aws:ecs:...:task-definition/web:42"
        LoadBalancerInfo:
          ContainerName: "web"
          ContainerPort: 8080
Hooks:
  - AfterAllowTestTraffic: "arn:aws:lambda:...:function:run-tests"
```

6 The new task definition revision to deploy.

11 Hooks here are Lambda functions, not scripts on an instance.

ON THE EXAM

ECS predefined configs: ECSAllAtOnce, ECSCanary10Percent5Minutes or 15Minutes, ECSLinear10PercentEvery1Minutes or 3Minutes.

Lambda: versions, aliases and weights

- A **version** is an immutable snapshot of code and configuration.
- An **alias** is a named pointer to a version, and callers invoke the alias.
- An alias can **split** invocations between two versions by weight.
- CodeDeploy moves that weight on a schedule, and rolls it back on an alarm.

> ON THE EXAM
>
> Callers invoking $LATEST or a version number directly bypass the alias, and so bypass traffic shifting.

SAM does the wiring

```
1  OrdersFunction:
2    Type: AWS::Serverless::Function
3    Properties:
4      Handler: app.handler
5      Runtime: python3.13
6      AutoPublishAlias: live
7      DeploymentPreference:
8        Type: Canary10Percent10Minutes
9        Alarms: [!Ref OrdersErrorAlarm]
10       Hooks:
11         PreTraffic: !Ref PreTrafficCheck
```

6 Publish a new version on every change and point 'live' at it.

8-9 Shift 10% for ten minutes; roll back if the alarm fires.

ON THE EXAM

Those two properties create the CodeDeploy application, group, and alias shifting. No CodeDeploy resources to write.

Other ways to shift Lambda traffic

- The **CodePipeline Lambda deploy action** (May 2025, V2 only) supports canary and linear with custom values.
- It rolls back automatically when named CloudWatch alarms fire during the shift.
- Predefined CodeDeploy configs: LambdaCanary10Percent 5, 10, 15, 30 minutes; LambdaLinear10Percent every 1, 2, 3, 10 minutes.
- Lambda hooks must call **PutLifecycleEventHookExecutionStatus**, or the deployment waits, then fails.

> ON THE EXAM
>
> Same lesson as a pipeline's Lambda action: custom code in a deployment must report its result back.

Elastic Beanstalk deployment policies

POLICY	CAPACITY DURING	IF IT FAILS
All at once	Outage	Redeploy the old version
Rolling	Reduced by one batch	Mixed versions; redeploy
Rolling with additional batch	Full	Mixed versions; redeploy
Immutable	Double, in a temporary group	Terminate the new group: fast
Traffic splitting	Double, with a canary share	Shift traffic back: fast

ON THE EXAM

Full capacity, cheapest: rolling with additional batch. Fast, clean rollback: immutable or traffic splitting.

In-environment policies, or a URL swap?

IMMUTABLE OR TRAFFIC SPLITTING

Inside one environment

- Same load balancer, same DNS name
- No client DNS caching problems
- For application version changes
- Rollback terminates new instances

BLUE/GREEN URL SWAP

Two whole environments

- Clone, deploy, then swap environment URLs
- A DNS change: clients may cache the old one
- For platform branch or major config changes
- Rollback is another swap

THE TIEBREAKER

Changing platform branch, such as leaving retired Amazon Linux 2: clone and swap. Routine releases: immutable.

Configuring Beanstalk from source

- **.ebextensions** config files set options and create resources during deployment.
- **.platform/hooks** scripts run at defined points on Amazon Linux platforms.
- **Managed platform updates** apply patches in a weekly maintenance window.
- A database created inside the environment is deleted with it. Keep production databases outside.

> ON THE EXAM
>
> Blue/green needs a database both environments share, which is another reason it must live outside the environment.

Amazon EKS: Kubernetes does the rolling

- A Deployment's rolling update is tuned by **maxSurge** and **maxUnavailable**.
- A **readiness probe** decides when a pod may receive traffic.
- A **liveness probe** decides when a stuck container should be restarted.
- Canary and blue/green on EKS usually come from progressive delivery tools running in the cluster.

> ON THE EXAM
>
> New pods get errors while warming up: a readiness probe that passes only when the pod can really serve.

> An ECS service behind an Application Load Balancer uses rolling updates with the deployment circuit breaker and rollback enabled.
>
> A new release starts cleanly and every task passes its health checks, but the ALB's 5xx error rate doubles. The deployment completes and nothing rolls back.

What should the DevOps engineer add so that such releases roll back automatically?

A. A CloudWatch alarm on the target group's 5xx rate, named in the service's deployment alarms with rollback enabled

B. A higher circuit breaker failure threshold

C. A lower minimumHealthyPercent on the service

D. ECS Exec on the tasks, so engineers can investigate faster

◆ PAUSE AND DECIDE

What should the DevOps engineer add so that such releases roll back automatically?

A Deployment alarm on 5xx

Watches what the circuit breaker cannot: tasks that run healthily but return errors.

B Higher circuit breaker threshold

No task ever failed, so no threshold, high or low, would be reached.

C Lower minimumHealthyPercent

Changes how many tasks run during the update, not whether bad ones are detected.

D ECS Exec

Helps a human investigate. The requirement was automatic rollback.

THE SIGNAL

Healthy tasks, rising errors, no rollback: the circuit breaker only sees tasks that fail. Add deployment alarms.

> An ECS service runs 4 tasks on an EC2 capacity provider that has no spare room, and the company will not add instances. The service uses minimumHealthyPercent 100 and maximumPercent 200.
>
> Every deployment stalls with an 'unable to place a task' event. Briefly running at half capacity during deployments is acceptable.

What should the DevOps engineer change?

A. Set maximumPercent to 300

B. Set minimumHealthyPercent to 50 and maximumPercent to 100

C. Switch the service to a blue/green deployment strategy

D. Increase the service's desired count to 8

◆ PAUSE AND DECIDE

What should the DevOps engineer change?

A maximumPercent 300

Allows even more extra tasks, on a cluster with no room for one.

B 50 and 100

Stops two old tasks first, then starts two new ones in their place. No extra room needed.

C Blue/green

Needs a full second set of tasks at once: the most extra room of all.

D Desired count 8

Needs double the capacity permanently. The opposite of the constraint.

THE SIGNAL

No spare capacity, reduced capacity acceptable: lower minimumHealthyPercent and keep maximumPercent at 100.

A team wants to run its automated API test suite against each new ECS release on production infrastructure before any customer request reaches it. If the tests fail, the release must roll back automatically.

The team does not want to create or manage CodeDeploy resources, and wants the least operational overhead.

Which solution meets these requirements?

A. ECS native blue/green with a test listener rule, and a Lambda lifecycle hook at POST_TEST_TRAFFIC_SHIFT that runs the tests

B. A rolling update with the circuit breaker and rollback enabled

C. A separate staging service, with a manual approval before production

D. A CodeDeploy canary configuration that sends 10% of production traffic for 5 minutes

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A Native blue/green, test listener, hook

Green is tested on production infrastructure through the test listener, with no customers on it. A FAILED hook rolls back.

B Rolling with circuit breaker

No test stage: customers reach new tasks as soon as they are healthy.

C Staging and approval

Not production infrastructure, and not automatic.

D CodeDeploy canary

Tests on real customers, and uses the CodeDeploy resources the team wants to avoid.

THE SIGNAL

'Before any customer request' plus 'on production infrastructure' is a test listener. 'No CodeDeploy' makes it native.

> An API runs on Amazon API Gateway and a Lambda function, deployed with AWS SAM. The team wants each release to receive 10% of requests for ten minutes before taking all traffic.
>
> If the function's error alarm fires during that time, the release must roll back automatically. The team wants the least effort.

What should the team add to the SAM template?

A. A script that publishes a version and updates the alias weights after ten minutes

B. AutoPublishAlias, and a DeploymentPreference of Canary10Percent10Minutes naming the alarm

C. An API Gateway canary release on the stage, with 10% of traffic

D. Two separate functions behind Route 53 weighted records

◆ PAUSE AND DECIDE

What should the team add to the SAM template?

A **Custom script**

Rebuilds by hand the shifting and rollback that CodeDeploy provides.

B **AutoPublishAlias plus DeploymentPreference**

SAM creates the CodeDeploy wiring. Ten percent, ten minutes, alarm rollback: all declared.

C **API Gateway canary**

Splits at the API stage, but promotion and rollback on the alarm are not automatic.

D **Route 53 weighted**

DNS caching makes percentages imprecise, and nothing rolls back.

THE SIGNAL

SAM plus gradual Lambda release plus alarm rollback: AutoPublishAlias and DeploymentPreference, every time.

A Lambda function is deployed through CodeDeploy with a BeforeAllowTraffic hook. The hook is itself a Lambda function that invokes the new version and checks the response.

The hook's logs show its checks pass within seconds, yet every deployment stays in progress for a long time and then fails. Traffic never shifts.

What is the most likely cause?

A The hook function's timeout is too short

B The alias is pointing at $LATEST

C The hook never calls PutLifecycleEventHookExecutionStatus

D The deployment should use a linear configuration instead

◆ PAUSE AND DECIDE

What is the most likely cause?

A **Hook timeout too short**

The checks finished in seconds. A short timeout would show in the logs as a timeout.

B **Alias on $LATEST**

Would cause other errors. It does not explain a successful hook followed by a hang.

C **No PutLifecycleEventHookExecutionStatus**

The hook succeeds but never tells CodeDeploy, which waits, then fails.

D **Use linear**

The configuration shapes the shift. The shift never started.

THE SIGNAL

Hook succeeds, deployment hangs, then fails: the hook never reported its status. Same lesson as module 2.

A company deploys a web application to Elastic Beanstalk. Deployments must keep full capacity, and a failed release must be removed quickly without affecting the instances already serving users.

Many of the company's customers are enterprises whose networks cache DNS records for long periods, so the application's DNS name must not change.

Which deployment approach should the company use?

A Rolling

B Rolling with additional batch

C Blue/green, cloning the environment and swapping environment URLs

D Immutable

◆ PAUSE AND DECIDE

Which deployment approach should the company use?

A **Rolling**

Reduces capacity, and a failure leaves old instances already modified.

B **Rolling with additional batch**

Full capacity, but existing instances are still updated in place. A failure touches them.

C **Blue/green URL swap**

Clean and fast, but a URL swap is a DNS change, which long DNS caching defeats.

D **Immutable**

New instances in a temporary group; original instances untouched; same DNS name.

THE SIGNAL

Full capacity, untouched originals, and no DNS change: immutable. DNS caching rules out the URL swap.

A production Elastic Beanstalk environment runs on an Amazon Linux 2 platform branch, which has been retired. The team must move it to an Amazon Linux 2023 platform branch.

The move must have near-zero downtime, allow testing of the new platform before users reach it, and allow a fast return to the old platform. The database runs outside the environment.

What should the team do?

A Clone the environment onto the new platform branch, test it, then swap environment URLs

B Run an immutable deployment of the current application version to the existing environment

C Enable managed platform updates and wait for the next maintenance window

D Change the platform branch in place during a quiet period using All at once

◆ PAUSE AND DECIDE

What should the team do?

A Clone, test, swap URLs

The new platform is fully testable first, and swapping back is the fast return. The external database makes it safe.

B Immutable deployment

Deploys an application version. It does not move the environment to a new platform branch.

C Managed platform updates

Patches within the current branch. It will not cross to a different branch.

D In place, all at once

Downtime, no testing beforehand, and no quick way back.

THE SIGNAL

Platform branch change with testing and fast rollback: clone and swap. This is where the URL swap earns its place.

> An application runs on Amazon EKS. Each pod loads a large cache for about 30 seconds after starting before it can serve requests.
>
> During every rolling update, users receive errors for roughly 30 seconds per batch of new pods. Pods are never restarted unexpectedly.

What should the DevOps engineer configure?

A. A liveness probe on the container

B. A readiness probe that succeeds only once the cache has loaded

C. A larger maxSurge on the Deployment

D. A higher minimum replica count on the Horizontal Pod Autoscaler

◆ PAUSE AND DECIDE

What should the DevOps engineer configure?

A Liveness probe

Restarts stuck containers. A warming pod is not stuck; it would still get traffic too early.

B Readiness probe after cache load

The pod receives traffic only once it can serve, and the rollout waits for readiness.

C Larger maxSurge

More new pods at once, all receiving traffic before they are warm.

D More minimum replicas

More pods overall; new ones still take traffic too early.

THE SIGNAL

Traffic reaches pods before they can serve: readiness. Containers hang and need restarting: liveness.

Module 7 in five lines

- ECS rolling: min and max percent. Circuit breaker catches tasks that fail; alarms catch tasks that misbehave.
- ECS native blue/green, linear and canary since 2025: test listener, hooks, bake, instant rollback.
- Lambda: an alias splits traffic by weight. SAM's AutoPublishAlias and DeploymentPreference wire CodeDeploy.
- Beanstalk: immutable for clean releases; clone and URL swap for platform changes.
- Hooks must report back. EKS readiness probes gate traffic; liveness probes restart.

> ON THE EXAM
>
> Next, module 8: cross-account and multi-Region pipelines, the last module of Domain 1.

MODULE 08 · DOMAIN 1 - SDLC AUTOMATION

Cross-Account and Multi-Region Pipelines

One tooling account releasing into many accounts and Regions: the roles, keys and policies that make it work, and the tools that scale it.

DOMAIN 1 of 6 EXAM WEIGHT 22% MODULE 8 of 34

admin@sthithapragna.com

Every boundary is a door with **two locks**: the caller must be allowed to ask, and the other side must agree to answer. Encrypted artifacts add a **third**: the key.

The locks on a cross-account deployment

LOCK	LIVES IN	MUST ALLOW
Pipeline service role policy	Tooling account	sts:AssumeRole on the target's deploy role
Deploy role trust policy	Target account	The pipeline service role to assume it
Deploy role permissions	Target account	Read the artifact bucket, decrypt with the key
Artifact bucket policy	Tooling account	The target's deploy role to get objects
KMS key policy	Tooling account	The target's deploy role to decrypt

ON THE EXAM

Five places, two accounts. A question usually confirms two of them are correct and hides the fault in a third.

One cross-account deploy, step by step

01

Assume

The pipeline assumes the deploy role in production.

02

Read

The deploy role gets the artifact from the tooling bucket.

03

Decrypt

The customer managed key lets it decrypt.

04

Hand over

It calls CloudFormation, passing an execution role.

05

Create

CloudFormation builds resources as that execution role.

ON THE EXAM

Two roles in the target account: one the pipeline assumes, one CloudFormation works as. They fail differently.

Action role, or execution role?

ACTION ROLE

Assumed by the pipeline

- Set as the action's role ARN
- Reads artifacts, starts the stack operation
- Needs iam:PassRole for the execution role
- Fails as: cannot read or cannot start

CLOUDFORMATION EXECUTION ROLE

Used by CloudFormation

- Set in the action's configuration
- Creates, updates and deletes resources
- Needs permissions for every resource type
- Fails as: stack events show access denied

THE TIEBREAKER

Stack starts, then a resource fails with access denied: the execution role. Nothing starts at all: the action role.

The key policy statement that opens the third lock

```
{
  "Sid": "TargetAccountsDecryptArtifacts",
  "Effect": "Allow",
  "Principal": { "AWS": [
    "arn:aws:iam::222222222222:role/deploy-role",
    "arn:aws:iam::333333333333:role/deploy-role" ] },
  "Action": ["kms:Decrypt", "kms:DescribeKey"],
  "Resource": "*",
  "Condition": { "StringEquals": {
    "kms:ViaService": "s3.us-east-1.amazonaws.com" } }
}
```

5-6 The deploy roles in staging and production, named explicitly.

10 Only usable through S3 in this Region, not directly.

ON THE EXAM

The AWS managed key for S3 has a policy nobody can edit. That is why cross-account needs a customer managed key.

Artifacts never leave the tooling account

- Every action reads inputs from, and writes outputs to, the pipeline's own artifact store.
- An action in account B writing output needs **put** access to the bucket and **encrypt** on the key.
- Anything that fetches artifacts itself, such as EC2 instances running CodeDeploy, needs the same read and decrypt.
- The key must be in the **same Region** as the pipeline. KMS keys are Regional.

> ON THE EXAM
>
> Build in one target account, deploy in another: both read and write through the tooling bucket and key.

Crossing Regions

- An action can run in another Region by setting its **Region** field.
- The pipeline then needs an **artifact store in that Region**: a bucket and a key there.
- CodePipeline copies artifacts between the Regional stores automatically.
- Replicating the main bucket yourself is not how it works. The stores are declared on the pipeline.

> ON THE EXAM
>
> Cross-Region action fails because no artifact store exists there: add a Regional store to the pipeline.

Declaring a store per Region

```
"artifactStores": {
  "us-east-1": {
    "type": "S3", "location": "artifacts-111111111111-us-east-1",
    "encryptionKey": { "type": "KMS", "id": "alias/pipeline-use1" } },
  "eu-west-1": {
    "type": "S3", "location": "artifacts-111111111111-eu-west-1",
    "encryptionKey": { "type": "KMS", "id": "alias/pipeline-euw1" } }
}
```

5-7 A second bucket and a second key, both in eu-west-1.

4, 7 One key per Region: a key cannot be used outside its Region.

ON THE EXAM

Cross-account and cross-Region together: every Regional key policy must admit every target account's deploy role.

Four ways to reach many accounts

TOOL	BEST FOR	MODULE
CodePipeline cross-account actions	Releasing an application through ordered environments	This one
CloudFormation StackSets	One template into many accounts and Regions at once	Module 10
CDK Pipelines	CDK apps, with a pipeline that updates itself	Module 11
Control Tower customisations	Baselines for every account, by OU	Module 12

ON THE EXAM

An application moving dev, staging, production: a pipeline. The same baseline in every account: StackSets or Control Tower.

StackSets, in brief

- **Service-managed** StackSets use Organizations: no roles to create in each account.
- **Automatic deployment** to a target OU includes accounts added to it later.
- Maximum concurrent accounts, failure tolerance and Region order limit blast radius.
- A **delegated administrator** account can run them instead of the management account.

> ON THE EXAM
>
> 'Every account in this OU, including future ones, with least overhead': a service-managed StackSet with automatic deployment.

CDK Pipelines, in brief

- Each target account is **bootstrapped** with a trust to the tooling account.
- The pipeline is **self-mutating**: change its code, and it updates itself on the next run.
- **Stages** map to environments; **waves** deploy several stages in parallel.
- Deploying to an account that was never bootstrapped with that trust fails.

> ON THE EXAM
>
> CDK pipeline cannot deploy into a new account: bootstrap it, trusting the tooling account.

Starting a pipeline from another account

- The source sits in account A; the pipeline in the tooling account.
- In account A, an **EventBridge rule** forwards the source event to the tooling account's event bus.
- The tooling bus's **resource policy** accepts events from account A.
- A rule on the tooling bus starts the pipeline, using a role allowed to do so.

> ON THE EXAM
>
> Pushes in another account do not start the pipeline: forward the event across accounts with EventBridge.

Releasing to many Regions in waves

01
First Region
Lowest traffic or least critical.

02
Bake
Alarms watch; a stage condition can roll back.

03
Wave two
A few Regions in parallel.

04
Bake again
Confidence grows with each wave.

05
The rest
Remaining Regions, still watched.

ON THE EXAM

A bad release should reach one Region, not all of them. Waves are how the pipeline limits blast radius.

Keeping cross-account power under control

- Deploy roles trust **only** the pipeline's service role, never the whole tooling account.
- A **separate deploy role** per environment, so a staging mistake cannot touch production.
- Manual approval before production accounts where change control requires it.
- SCPs can stop anyone but the pipeline from changing production resources.

> ON THE EXAM
>
> A trust policy naming the whole tooling account lets any principal there with AssumeRole deploy to production.

> A pipeline in a tooling account deploys a CloudFormation template to the production account. The action assumes a deploy role in production, which reads and decrypts the artifact successfully.
>
> The stack creation begins, but then fails: the stack events show access denied when creating a DynamoDB table.

What should the DevOps engineer fix?

A. Add DynamoDB permissions to the pipeline's service role in the tooling account

B. Add the production account to the artifact key's policy

C. Add DynamoDB permissions to the CloudFormation execution role in the production account

D. Add s3:GetObject for the deploy role to the artifact bucket policy

◆ PAUSE AND DECIDE

What should the DevOps engineer fix?

A **Pipeline service role**

It never creates resources in production. It only assumes the deploy role.

B **Key policy**

The scenario says decryption succeeded. That lock is already open.

C **CloudFormation execution role**

CloudFormation creates resources as this role. The stack started, so the failure is here.

D **Bucket policy**

The artifact was read successfully. That lock is already open too.

THE SIGNAL

Stack started, then a resource failed with access denied: the execution role. The scenario opened the other locks for you.

> A pipeline in us-east-1 deploys an application with CloudFormation. The team adds a second deploy action with its Region set to eu-west-1.
>
> Saving the pipeline fails with an error saying that no artifact store is configured for eu-west-1.

What should the DevOps engineer do?

A Enable S3 Cross-Region Replication from the us-east-1 artifact bucket to a bucket in eu-west-1

B Create a Multi-Region Access Point over the existing artifact bucket

C Create a second, separate pipeline in eu-west-1

D Add an artifact store for eu-west-1, with a bucket and a KMS key in that Region, to the pipeline

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Cross-Region Replication

The pipeline does not use replicated buckets. It needs a store declared on itself.

B Multi-Region Access Point

A real S3 feature, but not something CodePipeline's artifact stores use.

C Second pipeline

Duplicates the whole release process and loses the single ordered flow.

D Regional artifact store

Exactly what the error asks for. CodePipeline then copies artifacts across automatically.

THE SIGNAL

Cross-Region action, no artifact store there: declare one on the pipeline. The copying is automatic.

> A company keeps its CodeCommit repository in a development account. The release pipeline lives in a central tooling account and uses that repository as its source through a cross-account role.
>
> The pipeline runs correctly when started by hand, but it never starts automatically when developers push to the main branch.

Which solution starts the pipeline on every push?

A. An EventBridge rule in the development account that forwards the repository's events to the tooling account's event bus, and a rule there that starts the pipeline

B. A Lambda function in the tooling account that polls the repository every minute and starts the pipeline

C. Move the pipeline into the development account

D. A notification rule on the repository that emails the release team

◆ PAUSE AND DECIDE

Which solution starts the pipeline on every push?

A Forward events across accounts

The push event fires in the development account. Forwarding it to the tooling bus lets a local rule start the pipeline.

B Polling Lambda

Works, with delay and custom code. Event forwarding is the native answer.

C Move the pipeline

Abandons the central tooling account the company chose.

D Email notification

Tells people; starts nothing.

THE SIGNAL

Source events fire in the wrong account: forward them with EventBridge. Allowed to send, willing to receive.

A company uses AWS Organizations. It must deploy the same CloudFormation template, an IAM role and an AWS Config rule, to every account in its Workloads OU.

Accounts added to that OU in future must receive the template automatically. The company does not use Control Tower and wants the least operational overhead.

Which solution meets these requirements?

A. A pipeline with one cross-account deploy action per account, updated as accounts are added

B. A service-managed StackSet targeting the Workloads OU, with automatic deployment enabled

C. A Lambda function triggered by account creation events that deploys the stack

D. A CDK pipeline with one stage per account

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A One action per account

Must be edited for every new account. Fails 'automatically'.

B Service-managed StackSet, auto-deploy

Targets the OU, deploys to future accounts automatically, needs no per-account roles.

C Lambda on account creation

Rebuilds what automatic deployment already does, and misses accounts moved into the OU.

D CDK stage per account

Every new account needs bootstrapping and a new stage. Not automatic.

THE SIGNAL

Same template, every account in an OU, including future ones: service-managed StackSet with automatic deployment.

Module 8, and Domain 1, in five lines

- Every boundary has locks on both sides: caller permissions, trust or resource policy, and the key.
- Cross-account artifacts need a customer managed key in the pipeline's Region.
- Action role starts the work; CloudFormation execution role creates resources.
- Cross-Region actions need a declared artifact store in each Region.
- Application releases: a pipeline. Same template everywhere: StackSets. Release Regions in waves.

> ON THE EXAM
>
> Domain 1 complete. Next, module 9 opens Domain 2 with CloudFormation for operators.

MODULE 09 · DOMAIN 2 - CONFIGURATION MANAGEMENT AND IAC

CloudFormation for Operators

Change sets and drift, protecting data from replacement and deletion, bootstrapping instances with signals, custom resources, and reshaping stacks.

DOMAIN 2 of 6 EXAM WEIGHT 17% MODULE 9 of 34

admin@sthithapragna.com

A stack is a **promise** that the template and reality match. Operating CloudFormation means managing the moments that promise is at risk.

Moments of risk, and the tool for each

THE MOMENT	THE TOOL
About to change something	Change sets
Someone changed it by hand	Drift detection; drift-aware change sets
An update would replace or delete data	Update replace and deletion policies; stack policy
Instance up, software not ready	Creation policy with cfn-signal
An update fails part-way	Rollback, rollback triggers, continue rollback
Existing resources, or the wrong structure	Import, IaC generator, stack refactoring

ON THE EXAM

Match the moment in the scenario to its row, and most options belong to a different row.

Change sets: look before you leap

- A change set previews what an update will add, modify or remove, **before** anything happens.
- Each modification shows whether it needs **replacement**: True, False, or Conditional.
- In a pipeline: create change set, manual approval, execute change set, as three actions.
- A change set shows what CloudFormation will do, not whether the application will work.

> ON THE EXAM
>
> Review infrastructure changes before production, least overhead: change set, approval, execute, in the pipeline.

Three kinds of update

UPDATE BEHAVIOUR	WHAT HAPPENS	WATCH OUT FOR
No interruption	Changed in place, keeps serving	Nothing
Some interruption	Changed in place, briefly unavailable	An instance reboot
Replacement	New resource created, old one deleted	New ID, new endpoint, lost data

ON THE EXAM

Replacement of a stateful resource is how data is lost. A change set showing Replacement: True on a database is a stop sign.

Deletion policy, or update replace policy?

DELETIONPOLICY

When the resource leaves the stack

- Removed from the template, or stack deleted
- Delete, Retain, Snapshot
- RetainExceptOnCreate: clean up failed creates
- Protects against deletion

UPDATEREPLACEPOLICY

When an update replaces it

- The old copy, after a replacement
- Delete, Retain, Snapshot
- RetainExceptOnCreate is not allowed
- Protects against replacement

THE TIEBREAKER

Many stateful resources need both. A deletion policy alone does nothing when an update replaces the resource.

Stopping a dangerous update before it happens

- A **stack policy** denies update actions on named resources, such as Update:Replace or Update:Delete.
- It applies to **everyone** who updates the stack, including pipelines, and can be overridden deliberately.
- **Termination protection** blocks deleting the whole stack. It does nothing for updates.
- Once set, a stack policy cannot be removed, only replaced. The default after setting one is deny.

> ON THE EXAM
>
> Prevent any update from replacing the production database, for every user: a stack policy on that resource.

Drift: when reality and template disagree

- **Drift detection** compares live resources with the template: IN_SYNC, MODIFIED, DELETED, NOT_CHECKED.
- The Config managed rule **cloudformation-stack-drift-detection-check** runs it continuously.
- Classic change sets compare new template with old template. They ignore drift entirely.
- **Drift-aware change sets** (November 2025) compare template, last deployment and live state.

> ON THE EXAM
>
> Detect drift across many stacks on a schedule: the AWS Config rule, not a scheduled Lambda.

Classic change set, or drift-aware?

DRIFT-AWARE CHANGE SET

Three-way comparison

- Template, last deployment, and live state
- Shows drift the update will overwrite
- Can revert drifted properties to the template
- Deployment mode REVERT_DRIFT

CLASSIC CHANGE SET

Two-way comparison

- New template against old template
- Blind to manual changes
- Unchanged properties keep their drift
- Still the default

THE TIEBREAKER

'Restore resources changed by hand to the template's configuration, and preview it first': a drift-aware change set.

Bootstrapping an instance from the template

- **AWS::CloudFormation::Init** metadata declares packages, files, users, commands and services.
- **cfn-init**, called from user data, reads that metadata and applies it.
- **configSets** control the order in which groups of configuration run.
- Declarative metadata is easier to read and update than a long user data script.

> ON THE EXAM
>
> The helper scripts ship with Amazon Linux AMIs. Instances need a network path to the CloudFormation endpoint.

Waiting for the instance to say it is ready

```
1  WebServerGroup:
2    Type: AWS::AutoScaling::AutoScalingGroup
3    CreationPolicy:
4      ResourceSignal: { Count: 3, Timeout: PT15M }
5    # launch template user data runs:
6    #   /opt/aws/bin/cfn-init -s ${AWS::StackName} -r LaunchTemplate
7    #   /opt/aws/bin/cfn-signal -e $? -s ${AWS::StackName} -r WebServerGroup
8    Properties:
9      MinSize: 3
10     MaxSize: 6
```

4 Wait for three success signals, for at most fifteen minutes.

7 Signal cfn-init's exit code: success only if configuration worked.

ON THE EXAM

No signals in time, or a failure signal: the resource fails and the stack rolls back.

cfn-hup: configuration changes without replacement

- **cfn-hup** is a daemon that checks the metadata for changes, every 15 minutes by default.
- When metadata changes, its hooks run actions, usually cfn-init again.
- So a template update can change files or services on running instances, in place.
- Without cfn-hup, changing Init metadata does nothing to instances already running.

> ON THE EXAM
>
> Metadata updated, running instances unchanged: cfn-hup is missing or not configured.

Update policies for Auto Scaling groups

UPDATEPOLICY	WHAT AN UPDATE DOES	ROLLBACK
`AutoScalingRollingUpdate`	Replaces instances in batches, keeping a minimum in service	Rolls batches back
`AutoScalingReplacingUpdate`	Creates a whole new group, then removes the old	Keeps the old group: fast
`AutoScalingScheduledAction`	Stops the template resetting sizes set by schedules	Not applicable

ON THE EXAM

Rolling update with WaitOnResourceSignals makes each batch prove itself with cfn-signal before the next.

When a stack operation fails

- By default a failed operation **rolls back** to the last good state.
- **Rollback triggers** name CloudWatch alarms, watched during and up to 180 minutes after an update.
- Choosing to **preserve successfully provisioned resources** keeps them for debugging a failed create or update.
- UPDATE_ROLLBACK_FAILED: fix the cause, then **continue update rollback**, skipping resources if needed.

> ON THE EXAM
>
> Roll back a stack update if application errors rise shortly afterwards: rollback triggers on the stack.

Custom resources

- A **ServiceToken** points at a Lambda function or SNS topic that handles Create, Update and Delete.
- The handler must send its result to a **presigned S3 URL**. That is how CloudFormation hears back.
- **ServiceTimeout** (June 2024), 1 to 3600 seconds, replaces the old fixed wait of one hour.
- A handler that ignores Delete, or cannot reach S3, leaves the stack waiting.

> ON THE EXAM
>
> Stack stuck for an hour on a custom resource whose function succeeded: the response never reached the S3 URL.

Getting values into templates safely

- **Dynamic references** resolve at deploy time: resolve:ssm, resolve:ssm-secure, resolve:secretsmanager.
- The secret never appears in the template, the parameters, or the stack's console view.
- **NoEcho** parameters hide a value in output, but someone still has to supply it.
- A plaintext default value for a password parameter is visible to anyone who reads the template.

> ON THE EXAM
>
> Database password in a template, least exposure: a Secrets Manager dynamic reference, or a managed master password.

Nested stacks, or cross-stack references?

NESTED STACKS

One unit, reusable parts

- A parent stack contains child stacks
- Deployed and rolled back together
- Good for reusable components
- Outputs passed parent to child

EXPORTS AND IMPORTVALUE

Separate lifecycles

- One stack exports, others import
- Each stack deployed on its own
- Exporter cannot delete an export in use
- Nor change its value while imported

THE TIEBREAKER

Network owned by one team, apps by others: exports. Components always deployed together: nested stacks.

Reshaping what already exists

SITUATION	TOOL
Resources exist, but no stack manages them	Resource import, with DeletionPolicy set
Many existing resources, and no template	IaC generator: scan, then generate a template or CDK app
Resources in the wrong stack, or badly named	Stack refactoring (February 2025)
Old way to move a resource	Retain, remove from stack, import elsewhere

ON THE EXAM

Split a monolithic stack without recreating resources: stack refactoring, previewed, then executed atomically.

A template creates an Auto Scaling group in private subnets with no NAT gateway, using a CreationPolicy that waits for three signals within 15 minutes. User data runs cfn-init and then cfn-signal.

Stack creation fails after 15 minutes with 'received 0 SUCCESS signals'. Connecting to an instance shows the application installed and running correctly.

What should the DevOps engineer do?

A Increase the signal timeout to one hour

B Remove the CreationPolicy from the Auto Scaling group

C Give the instances a path to the CloudFormation endpoint, such as an interface VPC endpoint

D Replace the CreationPolicy with a WaitCondition

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Longer timeout

The signals are not slow. They can never arrive, so any timeout expires.

B Remove the CreationPolicy

Stops the failure by removing the readiness check. The stack no longer knows the fleet works.

C Endpoint path for cfn-signal

The application works; the signal cannot leave the subnet. A CloudFormation interface endpoint carries it.

D WaitCondition

Its signals also need to reach AWS. Same network problem, older mechanism.

THE SIGNAL

Software fine, zero signals, private subnets: cfn-signal cannot reach CloudFormation.

A developer changed a property on the production RDS instance in a stack's template. The change required replacement, and the update created a new, empty database.

The company wants to prevent any stack update, by anyone or any pipeline, from replacing or deleting that database, with the least operational overhead.

What should the DevOps engineer implement?

A Set DeletionPolicy: Retain on the database resource

B An IAM policy that denies developers rds:DeleteDBInstance

C Enable termination protection on the stack

D A stack policy that denies Update:Replace and Update:Delete on the database resource

◆ PAUSE AND DECIDE

What should the DevOps engineer implement?

A DeletionPolicy: Retain

Applies when the resource leaves the stack. A replacement still happens, with a new empty database.

B IAM deny for developers

CloudFormation or the pipeline performs the replacement, not the developer directly.

C Termination protection

Blocks deleting the whole stack. Updates are unaffected.

D Stack policy on the database

Blocks the update itself, for every user and pipeline, until deliberately overridden.

THE SIGNAL

'Prevent any update from replacing' is a stack policy. Add UpdateReplacePolicy: Snapshot as a second safety net.

During an incident, engineers edited several security group rules and an S3 bucket policy by hand in the console. Those resources belong to a CloudFormation stack.

The team wants the next deployment to return every hand-edited property to the template's values, and to preview that before it happens, with the least effort.

What should the team do?

A Create a drift-aware change set that reverts drift, review it, and execute it

B Delete the stack and create it again from the template

C Run drift detection, then reverse each difference by hand in the console

D Enable the Config rule for stack drift so the team is alerted next time

◆ PAUSE AND DECIDE

What should the team do?

A Drift-aware change set

Previews the drift it will overwrite, then restores template values, in one reviewed operation.

B Delete and recreate

Destroys resources, including anything stateful, to fix configuration. Far too much.

C Detect, then fix by hand

Works, but more manual console edits: the very thing that caused the drift.

D Config drift rule

Detects future drift. Fixes nothing that has already happened.

THE SIGNAL

Restore hand edits to the template, with a preview: a drift-aware change set. A classic one would leave them.

> A stack includes a Lambda-backed custom resource. The function runs in private subnets with no NAT gateway and no VPC endpoints, because it configures a private database.
>
> The stack stays in CREATE_IN_PROGRESS for an hour and then fails. The function's logs show it configured the database successfully within seconds.

How should the DevOps engineer fix this?

A Increase the Lambda function's timeout to 15 minutes

B Add an S3 gateway endpoint so the function can send its response, and set a shorter ServiceTimeout

C Change the custom resource to be backed by an SNS topic

D Add a WaitCondition that depends on the custom resource

◆ PAUSE AND DECIDE

How should the DevOps engineer fix this?

A Longer Lambda timeout

The work finished in seconds. Time was never the problem.

B S3 gateway endpoint, shorter ServiceTimeout

The response goes to a presigned S3 URL, which this subnet cannot reach. A shorter timeout fails fast next time.

C SNS-backed

The handler would still need to write its response to S3.

D WaitCondition

Adds another wait. The custom resource still never responds.

THE SIGNAL

Work succeeded, stack waited an hour: the response never reached S3. Same shape as a missing cfn-signal.

Module 9 in five lines

- Change sets preview; drift-aware change sets also see and revert hand edits.
- DeletionPolicy for leaving the stack; UpdateReplacePolicy for replacement; stack policy to forbid either.
- Creation policy plus cfn-signal proves software is ready; cfn-hup applies later metadata changes.
- Custom resources and signals must reach AWS endpoints, or the stack waits.
- Dynamic references for secrets. Import, generator and refactoring reshape existing estates.

ON THE EXAM

Next, module 10: StackSets, modules, Service Catalog, and Hooks with Guard.

MODULE 10 · DOMAIN 2 - CONFIGURATION MANAGEMENT AND IAC

Infrastructure as Code at Scale

StackSets across accounts and Regions, modules for reuse, Service Catalog for self-service, and Guard with Hooks for guardrails.

DOMAIN 2 of 6 EXAM WEIGHT 17% MODULE 10 of 34

admin@sthithapragna.com

Four problems of scale, four tools

PROBLEM	TOOL
The same template in many accounts and Regions	CloudFormation StackSets
The same snippet repeated in many templates	CloudFormation modules, or CDK constructs
Teams need approved resources without broad IAM power	AWS Service Catalog
Non-compliant resources must be stopped before they exist	CloudFormation Guard and Hooks

ON THE EXAM

Distribution, reuse, self-service, guardrails. Name the problem and the tool follows.

Self-managed or service-managed StackSets?

SERVICE-MANAGED

Uses AWS Organizations

- No roles to create in each account
- Target the organisation or OUs
- Automatic deployment to new accounts
- Management or delegated admin account runs it

SELF-MANAGED

You create the roles

- An administration role, and an execution role per target
- Target individual account IDs
- No automatic deployment
- Works outside an organisation

THE TIEBREAKER

Inside an organisation, targeting OUs, including future accounts: service-managed. Accounts outside it: self-managed.

Operation preferences: controlling the blast radius

SETTING	WHAT IT CONTROLS
Maximum concurrent accounts	How many accounts per Region are worked on at once
Failure tolerance	How many accounts per Region may fail before stopping
Region concurrency	Sequential, one Region at a time, or parallel
Region order	Which Region goes first when sequential
Concurrency mode	Strict: slows down as failures occur. Soft: keeps its pace

ON THE EXAM

Exceed the failure tolerance in a Region, and the operation stops there and skips every later Region.

The arithmetic of a safe rollout

- Defaults are cautious: one account at a time, and zero failures tolerated.
- In strict mode, maximum concurrency can be at most **failure tolerance plus one**.
- Tolerance 2, concurrency 3: at worst three accounts fail before it stops.
- Operation preferences do **not** apply to automatic deployments to new accounts.

> ON THE EXAM
>
> 'Stop quickly if more than two accounts fail, one Region at a time': tolerance 2, sequential, with a Region order.

Service-managed details that get examined

- Targeting an OU includes its child OUs. Account filters can narrow or widen the targets.
- The **management account never receives stacks**, even if it sits in a targeted OU.
- When an account leaves a target OU, its stacks are deleted or retained, as you choose.
- **StackSet dependencies**, up to ten, order automatic deployments between StackSets.

> ON THE EXAM
>
> A baseline never appears in the management account: expected. Deploy there separately, with a normal stack.

When StackSet instances go wrong

- **Parameter overrides** give one account or Region different values from the same StackSet.
- Names that must be unique, such as S3 buckets or IAM roles, collide across Regions or accounts.
- Include the account ID and Region in such names, or let CloudFormation generate them.
- Drift detection works across a whole StackSet, instance by instance.

> ON THE EXAM
>
> StackSet fails in the second Region only, 'already exists': a globally named resource is colliding.

A module, or a nested stack?

CLOUDFORMATION MODULE

Expands into your template

- Registered in the registry, type ending ::MODULE
- Its resources join the parent stack
- Versioned, shareable building block
- No separate stack to manage

NESTED STACK

A stack inside a stack

- A separate child stack, with its own events
- Resources belong to the child
- Referenced by template URL
- Its own limits and lifecycle

THE TIEBREAKER

Reusable, versioned snippet with no extra stacks: a module. A separately managed component: a nested stack.

AWS Service Catalog: approved self-service

- A **product** is a versioned template: CloudFormation, or Terraform.
- A **portfolio** groups products and grants them to users, groups or roles.
- Users launch **provisioned products**, choosing only the parameters you expose.
- Users need Service Catalog permissions, not permissions for the resources underneath.

> ON THE EXAM
>
> Teams must launch only approved, compliant configurations, without broad permissions: Service Catalog.

Service Catalog constraints

CONSTRAINT	WHAT IT DOES
Launch constraint	Names an IAM role that Service Catalog assumes to provision
Template constraint	Limits parameter values, such as allowed instance types
TagOptions	Applies approved tags, or lets users choose from approved values
Notification constraint	Sends stack events to an SNS topic
StackSet constraint	Lets a product deploy to several accounts and Regions

ON THE EXAM

The launch constraint is how least privilege works: the role creates the resources, not the user.

Sharing and updating a catalogue

- Portfolios can be shared with accounts, or with OUs through AWS Organizations.
- The receiving account imports the portfolio and grants it to its own users.
- New template versions become new product versions. Users update their provisioned products.
- A delegated administrator account can manage organisation sharing.

> ON THE EXAM
>
> One central catalogue for every account in the organisation: share the portfolio with the OU.

CloudFormation Guard: policy as code

- **Guard** is a rule language for checking JSON or YAML against your policies.
- It checks CloudFormation templates, and also Terraform plans and Kubernetes manifests.
- **cfn-guard validate** in a build fails the pipeline on a violation, before any deployment.
- **cfn-lint** is different: it checks template syntax and best practice, not your organisation's rules.

> ON THE EXAM
>
> The same Guard rules can run in three places: a developer's machine, the build, and a Hook at deploy time.

A Guard rule

```
let buckets = Resources.*[ Type == 'AWS::S3::Bucket' ]

rule buckets_are_versioned_and_private when %buckets !empty {
  %buckets.Properties.VersioningConfiguration.Status == 'Enabled'
  %buckets.Properties.PublicAccessBlockConfiguration.BlockPublicAcls == true
  %buckets.Properties.PublicAccessBlockConfiguration.RestrictPublicBuckets == true
}
```

1 Select every S3 bucket resource in the template.

3 Only evaluate the rule if there are buckets to check.

ON THE EXAM

Every clause must hold for every selected resource. One unversioned bucket fails the rule.

CloudFormation Hooks: guardrails at deploy time

- Four kinds: **Control Catalog** proactive controls, **Guard**, **Lambda**, and custom Hooks.
- Targets: resources, whole stacks, change sets, and Cloud Control API calls.
- Failure mode **FAIL** stops the operation; **WARN** lets it continue with a warning.
- Hooks are set per account and Region. Roll them out organisation-wide with StackSets.

> ON THE EXAM
>
> Since September 2025, Hooks can apply Control Tower's managed proactive controls, with no rules to write.

One policy, checked at every stage

01
Developer
cfn-lint and cfn-guard locally, in seconds.

02
Pull request
Guard in a CodeBuild check before merge.

03
Pipeline
Guard fails the build: nothing deploys.

04
Deploy time
A Hook in FAIL mode blocks what slipped through.

05
After deploy
AWS Config rules detect changes made later.

ON THE EXAM

Earlier stages give faster feedback. The Hook is the final gate that catches anything else.

Hook, SCP, or Config rule?

CLOUDFORMATION HOOK

Preventive, rich checks

- Sees full resource properties
- Only CloudFormation and Cloud Control operations
- Stops the stack operation
- Per account and Region

SCP OR CONFIG RULE

Broader, but different

- SCP: every API call, but only condition keys
- SCP: cannot inspect most resource properties
- Config: any change, but after the fact
- Config: detective, with optional remediation

THE TIEBREAKER

Check properties of resources deployed through CloudFormation, before creation: a Hook. Deny an API everywhere: an SCP.

A service-managed StackSet deploys a monitoring baseline to 60 accounts in four Regions. A recent update failed in many accounts at once before anyone noticed.

For future updates, the company wants Regions updated one at a time, starting with eu-west-1, and wants the update to stop as soon as more than two accounts fail in a Region.

Which operation preferences should the DevOps engineer set?

A. Parallel Region concurrency, with a failure tolerance of 2

B. Maximum concurrent accounts of 100%, with soft failure tolerance

C. Sequential Region concurrency with eu-west-1 first in the Region order, and a failure tolerance of 2

D. Soft failure tolerance with 60 maximum concurrent accounts

◆ PAUSE AND DECIDE

Which operation preferences should the DevOps engineer set?

A Parallel, tolerance 2

Right tolerance, but every Region at once. Fails 'one at a time'.

B 100% concurrency, soft

Everything at once and keeps going through failures: the incident, repeated.

C Sequential, eu-west-1 first, tolerance 2

One Region at a time in a chosen order, stopping after the third failure in a Region.

D Soft, 60 concurrent

Soft mode ignores failures when setting pace. The opposite of stopping quickly.

THE SIGNAL

One Region at a time: sequential. Starting with a named Region: Region order. Stop after N failures: tolerance N.

Developers frequently need PostgreSQL databases for new services. Each must be encrypted, have backups enabled, and use approved instance classes.

The security team will not give developers permission to create RDS resources directly. The company wants developers to self-serve compliant databases with the least operational overhead.

Which solution meets these requirements?

A Grant developers RDS permissions, and use an AWS Config rule to flag non-compliant databases

B A CodeBuild project that developers start, which creates the database with the AWS CLI

C Publish an approved template in S3 and let developers deploy it with CloudFormation

D A Service Catalog product in a portfolio shared with developers, with a launch constraint role and a template constraint on instance classes

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A RDS permissions plus Config

Gives developers exactly the permission the security team refused, and only detects problems later.

B CodeBuild with the CLI

A home-built self-service system: parameters, validation and updates all to maintain.

C Template in S3

Deploying it still needs RDS permissions, and developers could edit the template.

D Service Catalog, launch and template constraints

The launch role creates the database; developers need only catalogue access and pick approved values.

THE SIGNAL

Self-service without the underlying permissions: Service Catalog with a launch constraint.

A security team has written a Guard Hook requiring encryption with a customer managed key on every DynamoDB table. Forty teams deploy with CloudFormation.

The security team is concerned that blocking immediately would break some teams' releases. It wants to see which stacks would fail before enforcing the rule.

What should the security team do?

A Activate the Hook in FAIL mode, filtered to a single test stack

B Replace the Hook with an AWS Config rule

C Activate the Hook in WARN mode, review its invocation results, then switch to FAIL mode

D Write an SCP denying dynamodb:CreateTable without customer managed key encryption

◆ PAUSE AND DECIDE

What should the security team do?

A FAIL on one test stack

Tells you nothing about the other forty teams' stacks.

B Config rule

Detects after creation. Gives up the preventive goal the Hook was written for.

C WARN, review, then FAIL

Every stack is evaluated and warned, nothing is blocked, and enforcement follows once teams have fixed things.

D SCP

Blocks immediately, the exact risk the team wants to avoid, and cannot inspect the property reliably.

THE SIGNAL

See the impact before enforcing: WARN mode first, invocation summaries, then FAIL. AWS documents this rollout.

> A Guard Hook in FAIL mode blocks non-compliant stacks at deploy time. Developers only learn of violations when a pipeline reaches its deploy stage, around 20 minutes after they push.
>
> The team wants developers to see the same violations within a minute or two of pushing, before deployment, with the least effort. The Hook must remain.

What should the DevOps engineer do?

A. Add an AWS Config rule that evaluates the same policy

B. Reduce the Hook's timeout so it fails faster

C. Switch the Hook to WARN mode so pipelines are not blocked

D. Run cfn-guard validate with the same rule files in the build and pull request checks, failing on violations

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Config rule

Evaluates after deployment. Later feedback, not earlier.

B Shorter Hook timeout

The Hook is quick. The 20 minutes is the pipeline reaching it.

C WARN mode

Removes the protection, and developers still hear nothing until deploy.

D cfn-guard in build and pull request

Same rules, run minutes after a push. The Hook stays as the final gate.

THE SIGNAL

Same policy, earlier feedback: run Guard in the build. Keep the Hook for anything that bypasses the pipeline.

Module 10 in five lines

- Service-managed StackSets for OUs and future accounts; never the management account.
- Failure tolerance per Region stops the rollout; sequential Regions follow your order.
- Modules expand into templates; nested stacks are separate stacks.
- Service Catalog launch constraints give self-service without underlying permissions.
- Guard in the build for fast feedback; Hooks at deploy time; start Hooks in WARN.

ON THE EXAM

Next, module 11: the AWS CDK and AWS SAM.

MODULE 11 · DOMAIN 2 - CONFIGURATION MANAGEMENT AND IAC

The AWS CDK and AWS SAM

Constructs and stacks, tagging and aspects, bootstrapping, context and logical IDs, testing, CDK Pipelines, and SAM's build, local and sync workflow.

DOMAIN 2 of 6 EXAM WEIGHT 17% MODULE 11 of 34

admin@sthithapragna.com

The CDK is a program that **writes** CloudFormation. SAM is a **shorthand** for it. Both end as a stack, so modules 9 and 10 still apply.

CDK or SAM?

AWS CDK

Infrastructure in a programming language

- TypeScript, Python, Java, C#, Go
- Any AWS service, any architecture
- Reusable constructs, loops, types, tests
- Best for large or shared infrastructure

AWS SAM

Serverless shorthand in YAML

- A transform over a CloudFormation template
- Functions, APIs, tables, state machines
- Local invoke and fast sync for developers
- Best for serverless applications

THE TIEBREAKER

Reusable components across many teams: CDK constructs. A serverless app with local testing: SAM. They can coexist.

Three levels of construct

LEVEL	WHAT IT IS	EXAMPLE
L1	One-to-one with a CloudFormation resource	CfnBucket: every property, no defaults
L2	An intent-based resource with sensible defaults	Bucket: encryption, grant methods, helpers
L3	A pattern combining several resources	A load-balanced Fargate service
Your own L3	Your organisation's approved pattern	A standard service with alarms and logging

ON THE EXAM

Reusable infrastructure patterns for many teams: custom L3 constructs, shared as a library.

Apps, stacks and environments

- An **app** contains **stacks**; each stack becomes one CloudFormation stack.
- One stack class, instantiated once per environment, with the differences passed in as **props**.
- Separate stacks per microservice let each deploy on its own schedule.
- Copying stack code per environment guarantees the environments drift apart.

> ON THE EXAM
>
> Consistent environments with small differences: one stack definition, parameterised, instantiated per environment.

One definition, three environments

```
1  const app = new cdk.App();
2
3  for (const env of ['dev', 'staging', 'prod']) {
4    new OrdersServiceStack(app, `orders-${env}`, {
5      env: { account: accounts[env], region: 'eu-west-2' },
6      stage: env,
7      minTasks: env === 'prod' ? 4 : 1,
8    });
9  }
10
11 cdk.Tags.of(app).add('cost-centre', 'orders');
12 cdk.Aspects.of(app).add(new AwsSolutionsChecks());
```

7 The only difference between environments, passed as a prop.

11-12 A tag and a compliance check applied to everything below the app.

ON THE EXAM

Tags.of(scope).add tags every taggable resource beneath that scope, in every stack.

Tags and aspects

- **Tags.of(scope).add** tags every taggable resource under that scope. Apply at the app for everything.
- An **aspect** visits every construct in a scope, to check or change it.
- **cdk-nag** is a set of aspects that fails synthesis on rule violations.
- Tagging resources one by one in each stack is the high-maintenance distractor.

> ON THE EXAM
>
> Same cost allocation tags across every microservice: Tags.of(app), once. Compliance checks at synth: an aspect.

From code to stack

01
Write
Constructs in your chosen language.

02
Synth
Templates and assets appear in cdk.out.

03
Diff
Compare with what is deployed.

04
Deploy
Assets to the bootstrap bucket and registry; stack updated.

05
Watch
cdk drift compares deployed stacks with reality.

ON THE EXAM

Synthesis produces ordinary CloudFormation. You can review it, test it, and scan it like any template.

Bootstrapping

- **cdk bootstrap** creates the CDKToolkit stack in each account and Region: a bucket, a registry, and roles.
- **--trust** lets a pipeline account deploy into this account.
- **--cloudformation-execution-policies** limits what deployments may create. By default it is administrator access.
- A custom permissions boundary can also be applied to roles the CDK creates.

> ON THE EXAM
>
> Restrict what CDK deployments can create in production: re-bootstrap with narrower execution policies.

Context and lookups

- Lookups such as **Vpc.fromLookup** query your account during synthesis.
- Results are cached in **cdk.context.json**. Commit that file.
- With the cache committed, synthesis is repeatable, and pipelines need no lookup access.
- Stacks without an explicit account and Region cannot use lookups.

> ON THE EXAM
>
> Synthesis gives different templates on different machines or days: commit cdk.context.json.

Logical IDs: the refactoring trap

- A resource's logical ID comes from its **path** in the construct tree.
- Moving or renaming a construct changes that path, so CloudFormation sees a **new** resource and **replaces** it.
- Keep the original ID with **overrideLogicalId**, or use **cdk refactor**, in preview since September 2025.
- **RemovalPolicy.RETAIN** keeps the old resource, but the new one still starts empty.

> ON THE EXAM
>
> Always run cdk diff after restructuring code. 'Replace' on a stateful resource means the logical ID changed.

Testing CDK code

- The **assertions** module checks synthesised templates: a resource exists, with these properties.
- **Snapshot tests** compare a whole template with an approved copy, catching unintended changes.
- Both run as ordinary unit tests in CodeBuild, before any deployment.
- cdk-nag aspects and Guard rules add policy checks on the same output.

> ON THE EXAM
>
> Prove every bucket the construct library creates is encrypted, before deploying: fine-grained assertions in unit tests.

CDK Pipelines, revisited

- A **synth** step builds the app; the pipeline then **updates itself** if its definition changed.
- Each **stage** is an environment; **waves** deploy several stages in parallel.
- **Pre** and **post** steps add tests or a manual approval around any stage.
- Target accounts must be bootstrapped with --trust for the pipeline account.

> ON THE EXAM
>
> It generates an ordinary CodePipeline pipeline, so everything from Domain 1 still applies underneath.

AWS SAM templates

- The **Transform: AWS::Serverless-2016-10-31** line tells CloudFormation to expand SAM resources.
- Resource types include Function, Api, HttpApi, SimpleTable, StateMachine and LayerVersion.
- **Policy templates** such as DynamoDBCrudPolicy grant scoped permissions in one line.
- **Connectors** declare that one resource talks to another, and SAM writes the permissions.

> ON THE EXAM
>
> Least-privilege Lambda permissions in SAM, with least effort: policy templates or connectors, not hand-written IAM.

The SAM CLI

COMMAND	WHAT IT DOES
`sam build`	Builds function code and dependencies
`sam local invoke, start-api`	Runs functions and APIs locally, in containers
`sam deploy --guided`	Deploys via CloudFormation; saves settings in samconfig.toml
`sam sync --watch`	Pushes code changes in seconds to a development stack
`sam logs, sam traces`	Reads CloudWatch logs and X-Ray traces
`sam pipeline init --bootstrap`	Generates a CI/CD pipeline and its resources

ON THE EXAM

sam local needs Docker. It tests your code, not IAM permissions or real service integrations.

sam deploy, or sam sync?

SAM SYNC

Speed, for development

- Updates function code directly where it can
- Seconds per change with --watch
- Can bypass a full CloudFormation deployment
- Development stacks only

SAM DEPLOY

Safety, for real environments

- Always a CloudFormation change set
- Minutes per change
- Traffic shifting and rollback apply
- Staging and production

THE TIEBREAKER

Faster developer iteration in the cloud: sam sync --watch. Never use it for production.

A CDK app uses Vpc.fromLookup to find an existing VPC. Developers synthesise locally, and a pipeline synthesises the same commit in CodeBuild.

The pipeline's CodeBuild role has no permission to read VPC details, so synthesis fails there. On developer machines, synthesis sometimes produces different templates from day to day.

What should the team do with the LEAST effort?

A Commit cdk.context.json to the repository so lookup results are cached and reused

B Grant the CodeBuild role full EC2 read access

C Replace every lookup with hard-coded VPC and subnet IDs throughout the code

D Run cdk deploy with the --force flag in the pipeline

◆ PAUSE AND DECIDE

What should the team do with the LEAST effort?

A Commit cdk.context.json

Lookups are cached in the repository. Synthesis is repeatable everywhere and needs no lookup access.

B EC2 read access

Fixes the pipeline error but not the changing templates. Synthesis still depends on the day.

C Hard-code IDs

Works, but throws away the lookup and spreads IDs through the code. More effort, more fragile.

D --force

Forces a deployment. Does nothing about how synthesis behaves.

THE SIGNAL

Two symptoms, one cause: lookups at synthesis time. The context file makes them deterministic.

> Production accounts were bootstrapped for the CDK with default settings. A security review notes that any CDK deployment there can create any resource, including IAM users.
>
> The security team wants CDK deployments in production limited to an approved set of managed policies, with the least operational effort and without changing developers' code.

What should the DevOps engineer do?

A. Write an SCP denying every action except those in the approved policies

B. Re-run cdk bootstrap in production with --cloudformation-execution-policies naming the approved policies

C. Delete the CDKToolkit stack from production accounts

D. Add a manual approval before every production deployment

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A SCP allow-list

Would restrict every principal in the account, not just CDK deployments. Far wider than asked.

B Re-bootstrap with execution policies

The execution role CloudFormation uses gets only the approved policies. Code unchanged.

C Delete the toolkit stack

Stops CDK deployments altogether.

D Manual approval

A person reviewing each change is not a limit on what can be created.

THE SIGNAL

Default bootstrap gives deployments administrator access. Execution policies at bootstrap are the fix.

A developer reorganises a CDK app, moving an existing DynamoDB table construct inside a new parent construct. The table holds production data.

Running cdk diff shows the table will be destroyed and a new table created. The team must keep the existing table and its data, with the least effort.

What should the developer do?

A Keep the table's original logical ID, for example with overrideLogicalId, then diff again

B Set RemovalPolicy.RETAIN on the table and deploy

C Export the data, deploy, then import the data into the new table

D Deploy with rollback disabled

◆ PAUSE AND DECIDE

What should the developer do?

A Keep the original logical ID

CloudFormation sees the same resource, so nothing is replaced. The diff confirms it.

B RemovalPolicy.RETAIN

The old table survives, orphaned. The application gets a new, empty table.

C Export and import

Works, with downtime and effort, to fix what is only a naming change.

D Rollback disabled

Changes what happens on failure. The replacement would still succeed.

THE SIGNAL

Code moved, diff says replace: the logical ID changed. Pin it back, or use cdk refactor now that it exists.

> Developers building a serverless app with SAM wait several minutes after every code change, while sam build and sam deploy update their personal development stacks.
>
> They want changes live in their development stacks within seconds, calling real AWS services. The production release process must not change.

What should the developers use?

A sam local invoke for every change, and no cloud deployments during development

B sam sync --watch against their development stacks

C Edit function code directly in the Lambda console

D Split the template into smaller stacks so each deployment is faster

◆ PAUSE AND DECIDE

What should the developers use?

A sam local only

Fast, but not real AWS services. Fails the stated requirement.

B sam sync --watch

Pushes code changes to the development stack in seconds. Production still uses deploy.

C Console edits

Drift from the template, lost on the next deployment, and no version control.

D Smaller stacks

Restructures the application to shave some minutes. Still not seconds.

THE SIGNAL

Seconds, in the cloud, development only: sam sync --watch. Production stays on sam deploy.

Module 11 in five lines

- CDK writes CloudFormation; SAM expands into it. Everything from modules 9 and 10 still applies.
- Custom L3 constructs for reuse; one stack class per environment via props; Tags.of(app) once.
- Bootstrap per account and Region; --trust for pipelines; execution policies to limit deployments.
- Commit cdk.context.json. Moving constructs changes logical IDs: diff, then pin or refactor.
- SAM: policy templates and connectors; sync for development speed, deploy for real environments.

> ON THE EXAM
>
> Next, module 12: Organizations and Control Tower. SCPs, RCPs, controls, Account Factory and customisations.

MODULE 12 · DOMAIN 2 - CONFIGURATION MANAGEMENT AND IAC

Organizations and Control Tower

SCPs, RCPs and declarative policies, delegated administration and resource sharing, Control Tower controls, and the ways to vend and customise accounts.

DOMAIN 2 of 6 EXAM WEIGHT 17% MODULE 12 of 34

admin@sthithapragna.com

Organisation policies **never grant** anything. They set **ceilings**. Accounts and resources grant access underneath them.

AWS Organizations, in one slide

- A **management account** owns the organisation; **member accounts** sit in a tree of **OUs**.
- **All features** mode enables policies; consolidated billing alone does not.
- Policies attached to the root or an OU are **inherited** by everything beneath.
- Services integrate through **trusted access**, and many allow a **delegated administrator** account.

> ON THE EXAM
>
> Keep the management account nearly empty: no workloads, few users, delegated administrators doing the daily work.

The policy types in an organisation

POLICY	SETS A CEILING ON	TYPICAL USE
Service control policy	What principals in member accounts can do	Deny Regions, protect CloudTrail
Resource control policy	What can be done to resources in member accounts	No access from outside the organisation
Declarative policy	A service's configuration	IMDSv2 by default; block public AMIs
Tag policy	Tag keys and allowed values	Consistent cost allocation tags
Backup policy	AWS Backup plans across accounts	Organisation-wide backups
AI services opt-out	Use of content to improve AI services	Data governance

ON THE EXAM

SCPs and RCPs are authorisation policies. The rest are management policies that shape configuration.

How an SCP decision is made

01
Root
An Allow must be present here.

02
Each OU
An Allow must be present at every level.

03
The account
And here, too.

04
Any Deny
An explicit Deny anywhere wins outright.

05
Then IAM
Identity and resource policies grant within the ceiling.

ON THE EXAM

FullAWSAccess is attached everywhere by default. Remove it from one OU and everything below it is denied.

SCP exceptions to memorise

- SCPs **do not** affect the **management account**.
- SCPs **do not** affect **service-linked roles**.
- SCPs **do** affect the **root user** of member accounts.
- SCPs never grant, so an SCP 'allowing' a service gives nobody access by itself.

> ON THE EXAM
>
> A guardrail that 'does not work' in the management account is working as designed.

SCPs now speak the full IAM language

- Since **19 September 2025**: conditions and specific resource ARNs in **Allow** statements.
- **NotAction** with Allow, and **NotResource** in Allow and Deny.
- Wildcards anywhere in an action, such as s3:*Object*.
- Existing SCPs keep working. AWS still recommends explicit Deny statements for guardrails.

> ON THE EXAM
>
> Older material says SCP Allow statements cannot use conditions. That stopped being true in September 2025.

A Region guardrail that does not break global services

```
1 { "Effect": "Deny",
2   "NotAction": [ "iam:*", "organizations:*", "sts:*", "route53:*",
3                  "cloudfront:*", "support:*", "budgets:*" ],
4   "Resource": "*",
5   "Condition": {
6     "StringNotEquals": { "aws:RequestedRegion": ["eu-west-1", "eu-central-1"] },
7     "ArnNotLike": { "aws:PrincipalArn": "arn:aws:iam::*:role/BreakGlass" } } }
```

2-3 Global services send requests to us-east-1, so they must be exempt.

7 A break-glass role is excluded, so an emergency is not blocked.

ON THE EXAM

Region SCP breaks IAM or CloudFront: global services were not exempted with NotAction.

SCP or RCP?

RESOURCE CONTROL POLICY

Protects your data

- Caps what may be done to your resources
- Overrides a permissive resource policy
- Blocks access from outside the organisation
- Launched November 2024

SERVICE CONTROL POLICY

Limits your people

- Caps what your principals may do
- Cannot limit principals outside the organisation
- Restricts Regions, services, actions
- The long-established guardrail

THE TIEBREAKER

Who is acting? Your engineers: an SCP. Someone outside reaching your data: an RCP.

Resource control policies

- Launched with S3, STS, KMS, SQS and Secrets Manager; now more than two dozen services.
- A data perimeter: deny access unless aws:PrincipalOrgID matches your organisation.
- **RCPFullAWSAccess** is attached by default, as FullAWSAccess is for SCPs.
- They do not affect resources in the management account.

> ON THE EXAM
>
> A bucket policy granting a named external account is not 'public', so Block Public Access permits it. An RCP does not.

Declarative policies

- Enforce a **desired configuration** for EC2, EBS and VPC, rather than a permission.
- Examples: IMDSv2 defaults, VPC Block Public Access, blocking public AMIs and snapshots, allowed AMIs.
- Maintained even as the service adds new APIs, and for accounts that join later.
- An **account status report** shows current values before you enforce.

> ON THE EXAM
>
> An SCP must enumerate every API that could change a setting. A declarative policy just sets it.

Which organisation policy?

REQUIREMENT	POLICY
No one may stop CloudTrail or leave the organisation	SCP
No principal outside the organisation may read our data	RCP
Every instance, now and in future accounts, uses IMDSv2	Declarative policy
Cost-centre tags use one of five approved values	Tag policy
Every account follows the same backup plan	Backup policy

ON THE EXAM

Read the subject of the sentence: a person acting, a resource being reached, a setting, a tag, a backup.

Delegated administrators

- A member account runs a service for the whole organisation: GuardDuty, Security Hub, Config, Macie, StackSets and more.
- Registered **per service**. Delegating one service delegates nothing else.
- Some actions, such as creating accounts, still need the management account.
- Typical layout: a security tooling account administers the security services.

> ON THE EXAM
>
> Security team must manage detection for every account without using the management account: delegated administrator.

Sharing resources with AWS RAM

- **AWS RAM** shares resources such as VPC subnets, Transit Gateways and Route 53 Resolver rules.
- With sharing enabled for Organizations, shares to OUs need **no invitations**.
- Shared subnets let workload accounts launch into centrally managed networks.
- Advanced-tier Parameter Store parameters can also be shared through RAM.

> ON THE EXAM
>
> Central networking, workloads in their own accounts, no peering: share the subnets with RAM.

AWS Control Tower

- Builds a governed **landing zone** on Organizations: log archive and audit accounts, Identity Center, baselines.
- Applies **controls** to OUs and reports **drift** from them.
- **Landing zone 4.0** (November 2025) makes service integrations optional.
- A **controls-only** experience now offers managed controls without a full landing zone.

> ON THE EXAM
>
> Many accounts, governed consistently from day one, least effort: Control Tower.

Three behaviours of control

BEHAVIOUR	IMPLEMENTED AS	ACTS
Preventive	SCPs, RCPs, declarative policies	Blocks the API call
Proactive	CloudFormation Hooks	Blocks the stack before resources exist
Detective	AWS Config rules	Reports non-compliance after it happens

ON THE EXAM

Guidance levels: mandatory, strongly recommended, elective. Controls are enabled per OU.

Vending and customising accounts

TOOL	HOW IT WORKS	CHOOSE IT WHEN
Account Factory	Service Catalog product for new accounts	Simple, console-driven vending
Account Factory Customization	Blueprints applied as accounts are made	A few standard account types
Customizations for Control Tower	Pipeline: CloudFormation and SCPs per OU, from a manifest	CloudFormation shops, Git-managed
Account Factory for Terraform	GitOps: account requests and customisations in Terraform	Terraform shops

ON THE EXAM

Same need, different language: CfCT for CloudFormation, AFT for Terraform.

Hooking into the account lifecycle

- Control Tower emits **lifecycle events**, such as CreateManagedAccount, to EventBridge.
- Rules on those events can start follow-up automation for each new account.
- **Registering** an existing OU enrols its accounts into Control Tower governance.
- Changing managed resources outside Control Tower causes drift that must be repaired.

> ON THE EXAM
>
> Existing accounts need the same governance as new ones: register their OU, rather than recreating accounts.

A company attaches an SCP to its Workloads OU that denies every action when aws:RequestedRegion is not eu-west-1 or eu-central-1.

Since then, engineers in those accounts cannot create IAM roles or update CloudFront distributions, even though their IAM policies allow it.

How should the DevOps engineer fix the SCP?

A Add Allow statements for IAM and CloudFront to the engineers' IAM policies

B Attach FullAWSAccess directly to each account

C Rewrite the Deny with NotAction, exempting global services such as IAM, CloudFront, STS and Route 53

D Move the accounts from the Workloads OU to the root

◆ PAUSE AND DECIDE

How should the DevOps engineer fix the SCP?

A **More IAM Allows**

An explicit Deny in an SCP beats any Allow. The engineers already had permission.

B **FullAWSAccess on accounts**

Allows cannot override an explicit Deny either. Nothing changes.

C **NotAction for global services**

Global services use us-east-1, so the Region Deny caught them. Exempting them keeps the guardrail.

D **Move to the root**

Removes the guardrail entirely for those accounts.

THE SIGNAL

Region guardrail breaks IAM or CloudFront: the global services were not exempted.

Teams in member accounts write their own S3 bucket policies and KMS key policies. An audit finds several that grant access to AWS accounts outside the company's organisation.

The security team must ensure no principal outside the organisation can access S3 buckets or KMS keys in member accounts, whatever those policies say, with the least operational overhead.

Which solution meets these requirements?

A An SCP denying S3 and KMS actions by principals outside the organisation

B Enable S3 Block Public Access on every account

C An AWS Config rule with a Lambda remediation that removes external statements

D An RCP denying S3 and KMS access unless aws:PrincipalOrgID matches the organisation

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A SCP on outside principals

SCPs only limit principals inside the organisation. Outsiders are untouched.

B Block Public Access

A grant to a named external account is not public. It still works. And it does nothing for KMS.

C Config and remediation

Detects and repairs after exposure, with custom code. Not 'whatever those policies say'.

D RCP on aws:PrincipalOrgID

Caps what can be done to the resources, overriding any permissive policy, centrally.

THE SIGNAL

Outsiders reaching your data despite member-account policies: an RCP. SCPs cannot touch outside principals.

A company requires every EC2 instance in every account to use IMDSv2. This must apply to accounts created in the future, and keep working as EC2 adds new APIs.

The company wants the least operational overhead, and a way to see current settings across accounts before enforcing.

Which solution meets these requirements?

A. An EC2 declarative policy enforcing IMDSv2 defaults, attached at the organisation root, after reviewing the account status report

B. An SCP denying ec2:RunInstances unless ec2:MetadataHttpTokens is required

C. An AWS Config rule with automatic remediation that modifies non-compliant instances

D. A Lambda function triggered by CloudTrail events that stops non-compliant instances

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A Declarative policy, after the status report

Sets the configuration itself, survives new APIs, covers future accounts, and the report shows readiness first.

B SCP on RunInstances

Works today, but must enumerate every API that could change the setting. Fails 'as EC2 adds APIs'.

C Config with remediation

Detects after launch, then repairs. More moving parts, and not preventive.

D Lambda on CloudTrail

Custom code reacting after the fact, and stopping instances disrupts workloads.

THE SIGNAL

'Keep working as the service adds new APIs' is the declarative policy's defining promise.

> A company's security team works in a dedicated security tooling account. It must enable and manage Amazon GuardDuty and AWS Security Hub for every account in the organisation.
>
> Company policy forbids the security team from working in the management account.

What should the DevOps engineer do?

A. Give the security team an administrator role in the management account

B. Register the security tooling account as delegated administrator for GuardDuty and for Security Hub

C. Create a cross-account role in every member account for the security team

D. Move the security tooling account to the root of the organisation

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A — Admin in management

Directly violates the stated policy.

B — Delegated administrator, per service

The tooling account manages both services organisation-wide. Registered once for each service.

C — Cross-account roles everywhere

Works account by account, but new accounts need new roles, and it is not how the services organise.

D — Move to the root

Where an account sits in the tree grants no administrative rights.

THE SIGNAL

Run a service for the whole organisation from a member account: delegated administrator, registered for each service.

A central networking team owns a VPC with carefully controlled subnets, routing and firewalls. Application teams work in their own accounts in the Workloads OU.

Application teams must launch resources directly into the central subnets, without VPC peering, and new accounts in the OU should get access automatically.

Which solution meets these requirements with the LEAST operational overhead?

A. A VPC peering connection from each application account's VPC to the central VPC

B. Transit Gateway attachments from each application account

C. A StackSet that creates an identical VPC in every application account

D. Share the subnets with the Workloads OU through AWS RAM, with sharing enabled for Organizations

◆ PAUSE AND DECIDE

Which solution meets these requirements with the LEAST operational overhead?

A Peering per account

Explicitly ruled out, and the teams would still launch into their own VPCs.

B Transit Gateway

Connects separate VPCs. Teams still would not launch into the central subnets.

C Identical VPCs

Many VPCs to govern, rather than one central network.

D RAM share to the OU

Teams launch straight into central subnets; new accounts in the OU are included automatically.

THE SIGNAL

'Launch into central subnets' is subnet sharing. Peering and Transit Gateway connect separate networks.

A company uses AWS Control Tower and has standardised on Terraform for all infrastructure. Account requests must be made as code, through pull requests in Git.

Each new account must automatically receive account-specific customisations, also written in Terraform.

Which solution meets these requirements?

A Customizations for AWS Control Tower, with a manifest mapping templates to OUs

B Create accounts in Account Factory by hand, then apply Terraform afterwards

C Account Factory for Terraform

D A service-managed StackSet with automatic deployment

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A **CfCT**

Git-driven and automatic, but its templates are CloudFormation. The wrong language here.

B **Manual Account Factory**

Requests are not code, and customisation is not automatic.

C **Account Factory for Terraform**

Account requests and customisations as Terraform, through a GitOps workflow.

D **StackSet**

Deploys CloudFormation, and creates no accounts.

THE SIGNAL

Same need, different language: Terraform points to AFT, CloudFormation to CfCT.

> A platform team uses Control Tower. It wants CloudFormation deployments in the Workloads OU to be stopped before an S3 bucket without versioning is created.
>
> The team does not want to write or maintain any custom rules.

What should the platform team do?

A Enable the detective control that checks S3 bucket versioning on the OU

B Enable the managed proactive control that requires S3 bucket versioning on the OU

C Attach an SCP that denies s3:CreateBucket

D Write a Guard rule and deploy it as a Hook in every account

◆ PAUSE AND DECIDE

What should the platform team do?

A **Detective control**

A Config rule reports the bucket after it exists. Not 'before it is created'.

B **Managed proactive control**

Implemented as a CloudFormation Hook. Stops the stack before the bucket exists, with no rules to write.

C **SCP on CreateBucket**

Blocks every bucket. Versioning is set by a separate call, so an SCP cannot test for it.

D **Custom Guard Hook**

Would work, but it is exactly the custom rule the team refused to maintain.

THE SIGNAL

Before creation, through CloudFormation, no custom rules: a managed proactive control.

A company set up Control Tower last year. Twelve older accounts sit in an OU called Legacy, which Control Tower does not govern.

The company wants those twelve accounts to receive the same controls and baselines as accounts created through Account Factory, with the least effort and no downtime.

What should the DevOps engineer do?

A Register the Legacy OU with Control Tower so its accounts are enrolled

B Create twelve new accounts through Account Factory and migrate the workloads

C Apply matching SCPs and Config rules to the Legacy OU by hand

D Deploy the baselines to the twelve accounts with a StackSet

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Register the OU

Enrols the existing accounts in place, with the same baselines and controls, and ongoing drift detection.

B New accounts and migrate

Enormous effort and risk, for something enrolment does in place.

C Copy controls by hand

Looks similar, but Control Tower neither manages nor reports drift on it.

D StackSet baselines

Deploys some resources, but not Control Tower's controls or governance.

THE SIGNAL

Existing accounts, same governance, in place: register the OU. Recreating accounts is almost never the answer.

Module 12 in five lines

- Organisation policies set ceilings; they never grant. An explicit Deny anywhere wins.
- SCPs: your principals, not the management account, not service-linked roles. Full IAM language since September 2025.
- RCPs: your resources, against outsiders. Declarative policies: configuration that survives new APIs.
- Delegated administrators per service; RAM shares subnets across the organisation.
- Control Tower controls: preventive, proactive, detective. CfCT for CloudFormation, AFT for Terraform.

ON THE EXAM

Next, module 13: Systems Manager fleet automation, AppConfig, and life after OpsWorks.

MODULE 13 · DOMAIN 2 - CONFIGURATION MANAGEMENT AND IAC

Systems Manager and AppConfig

Managing fleets as one: commands, desired state, runbooks, patching, secure access, inventory, life after OpsWorks, and feature flags.

DOMAIN 2 of 6 EXAM WEIGHT 17% MODULE 13 of 34

admin@sthithapragna.com

The agent is the hand on every node. A document is the instruction. Targets decide which hands move, and when.

admin@sthithapragna.com

Which Systems Manager tool?

THE NEED	TOOL
Run something on many nodes, once, now	Run Command
Keep nodes in a desired state, continuously	State Manager
A multi-step operational procedure, with approvals	Automation
Scan and install patches, and report compliance	Patch Manager
Shell access without SSH keys or open ports	Session Manager
Know what software is installed, everywhere	Inventory
Install or update software packages	Distributor

ON THE EXAM

Once: Run Command. Always: State Manager. A procedure: Automation. The verb in the scenario picks the tool.

What makes a node 'managed'

- The **SSM Agent** is installed and running. It is preinstalled on many AWS AMIs.
- The node has **permissions**: an instance profile with AmazonSSMManagedInstanceCore, or DHMC.
- The node has a **network path**: internet access, or interface endpoints for ssm, ssmmessages and ec2messages.
- On-premises and multicloud servers join through a **hybrid activation**.

> ON THE EXAM
>
> Node missing from Systems Manager: check agent, permissions, network path, in that order.

Default Host Management Configuration

- **DHMC** gives every EC2 instance in an account and Region Systems Manager permissions.
- No instance profile needed. Credentials reach the agent through the instance metadata service.
- Requires IMDSv2 and a recent agent version.
- Enable it across an organisation with Quick Setup.

> ON THE EXAM
>
> Instances launched by many teams without instance profiles must all be managed: turn on DHMC, not per-team profiles.

Run Command, or State Manager?

STATE MANAGER

Keep it that way

- An association: document, targets, schedule
- Re-applied on a schedule, and to new nodes
- Reports association compliance
- Corrects drift automatically

RUN COMMAND

Do it now

- One execution, on the targets of the moment
- Nodes launched later are not included
- Rate controls: concurrency and error threshold
- Output to S3 or CloudWatch Logs

THE TIEBREAKER

'Ensure', 'continuously', 'including new instances': State Manager. 'Now', 'once', 'urgently': Run Command.

Useful AWS-owned documents

DOCUMENT	WHAT IT DOES
AWS-RunPatchBaseline	Scans for or installs patches against a baseline
AWS-ApplyChefRecipes	Runs Chef cookbooks from S3 or Git, no Chef server
AWS-ApplyAnsiblePlaybooks	Runs Ansible playbooks on the node
AWS-GatherSoftwareInventory	Collects inventory data
AWS-ConfigureAWSPackage	Installs a Distributor package, such as the CloudWatch agent
AWS-UpdateSSMAgent	Keeps the agent itself current

ON THE EXAM

Before writing a custom document, look for an AWS-owned one. Exam answers usually use them.

Life after OpsWorks

RETIRED	ENDED	REPLACE WITH
OpsWorks Stacks	26 May 2024	State Manager with AWS-ApplyChefRecipes
OpsWorks for Chef Automate	5 May 2024	Chef cookbooks through State Manager
OpsWorks for Puppet Enterprise	31 March 2024	State Manager, or a self-run Puppet server

ON THE EXAM

Run existing Chef cookbooks periodically, with no Chef server to manage: a State Manager association with AWS-ApplyChefRecipes.

Automation runbooks

- Multi-step procedures: call APIs, run scripts, run commands on nodes, branch, wait, approve.
- Hundreds of AWS-owned runbooks, such as AWS-RestartEC2Instance and AWSSupport troubleshooting runbooks.
- Run under an **assume role**, with rate control, across accounts and Regions.
- Started by hand, by EventBridge rules, by Config remediation, or by maintenance windows.

> ON THE EXAM
>
> Automation is the usual 'target' that makes an event-driven fix happen. Domain 5 relies on it heavily.

A runbook with a human in the loop

```yaml
schemaVersion: '0.3'
assumeRole: '{{ AutomationAssumeRole }}'
parameters:
  InstanceId: { type: String }
  AutomationAssumeRole: { type: String }
mainSteps:
  - name: approve
    action: aws:approve
    inputs: { Approvers: ['arn:aws:iam::111122223333:role/OnCallLead'] }
  - name: restart
    action: aws:executeAwsApi
    inputs: { Service: ec2, Api: RebootInstances, InstanceIds: ['{{ InstanceId }}'] }
```

8 Pause until an approver approves or rejects.

11 Then call the EC2 API directly: no script, no agent needed.

ON THE EXAM

aws:executeAwsApi calls any API; aws:executeScript runs Python or PowerShell; aws:runCommand runs on nodes.

Patch Manager

- A **patch baseline** says which patches are approved: rules with auto-approval delays, plus approved and rejected lists.
- AWS-RunPatchBaseline runs **Scan** to report, or **Install** to patch, with a reboot option.
- Compliance reports which nodes are missing which patches.
- Each scan overwrites the previous compliance result. Keep history elsewhere if auditors need it.

> ON THE EXAM
>
> 'Approve security patches seven days after release' is an auto-approval rule in a custom baseline.

Patch policies, or maintenance windows?

PATCH POLICY

Quick Setup, organisation-wide

- One policy across OUs and Regions
- Separate scan and install schedules
- Applies to new accounts and nodes
- The recommended approach today

MAINTENANCE WINDOW

The classic, per account

- A schedule with targets and tasks
- Patch groups chosen by tag
- Set up in each account and Region
- Also runs other tasks, not just patching

THE TIEBREAKER

Patch many accounts and Regions with least overhead: a Quick Setup patch policy targeting OUs.

Scheduling safely

- **Maintenance windows** run tasks, such as commands or runbooks, in a defined period.
- **Change Calendar** defines periods when changes are blocked, such as a trading freeze.
- Automation, State Manager and maintenance windows can check the calendar before acting.
- **Change Manager** closed to new customers on 7 November 2025.

> ON THE EXAM
>
> Stop automated changes during a freeze without editing every schedule: a Change Calendar.

Session Manager

- Shell or PowerShell access through the agent: **no inbound ports, no SSH keys, no bastions**.
- Access is controlled by IAM. Sessions can be logged to S3 or CloudWatch Logs, and encrypted with KMS.
- Port forwarding and SSH tunnelled through Session Manager are **not** content-logged.
- **Just-in-time node access** (April 2025) adds approval policies and time-bound access.

> ON THE EXAM
>
> Just-in-time access only protects nodes once users' direct StartSession permission has been removed.

Inventory, Distributor and Fleet Manager

- **Inventory** collects installed software, files, services and more from every node.
- **Resource Data Sync** sends inventory from many accounts and Regions to one S3 bucket, for Athena queries.
- **Distributor** packages software, yours or AWS's, and installs versions across the fleet.
- **Fleet Manager** is a console for browsing files, logs and performance on nodes.

> ON THE EXAM
>
> Which instances in every account run a vulnerable library version? Inventory plus Resource Data Sync plus Athena.

AWS AppConfig

- Deploys **feature flags** and configuration to running applications, **without redeploying code**.
- **Validators**, a JSON schema or a Lambda function, reject bad configuration before it deploys.
- **Deployment strategies**: linear or exponential growth, then a **bake time** watched by alarms.
- A CloudWatch alarm during deployment or bake triggers **automatic rollback**.

> ON THE EXAM
>
> CloudWatch Evidently was discontinued in October 2025. AppConfig now covers feature flags and experiments.

AppConfig, or Parameter Store?

APPCONFIG

Change behaviour safely

- Validated before deployment
- Gradual rollout with bake time
- Rolls back on alarms
- Feature flags and experiments

PARAMETER STORE

Store values

- A value changes immediately for every reader
- No rollout, no validation, no rollback
- Secrets as SecureString
- Great for configuration read at start-up

THE TIEBREAKER

Turn a feature on gradually and roll back on errors: AppConfig. Store a connection string: Parameter Store.

A company runs Linux and Windows instances in 30 accounts across two Regions, organised in AWS Organizations. Patching is currently done by hand.

The company wants patch compliance scanned daily, security patches installed weekly, new accounts covered automatically, and the least operational overhead.

Which solution meets these requirements?

A. A cron job on every instance that runs the operating system's package manager weekly

B. Maintenance windows running AWS-RunPatchBaseline, created in each account and Region

C. A Quick Setup patch policy targeting the organisation's OUs and both Regions, with daily scans and weekly installs

D. A Lambda function that loops through every account and runs patch commands

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A Cron on each instance

No compliance reporting, nothing for Windows, and every new instance must be configured.

B Maintenance windows everywhere

Works, but sixty set-ups to build and maintain, and new accounts are not covered.

C Quick Setup patch policy

One policy across OUs and Regions, separate scan and install schedules, new accounts included.

D Looping Lambda

Custom code rebuilding what patch policies already provide.

THE SIGNAL

Many accounts and Regions, new accounts automatic, least overhead: a patch policy.

> Engineers reach private EC2 instances through a bastion host using shared SSH keys. A security review requires removing the bastion, the keys, and all inbound ports.
>
> Engineers still need interactive shell access, and every command they type must be recorded for audit.

Which solution meets these requirements?

A Keep the bastion, but require MFA and rotate the SSH keys monthly

B An EC2 Instance Connect Endpoint with short-lived SSH keys

C A client VPN into the VPC, then SSH to the instances

D Session Manager with session logging to S3 or CloudWatch Logs, and port 22 closed

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A **Bastion with MFA**

Keeps the bastion and the keys the review said to remove.

B **Instance Connect Endpoint**

Removes the bastion, but is still SSH to port 22, and does not record commands.

C **Client VPN and SSH**

Keys and inbound SSH remain. Nothing is recorded.

D **Session Manager with logging**

No bastion, no keys, no inbound ports, and session content logged for audit.

THE SIGNAL

No keys, no ports, every command recorded: Session Manager with logging. Avoid its tunnels if content must be logged.

In a new account, dozens of teams launch EC2 instances from their own launch templates. Most templates attach no instance profile, so the instances never appear in Systems Manager.

The platform team wants every instance in the account and Region managed by Systems Manager, without changing each team's templates.

What should the platform team do?

A Ask every team to add an instance profile to its launch templates

B Install the SSM Agent through user data in every launch template

C Enable Default Host Management Configuration in the account and Region

D Create interface VPC endpoints for Systems Manager

◆ PAUSE AND DECIDE

What should the platform team do?

A Instance profiles everywhere

Works, but changes every team's template, which the requirement ruled out.

B Agent via user data

The agent is usually present already. Permissions are what is missing.

C Enable DHMC

Gives every instance in the account and Region the permissions it lacks, with no template changes.

D VPC endpoints

Fixes network paths, not missing permissions. The instances still cannot register.

THE SIGNAL

Agent present, no instance profile, many teams: default host management, once per account and Region.

> A retailer has built a new checkout flow, already deployed but switched off. It wants to enable it for a growing share of users over an hour, without redeploying code.
>
> If the checkout error rate alarm fires during the rollout, or in the half hour afterwards, the feature must switch off automatically.

Which solution meets these requirements?

A Change a Lambda environment variable to turn the feature on

B Store the flag in Parameter Store and have the application poll it

C A CodeDeploy canary deployment of a new version with the flag on

D An AppConfig feature flag with a linear deployment strategy, a 30-minute bake time, and the alarm attached

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A. Environment variable

Everyone at once, a function update, and no automatic rollback.

B. Parameter Store flag

No gradual rollout and no alarm rollback. Everyone sees the change at once.

C. CodeDeploy canary

Gradual and alarm-aware, but it redeploys code, which was ruled out.

D. AppConfig feature flag

Gradual rollout, bake time, and alarm rollback, with no code deployment.

THE SIGNAL

Gradual, reversible, no redeploy: an AppConfig flag. The same safety ideas as Domain 1, applied to configuration.

Module 13, and Domain 2, in five lines

- Managed node: agent, permissions, network path. DHMC supplies permissions account-wide.
- Run Command once; State Manager continuously; Automation for procedures with approvals.
- OpsWorks is gone: Chef cookbooks run through State Manager. Patch policies patch organisations.
- Session Manager replaces bastions and keys; just-in-time access adds approvals.
- AppConfig rolls configuration out gradually and rolls back on alarms.

> ON THE EXAM
>
> Domain 2 complete. Next, module 14 opens Domain 3 with high availability and multi-Region design.

MODULE 14 · DOMAIN 3 - RESILIENT CLOUD SOLUTIONS

High Availability and Multi-Region Design

Surviving the loss of an Availability Zone or a Region: data replication, DNS and health checks, the edge, and Application Recovery Controller.

DOMAIN 3 of 6 EXAM WEIGHT 15% MODULE 14 of 34

admin@sthithapragna.com

Resilience is three separate problems: **the data** must already be there, **the traffic** must find it, and **someone or something** must decide to move.

Zone failure or Region failure?

FAILURE	TYPICAL PROTECTION	COST
An instance	Auto Scaling replaces it	Almost nothing
An Availability Zone	Multi-AZ everything: subnets, load balancer, database	Modest
A Region	A second Region with data replicated and traffic steerable	Significant
A bad deployment	Rollback, and shifting traffic away from where it landed	Process, not infrastructure

ON THE EXAM

Multi-AZ is the default expectation. Multi-Region needs a stated requirement: a Regional RTO, or regulation.

Multi-AZ, done properly

- Subnets and instances in at least two, ideally three, Availability Zones behind a load balancer.
- **RDS Multi-AZ**: one standby for failover, or a Multi-AZ **cluster** with two readable standbys.
- Enough capacity that losing one zone still leaves enough to serve: static stability.
- A NAT gateway per zone. One shared NAT gateway is a single-zone dependency.

> ON THE EXAM
>
> Statically stable: survive a zone loss without launching anything new, because launching may fail during the event.

Getting data to another Region

DATA STORE	CROSS-REGION OPTION	WRITES IN
Aurora	Global Database: storage-level replication, typically under a second	One Region
DynamoDB	Global tables: eventual, or strongly consistent	Every Region
S3	Cross-Region Replication, with RTC for a 15-minute objective	Each bucket
RDS (non-Aurora)	Cross-Region read replica, promoted in a disaster	One Region
ElastiCache	Global Datastore	One Region

ON THE EXAM

Only DynamoDB global tables accept writes in every Region. Everything else has one writer and needs a promotion.

Aurora Global Database: switchover or failover?

SWITCHOVER

Planned, no data loss

- Waits for the secondary to fully catch up
- Swaps writer and reader Regions
- Global topology kept intact
- For DR tests and Regional rotation

FAILOVER

Unplanned, with allow-data-loss

- Promotes a secondary during an outage
- RPO of seconds: recent writes may be lost
- Topology rebuilt once the old Region returns
- For real disasters only

THE TIEBREAKER

Planned move with no data loss: switchover. Region down: failover. Detaching and promoting breaks the global database.

DynamoDB global tables: eventual or strong?

STRONG CONSISTENCY (MRSC)

Zero RPO

- Writes replicated before they succeed
- Strongly consistent reads in any Region
- Exactly three Regions, or two plus a witness
- Higher write latency; no transactions

EVENTUAL CONSISTENCY (MREC)

The default

- Asynchronous, usually within a second
- Last writer wins on conflicts
- Any number of Regions
- RPO greater than zero

THE TIEBREAKER

Generally available June 2025. The mode is chosen at creation and cannot be changed later.

S3 across Regions

- **Replication** needs versioning on both buckets and copies new objects only.
- **Batch Replication** copies objects that existed before the rule, or failed earlier.
- **Replication Time Control**: 99.99% of objects within 15 minutes, with metrics and events.
- **Multi-Region Access Points** give one global endpoint, active-active or active-passive with failover controls.

> ON THE EXAM
>
> 'Replicated within 15 minutes, guaranteed': RTC. 'One endpoint, fail over between buckets': a Multi-Region Access Point.

Route 53 routing policies

POLICY	SENDS TRAFFIC TO
Failover	Primary while healthy; secondary when not
Latency	The Region with lowest latency for the user
Weighted	Endpoints in proportion to weights: 90/10, for example
Geolocation	Endpoints by the user's country or continent
Geoproximity	Endpoints by distance, adjustable with a bias
Multivalue answer	Up to eight healthy records, chosen at random

ON THE EXAM

Health checks make every policy smarter: unhealthy endpoints are left out of answers.

Health checks that tell the truth

- **Endpoint** checks probe a URL or port from locations around the world.
- **Calculated** checks combine others: healthy if at least two of three are.
- **CloudWatch alarm** checks follow an alarm, which is how you watch private resources.
- **Evaluate target health** on alias records lets Route 53 use a load balancer's own health.

> ON THE EXAM
>
> Check a deep health page that tests dependencies, not just the web server. A shallow check fails over too late.

Route 53 or Global Accelerator?

GLOBAL ACCELERATOR

Anycast IPs on the AWS network

- Two static IP addresses, worldwide
- Failover in seconds, no DNS caching
- TCP and UDP
- Traffic dials and endpoint weights

ROUTE 53

DNS answers

- Changes the answer clients receive
- Failover bounded by TTL and client caching
- Any protocol, since it is only DNS
- Cheaper and simpler

THE TIEBREAKER

Static IPs, UDP, or failover faster than DNS caching allows: Global Accelerator. Otherwise Route 53 is usually enough.

Resilience at the edge: CloudFront

- An **origin group** pairs a primary and secondary origin, such as S3 buckets in two Regions.
- On chosen error codes or timeouts, CloudFront retries the request on the secondary.
- Origin failover applies to **GET, HEAD and OPTIONS**. Writes are not failed over.
- **Origin Shield** adds a central cache layer, reducing load on the origin.

> ON THE EXAM
>
> Static content that must survive a Regional S3 failure: an origin group across two replicated buckets.

Application Recovery Controller

CAPABILITY	WHAT IT DOES
Zonal shift	Moves traffic away from one AZ, for up to three days, then expires
Zonal autoshift	AWS starts the shift itself when it detects a zone problem
Routing control	Highly available on/off switches for Route 53 health checks
Region switch (August 2025)	Orchestrated, multi-step, cross-account Region failover plans
Readiness check	Closed to new customers from 30 April 2026

ON THE EXAM

Zonal shift and autoshift are free. Region switch plans evaluate themselves every 30 minutes.

Why recovery tools must be independent

- Control planes, which create and change resources, are less available than data planes.
- Recovery should use **data-plane** actions: health checks, routing controls, already-running capacity.
- A failover that needs a console, or a resource launched in the failing Region, can fail with it.
- Region switch plans are replicated to every Region they cover, so no Region depends on another.

> ON THE EXAM
>
> Rehearse failover regularly. An untested recovery plan is a hope, not a plan.

Active-active or active-passive?

ACTIVE-ACTIVE

Every Region serves traffic

- Failover is just removing a Region
- Capacity already warm everywhere
- Data must accept writes in each Region
- Conflicts must be designed for

ACTIVE-PASSIVE

One Region serves; one waits

- Simpler data: one writer
- Standby may need scaling up first
- Failover needs a promotion and a switch
- Cheaper, if the standby is small

THE TIEBREAKER

Active-active needs a multi-writer data layer, such as DynamoDB global tables. With Aurora, the writer is always in one Region.

Load balancers during failures and deployments

- Target group **health checks** remove unhealthy targets; set path, interval and thresholds deliberately.
- **Deregistration delay** lets in-flight requests finish before a target is removed. Default 300 seconds.
- **Slow start** ramps traffic to a new target gradually, for applications that warm up.
- **Cross-zone load balancing** spreads traffic evenly across targets in all zones. Always on for ALB.

> ON THE EXAM
>
> Requests fail as instances are removed during scale-in or deployments: check the deregistration delay.

> A payments company stores account balances in DynamoDB. It runs in several Regions so that it can survive a Regional outage.
>
> After a Regional failure, no acknowledged write may be lost, and any Region must return the latest balance on a strongly consistent read. Latency on writes is acceptable.

What should the company use?

A. A DynamoDB global table with multi-Region strong consistency, in three Regions or two plus a witness

B. A DynamoDB global table with the default eventual consistency mode

C. DynamoDB Streams with a Lambda function writing to a table in another Region

D. Point-in-time recovery, with backups copied to another Region

◆ PAUSE AND DECIDE

What should the company use?

A Global table, strong consistency

Writes replicate before succeeding: zero RPO, and strongly consistent reads in any Region.

B Global table, eventual

Asynchronous: the last second of writes can be lost, and remote reads can be stale.

C Streams and Lambda

Custom, asynchronous replication. Worse than B on every requirement.

D Backups copied across

Restores lose everything since the last backup, and take time.

THE SIGNAL

Zero RPO plus strongly consistent reads anywhere: MRSC. 'Write latency is acceptable' is the planted permission.

> A multiplayer game uses UDP, with game servers behind Network Load Balancers in two Regions. Some players' networks allow outbound traffic only to IP addresses on an approved list.
>
> When a Region fails, players must reach the other Region within seconds. Past Route 53 failovers took many minutes for some players because of DNS caching.

Which solution meets these requirements?

A. Route 53 failover routing with a 10-second TTL

B. AWS Global Accelerator with an endpoint group in each Region and health checks

C. CloudFront with an origin group containing both load balancers

D. Cross-zone load balancing enabled on both Network Load Balancers

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A Shorter TTL

Clients that ignore TTL still cache. And IP addresses still change, breaking allow-lists.

B Global Accelerator

Two static IPs for allow-lists, UDP support, and failover in seconds with no DNS involved.

C CloudFront origin group

CloudFront serves HTTP and HTTPS. It does not carry game UDP traffic.

D Cross-zone

Spreads load across zones in one Region. Nothing to do with Regional failover.

THE SIGNAL

Static IPs, UDP, and failover that DNS caching cannot slow: every clue points to Global Accelerator.

> A company's Aurora Global Database has its writer in us-east-1 and a secondary in us-west-2. Both Regions are healthy.
>
> For an annual disaster recovery test, the company must move the writer to us-west-2 with no data loss, and keep the global database intact so it can move back afterwards.

What should the DevOps engineer do?

A. Perform a managed switchover of the global database to us-west-2

B. Perform a failover to us-west-2 using the allow-data-loss option

C. Detach the us-west-2 cluster from the global database and promote it

D. Copy a snapshot to us-west-2 and restore it as a new cluster

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Switchover

Waits for full synchronisation, swaps Regions, keeps the topology. Built for exactly this.

B Failover with data loss

For outages. Accepts losing recent writes, which this test must not.

C Detach and promote

Breaks the global database, so there is nothing to move back with.

D Snapshot and restore

Loses writes after the snapshot, takes far longer, and creates an unrelated cluster.

THE SIGNAL

Both Regions healthy, planned, no data loss, move back later: switchover. Failover is for when a Region is down.

> A web application runs behind an Application Load Balancer across three Availability Zones. A faulty deployment reached only the instances in one zone, and requests there are failing.
>
> The team wants to move traffic away from that zone within minutes, reverse it easily later, and have AWS do the same automatically if it detects a zone problem in future.

What should the team use?

A Deregister that zone's instances from the target group by hand

B ARC zonal shift now, and enable zonal autoshift for the load balancer

C Route 53 failover routing to a second Region

D Remove that zone's subnet from the load balancer

◆ PAUSE AND DECIDE

What should the team use?

A. Deregister by hand

Works slowly, must be undone by hand, and nothing is automatic next time.

B. Zonal shift and autoshift

Moves traffic away in one action, expires or is cancelled to reverse, and autoshift covers the future.

C. Fail over to another Region

Two healthy zones remain. A Regional failover is far out of proportion.

D. Remove the subnet

A configuration change to the load balancer, harder to reverse, and not automatic.

THE SIGNAL

One zone bad, two good: shift away from the zone, not the Region. Autoshift makes AWS do it for you next time.

> An application in two Regions uses Route 53 failover routing. The primary Region's health really depends on an internal database that is only reachable inside its VPC.
>
> The web tier sometimes stays up while the database is failing, so the endpoint health check passes and no failover happens.

How should the DevOps engineer make failover reflect the database's health?

A. Point a Route 53 endpoint health check at the database's private IP address

B. Replace the check with a calculated health check containing only the web tier check

C. Create a CloudWatch alarm on the database's health metrics, and a Route 53 health check that follows the alarm

D. Write a Lambda function that edits the DNS record when it detects a database problem

◆ PAUSE AND DECIDE

How should the DevOps engineer make failover reflect the database's health?

A Endpoint check on a private IP

Route 53 checkers run on the internet and cannot reach private addresses.

B Calculated check of the web tier

Combines the same shallow check that already misses the problem.

C Alarm-based health check

The alarm sees private metrics; the health check follows it; failover then reflects the database.

D Lambda edits DNS

Custom failover logic running in the Region that is failing. Rebuilds what alarm checks do.

THE SIGNAL

Private resource, Route 53 failover: a health check driven by a CloudWatch alarm.

> An Auto Scaling group runs 4 instances across two Availability Zones, sized for normal peak load. During a zone outage, the group tried to launch replacements in the surviving zone, but launches were slow and the service degraded for an hour.
>
> The company wants the application to survive the loss of any one zone without depending on launching new instances during the event.

What should the DevOps engineer do?

A. Add a predictive scaling policy to the group

B. Replace the instances with larger instance types

C. Add a warm pool of stopped instances in the same two zones

D. Spread across three zones, with enough running capacity that any two zones can carry peak load

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A **Predictive scaling**

Forecasts demand. It still launches instances, which is what failed.

B **Larger instances**

Losing one of two zones still halves capacity, however large each instance is.

C **Warm pool**

Faster launches, but still launches during the event, and one zone of two is still half.

D **Three zones, N+1 capacity**

Losing a zone leaves enough running capacity. Nothing needs launching: static stability.

THE SIGNAL

'Without launching anything during the event' is static stability: pre-provisioned capacity that survives a zone loss.

Module 14 in five lines

- Three problems: data already there, traffic able to find it, and something that decides to move.
- Only DynamoDB global tables write everywhere; MRSC gives zero RPO across exactly three Regions.
- Aurora: switchover for planned moves, failover with data loss for outages.
- Route 53 is bounded by DNS caching; Global Accelerator gives static IPs and fast failover.
- ARC: zonal shift and autoshift for zones; Region switch for orchestrated Regional failover.

> ON THE EXAM
>
> Next, module 15: scaling everything. Auto Scaling, ECS, EKS, Lambda, databases and queues.

MODULE 15 · DOMAIN 3 - RESILIENT CLOUD SOLUTIONS

Scaling Everything

EC2 Auto Scaling policies, warm pools, lifecycle hooks and instance refresh; ECS and EKS scaling; Lambda concurrency; databases, RDS Proxy and queues.

DOMAIN 3 of 6 EXAM WEIGHT 15% MODULE 15 of 34

admin@sthithapragna.com

Every scaling question has three parts: the **signal** you scale on, the **speed** of the response, and the **ceiling** somewhere else that stops you.

What scales what

WORKLOAD	SCALES THE WORK	SCALES THE CAPACITY UNDERNEATH
EC2	Auto Scaling group policies	The group itself
Amazon ECS	Service auto scaling: task count	Capacity providers, or Fargate
Amazon EKS	Horizontal Pod Autoscaler: pods	Karpenter, Cluster Autoscaler, or Auto Mode
Lambda	Automatic, per request	Concurrency quotas and reservations
DynamoDB	On-demand, or provisioned with auto scaling	Managed by the service
Aurora	Replica auto scaling; Serverless v2 capacity	Managed by the service

ON THE EXAM

Containers have two layers. Scaling tasks or pods does nothing if there is no capacity to place them on.

EC2 Auto Scaling policies

POLICY	HOW IT DECIDES	BEST FOR
Target tracking	Holds a metric near a target	Most workloads
Step scaling	Bigger steps as alarms breach further	Fine control
Simple scaling	One step, then a cooldown	Legacy
Scheduled	Sets capacity at set times	Known events
Predictive	Forecasts and scales ahead	Daily or weekly patterns

ON THE EXAM

Target tracking plus predictive scaling covers most real workloads: react to surprises, prepare for patterns.

Target tracking, done well

- Choose a metric that rises in proportion to load: CPU, ALB requests per target, or a custom metric.
- With several target tracking policies, the group scales **out if any** wants to, and **in only if all** agree.
- **Default instance warm-up** stops new instances' low metrics from triggering scale-in too early.
- CPU is the wrong signal for I/O-bound or queue-driven work. Scale on what actually hurts.

> ON THE EXAM
>
> Scaling reacts, but on the wrong thing: change the metric, not the threshold.

Predictive scaling

- Learns daily and weekly patterns from up to 14 days of history, then launches capacity ahead of forecast demand.
- Start in **forecast only** mode to compare the forecast with reality, then switch to **forecast and scale**.
- A **pre-launch buffer** starts instances early enough to finish booting before the peak.
- Combine with target tracking, which handles whatever the forecast missed.

> ON THE EXAM
>
> A peak at the same time every weekday, and target tracking lags: predictive scaling, not hand-maintained schedules.

Warm pools: for applications that boot slowly

- A **warm pool** keeps pre-initialised instances ready: stopped, hibernated, or running.
- Scale-out moves an instance from the pool into service, skipping the slow initialisation.
- Stopped instances cost only their storage. Hibernated ones keep memory, so caches survive.
- A reuse policy can return instances to the pool on scale-in instead of terminating them.

ON THE EXAM

Minutes-long start-up makes scale-out too slow for spikes: a warm pool, rather than running peak capacity all day.

Lifecycle hooks

- Pause an instance while **launching** or **terminating**, so you can act before it moves on.
- The hook emits an EventBridge event; a Lambda function or SSM runbook does the work.
- Finish with **complete-lifecycle-action**, or extend with heartbeats. Default timeout one hour.
- Typical uses: register with a service before traffic; copy logs or drain work before termination.

> ON THE EXAM
>
> Copy logs before scale-in terminates an instance: a terminating lifecycle hook with an SSM command.

Instance refresh

- Replaces instances gradually after a launch template or AMI change.
- **Minimum healthy percentage** keeps capacity; **checkpoints** pause at chosen percentages.
- **Skip matching** leaves instances already on the new template alone.
- **Automatic rollback** returns to the previous template on failure, or when a CloudWatch alarm fires.

> ON THE EXAM
>
> Roll a new AMI across the group, keep 90% healthy, pause to check, roll back on alarms: instance refresh.

Health, Spot and instance choice

- Turn on **ELB health checks** so the group replaces instances the load balancer marks unhealthy.
- A **health check grace period** stops new instances being replaced before they finish starting.
- **Mixed instances** policies combine On-Demand and Spot across many instance types.
- **Capacity rebalancing** replaces Spot instances proactively when they are at risk.

> ON THE EXAM
>
> Instances keep failing and relaunching right after start: the grace period is shorter than the start-up time.

Scaling Amazon ECS

- **Service auto scaling** changes the task count: target tracking on CPU, memory, or ALB requests per target.
- **Capacity providers** scale the EC2 instances underneath, with managed scaling.
- A capacity provider strategy mixes Fargate and Fargate Spot, with a base and weights.
- Tasks stuck in PROVISIONING mean the task count scaled but the capacity did not.

> ON THE EXAM
>
> Queue workers: scale on backlog per task, not CPU. That needs a custom metric.

Scaling queue workers on backlog per task

```
# Each task processes about 60 messages a minute.
# Messages must be processed within 5 minutes of arrival.
# So an acceptable backlog is 60 x 5 = 300 messages per task.

backlog  = SQS ApproximateNumberOfMessagesVisible
tasks    = ECS RunningTaskCount
metric   = backlog / tasks          # CloudWatch metric math

target tracking: keep metric at 300
```

3 The target comes from the service level objective, not from guesswork.

7 Metric math divides one metric by another, with no custom code.

ON THE EXAM

Backlog alone does not scale well: 1,000 messages means different things for 2 tasks and for 50.

Scaling Amazon EKS

- The **Horizontal Pod Autoscaler** changes pod counts; **KEDA** scales pods on events such as queue depth.
- **Cluster Autoscaler** resizes node groups, but is slow and packs pods poorly across many groups.
- **Karpenter** launches right-sized nodes directly, uses Spot, and consolidates underused nodes.
- **EKS Auto Mode** (December 2024) runs Karpenter-style node management for you.

> ON THE EXAM
>
> Faster node scaling, better packing, Spot, least operational overhead: EKS Auto Mode.

Lambda concurrency

SETTING	WHAT IT DOES	COST
Account concurrency	Shared per Region; 1,000 by default	None
Scaling rate	1,000 new environments per function per 10 s	None
Reserved concurrency	Guarantees a share, and caps it	None
Provisioned concurrency	Pre-initialised: no cold starts	While configured
SnapStart	Restores from a cached snapshot	Low; not with provisioned

ON THE EXAM

429s below the account limit: the scaling rate was exceeded, or another function took the pool.

Reserved or provisioned concurrency?

PROVISIONED

How ready

- Environments initialised in advance
- No cold starts, up to the number set
- Set on a version or alias
- Scale it on a schedule with Application Auto Scaling

RESERVED

How much

- Guarantees concurrency for this function
- Also caps it: protects downstream systems
- Free
- Zero stops the function entirely

THE TIEBREAKER

Starved by other functions, or overwhelming a database: reserved. Cold starts hurting latency: provisioned or SnapStart.

Lambda and its event sources

- With SQS, Lambda adds pollers as the queue grows. **Maximum concurrency** on the mapping caps it.
- Batch size and batching window trade latency for efficiency.
- **Partial batch responses** retry only the failed messages, not the whole batch.
- Set the queue's visibility timeout well above the function timeout, or messages are processed twice.

> ON THE EXAM
>
> Limit how fast a queue drains into a fragile database: maximum concurrency on the event source mapping.

Scaling databases

- **Read replicas** absorb read traffic; Aurora can add and remove replicas automatically.
- **Aurora Serverless v2** scales capacity in fine steps, and since November 2024 can pause at zero.
- **DynamoDB on-demand** needs no capacity planning; provisioned mode can auto scale.
- Caching with **ElastiCache** or **DAX** removes reads before they reach the database.

> ON THE EXAM
>
> Writes do not scale with read replicas. A write bottleneck needs a bigger writer, sharding, or a different store.

RDS Proxy

- **Pools and reuses** database connections, so bursts of clients share a few connections.
- Ideal for Lambda, where each concurrent environment would otherwise open its own connection.
- Supports IAM authentication and Secrets Manager credentials.
- Speeds up failover, because clients stay connected to the proxy.

> ON THE EXAM
>
> 'Too many connections' as Lambda scales: RDS Proxy. A bigger instance only moves the ceiling.

> An ECS service processes messages from an SQS queue. Each task spends most of its time waiting on a slow partner API, so CPU stays under 20%.
>
> The service scales on CPU, and during bursts the backlog grows for hours while task count stays flat. Messages must be processed within 10 minutes.

What should the DevOps engineer change?

A Lower the CPU target to 10%

B Add scheduled scaling for the busiest hours

C Double the CPU and memory of each task

D Target tracking on backlog per task: visible messages divided by running tasks, using metric math

◆ PAUSE AND DECIDE

What should the DevOps engineer change?

A Lower CPU target

CPU does not rise with the backlog, so it stays a poor signal at any target.

B Scheduled scaling

Bursts are not described as predictable, and it still ignores the backlog.

C Bigger tasks

Tasks are waiting on an API, not short of CPU. More CPU changes nothing.

D Backlog per task

Scales on what actually hurts, with a target derived from the 10-minute objective.

THE SIGNAL

Wrong signal: the thing that hurts is the backlog. Scale on backlog per task.

> Several Lambda functions share an account. Every night a batch function scales to most of the account's concurrency.
>
> During that time, the customer-facing API function is throttled with 429 errors. The API needs about 200 concurrent executions at night.

What should the DevOps engineer do?

A Request a higher account concurrency quota, and change nothing else

B Set reserved concurrency of 200 on the API function

C Configure provisioned concurrency on the batch function

D Enable SnapStart on the API function

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Bigger quota only

The batch function can grow to consume the new quota too.

B Reserve 200 for the API

Guarantees the API its share, whatever the batch function does. Free.

C Provisioned on batch

Makes the batch function faster to start, and adds cost. It still takes the pool.

D SnapStart on the API

Removes cold starts. Throttling is about concurrency, not start-up.

THE SIGNAL

One function starving another: reserved concurrency. Capping the batch function would also work.

> An application on an EC2 Auto Scaling group takes about eight minutes to start, while it loads a large cache. Traffic spikes are sudden and unpredictable.
>
> Scale-out is too slow to protect users during spikes. The company wants faster scale-out without paying for peak capacity all day.

What should the DevOps engineer do?

A. Run the group at peak capacity at all times

B. Replace target tracking with predictive scaling

C. Add a warm pool of pre-initialised instances in the stopped or hibernated state

D. Move to larger instance types

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A **Peak capacity always**

Fast, but pays for peak all day: ruled out.

B **Predictive scaling**

Needs patterns. Spikes here are unpredictable, and instances still take eight minutes.

C **Warm pool**

Instances have already initialised, so scale-out skips the eight minutes. Stopped ones cost only storage.

D **Larger instances**

The cache still takes minutes to load.

THE SIGNAL

Too slow because start-up is slow: pre-initialise. Warm pools do it cheaply.

> An API runs on Lambda and writes to an Aurora PostgreSQL cluster. During traffic bursts, Lambda scales to hundreds of concurrent executions.
>
> Requests start failing with 'too many connections' errors, although the database's CPU and memory are fine.

What should the DevOps engineer do?

A Put Amazon RDS Proxy between the functions and the database

B Move the database to a larger instance class

C Add an Aurora read replica

D Enable SnapStart on the function

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A RDS Proxy

Pools connections, so hundreds of environments share a few real connections.

B Larger instance

Raises the connection limit a little. The next burst hits it again.

C Read replica

The API writes. Replicas only take reads.

D SnapStart

Speeds start-up. Each environment still opens its own connection.

THE SIGNAL

CPU fine, connections exhausted, Lambda in front: the ceiling is connections. RDS Proxy.

A booking site on an EC2 Auto Scaling group sees traffic triple every weekday at 09:00, and the pattern has been stable for months. Target tracking reacts, but users see slow pages for the first ten minutes.

The team wants capacity in place before the rise, with the least ongoing maintenance, and still wants protection against unexpected surges.

What should the DevOps engineer do?

A. Create scheduled actions for 08:45 each weekday, and review them monthly

B. Add a predictive scaling policy in forecast and scale mode, and keep the target tracking policy

C. Add a warm pool

D. Replace target tracking with aggressive step scaling

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Scheduled actions

Works, but must be maintained by hand as the pattern shifts. More upkeep.

B Predictive plus target tracking

Learns the pattern, launches ahead of 09:00, and target tracking still catches surprises.

C Warm pool

Speeds each launch, but still waits for the rise to start before scaling.

D Aggressive step scaling

Still reactive: always behind a rise that has already begun.

THE SIGNAL

Recurring pattern, capacity before the rise, least maintenance: predictive scaling alongside target tracking.

A platform team publishes a patched AMI and updates an Auto Scaling group's launch template. The group runs 40 instances behind a load balancer.

Instances must be replaced gradually while keeping 90% healthy, pausing after 20% for checks, and rolling back automatically if an error-rate alarm fires.

Which solution meets these requirements with the LEAST effort?

A Terminate instances by hand in batches of four

B Create a second Auto Scaling group and move the load balancer to it

C A CodeDeploy blue/green deployment of the new AMI

D An instance refresh with 90% minimum healthy, a checkpoint at 20%, and automatic rollback on the alarm

◆ PAUSE AND DECIDE

Which solution meets these requirements with the LEAST effort?

A Manual termination

No checkpoint, no automatic rollback, and hours of human effort.

B Second group

A whole second fleet and a manual switch, with no gradual replacement.

C CodeDeploy blue/green

Deploys application revisions, not AMIs. The wrong tool for an image change.

D Instance refresh

Every requirement is a setting: minimum healthy, checkpoint, alarm rollback.

THE SIGNAL

New AMI in a launch template, gradual, checkpointed, alarm rollback: instance refresh.

> Instances in an Auto Scaling group write important application logs to local disk, uploading them to S3 every hour. When the group scales in, up to an hour of logs is lost.
>
> The team wants the remaining logs copied to S3 before each instance terminates, with the least effort. The application is not deployed with CodeDeploy.

What should the DevOps engineer do?

A. A terminating lifecycle hook, with an EventBridge rule that runs an SSM command to copy the logs, then completes the lifecycle action

B. Add a shutdown script to the instances' user data

C. Increase the load balancer's deregistration delay

D. Enable scale-in protection on every instance

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Terminating lifecycle hook

Pauses termination, runs the copy, then releases the instance. Exactly its purpose.

B User data

User data runs at launch, not at termination.

C Deregistration delay

Lets requests finish. It does not run anything on the instance.

D Scale-in protection

Stops scale-in altogether, which defeats scaling.

THE SIGNAL

Act on an instance before it terminates, without CodeDeploy: a terminating lifecycle hook.

> An EKS cluster uses the Cluster Autoscaler with eleven managed node groups. Nodes take several minutes to appear, pods are packed poorly, and Spot is barely used.
>
> The team wants faster node scaling, right-sized nodes, more use of Spot, and the least operational overhead.

What should the DevOps engineer do?

A Add more managed node groups with more instance types

B Tune the Horizontal Pod Autoscaler's thresholds

C Enable EKS Auto Mode for the cluster

D Move every workload to Fargate profiles

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A More node groups

More groups make the Cluster Autoscaler's packing problem worse, not better.

B Tune the HPA

Scales pods. The problem is nodes.

C EKS Auto Mode

Managed, Karpenter-style nodes: fast, right-sized, Spot-aware, consolidated, with no node groups to run.

D Fargate for everything

Removes nodes, but DaemonSets and some workloads cannot run there, and Spot is lost.

THE SIGNAL

Node scaling slow, packing poor, Spot unused, least overhead: Auto Mode, or Karpenter if you run it yourself.

Module 15 in five lines

- Signal, speed, ceiling: find which one failed. Scale on what actually hurts.
- Target tracking for most, predictive for patterns, warm pools for slow starts.
- Lifecycle hooks act before launch or termination; instance refresh rolls new AMIs with rollback.
- Containers scale twice: tasks or pods, then capacity. Auto Mode for EKS nodes.
- Lambda: reserved for how much, provisioned for how ready. RDS Proxy for connection ceilings.

ON THE EXAM

Next, module 16: disaster recovery. RTO and RPO, four strategies, Backup, Elastic Disaster Recovery and FIS.

MODULE 16 · DOMAIN 3 - RESILIENT CLOUD SOLUTIONS

Disaster Recovery

RTO and RPO, the four strategies, AWS Backup and its vaults, Elastic Disaster Recovery, and proving recovery with Resilience Hub and Fault Injection Service.

DOMAIN 3 of 6 EXAM WEIGHT 15% MODULE 16 of 34

admin@sthithapragna.com

Two numbers pick the strategy: how much data you can **lose**, and how long you can be **down**. Then choose the **cheapest** design that meets both.

RPO and RTO

RECOVERY POINT OBJECTIVE

How much data you lose

- Measured backwards from the failure
- Set by how often data is copied
- Hourly backups: up to an hour lost
- Continuous replication: seconds

RECOVERY TIME OBJECTIVE

How long you are down

- Measured forwards from the failure
- Set by how much is already running
- Restore from backup: hours
- Traffic switch to a live copy: minutes

THE TIEBREAKER

RPO is about copying frequency. RTO is about readiness. They are improved by different spending.

The four disaster recovery strategies

STRATEGY	IN THE RECOVERY REGION	RPO / RTO	COST
Backup and restore	Backups and templates only	Hours / hours	Lowest
Pilot light	Data replicated; compute off or minimal	Seconds to minutes / tens of minutes	Low
Warm standby	A smaller, fully working copy, running	Seconds / minutes	Medium
Multi-site active-active	Full capacity, serving traffic	Near zero / near zero	Highest

ON THE EXAM

Pilot light: data live, servers ready to start. Warm standby: everything running, just smaller.

Making each strategy work

- **Infrastructure as code** rebuilds the recovery Region reliably. Without it, backup and restore takes days.
- AMIs, container images and secrets must already exist in the recovery Region.
- Pilot light and warm standby need a scaling step, then a traffic switch, as in module 14.
- Quotas in the recovery Region must allow full production capacity. Check them before the disaster.

> ON THE EXAM
>
> The most common DR failure is not data loss. It is discovering the recovery Region cannot run the application.

AWS Backup

- **Backup plans** define schedules, retention and lifecycle, and select resources by tag.
- Plans can **copy** backups to another Region and another account automatically.
- **Backup policies** in Organizations apply plans across every account.
- **Backup Audit Manager** reports whether resources meet your backup controls.

> ON THE EXAM
>
> Many services, many accounts, one policy, cross-Region copies: AWS Backup with an organisation backup policy.

Protecting the backups themselves

PROTECTION	WHAT IT STOPS	CAN IT BE UNDONE?
Standard vault with access policy	Casual deletion	Yes, by an administrator
Vault Lock, governance mode	Deletion without special permission	Yes, with that permission
Vault Lock, compliance mode	Deletion by anyone, even root	No, after the grace period
Logically air-gapped vault	Access from a compromised account	No: locked, and held outside your account

ON THE EXAM

Compliance mode is permanent once its grace period ends. Test with governance mode first.

Logically air-gapped vaults

- Backups live in an **AWS Backup service-owned account**, always under compliance-mode Vault Lock.
- Shared through **AWS RAM** to a recovery account, which restores directly, with no copy first.
- **Multi-party approval** (June 2025): an approval team can grant access even if your accounts are compromised.
- Since November 2025, a plan can back up to an air-gapped vault directly, as its primary target.

> ON THE EXAM
>
> Recover even if the production account, or the management account, is compromised: air-gapped vault plus multi-party approval.

Proving backups restore

- **Restore testing** runs scheduled restores in isolation, then deletes the test resources.
- Validation can run automatically, for example a Lambda function checking the restored data.
- Results show how long each restore took, which is evidence for your RTO.
- Backup Audit Manager proves backups exist. It does not prove they restore.

> ON THE EXAM
>
> Auditors want proof that backups actually restore, on a schedule: restore testing, not audit reports.

AWS Elastic Disaster Recovery

- Continuous **block-level replication** of servers, on-premises or EC2, into a low-cost staging area.
- RPO of seconds; recovery launches full instances in minutes.
- **Drills** launch recovery instances without interrupting replication.
- Point-in-time recovery helps roll back past ransomware; **failback** returns to the source.

> ON THE EXAM
>
> Servers that cannot be re-architected, seconds of RPO, minutes of RTO, low standby cost: Elastic Disaster Recovery.

AWS Resilience Hub

- Define an application from CloudFormation stacks, tags, AppRegistry or EKS clusters.
- A **resiliency policy** sets RTO and RPO targets for AZ, Region, infrastructure and application failures.
- Assessments report whether the design can meet them, with recommended alarms, runbooks and experiments.
- Run assessments from a pipeline through the API, and fail the release if the policy is breached.

> ON THE EXAM
>
> Check every release against RTO and RPO targets automatically: a Resilience Hub assessment in the pipeline.

AWS Fault Injection Service

- **Experiment templates** define actions, targets, an IAM role and stop conditions.
- Actions include stopping instances, adding latency, throttling APIs, and disrupting a whole AZ.
- **Stop conditions** are CloudWatch alarms that halt the experiment if harm goes too far.
- A **scenario library** offers ready-made experiments, such as an AZ power interruption.

> ON THE EXAM
>
> Resilience Hub assesses the design on paper. FIS tests the real system under real failure.

Service-level recovery building blocks

SERVICE	BUILT-IN RECOVERY	ACROSS REGIONS
RDS	Automated backups and point-in-time restore	Automated backup replication
Aurora MySQL	Backtrack: rewind in place, in minutes	Global Database
DynamoDB	Point-in-time recovery, up to 35 days	Global tables, or Backup copies
S3	Versioning; Object Lock for immutability	Replication
EBS and AMIs	Snapshots; Recycle Bin for deleted ones	Snapshot copy

ON THE EXAM

Undo a bad data change in minutes without a new cluster: Aurora Backtrack. Restore to a moment: point-in-time recovery.

Protecting against mistakes, not just disasters

- **Recycle Bin** retention rules keep deleted EBS snapshots and AMIs recoverable, for a set period.
- **S3 Object Lock** stops objects being deleted or overwritten, in governance or compliance mode.
- **Deletion protection** on databases and stacks stops a single call removing them.
- Most data loss is a mistake or a script, not a Region failure. Plan for both.

> ON THE EXAM
>
> A clean-up script deleted snapshots it should not have: Recycle Bin would have made them recoverable.

A Region failover, end to end

01
Detect
Alarms and health checks show the Region failing.

02
Decide
A person or a rule declares a disaster.

03
Promote data
Failover the database; confirm replication state.

04
Scale
Bring recovery capacity to production size.

05
Switch traffic
Route 53, Global Accelerator, or Region switch.

06
Verify
Synthetic tests confirm users are served.

ON THE EXAM

Region switch plans or Automation runbooks turn these steps into one tested, repeatable action.

Game days and drills

- Schedule recovery exercises, including the people and the runbooks, not just the technology.
- Measure the **actual** RTO and RPO achieved, and compare them with the targets.
- Use the built-in tools: Elastic Disaster Recovery drills, restore testing, Region switch plan evaluations.
- Record every gap found, fix it, and test again.

> ON THE EXAM
>
> The objective you state is a promise. The objective you measured in a drill is a fact.

> An internal reporting application can be unavailable for up to four hours after a Regional disaster, and can lose up to one hour of data.
>
> Its infrastructure is defined in CloudFormation. The company wants the lowest-cost DR design that meets these objectives.

Which strategy should the company use?

A Warm standby in a second Region

B Backup and restore: hourly AWS Backup copies to a second Region, with the stack redeployed from templates

C Pilot light, with a cross-Region read replica and stopped instances

D Multi-site active-active across two Regions

◆ PAUSE AND DECIDE

Which strategy should the company use?

A Warm standby

Recovers in minutes: far better than needed, at far higher cost.

B Backup and restore

Hourly copies meet the one-hour RPO; templates make a four-hour rebuild realistic. Cheapest.

C Pilot light

Works, but a continuously running replica costs more than the objectives require.

D Active-active

The most expensive option, for an internal tool that tolerates four hours down.

THE SIGNAL

Hours of RTO and an hour of RPO: backup and restore, made fast enough by infrastructure as code.

A company runs a legacy order system on EC2 instances whose state lives on EBS volumes. The application cannot be re-architected.

After a Regional failure it must recover within 20 minutes, losing no more than a few seconds of data, at the lowest standby cost.

Which solution meets these requirements?

A Daily AMIs copied to a second Region

B A full-size copy of the fleet running in a second Region

C Hourly EBS snapshots copied to a second Region with AWS Backup

D AWS Elastic Disaster Recovery replicating the instances to a second Region, with regular drills

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A Daily AMIs

Up to a day of data lost. Far outside a few seconds.

B Full-size running copy

Meets the times, but at the highest standby cost, and the data still needs syncing.

C Hourly snapshots

Up to an hour lost, and restoring volumes takes time.

D Elastic Disaster Recovery

Block-level replication gives seconds of RPO, minutes of RTO, and a cheap staging area.

THE SIGNAL

Legacy servers, seconds of RPO, minutes of RTO, low standby cost: Elastic Disaster Recovery.

> After a security review, a company fears that an attacker holding administrator access to its production account, or even its management account, could delete every backup.
>
> Critical backups must remain recoverable into a clean account even if those accounts are fully compromised.

Which solution meets this requirement?

A. Copy backups to a logically air-gapped vault, and associate a multi-party approval team from a separate recovery organisation

B. Enable Vault Lock in governance mode on the production account's vault

C. Copy backups to a second Region in the same account

D. Export backups to an S3 bucket with versioning enabled

◆ PAUSE AND DECIDE

Which solution meets this requirement?

A Air-gapped vault with approval team

Locked, held outside your accounts, and an independent team can grant a clean account access.

B Governance mode

An administrator with the bypass permission can still delete. The attacker is an administrator.

C Second Region, same account

The compromised account controls both copies.

D Versioned S3 bucket

Versions can be deleted by an administrator of the same account.

THE SIGNAL

Attacker owns the account, even management: the backup must live outside it, with an independent path to recover.

> Auditors now require monthly evidence that critical database backups can actually be restored, and how long each restore takes.
>
> The company already uses AWS Backup and wants the least operational overhead.

What should the DevOps engineer do?

A. Have an engineer restore a sample backup by hand each quarter

B. Enable Backup Audit Manager and send its reports to the auditors

C. Create an AWS Backup restore testing plan on a monthly schedule, with automatic validation

D. Write a scheduled Lambda function that restores snapshots and times them

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Quarterly by hand

Too infrequent for monthly evidence, and manual.

B Backup Audit Manager

Proves backups exist and follow policy. Not that they restore, nor how long it takes.

C Restore testing plan

Scheduled restores, automatic validation and clean-up, with durations recorded as evidence.

D Custom Lambda

Rebuilds restore testing by hand.

THE SIGNAL

Proof of restore, with timings, on a schedule: restore testing. Audit Manager proves existence, not recoverability.

> A company claims its application survives the loss of an Availability Zone, but has never tested it. It wants to prove this in a production-like environment.
>
> If customers begin to see errors during the test, it must stop automatically.

What should the DevOps engineer do?

A. Run an FIS experiment from the AZ power interruption scenario, with a CloudWatch alarm on error rate as a stop condition

B. Terminate the instances in one zone by hand and watch the dashboards

C. Run a Resilience Hub assessment of the application

D. Write a Lambda function that randomly stops instances every hour

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A FIS with a stop condition

A realistic zone failure, and the alarm halts it automatically if customers are affected.

B Terminate by hand

Only partly simulates a zone loss, and nothing stops it automatically.

C Resilience Hub

Assesses the design. It does not test the running system.

D Random-stop Lambda

Not a zone failure, no stop condition, and runs indefinitely.

THE SIGNAL

Prove it for real, stop automatically if harm appears: an FIS experiment with an alarm stop condition.

> A company has RTO and RPO targets for each of its applications. Architectural changes sometimes quietly break those targets, for example by removing a Multi-AZ setting.
>
> The company wants every release checked against its targets automatically, failing the pipeline if a change would breach them.

What should the DevOps engineer do?

A Deploy an AWS Config conformance pack for resilience best practices

B Review AWS Trusted Advisor's resilience checks before each release

C Define the application and a resiliency policy in Resilience Hub, and run an assessment from the pipeline, failing on a breach

D Run a Fault Injection Service experiment on every release in production

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Config conformance pack

Checks settings after deployment, and knows nothing of RTO or RPO targets.

B Trusted Advisor by hand

Manual, generic, and not tied to the company's targets.

C Resilience Hub in the pipeline

Assesses each release against its own RTO and RPO policy, and the pipeline can fail on a breach.

D FIS on every release

Risky and slow for every release, and it tests one failure, not the policy.

THE SIGNAL

Every release, against RTO and RPO targets, fail the pipeline: Resilience Hub. FIS proves; Resilience Hub assesses.

A nightly clean-up script deletes old EBS snapshots and AMIs. A bug made it delete snapshots still needed for recovery, and they could not be recovered.

The team wants deleted snapshots and AMIs to remain recoverable for 14 days, while the script keeps running, with the least effort.

What should the DevOps engineer do?

A. Copy every snapshot to another account each day with AWS Backup

B. Create Recycle Bin retention rules for EBS snapshots and AMIs with a 14-day retention period

C. Enable S3 Object Lock on the bucket that stores the snapshots

D. Attach an SCP that denies ec2:DeleteSnapshot

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A **Daily cross-account copies**

Protects data, but doubles storage and is far more effort than needed here.

B **Recycle Bin rules**

Deleted snapshots and AMIs stay recoverable for 14 days; the script is unchanged.

C **S3 Object Lock**

Snapshots are not objects in a bucket you control. There is nothing to lock.

D **SCP denying deletion**

Stops the script doing its legitimate job, and the storage grows forever.

THE SIGNAL

Deleted by mistake, recoverable for a window, cleanup still allowed: Recycle Bin.

> An order service runs on ECS with an Aurora database. After a Regional failure it must be serving again within 10 minutes, losing no more than a few seconds of data.
>
> The company wants the lowest cost that reliably meets these targets.

Which strategy should the company use?

A. Backup and restore with hourly cross-Region copies

B. Pilot light: Aurora Global Database secondary, with no ECS tasks running in the recovery Region

C. Active-active: full capacity in both Regions, serving traffic

D. Warm standby: Aurora Global Database secondary and a small ECS service running, scaled up on failover

◆ PAUSE AND DECIDE

Which strategy should the company use?

A Backup and restore

Loses up to an hour, and takes hours. Fails both targets.

B Pilot light

Data is fine, but starting and proving every service from nothing in 10 minutes is not reliable.

C Active-active

Meets the targets, at the highest cost. More than needed.

D Warm standby

Data within seconds, and a running, tested service that only needs scaling. Reliably inside 10 minutes.

THE SIGNAL

Seconds of RPO needs replicated data. Ten minutes of RTO needs something already running: warm standby.

Module 16, and Domain 3, in five lines

- RPO is copy frequency; RTO is readiness. Choose the cheapest strategy that meets both.
- Backup and restore, pilot light, warm standby, active-active: cost rises, time falls.
- AWS Backup copies across Regions and accounts; compliance lock and air-gapped vaults defeat attackers.
- Elastic Disaster Recovery for servers; restore testing proves backups work.
- Resilience Hub assesses designs against targets; FIS proves them under real failure.

ON THE EXAM

Domain 3 complete. Next, module 17 opens Domain 4: collecting logs and metrics.

MODULE 17 · DOMAIN 4 - MONITORING AND LOGGING

Collecting Logs and Metrics

The CloudWatch agent, custom metrics and the embedded metric format, log groups and log classes, routing logs out in real time, and centralising across accounts.

DOMAIN 4 of 6 EXAM WEIGHT 15% MODULE 17 of 34

admin@sthithapragna.com

No dashboard can show a signal that was never **captured**. Collection has four steps: a **source**, a **collector**, a **store**, and a **route** onwards.

Where signals come from

SOURCE	CAPTURED HOW	NEEDS YOU TO ACT?
AWS service metrics	Published to CloudWatch automatically	No
Service logs: VPC Flow, ALB, CloudTrail	Vended logs, once enabled	Enable them
Operating system: memory, disk space	CloudWatch agent	Install and configure
Application logs and metrics	Agent, SDK, or embedded metric format	Instrument
Distributed traces	X-Ray or OpenTelemetry	Instrument (module 19)

ON THE EXAM

EC2 memory and free disk space are not default metrics. That single fact answers a whole family of questions.

EC2 metrics: basic, detailed, and missing

- **Basic monitoring**: CPU, network and disk operations every 5 minutes, free.
- **Detailed monitoring**: the same metrics every minute, charged.
- Neither includes **memory** or **disk space used**. Those need the CloudWatch agent.
- Status check metrics report instance and system health, as in module 14's recovery alarms.

> ON THE EXAM
>
> Faster detection of CPU spikes: detailed monitoring. Any memory or disk-space alarm: the agent.

The CloudWatch agent

- Collects system metrics, process metrics, StatsD and collectd metrics, and log files.
- Runs on EC2 and on-premises servers, Linux and Windows.
- Store its configuration in **Parameter Store**; install and update it with Systems Manager across the fleet.
- Needs permission to publish: the CloudWatchAgentServerPolicy on the instance role.

> ON THE EXAM
>
> Hundreds of instances, consistent configuration, least effort: config in Parameter Store, deployed with Systems Manager.

An agent configuration

```
{ "metrics": {
    "append_dimensions": { "AutoScalingGroupName": "${aws:AutoScalingGroupName}" },
    "metrics_collected": {
      "mem":  { "measurement": ["mem_used_percent"] },
      "disk": { "measurement": ["used_percent"], "resources": ["/"] } } },
  "logs": { "logs_collected": { "files": { "collect_list": [
      { "file_path": "/var/log/app/*.log",
        "log_group_name": "/app/orders",
        "retention_in_days": 30 } ] } } } }
```

2 Tag every metric with its group, so you can alarm per fleet.

9 Set retention here, or log groups keep data forever.

ON THE EXAM

Aggregate by Auto Scaling group to alarm on a fleet, not on instances that come and go.

Four ways to publish custom metrics

METHOD	HOW	BEST WHEN
PutMetricData API	Your code calls CloudWatch	Low volume, any environment
CloudWatch agent	StatsD or collectd from the app	Servers already running the agent
Embedded metric format	Structured JSON logs become metrics	Lambda and containers at high volume
Metric filter	A pattern extracts values from logs	Logs already contain the number

ON THE EXAM

No code change allowed and the value is already logged: a metric filter. High-volume Lambda: EMF.

Metric essentials

- A metric is a **namespace**, a **name** and up to 30 **dimensions**; each combination is a separate metric.
- Standard resolution is one minute; **high resolution** goes down to one second.
- High-resolution alarms can evaluate every 10 or 30 seconds.
- A dimension such as customer ID creates one metric per customer: cardinality becomes cost.

> ON THE EXAM
>
> Need per-request detail? Put it in logs and query it. Keep metric dimensions low in cardinality.

The embedded metric format

```
1 { "_aws": { "Timestamp": 1758528000000,
2     "CloudWatchMetrics": [{ "Namespace": "Orders",
3       "Dimensions": [["Service", "PaymentMethod"]],
4       "Metrics": [{ "Name": "OrderValue", "Unit": "None" }] }] },
5   "Service": "checkout",
6   "PaymentMethod": "card",
7   "OrderValue": 84.50,
8   "OrderId": "o-7731",
9   "CustomerTier": "gold" }
```

2-4 Instructions: which fields become a metric, and its dimensions.

8-9 Extra fields stay in the log line, queryable, without becoming metrics.

ON THE EXAM

One log line is both a metric and a searchable record. No API calls, no added latency, no throttling.

Log groups: retention, encryption, protection

- Default retention is **never expire**. Set retention on every log group, ideally in infrastructure as code.
- Encrypt with a **KMS key** per log group; the key policy must allow the Logs service.
- **Data protection policies** detect and mask sensitive data, such as card numbers, as logs arrive.
- Masked values can be seen only by principals with the logs:Unmask permission.

> ON THE EXAM
>
> Sensitive data appears in logs and code cannot change quickly: a data protection policy masks it on ingestion.

Standard or Infrequent Access log class?

INFREQUENT ACCESS

Cheaper to ingest

- Lower price per GB ingested
- Querying, encryption, cross-account analysis
- No real-time features such as filters
- Chosen when the log group is created

STANDARD

Full features

- Metric filters and subscription filters
- Live Tail and anomaly detection
- Embedded metric format extraction
- The default

THE TIEBREAKER

Logs kept for audits and occasional forensics: Infrequent Access. Logs driving alarms or pipelines: Standard.

Getting logs out of a log group

ROUTE	TIMING	NOTES
Export task to S3	Batch	One task at a time per account
Subscription filter	Real time	Lambda, Kinesis, Firehose; two per group
Account-level filter	Real time	One per account; includes new groups
Cross-account destination	Real time	To a stream in another account
Centralisation rules	Continuous copy	Organisation-wide, cross-Region (2025)

ON THE EXAM

'Real time' rules out export tasks. 'Every log group, including new ones' points to the account-level filter.

A real-time log pipeline

01

Log group

Application and service logs arrive.

02

Subscription filter

Matches events, account-wide if needed.

03

Firehose

Buffers, and a Lambda can transform.

04

Destination

S3, OpenSearch, or a third-party tool.

05

S3 lifecycle

Cheaper tiers, then expiry.

ON THE EXAM

Firehose is the managed default for delivery. Kinesis Data Streams adds custom consumers and replay.

Cross-account observability, or log centralisation?

LOG CENTRALISATION

Copy the logs

- Copies across accounts and Regions
- Organisation, OUs or chosen accounts
- Adds @aws.account and @aws.region fields
- First copy free: compliance retention

CROSS-ACCOUNT OBSERVABILITY

Look without copying

- Monitoring account sees source accounts
- Metrics, logs and traces, via sink and links
- No copy; data stays in the source
- Within a Region

THE TIEBREAKER

Retain everything centrally for years, across Regions: centralisation. One pane of glass for operators: observability.

Metric streams

- Stream CloudWatch metrics continuously through **Firehose**, to S3 or a partner tool.
- Filter by namespace and metric; choose JSON or OpenTelemetry format.
- Metric streams carry **metrics only**. Logs use subscription filters.
- Metrics can also be centralised across accounts and Regions with centralisation rules.

> ON THE EXAM
>
> Send metrics to a third-party monitoring tool in near real time: a metric stream, not API polling.

Service logs worth knowing

LOG	DELIVERED TO	ANSWERS
VPC Flow Logs	CloudWatch Logs, S3, Firehose	Which traffic was accepted or rejected
ALB access logs	S3	Every request: client, latency, status
CloudTrail	S3, and optionally CloudWatch Logs	Who called which API
S3 server access logs	S3	Requests made to a bucket
API Gateway access logs	CloudWatch Logs, Firehose	Every API request
Lambda logs	CloudWatch Logs; JSON and level controls	Function output and errors

ON THE EXAM

Load balancer access logs go to S3 only. Query them with Athena, not CloudWatch Logs Insights.

Collecting from containers

- The **awslogs** driver sends container output to CloudWatch Logs.
- **FireLens** runs Fluent Bit beside the app, routing logs to many destinations with filtering.
- **Container Insights** collects cluster, service, task and pod metrics for ECS and EKS.
- The awslogs driver needs log permissions on the execution role, or the container instance role on EC2.

> ON THE EXAM
>
> Send container logs to several destinations with filtering: FireLens. Simple CloudWatch delivery: awslogs.

A company runs 300 Linux EC2 instances across several Auto Scaling groups. Applications have crashed when instances ran out of memory, with no warning.

The operations team needs alarms when memory utilisation exceeds 85% for any group, applied consistently to every instance with the least operational overhead.

What should the DevOps engineer do?

A Enable detailed monitoring on every instance

B Add a cron job on each instance that calls PutMetricData with free memory

C Store a CloudWatch agent configuration collecting memory in Parameter Store, and deploy the agent with Systems Manager

D Enable AWS Compute Optimizer for the instances

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Detailed monitoring

More frequent CPU and network metrics. Still no memory.

B Cron and PutMetricData

Works, but custom scripts on 300 instances, and new instances need them too.

C Agent via Systems Manager

The agent collects memory; one stored config and SSM deployment keep every instance consistent.

D Compute Optimizer

Makes sizing recommendations. It does not alarm.

THE SIGNAL

Memory or disk space: the agent. At scale: configuration in Parameter Store, deployment with Systems Manager.

> A high-volume checkout function on Lambda must publish an order-value metric with dimensions for service and payment method. Individual order IDs must remain searchable.
>
> An earlier attempt using PutMetricData added latency and hit API throttling during sales.

Which approach should the developers use?

A Write structured logs in the embedded metric format

B Batch PutMetricData calls at the end of each invocation

C Create a metric filter on the existing unstructured logs

D Record order values as X-Ray annotations

◆ PAUSE AND DECIDE

Which approach should the developers use?

A Embedded metric format

Metrics extracted asynchronously from log lines: no API calls, no throttling, order IDs stay queryable.

B Batched PutMetricData

Fewer calls, but still API calls in the request path, still throttled at scale.

C Metric filter on unstructured logs

Fragile pattern-matching, and awkward for multiple dimensions.

D X-Ray annotations

Annotations index traces for searching. They are not CloudWatch metrics.

THE SIGNAL

High volume, dimensions, no API calls, records still searchable: the embedded metric format.

> An audit finds that an application occasionally writes full card numbers into CloudWatch Logs. A code fix will take several weeks.
>
> Until then, card numbers must be masked in the logs as they arrive, and only the security team may view unmasked values.

What should the DevOps engineer do?

A Create a metric filter that counts card numbers

B Apply a data protection policy with the card number identifier, and grant only the security team logs:Unmask

C Add a subscription filter that sends logs to a Lambda function which removes card numbers

D Encrypt the log group with a customer managed KMS key

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Metric filter

Counts occurrences. The card numbers remain visible.

B Data protection policy with Unmask

Masks matching data as it arrives; only principals with logs:Unmask see the original.

C Scrubbing Lambda

Cleans a copy elsewhere. The original log group still holds the card numbers.

D Customer managed key

Anyone allowed to read the logs still sees the numbers. Encryption is not masking.

THE SIGNAL

Mask sensitive data in logs without code changes, with selective viewing: a data protection policy.

> A company with 40 accounts in AWS Organizations, operating in three Regions, must keep a copy of all application logs in a central log archive account for seven years.
>
> It wants the least operational overhead and no custom code.

Which solution meets these requirements?

A. CloudWatch cross-account observability links from every account to the log archive account

B. CloudWatch Logs centralisation rules scoped to the organisation, copying to the log archive account

C. Subscription filters in every account and Region, streaming to Kinesis in the log archive account

D. Nightly export tasks from every log group to an S3 bucket in the log archive account

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A **Cross-account observability**

Views data in place without copying, and within one Region. No retained copy.

B **Centralisation rules**

Copies across accounts and Regions, organisation-wide, with source fields added. No code.

C **Subscription filters to Kinesis**

The pre-2025 design: 120 set-ups, streams and consumers to run.

D **Nightly exports**

Batch jobs to schedule across every log group, with gaps and custom automation.

THE SIGNAL

A retained copy, many accounts, many Regions, no code: centralisation rules.

> An operations team works in a monitoring account. Thirty application accounts run in the same Region.
>
> Operators want to search logs, view metrics and follow traces across all thirty accounts from the monitoring account, without copying any data.

What should the DevOps engineer set up?

A Log centralisation rules to the monitoring account

B Metric streams from each account to the monitoring account

C A shared CloudWatch dashboard in each application account

D CloudWatch cross-account observability: a sink in the monitoring account and links from the application accounts

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A **Centralisation**

Copies logs, which is ruled out, and does not cover metrics and traces together.

B **Metric streams**

Metrics only, and a copy.

C **Shared dashboards**

Thirty separate dashboards, and no searching or tracing across accounts.

D **Cross-account observability**

Logs, metrics and traces viewed in place from one account, in the same Region.

THE SIGNAL

Pair this with scenario 4: copy for retention, link for viewing.

> A team must investigate slow requests through an Application Load Balancer: client IP, target, response time and status code for every request.
>
> It wants to run ad hoc SQL queries over months of data at the lowest cost.

What should the DevOps engineer do?

A Enable VPC Flow Logs on the load balancer's subnets

B Create alarms on the load balancer's TargetResponseTime metric

C Enable ALB access logs to S3, and query them with Athena

D Enable CloudTrail data events for Elastic Load Balancing

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A VPC Flow Logs

Network flows, not HTTP requests. No response times or status codes.

B Response time alarms

Aggregated metrics tell you something is slow, not which requests.

C ALB access logs and Athena

Every request, with all four fields, stored cheaply in S3, queried with SQL.

D CloudTrail data events

Records API calls to the ELB service, not traffic through the load balancer.

THE SIGNAL

Per-request HTTP detail from a load balancer: access logs in S3, and Athena to query them.

Module 17 in five lines

- Source, collector, store, route. EC2 memory and disk space need the CloudWatch agent.
- Custom metrics: API, agent, embedded metric format, or metric filters. Watch cardinality.
- Set log retention; mask sensitive data with data protection policies; IA class for rare queries.
- Real time out: subscription filters, account-level for every group. Export tasks are batch.
- Centralisation copies across accounts and Regions; cross-account observability views in place.

ON THE EXAM

Next, module 18: analysing and alarming. Logs Insights, anomaly detection, composite alarms and Synthetics.

MODULE 18 · DOMAIN 4 - MONITORING AND LOGGING

Analysing and Alarming

Logs Insights and its three query languages, anomaly detection, alarms that do not cry wolf, composite alarms, Contributor Insights, dashboards and Athena.

DOMAIN 4 of 6 EXAM WEIGHT 15% MODULE 18 of 34

admin@sthithapragna.com

An alarm is a **promise to wake someone**. If it fires for something that does not matter, people learn to ignore it, and then it fails when it does matter.

admin@sthithapragna.com

Which tool answers which question?

THE QUESTION	TOOL
What happened in these logs?	CloudWatch Logs Insights
What is happening right now?	Live Tail
Who or what is causing most of it?	Contributor Insights
Is this normal for a Tuesday at 9?	Anomaly detection
What happened over the last year, in S3?	Athena
What do customers actually experience?	Synthetics and RUM

ON THE EXAM

The data's location decides a lot: CloudWatch Logs means Logs Insights; S3 means Athena.

CloudWatch Logs Insights

- Query log groups interactively: filter, parse, aggregate, sort, and chart results over time.
- Since December 2024, three languages: Logs Insights QL, **OpenSearch SQL** with joins, and **OpenSearch PPL**.
- **Field indexes** reduce the data a query scans, so filtered queries run faster and cost less.
- Up to 50 log groups chosen one by one; queries time out after 60 minutes.

> ON THE EXAM
>
> Queries can be saved, added to dashboards, and generated from a plain-English description.

A Logs Insights query, read line by line

```
1  fields @timestamp, path, status, duration
2  | filter status >= 500
3  | stats count(*) as errors, avg(duration) as avgMs by bin(5m), path
4  | sort errors desc
5  | limit 20
```

2 Keep only server errors.

3 Count them, with average duration, per path, in five-minute buckets.

ON THE EXAM

stats … by bin() turns a query into a time series you can chart or add to a dashboard.

Letting CloudWatch notice for you

- **Live Tail** streams matching log events in near real time during an incident.
- **Pattern analysis** groups similar log lines, so new kinds of error stand out.
- **Log anomaly detection** learns a log group's normal patterns and flags unusual ones.
- **Metric anomaly detection** learns hourly and weekly seasonality, producing an expected band.

> ON THE EXAM
>
> No one knows what to search for: pattern analysis and log anomaly detection surface the unfamiliar.

The anatomy of an alarm

SETTING	WHAT IT CONTROLS
Metric and statistic	What is measured: Average, Sum, Maximum, or a percentile such as p99
Period	How long each data point covers
Threshold or band	A fixed value, or an anomaly detection band
Evaluation periods	How many recent data points are considered
Datapoints to alarm	How many of those must breach: M out of N
Missing data treatment	What a gap in the data means

ON THE EXAM

Latency alarms on Average hide the slowest users. Use p90 or p99 for user experience.

Stopping alarms that twitch

M OUT OF N DATAPOINTS

Sustained, but still fast

- 3 of 5 one-minute points must breach
- Ignores single spikes
- Still reacts within minutes
- Tolerates one odd point in the run

A LONGER PERIOD

Smoother, but slower

- One 15-minute data point
- Averages spikes away
- Reacts only after 15 minutes
- Can hide short, severe outages

THE TIEBREAKER

Pages for brief spikes that clear themselves: M out of N. A longer period trades away detection speed.

Treating missing data

SETTING	A GAP IS TREATED AS	USE WHEN
`missing (default)`	Not evaluated; may become INSUFFICIENT_DATA	Data should always be present
`notBreaching`	Good	Metric is only published when something goes wrong
`breaching`	Bad	Silence itself means failure, such as a heartbeat
`ignore`	Keeps the current state	Sparse metrics where state should persist

ON THE EXAM

An error-count metric published only when errors occur: treat missing data as notBreaching.

Kinds of alarm

- **Static threshold**: simple, right when 'bad' is a fixed number, such as disk 90% full.
- **Anomaly detection**: alarms outside the learned band, right for seasonal traffic.
- **Metric math**: alarm on an expression, such as errors divided by requests.
- **Metrics Insights** query alarms: alarm on a SQL-style query across many resources.

> ON THE EXAM
>
> Error count rises with traffic; error rate does not. Alarm on the ratio with metric math.

Composite alarms

- Combine alarms with **AND**, **OR** and **NOT** into one alarm with one action.
- Put actions on the composite; leave the child alarms without notifications.
- An **actions suppressor** silences a composite, for example during deployments or when an upstream alarm explains it.
- Result: one page for the cause, not forty for its symptoms.

> ON THE EXAM
>
> Alert storms during a database outage: composite alarms, with suppression from the database alarm.

What an alarm can do

ACTION	EXAMPLE
Notify through SNS	Email, chat, or a paging tool
Invoke a Lambda function	Custom response, directly from the alarm
EC2 action	Recover, reboot, stop or terminate the instance
Auto Scaling action	Trigger a scaling policy
Systems Manager	Open an OpsItem or an incident
EventBridge	Every state change is an event: route it anywhere

ON THE EXAM

EventBridge sees every alarm state change, so it can start runbooks, pipelines or rollbacks.

Contributor Insights

- Rules over structured logs find the **top contributors**: IP addresses, users, URLs, keys.
- Results are time series, so you can graph and alarm on them.
- Built-in rules exist for VPC Flow Logs and DynamoDB, including hot partition keys.
- A metric per client would explode cardinality. Contributor Insights avoids that.

> ON THE EXAM
>
> Which clients cause most throttling or errors, continuously: Contributor Insights, not a metric per client.

Dashboards

- Widgets for metrics, alarms, Logs Insights queries, and text or links to runbooks.
- One dashboard can show metrics from **several accounts and Regions**.
- Automatic dashboards appear per service; share dashboards with people outside AWS.
- Dashboards need someone to look. Anything urgent belongs in an alarm.

> ON THE EXAM
>
> A single view of a service running in three Regions and two accounts: a cross-account, cross-Region dashboard.

Querying logs in S3 with Athena

- Athena runs SQL directly over files in S3: ALB, CloudTrail, VPC Flow and S3 access logs.
- You pay per terabyte scanned, so scanning less is both faster and cheaper.
- **Partition** by date, ideally with partition projection, so queries read only relevant days.
- Convert to a columnar format such as **Parquet**, so queries read only the needed columns.

> ON THE EXAM
>
> Athena queries on years of logs are slow and expensive: partition by date and convert to Parquet.

Logs Insights or Athena?

ATHENA

Logs in S3

- Long-term, low-cost storage
- SQL, joins across data sets
- Tuned with partitions and Parquet
- Best for months or years of history

LOGS INSIGHTS

Logs in CloudWatch

- No set-up: query any log group
- Great for recent, operational data
- Charts and dashboard widgets
- Retention costs more than S3

THE TIEBREAKER

Investigating last hour's incident: Logs Insights. A year-long analysis of archived logs: Athena.

Seeing what customers see

- **Synthetics canaries** run scripted journeys on a schedule, from outside, as in module 4.
- **CloudWatch RUM** collects real users' page load times, errors and sessions from their browsers.
- Canaries catch breakage even with no traffic. RUM shows what real users actually suffered.
- Both feed metrics you can alarm on, alongside your server-side metrics.

> ON THE EXAM
>
> 'Users in one country report slow pages our metrics do not show': RUM captures real client-side experience.

> A CPU alarm on a web fleet uses one-minute periods, one evaluation period and a threshold of 80%. It pages the on-call engineer several times a night.
>
> Each time, CPU spikes for a single minute and recovers. The team wants pages only when high CPU is sustained, but still within about five minutes.

What should the DevOps engineer change?

A. Require 3 of 5 datapoints to breach, keeping one-minute periods

B. Raise the threshold to 95%

C. Change the period to one hour

D. Replace the alarm with an anomaly detection alarm

◆ PAUSE AND DECIDE

What should the DevOps engineer change?

A 3 of 5 datapoints

A single-minute spike never reaches three; sustained load alarms within five minutes.

B Higher threshold

Spikes can still exceed 95%, and real sustained problems at 90% are now missed.

C One-hour period

Calm, but detection is now an hour late. Fails 'within about five minutes'.

D Anomaly detection

A sudden spike is anomalous too. It changes the threshold, not the twitchiness.

THE SIGNAL

Spikes that self-correct, detection still needed in minutes: M out of N datapoints.

> When the shared database fails, about 40 alarms fire across the web, application and worker tiers, and each one pages the on-call engineer.
>
> The team wants a single page that identifies the database as the cause, while keeping the individual alarms for diagnosis.

What should the DevOps engineer do?

A Add SNS subscription filter policies to drop duplicate messages

B Disable the application and worker alarms

C Raise every threshold so fewer alarms fire

D Create composite alarms that carry the notifications, remove actions from child alarms, and use the database alarm as an actions suppressor

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A SNS filtering

The messages are not duplicates: 40 different alarms. Filtering cannot tell cause from symptom.

B Disable alarms

Loses diagnosis and blinds you to tier failures unrelated to the database.

C Raise thresholds

Fewer alarms, but also later detection of genuine problems everywhere.

D Composite alarms with suppression

One page for the cause; the symptom alarms stay visible but silent.

THE SIGNAL

Alert storm from one root cause: composite alarms and an actions suppressor.

> An API's request count varies strongly by hour and weekday. A static alarm set low fires every night; set high, it missed a real drop in traffic during business hours.
>
> The team wants an alarm that fires when traffic is unusually low or high for that time of the week.

What should the DevOps engineer use?

A. A static alarm with a threshold halfway between night and day traffic

B. An anomaly detection alarm on request count, alarming outside the band

C. A static alarm on the p99 of request count

D. A scheduled Lambda function that changes the alarm threshold every hour

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A **Halfway threshold**

Wrong at both ends: false alarms at night, missed drops by day.

B **Anomaly detection band**

Learns hourly and weekly seasonality, and alarms when traffic leaves the expected band either way.

C **p99 of a count**

Percentiles describe distributions of values like latency, not a request count. Still static.

D **Hourly threshold Lambda**

Hand-builds a crude version of what anomaly detection learns automatically.

THE SIGNAL

'Unusual for this time of the week': anomaly detection. No single number can be right.

> An application publishes a PaymentFailures metric only when a payment fails. An alarm fires when the sum exceeds 5 in 5 minutes.
>
> Most of the time there are no failures, so no data points arrive, and the alarm sits in INSUFFICIENT_DATA. The team wants it to show OK when nothing is failing.

What should the DevOps engineer change?

A Set the alarm to treat missing data as notBreaching

B Set the alarm to treat missing data as breaching

C Add a cron job that publishes a zero every minute

D Shorten the period to one minute

◆ PAUSE AND DECIDE

What should the DevOps engineer change?

A notBreaching

Silence means no failures, so gaps count as good and the alarm shows OK.

B breaching

The opposite: the alarm would fire whenever payments are healthy.

C Publish zeros

Works, but adds a job to run and pay for, to express what one setting says.

D Shorter period

More frequent gaps, same problem.

THE SIGNAL

Metric published only on failure: silence is good, so notBreaching. Heartbeat metric: silence is bad, so breaching.

> An API writes structured JSON logs that include the caller's account ID and the response status. Throttling errors sometimes rise sharply.
>
> Operators need to see, continuously and as a graph, which callers cause the most throttling, without writing a query each time and without creating a metric per caller.

What should the DevOps engineer use?

A. A saved Logs Insights query that operators run during incidents

B. A metric filter with the caller's account ID as a dimension

C. AWS X-Ray service maps

D. A Contributor Insights rule on the log group, keyed on caller and filtered to throttling

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A Saved query

Must be run each time. Not continuous.

B Metric filter per caller

One metric per caller. the cardinality the requirement ruled out.

C X-Ray service maps

Show services and latency, not a ranking of callers.

D Contributor Insights

Continuously ranks top callers as a time series, with no per-caller metrics.

THE SIGNAL

Continuous top-N by a high-cardinality key: Contributor Insights.

> Three years of ALB access logs, several terabytes, sit in S3 as compressed text files under one prefix. Security analysts query them with Athena.
>
> Queries about a single week take many minutes and scan the whole data set, and the Athena bill is rising.

What should the DevOps engineer do?

A Load the logs into an Amazon RDS database for querying

B Move the logs into CloudWatch Logs and use Logs Insights

C Partition the data by date with partition projection, and convert it to Parquet

D Increase the Athena workgroup's data scan limit

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Load into RDS

A database to size, load and run, for terabytes of append-only logs.

B Move to CloudWatch Logs

Re-ingesting terabytes costs far more, and CloudWatch storage exceeds S3's.

C Partitions and Parquet

A week's query reads a week's partitions, and only the columns it needs.

D Raise the scan limit

Lets queries scan even more. The opposite of the fix.

THE SIGNAL

Athena slow and expensive: scan less. Partition by what you filter on, and store columns.

Module 18 in five lines

- Logs Insights for CloudWatch Logs, now in SQL and PPL too; Athena for S3, tuned by partitions and Parquet.
- Alarms: M out of N for spikes, anomaly bands for seasonality, metric math for rates.
- Missing data: notBreaching when silence is good, breaching when silence is bad.
- Composite alarms and suppression turn alert storms into one page.
- Contributor Insights for top-N; Synthetics and RUM for the customer's view.

> ON THE EXAM
>
> Next, module 19: tracing and distributed observability. X-Ray, OpenTelemetry, Application Signals and Grafana.

MODULE 19 · DOMAIN 4 - MONITORING AND LOGGING

Tracing and Distributed Observability

Following one request across many services: X-Ray, the move to OpenTelemetry, Transaction Search, Application Signals and SLOs, and managed Prometheus and Grafana.

DOMAIN 4 of 6 EXAM WEIGHT 15% MODULE 19 of 34

admin@sthithapragna.com

Metrics say something is **wrong**. Logs say **what** happened. Traces say **where** in the chain it happened.

One request, one trace

01

API Gateway

Starts the trace and adds a trace header.

02

Lambda

Records its own segment, same trace ID.

03

DynamoDB call

A subsegment: how long the query took.

04

Partner API

A subsegment: 1.8 seconds. There it is.

05

Service map

Every hop, drawn with latency and errors.

ON THE EXAM

The trace ID must travel with the request. A service that drops the header breaks the trace in two.

Tracing vocabulary

TERM	MEANING
Trace	Everything that happened for one request, end to end
Segment	One service's part of the trace (X-Ray term)
Subsegment	A call that service made: a database, an HTTP API
Span	The OpenTelemetry term for a segment or subsegment
Trace context	The header carrying the trace ID between services
Trace map	The graph of services and their connections

ON THE EXAM

X-Ray says segment; OpenTelemetry says span. Exam options may use either.

The catalogue has moved: X-Ray instrumentation

DATE	CHANGE
November 2024	X-Ray accepts OpenTelemetry directly (OTLP endpoint); Transaction Search launched
25 February 2026	X-Ray SDKs and daemon enter maintenance mode: security fixes only
25 February 2027	X-Ray SDKs and daemon reach end of support
Ongoing	The X-Ray service itself continues, with new features

THE RULE

New instrumentation should use OpenTelemetry. Existing X-Ray SDK traces are still accepted and processed.

X-Ray SDK, or OpenTelemetry?

OPENTELEMETRY

The current path

- Industry standard, many languages
- Zero-code auto-instrumentation
- Collector: ADOT or the CloudWatch agent
- Sends to X-Ray, CloudWatch, or elsewhere

X-RAY SDK AND DAEMON

In maintenance mode

- AWS-specific libraries
- Security fixes only since February 2026
- End of support February 2027
- Still valid in exam-guide answers

THE TIEBREAKER

If an option uses the X-Ray SDK, it reflects the guide and still works. For new, future-proof work, choose OpenTelemetry.

AWS Distro for OpenTelemetry

- **ADOT** is AWS's supported distribution of the OpenTelemetry SDKs and collector.
- **Auto-instrumentation** agents trace common libraries with no code changes.
- Runs as a Lambda layer, an ECS sidecar, an EKS add-on, or on EC2.
- One collector can send traces to X-Ray and metrics to CloudWatch or managed Prometheus.

> ON THE EXAM
>
> The CloudWatch agent can also receive OpenTelemetry data, so one agent can cover metrics, logs and traces.

Turning on tracing, by platform

PLATFORM	HOW
API Gateway	Enable tracing on the stage
Lambda	Active tracing, or the ADOT Lambda layer
ECS	A collector sidecar in the task, plus instrumented code
EKS	The ADOT add-on or CloudWatch agent, often as a DaemonSet
EC2	The CloudWatch agent or ADOT collector on the instance

ON THE EXAM

Traces stop at a hop that is not instrumented. Every service in the chain must pass the context on.

Sampling

- Tracing every request is expensive, so **sampling rules** choose which to trace.
- A rule has a **reservoir**, a fixed number per second, and a **rate**, a percentage beyond it.
- The default traces the first request each second, then 5% of the rest.
- Rare failures may never be sampled. Raise sampling for important paths, or use Transaction Search.

> ON THE EXAM
>
> Rules are managed centrally in X-Ray, so sampling changes need no redeployment.

Annotations or metadata?

ANNOTATIONS

Indexed, searchable

- Simple key-value pairs
- Indexed for filter expressions
- Find traces by order ID or customer tier
- Limited number per trace

METADATA

Stored, not searchable

- Any object, including nested data
- Not indexed
- Useful context once a trace is found
- Cannot filter on it

THE TIEBREAKER

'Find all traces for customer tier gold' needs an annotation. Metadata cannot be searched.

Groups and Insights

- A **group** is a saved filter expression, such as all traces for the checkout API.
- Each group gets its own metrics and trace map, so you can alarm per group.
- **X-Ray Insights** detects anomalies in a group, such as rising faults, and tracks them as incidents.
- Insights events can go to EventBridge, starting notifications or remediation.

> ON THE EXAM
>
> Be told automatically when a service's fault rate becomes abnormal, with root-cause context: X-Ray Insights.

Transaction Search

- Sends **every span** to CloudWatch Logs, in the aws/spans log group, without sampling limits.
- Search and analyse spans with Logs Insights, by any attribute.
- A chosen percentage is indexed as trace summaries for the X-Ray trace views.
- Works with spans from OpenTelemetry, ADOT, or the X-Ray SDK.

> ON THE EXAM
>
> Find the one failing request among millions, even if it was never sampled: Transaction Search.

CloudWatch Application Signals

- An APM experience: services discovered automatically, with dependencies drawn.
- Standard health metrics for each operation: volume, latency, faults and errors.
- Auto-instrumentation on EKS, ECS, Lambda and EC2 for Java, Python, Node.js and .NET.
- **Service level objectives** tracked for each service or operation.

> ON THE EXAM
>
> Application performance monitoring on AWS with least set-up: Application Signals.

SLO vocabulary

TERM	MEANING	EXAMPLE
SLI	What you measure	Share of requests under 300 ms
SLO	The target for it, over a window	99.9% over 30 days
Error budget	Failure the SLO allows	About 43 minutes a month
Burn rate	How fast the budget is being spent	14x means gone in about 2 days

ON THE EXAM

Alarm on burn rate, not on single errors: it warns while there is still budget left to protect.

Amazon Managed Service for Prometheus

- A managed, Prometheus-compatible store for metrics, queried with **PromQL**.
- Data arrives by remote write, from Prometheus or ADOT, or from an **agentless managed collector** for EKS.
- Recording and alerting rules run in the workspace; alerts route through Alertmanager to SNS.
- Suits teams already using Prometheus, especially with Kubernetes.

> ON THE EXAM
>
> Keep Prometheus and PromQL, stop running Prometheus servers: managed Prometheus.

Amazon Managed Grafana

- Managed Grafana workspaces: no servers, patching or scaling to run.
- Sign-in through **IAM Identity Center** or a **SAML** identity provider, with Admin, Editor and Viewer roles.
- Data sources include CloudWatch, managed Prometheus, X-Ray, OpenSearch and Athena.
- Existing Grafana dashboards can be imported.

> ON THE EXAM
>
> Grafana dashboards, corporate sign-in, no Grafana servers: Managed Grafana with IAM Identity Center or SAML.

CloudWatch-native, or Prometheus and Grafana?

PROMETHEUS AND GRAFANA

Open-source ecosystem

- Teams already on Prometheus and PromQL
- Kubernetes-heavy estates
- Existing Grafana dashboards
- Portable across clouds

CLOUDWATCH AND APPLICATION SIGNALS

AWS-native

- No new query languages
- Deep integration with AWS services
- Alarms, SLOs and events built in
- Least to learn for AWS-first teams

THE TIEBREAKER

The deciding clue is usually what the team already uses. Migrations with least change keep the existing tools, managed.

> A checkout flow runs as eight microservices on ECS with Fargate. Latency has doubled, but each service's CPU, memory and logs look normal, and nobody can tell which service is slow.
>
> The team wants to find the slow hop, using instrumentation that will remain supported long term.

What should the DevOps engineer do?

A. Add the X-Ray SDK to every service and run the X-Ray daemon as a sidecar

B. Use ADOT auto-instrumentation in each service, with a collector sidecar sending traces to X-Ray

C. Enable Container Insights with enhanced observability

D. Increase every service's log level to DEBUG

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A X-Ray SDK and daemon

Would find the slow hop, but uses libraries in maintenance mode since February 2026. Fails 'supported long term'.

B ADOT and a collector sidecar

Traces every hop to X-Ray with OpenTelemetry, the supported path.

C Container Insights

Per-container resource metrics, which already look normal. Does not follow requests.

D DEBUG logging

More detail inside each service, still no view across them.

THE SIGNAL

Metrics and logs normal, slow somewhere across services: tracing. 'Supported long term': OpenTelemetry.

> An e-commerce team traces requests with X-Ray. Support staff often need to find the trace for a specific order ID, or all traces for premium customers.
>
> Today they search by time and guess. The team wants to filter traces directly by order ID and customer tier.

What should the developers add to their instrumentation?

A Record the order ID and tier as trace metadata

B Write the order ID and tier to CloudWatch Logs

C Record the order ID and tier as annotations, and use filter expressions

D Name a subsegment after each order ID

◆ PAUSE AND DECIDE

What should the developers add to their instrumentation?

A **Metadata**

Stored with the trace but not indexed. Filter expressions cannot use it.

B **Logs**

Searchable in logs, but does not filter traces.

C **Annotations**

Indexed key-value pairs: filter expressions find traces by order ID or tier.

D **Subsegment names**

Creates a new name per order, cluttering maps, and is not how traces are searched.

THE SIGNAL

Find traces by a business value: annotations. Extra context you only read: metadata.

> A payments service is traced with the default X-Ray sampling. A rare failure affects a handful of requests each day, and those requests are almost never sampled.
>
> Engineers need to search all spans for any request, sampled or not, and analyse them with Logs Insights.

What should the DevOps engineer enable?

A CloudWatch Transaction Search

B An X-Ray group for the payments service

C An annotation for payment status

D X-Ray Insights on the default group

◆ PAUSE AND DECIDE

What should the DevOps engineer enable?

A Transaction Search

Every span goes to CloudWatch Logs, searchable with Logs Insights, whether sampled or not.

B A group

Filters traces that exist. Unsampled requests are still missing.

C An annotation

Makes sampled traces searchable. Unsampled ones still do not exist.

D X-Ray Insights

Detects anomalies in sampled data. A handful of requests will not move it.

THE SIGNAL

Rare requests missing from traces because of sampling, analysed with Logs Insights: Transaction Search.

> A product team commits to 99.9% availability for its checkout API over each 30-day period.
>
> It wants to track that objective continuously, and to be alerted early when the rate of failures threatens it, not on every individual error.

What should the DevOps engineer set up?

A. A static alarm that fires whenever the 5xx count exceeds zero

B. A CloudWatch dashboard showing daily availability

C. A Synthetics canary calling the API every minute

D. An Application Signals SLO for the operation, with a burn-rate alarm

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A **Alarm on any error**

Fires on every error. the exact noise the team wants to avoid.

B **Dashboard**

Shows the objective, but alerts nobody.

C **Canary**

Measures synthetic requests, not the objective over real traffic.

D **SLO with burn-rate alarm**

Tracks the 30-day objective and warns when the budget is burning too fast.

THE SIGNAL

An availability objective over a window, alerting on threat rather than noise: an SLO and a burn-rate alarm.

A platform team runs self-managed Prometheus and Grafana on its EKS clusters. Keeping them patched, scaled and highly available takes too much effort.

The team wants managed services, keeping its PromQL queries and existing dashboards, with the fewest changes.

What should the platform team do?

A. Move to Container Insights, and rebuild every dashboard in CloudWatch

B. Amazon Managed Service for Prometheus with a managed collector, and Amazon Managed Grafana with the dashboards imported

C. Send metrics to Amazon OpenSearch Service

D. Send traces to X-Ray and use its trace map instead

◆ PAUSE AND DECIDE

What should the platform team do?

A Container Insights and rebuild

Managed, but abandons PromQL and every dashboard. Many changes.

B Managed Prometheus and Grafana

Same query language, same dashboards; the servers become AWS's problem.

C OpenSearch

A different query model, and still dashboards to rebuild.

D X-Ray

Traces, not the metrics and dashboards the team relies on.

THE SIGNAL

Keep the tools, lose the servers: managed Prometheus and managed Grafana.

A company adopts Amazon Managed Grafana. Engineers already sign in to AWS through IAM Identity Center, connected to the corporate directory.

Grafana access must use the same corporate identities, with SRE staff as editors and everyone else as viewers.

How should the DevOps engineer configure authentication?

A Create an IAM user for each engineer and share Grafana credentials

B Set up an Amazon Cognito user pool for the workspace

C Use IAM Identity Center authentication for the workspace, assigning groups to Editor and Viewer roles

D Create Grafana API keys for each engineer

◆ PAUSE AND DECIDE

How should the DevOps engineer configure authentication?

A **IAM users**

Separate long-lived identities, and not how Managed Grafana signs users in.

B **Cognito**

A second, separate identity store. Managed Grafana supports Identity Center or SAML.

C **IAM Identity Center groups to roles**

Same corporate sign-in, with groups mapped to Grafana's Editor and Viewer roles.

D **API keys**

Meant for automation, not people signing in.

THE SIGNAL

Managed Grafana users sign in with IAM Identity Center or SAML. Map groups to Admin, Editor, Viewer.

Module 19 in five lines

- Metrics say something is wrong; logs say what; traces say where across services.
- X-Ray SDKs and daemon: maintenance since February 2026. New work uses OpenTelemetry via ADOT.
- Annotations are searchable; metadata is not. Sampling can miss rare requests.
- Transaction Search captures every span; Application Signals tracks SLOs with burn-rate alarms.
- Prometheus users: managed Prometheus and Grafana, with Identity Center or SAML sign-in.

ON THE EXAM

Next, module 20: health checks and self-healing, the last module of Domain 4.

MODULE 20 · DOMAIN 4 - MONITORING AND LOGGING

Health Checks and Self-Healing

Health at every layer: EC2 status checks and recovery, Auto Scaling and load balancer checks, containers, serverless failure handling, and designing checks that do not cause outages.

DOMAIN 4 of 6 EXAM WEIGHT 15% MODULE 20 of 34

admin@sthithapragna.com

Self-healing is a loop: something **checks**, something **decides**, something **acts**. And in the cloud, **replacing** usually beats repairing.

Health checks, layer by layer

LAYER	CHECK	NOTICES
Physical host	EC2 system status check	AWS hardware or network failure
Operating system	EC2 instance status check	Kernel panic, exhausted memory, bad config
Storage	Attached EBS status check	Volumes that cannot complete I/O
Application endpoint	Load balancer target health check	The app not answering correctly
Container	ECS health check, Kubernetes probes	A hung or unready container
Whole service	Route 53 health check, Synthetics	The service failing from outside

ON THE EXAM

A check only notices failures at its own layer. EC2 status checks pass happily while the application is down.

EC2 status checks, and what to do

CHECK FAILS	WHOSE PROBLEM	FIX
System status	AWS: the host	Recover, or stop and start to move host
Instance status	Yours: the OS	Reboot, then fix the cause
Attached EBS (August 2024, Nitro)	Storage path	Replace the volume or the instance

ON THE EXAM

Rebooting a system check failure stays on the same broken host. Recovery or stop and start moves it.

Automatic recovery for single instances

- **Simplified automatic recovery** is on by default for supported instance types.
- A CloudWatch alarm on **StatusCheckFailed_System** with the **recover** action does it explicitly.
- Recovery keeps the instance ID, private IPs, Elastic IP, EBS volumes and metadata.
- Not for instances with instance store volumes. For OS failures, use the reboot action instead.

> ON THE EXAM
>
> The recover action belongs on the system check. For instance check failures, the matching action is reboot.

Auto Scaling health check types

TYPE	ON BY DEFAULT?	REPLACES INSTANCES WHEN
EC2	Yes, always	System or instance status checks fail
ELB	No, turn it on	The load balancer marks the target unhealthy
EBS	No, turn it on	Attached EBS status check fails
VPC Lattice	No, turn it on	VPC Lattice marks the target unhealthy
Custom	Your code	SetInstanceHealth marks it unhealthy

ON THE EXAM

App crashed, load balancer says unhealthy, yet the group keeps the instance: ELB health checks were never turned on.

Load balancer target health

- Settings: path, interval, timeout, healthy and unhealthy thresholds, and success codes.
- Unhealthy targets stop receiving new requests, and return once healthy again.
- If **every** target is unhealthy, an ALB **fails open** and sends traffic to all of them.
- Fail open assumes the check is wrong, since everything failing at once is suspicious.

> ON THE EXAM
>
> Fail open protects traffic, but an Auto Scaling group using ELB checks may still replace every instance.

Shallow or deep health checks?

SHALLOW

Can this instance serve?

- Process running, local resources fine
- No calls to shared dependencies
- Safe for load balancers and replacement
- Fails only when this instance is broken

DEEP

Does the whole path work?

- Calls the database and downstream APIs
- Fails on every instance when a dependency fails
- Right for alarms, canaries, Route 53 failover
- Dangerous when it drives replacement

THE TIEBREAKER

A deep check that triggers replacement turns a brief database blip into every instance being terminated.

Container health

- An ECS task definition can include a **health check command**, with interval, retries and a start period.
- An ECS service replaces tasks whose essential containers become unhealthy.
- With a load balancer, both the target health check and the container check matter.
- On EKS: startup, readiness and liveness probes, as in module 7.

> ON THE EXAM
>
> Workers with no load balancer still need health: a container health check lets ECS replace hung tasks.

Serverless failure handling

- Asynchronous Lambda retries twice by default, within a maximum event age.
- **On-failure destinations** send the event plus error details to SQS, SNS, Lambda or EventBridge.
- Stream sources can split failing batches in two, limit retries, and send failures to a destination.
- SQS moves repeatedly failing messages to a **dead-letter queue**, and can redrive them back later.

> ON THE EXAM
>
> Serverless self-healing is retry, then set aside for later: nothing is lost, and nothing blocks the rest.

Dead-letter queue, or on-failure destination?

ON-FAILURE DESTINATION

Event plus context

- Includes the error and invocation details
- SQS, SNS, Lambda or EventBridge
- Also on-success destinations
- The newer, richer option

DEAD-LETTER QUEUE

The event alone

- Stores the original event payload
- SQS or SNS
- Failure only
- Long-established

THE TIEBREAKER

Keep failed events with the reason they failed: an on-failure destination.

Managed services heal themselves; clients must cooperate

- RDS Multi-AZ fails over automatically; Aurora promotes a replica; ElastiCache fails over its primary.
- Failover changes what a DNS endpoint points to. Clients must reconnect and not cache DNS for long.
- Retries with exponential backoff and jitter ride out brief failovers without a stampede.
- An application that never reconnects turns a 30-second failover into an outage.

ON THE EXAM

Database failed over but the application stayed broken: connection handling or DNS caching in the client.

AWS Health: failures announced in advance

- AWS Health reports events affecting your resources, including scheduled retirements and maintenance.
- Events arrive in EventBridge, so a rule can act before the deadline.
- For example: stop and start an instance scheduled for retirement, moving it to new hardware.
- An organisational view gathers Health events across all accounts.

ON THE EXAM

Handle scheduled instance retirements automatically: an EventBridge rule on AWS Health events. Module 21 goes deeper.

The self-healing loop, designed well

01
Check
At the right layer, shallow if it drives action.

02
Decide
Thresholds and grace periods avoid false positives.

03
Act
Replace, recover, restart, or fail over.

04
Limit
Replace a few at a time, not everything at once.

05
Tell
Emit an event so people know it happened.

ON THE EXAM

Self-healing that hides repeated failures is a problem too. Always record and alarm on how often it acts.

> Queue-processing workers run on Nitro-based EC2 instances in an Auto Scaling group, with no load balancer. Occasionally an attached EBS volume becomes impaired and the worker hangs.
>
> The instances' system and instance status checks still pass, so the group never replaces them.

What should the DevOps engineer do?

A Turn on Amazon EBS health checks for the Auto Scaling group

B Enable detailed monitoring on the instances

C Increase the health check grace period

D Add a CloudWatch alarm with the recover action to each instance

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A EBS health checks for the group

The group then acts on the attached EBS check, and replaces instances whose volumes are impaired.

B Detailed monitoring

More frequent metrics. Nothing acts on them.

C Longer grace period

Delays checking further. The opposite of what is needed.

D Recover alarm

For single instances with host failures. In a group, replacement is simpler, and this is a storage failure.

THE SIGNAL

The storage layer has its own check. Auto Scaling only acts on it once EBS health checks are turned on.

A web application runs on an Auto Scaling group behind an Application Load Balancer. Sometimes the application process crashes while the instance keeps running.

The load balancer marks those targets unhealthy and stops sending them traffic, but the group never replaces them, and capacity slowly drains away.

What should the DevOps engineer change?

A Lower the load balancer's unhealthy threshold

B Add a CloudWatch alarm with the recover action to each instance

C Add a launch lifecycle hook to the group

D Turn on ELB health checks for the Auto Scaling group, with a suitable grace period

◆ PAUSE AND DECIDE

What should the DevOps engineer change?

A Lower threshold

The load balancer already detects it. The group is not listening.

B Recover alarm

Watches the host. The host is fine; the process crashed.

C Lifecycle hook

Acts at launch or termination. Nothing is being terminated.

D ELB health checks for the group

The group then replaces instances the load balancer marks unhealthy.

THE SIGNAL

Load balancer knows, Auto Scaling does not act: ELB health checks are off for the group.

> A licensed application runs on a single EC2 instance, not in an Auto Scaling group. Occasionally the operating system runs out of memory and stops responding, and the instance status check fails.
>
> An existing CloudWatch alarm on StatusCheckFailed_Instance uses the recover action, but nothing happens when it fires.

What should the DevOps engineer change?

A Increase the alarm's evaluation periods

B Change the alarm's action to reboot the instance

C Move the instance into an Auto Scaling group of one

D Enable detailed monitoring

◆ PAUSE AND DECIDE

What should the DevOps engineer change?

A More evaluation periods

The alarm fires correctly. The action is the problem.

B Reboot action

Instance check failures are inside the OS; reboot is the matching action. Recover is for host failures.

C Group of one

Replacement brings a new instance ID and IP, which a licensed server cannot accept.

D Detailed monitoring

Faster data. The action still does not match the failure.

THE SIGNAL

Recover pairs with the system check; reboot pairs with the instance check.

A web tier's load balancer health check calls /health, which queries the shared database. The Auto Scaling group uses ELB health checks.

During a 90-second database failover, every instance failed its health check, and the group terminated and replaced the whole fleet, causing a 20-minute outage.

What should the DevOps engineer do?

A. Make the load balancer health check shallow, and monitor database health with separate alarms

B. Double the unhealthy threshold on the target group

C. Turn off ELB health checks for the Auto Scaling group

D. Add more instances to the Auto Scaling group

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Shallow check, separate alarms

Instances fail only when they are broken; database problems alert people without killing the fleet.

B Higher threshold

Delays the same mass replacement. A longer failover still triggers it.

C ELB checks off

Stops the mass replacement, and also stops replacing genuinely crashed instances.

D More instances

More instances, all failing the same check, all replaced.

THE SIGNAL

Every instance failed at once: the check depends on something shared. Keep replacement checks shallow.

S3 uploads invoke a Lambda function asynchronously. When processing fails after all retries, the event is lost, and developers cannot tell why it failed.

The team wants every failed event kept together with the error that caused it, so it can be diagnosed and reprocessed, with the least effort.

What should the DevOps engineer configure?

A Increase the function's timeout and memory

B Enable detailed CloudWatch metrics for the function

C An on-failure destination that sends failed invocations to an SQS queue

D Invoke the function synchronously instead

◆ PAUSE AND DECIDE

What should the DevOps engineer configure?

A **More timeout and memory**

Might reduce some failures. Failed events are still lost, with no reason recorded.

B **Detailed metrics**

Counts failures. Keeps nothing.

C **On-failure destination**

Keeps each failed event with its error details, ready to diagnose and reprocess.

D **Synchronous invocation**

S3 notifications invoke asynchronously. The caller cannot be changed.

THE SIGNAL

Failed event plus the reason: on-failure destination. A dead-letter queue keeps the event alone.

> Background worker containers run as an ECS service with no load balancer. Sometimes a worker deadlocks: the container keeps running, but processes nothing.
>
> The team wants ECS to detect hung workers and replace them automatically. Each worker can report whether it has completed a job in the last two minutes.

What should the DevOps engineer do?

A. Put an Application Load Balancer in front of the workers

B. Alarm on the service's CPU utilisation

C. Enable the deployment circuit breaker

D. Add a container health check to the task definition that runs the worker's own check

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A **Add a load balancer**

Workers serve no requests. A load balancer adds cost to check the wrong thing.

B **CPU alarm**

A deadlocked worker may use little CPU, like an idle one. And it replaces nothing.

C **Circuit breaker**

Watches deployments, not tasks that hang long after starting.

D **Container health check**

Runs the worker's own check; ECS replaces tasks that become unhealthy.

THE SIGNAL

No load balancer, still needs health: a container health check. The best check is the application's own.

Module 20, and Domain 4, in five lines

- Each check sees only its own layer: system, instance, attached EBS, target, container, service.
- Recover for system checks; reboot for instance checks. Auto Scaling acts only on checks you turn on.
- Keep checks that drive replacement shallow; deep checks belong in alarms and failover.
- Serverless: retry, then on-failure destinations or dead-letter queues. Nothing lost.
- Clients must reconnect after managed failovers. AWS Health events can be acted on in advance.

ON THE EXAM

Domain 4 complete. Next, module 21 opens Domain 5: event-driven operations with EventBridge.

MODULE 21 · DOMAIN 5 - INCIDENT AND EVENT RESPONSE

Event-Driven Operations

EventBridge rules, patterns and buses, CloudTrail and AWS Health events, cross-account delivery, reliability, Scheduler, Pipes and Step Functions.

DOMAIN 5 of 6 EXAM WEIGHT 14% MODULE 21 of 34

admin@sthithapragna.com

Operations becomes event-driven when every change **announces itself**, and something is **already listening**.

Event, bus, rule, target

01
Event
A JSON record: source, detail-type, detail.

02
Event bus
Receives events: default, custom or partner.

03
Rule
An event pattern selects the events it wants.

04
Target
Up to five per rule: Lambda, SQS, runbooks…

05
Outcome
Notify, remediate, record, or start a workflow.

ON THE EXAM

When a rule 'never fires', check each link: was the event produced, on this bus, and does the pattern match exactly?

Where events come from

SOURCE	EXAMPLES
AWS service state changes	Instance stopped, deployment failed, pipeline succeeded
CloudTrail API calls	AuthorizeSecurityGroupIngress, DeleteBucket, CreateUser
AWS Health	Scheduled retirement, maintenance, service issues
CloudWatch alarms and Config	Alarm state change, rule compliance change
Security services	GuardDuty findings, Security Hub findings, Inspector findings
Your applications and partners	PutEvents from your code; SaaS partner events

ON THE EXAM

Many services emit their own state-change events directly. API calls come through CloudTrail.

An event pattern

```
1  {
2    "source": ["aws.ec2"],
3    "detail-type": ["AWS API Call via CloudTrail"],
4    "detail": {
5      "eventName": ["AuthorizeSecurityGroupIngress"],
6      "requestParameters": { "ipPermissions": { "items": {
7        "ipRanges": { "items": { "cidrIp": ["0.0.0.0/0"] } } } } },
8      "userIdentity": { "arn": [{ "anything-but": {
9        "prefix": "arn:aws:iam::111122223333:role/NetworkAdmin" } }] }
10   }
11 }
```

5, 7 Someone opened a rule to the whole internet.

8-9 Unless it was the network admin role: content filtering.

ON THE EXAM

Every field listed must match; values in an array are alternatives. Matching is exact and case-sensitive.

CloudTrail events: the trap

- 'AWS API Call via CloudTrail' events need a **CloudTrail trail with logging enabled**.
- Write management events match rules in the normal ENABLED state.
- Read-only management events need the rule state **ENABLED_WITH_ALL_CLOUDTRAIL_MANAGEMENT_EVENTS**.
- S3 object-level calls are data events: the trail must log data events for them.

> ON THE EXAM
>
> A rule on API calls never fires in a new account: there is no trail. Event history alone is not enough.

Three kinds of event bus

BUS	RECEIVES	TYPICAL USE
Default	Events from AWS services in the account	Operations automation
Custom	Your applications' events, and other accounts'	Application events, central buses
Partner	Events from SaaS partners	Integrations such as ticketing tools

ON THE EXAM

A bus's resource policy decides which other accounts may put events on it, including whole organisations.

Crossing accounts: direct target, or bus to bus?

DIRECT CROSS-ACCOUNT TARGET

January 2025

- Rule targets a queue, function or topic in another account
- Targets with resource-based policies only
- No intermediate bus to run
- Receiving team just grants access

BUS TO BUS

The established route

- Rule forwards to a bus in the other account
- A rule there picks the final target
- Works for any target, including pipelines
- Receiving account controls routing

THE TIEBREAKER

Target has a resource policy (SQS, Lambda, SNS, Kinesis, API Gateway): direct. Pipelines and workflows: bus to bus.

Common operational targets

TARGET	USE IT TO
SNS topic	Notify people and systems, with fan-out
SQS queue	Buffer events for a worker, absorbing bursts
Lambda function	Run a short custom action
Step Functions	Run a multi-step workflow with waits and approvals
Systems Manager	Run an Automation runbook or Run Command
CodePipeline, CodeBuild, ECS task	Start a release, a build, or a batch job

ON THE EXAM

An input transformer reshapes the event before it reaches the target, for example into a readable message.

Making delivery reliable

- A **retry policy** retries failed deliveries, by default for up to 24 hours and 185 attempts.
- A **dead-letter queue** on the target keeps events that still could not be delivered.
- An **archive** keeps events for a chosen period; **replay** sends a time window back through the bus.
- A rule whose target triggers the same rule again creates an infinite loop, and a large bill.

> ON THE EXAM
>
> Reprocess events after fixing a consumer bug: archive and replay. Keep undeliverable events: a target DLQ.

EventBridge Scheduler, or a scheduled rule?

EVENTBRIDGE SCHEDULER

The newer scheduler

- Time zones, with daylight saving handled
- One-time and recurring schedules
- Flexible windows to spread load
- Targets thousands of AWS API actions

SCHEDULED RULE

The older way

- Cron or rate expressions in UTC
- Recurring only
- Lives on an event bus
- Fewer target types

THE TIEBREAKER

'At 18:00 London time, all year': Scheduler with a time zone. A UTC cron rule drifts by an hour twice a year.

EventBridge, SNS, or Pipes?

EVENTBRIDGE PIPES

Point to point, enriched

- One source to one target
- Sources: SQS, Kinesis, DynamoDB Streams, Kafka
- Filter and enrich on the way
- Replaces glue Lambda functions

EVENTBRIDGE BUS OR SNS

Many to many

- Bus: rich content-based routing
- SNS: high-throughput fan-out, filter policies
- Both push to many subscribers
- SNS also reaches email, SMS, mobile

THE TIEBREAKER

Poll a stream, filter, enrich, deliver to one target, without code: Pipes. Route many events to many consumers: a bus.

Step Functions for operational workflows

- Wait, retry with backoff, branch on conditions, run steps in parallel, and catch errors.
- Pause for a person with a **task token**, then continue when they respond.
- Call over 200 AWS services directly through SDK integrations, often with no Lambda.
- Standard workflows run up to a year; Express workflows suit high-volume, short runs.

ON THE EXAM

A response with several steps, waits, approvals and retries: Step Functions, not one long Lambda function.

An automated security response

01
Finding
GuardDuty reports a compromised instance.

02
Rule
Matches high-severity findings only.

03
Isolate
Swap to a no-access security group.

04
Preserve
Snapshot the volumes for forensics.

05
Approve
A person decides whether to terminate.

06
Record
Notify, and open an OpsItem.

ON THE EXAM

The event starts it; the workflow carries it through. Detection to containment in seconds, with a person for the irreversible step.

AWS Health across an organisation

- AWS Health events arrive in each account's default bus as source aws.health.
- The **organisational view** gathers Health events from every account, with a delegated administrator.
- Rules act on scheduled changes before their deadlines: retirements, maintenance, certificate expiry.
- Forward Health events to a central operations bus for one team to handle.

> ON THE EXAM
>
> Scheduled retirement in any of 80 accounts must be handled automatically: Health events, forwarded centrally, with a rule and runbook.

> In a newly created account, a security engineer creates an EventBridge rule on the default bus that matches 'AWS API Call via CloudTrail' events for AuthorizeSecurityGroupIngress, targeting an SNS topic.
>
> Security groups are changed several times a day, but the rule never fires. The account has no CloudTrail trails.

What should the security engineer do?

A. Remove detail fields from the pattern so that it matches more broadly

B. Add a second target to the rule

C. Create a CloudTrail trail with logging enabled for management events

D. Set the rule state to ENABLED_WITH_ALL_CLOUDTRAIL_MANAGEMENT_EVENTS

◆ PAUSE AND DECIDE

What should the security engineer do?

A **Broader pattern**

No events are arriving at all. A broader pattern still matches nothing.

B **Second target**

The rule never fires, so no target is ever invoked.

C **Create a trail**

API call events need a trail with logging enabled. Event history alone does not deliver them.

D **All management events state**

Needed for read-only calls. This is a write call, and there is still no trail.

THE SIGNAL

API-call rule silent in a new account, 'no trails': the events are never produced.

> A security team wants every S3 bucket policy change in a workload account delivered to an SQS queue that it owns in its security account.
>
> The security team does not want to manage any EventBridge resources, and the company wants the fewest moving parts.

What should the DevOps engineer set up?

A. A rule in the workload account that targets the security account's queue directly, with a queue policy allowing it

B. A rule forwarding events to a custom bus in the security account, plus a rule there targeting the queue

C. A Lambda function in the workload account that sends each event to the queue

D. An SNS topic in the workload account, with the queue subscribed across accounts

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A Direct cross-account target

Since January 2025: the rule delivers straight to the queue; the security team only writes a queue policy.

B Bus to bus

Works, but puts a bus and a rule in the security account, which the team wanted to avoid.

C Forwarding Lambda

Custom code doing what EventBridge now does natively.

D SNS in between

An extra hop and service for no benefit.

THE SIGNAL

Target in another account with a resource policy, and no EventBridge for the receivers: direct delivery.

> An EventBridge rule sends order events to a partner's HTTP endpoint through an API destination. During a partner outage lasting several days, events were dropped once retries ran out.
>
> The company wants no event to be lost, and wants to send the missed events once the partner recovers.

What should the DevOps engineer configure?

A. A higher invocation rate limit on the API destination

B. A second rule with the same pattern and target

C. An input transformer on the target

D. A dead-letter queue on the target, keeping undelivered events for redelivery

◆ PAUSE AND DECIDE

What should the DevOps engineer configure?

A **Higher rate limit**

Sends faster to an endpoint that is down. Nothing is kept.

B **Duplicate rule**

Both copies fail in the same way, and duplicates follow when the partner recovers.

C **Input transformer**

Reshapes events. Does nothing for delivery failures.

D **Target dead-letter queue**

After retries are exhausted, events land in the queue instead of vanishing, ready to resend.

THE SIGNAL

Retries exhausted, events dropped: add a target DLQ. Retries cover minutes to a day; a DLQ covers longer.

> Development instances must stop at 18:00 London time every weekday and start at 07:30. A rule written in UTC cron has run an hour late for half of every year.
>
> The team also wants one-off stops before public holidays, with the least operational overhead.

What should the DevOps engineer use?

A Two scheduled EventBridge rules, edited by hand when the clocks change

B EventBridge Scheduler schedules in the Europe/London time zone, including one-time schedules, calling the EC2 API

C A cron job on a small always-on instance

D A Lambda function that runs every minute and checks the time

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A **Rules edited twice a year**
The same UTC problem, fixed by hand, forever.

B **Scheduler with a time zone**
Daylight saving handled, one-time schedules supported, and EC2 called directly.

C **Cron on an instance**
A server to run, patch and keep alive, to tell the time.

D **Lambda every minute**
Over 40,000 invocations a month to do the work of four schedules.

THE SIGNAL

Local time with daylight saving, plus one-off runs: EventBridge Scheduler.

> Order events flow through a custom event bus to several consumers. Last month a consumer bug mishandled six hours of events, and they could not be reprocessed.
>
> The company wants to be able to reprocess any events from the past seven days after fixing a future consumer bug.

What should the DevOps engineer set up?

A An archive on the custom bus with seven days' retention, and replay when needed

B A dead-letter queue on each target

C A CloudTrail trail with data events

D Log every event to CloudWatch Logs and write a script to republish them

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A Archive and replay

Keeps events for seven days and replays any time window through the bus after the fix.

B Target DLQs

Catch failed deliveries. These events were delivered, and then mishandled.

C CloudTrail data events

Records API calls, not the application's event stream.

D Logs and a republish script

Rebuilds archive and replay by hand.

THE SIGNAL

Delivered but mishandled: DLQs cannot help. Archive and replay can.

> On a high-severity GuardDuty finding for an EC2 instance, the security team wants to isolate the instance, snapshot its volumes, wait for an engineer to approve termination, and then terminate or release it.
>
> Each step needs retries, and the approval may take hours.

What should the DevOps engineer build?

A. A single Lambda function that performs every step and waits for approval

B. An SNS email to the team asking them to carry out the steps

C. An EventBridge rule on high-severity findings that starts a Step Functions workflow with a task-token approval step

D. Several EventBridge rules, each triggering the next step

◆ PAUSE AND DECIDE

What should the DevOps engineer build?

A One Lambda function

Lambda stops after 15 minutes. An approval taking hours cannot fit.

B Email the team

Manual, slow, and containment waits for someone to read it.

C Rule and Step Functions workflow

Retries per step, a task token for the approval, and waits of hours or days.

D Chained rules

No state, no approval step, and hard to follow or retry.

THE SIGNAL

Several steps, retries, a human approval that takes hours: an event starts a Step Functions workflow.

Module 21 in five lines

- Event, bus, rule, target. Patterns match exactly; arrays are alternatives.
- API-call events need a trail; read-only calls need the all-management-events rule state.
- Cross-account: direct to resource-policy targets since January 2025; bus to bus for the rest.
- Retries and target DLQs for failed delivery; archive and replay for mishandled events.
- Scheduler for time zones and one-offs; Pipes for enriched point to point; Step Functions for steps.

ON THE EXAM

Next, module 22: automated remediation with AWS Config, runbooks and OpsCenter.

MODULE 22 · DOMAIN 5 - INCIDENT AND EVENT RESPONSE

Automated Remediation

AWS Config rules, recording and remediation, conformance packs and aggregators, OpsCenter, chat operations, and AI-assisted investigation.

DOMAIN 5 of 6 EXAM WEIGHT 14% MODULE 22 of 34

admin@sthithapragna.com

Detect, decide, fix, record. Automation handles **decide** and **fix**, but only for problems you already **understand**.

Detection paired with a fix

DETECTED BY	TYPICAL FIX
AWS Config rule, non-compliant resource	Config remediation running an Automation runbook
EventBridge event, such as an API call	A rule targeting a runbook, Lambda or Step Functions
CloudWatch alarm	An alarm action: runbook, Lambda, Auto Scaling, EC2
Security finding	EventBridge, or Security Hub automation (module 27)

ON THE EXAM

Config answers 'is this resource out of policy'. EventBridge answers 'did something just happen'.

AWS Config, in one slide

- The **configuration recorder** captures a configuration item whenever a supported resource changes.
- Each resource gets a **timeline**: what it looked like, when it changed, and who changed it via CloudTrail.
- **Rules** evaluate resources and mark them compliant or non-compliant.
- Findings and compliance changes are events, so EventBridge can act on them too.

> ON THE EXAM
>
> 'What did this security group look like last Tuesday, and who changed it?': Config's resource timeline.

Config rules

CHOICE	OPTIONS
Rule type	AWS managed; custom Lambda; custom policy written in Guard
Trigger	On configuration change; periodic, such as every 24 hours
Evaluation mode	Detective: existing resources; proactive: before deployment
Scope	Resource types, tags, or specific resources

ON THE EXAM

Use a managed rule when one exists. A custom Guard policy avoids writing and running a Lambda function.

Recording: what, and how often

- Record all resource types, or include or exclude specific ones.
- **Continuous** recording captures every change; **daily periodic** recording captures one state a day.
- Periodic recording cuts cost for resources that change constantly, such as short-lived instances.
- Record global resources, such as IAM, in one Region only, or you pay for duplicates.

> ON THE EXAM
>
> Config costs rising from churning resources, and daily state is enough: periodic recording for those types.

Config remediation

- A remediation action is a Systems Manager **Automation runbook**, such as AWS-DisablePublicAccessForSecurityGroup.
- **Manual** remediation waits for a person to click; **automatic** runs on every non-compliant evaluation.
- Automatic remediation retries a set number of times, within a time window.
- The runbook runs as an **AutomationAssumeRole**, which needs permission for everything it changes.

> ON THE EXAM
>
> Remediation 'fails with access denied': the assume role lacks permissions, or does not trust Systems Manager.

Automatic remediation, in a template

```
1  Type: AWS::Config::RemediationConfiguration
2  Properties:
3    ConfigRuleName: restricted-ssh
4    TargetType: SSM_DOCUMENT
5    TargetId: AWS-DisablePublicAccessForSecurityGroup
6    Automatic: true
7    MaximumAutomaticAttempts: 3
8    RetryAttemptSeconds: 60
9    Parameters:
10     GroupId: { ResourceValue: { Value: RESOURCE_ID } }
11     AutomationAssumeRole: { StaticValue: { Values: [ !GetAtt RemediationRole.Arn ] } }
```

10 The non-compliant security group's ID is passed in automatically.

11 The role the runbook runs as. Missing permissions here cause failures.

ON THE EXAM

Deploy the rule and its remediation together, as code, then roll out across accounts with a conformance pack.

Conformance packs

- A **conformance pack** bundles rules and remediations into one deployable template.
- Sample packs map to frameworks, such as operational best practices for CIS or PCI DSS.
- **Organisation conformance packs** deploy to every account from a delegated administrator.
- Each pack reports a compliance score across its rules.

> ON THE EXAM
>
> The same rules and fixes in every account, managed centrally: an organisation conformance pack.

Aggregators: one view of many accounts

- An **aggregator** gathers configuration and compliance data from many accounts and Regions.
- With Organizations, it covers every account automatically, including new ones.
- **Advanced queries** use SQL across the aggregated inventory.
- An aggregator views and queries. It does not deploy rules; conformance packs do that.

> ON THE EXAM
>
> Auditors want one view of compliance across 60 accounts and four Regions: an aggregator in the delegated admin account.

Fix automatically, or notify a person?

AUTOMATE THE FIX

Understood and reversible

- The cause and fix are well known
- Safe to apply without judgement
- Easy to reverse if wrong
- Examples: open SSH, public snapshot, missing tags

NOTIFY AND ASSIST

Ambiguous or risky

- The cause needs investigating
- The fix could cause an outage
- Hard to reverse, such as deleting
- Examples: error spikes, cost anomalies, data loss

THE TIEBREAKER

Auto-remediation that deletes data or restarts production on a guess is a second incident waiting to happen.

OpsCenter

- **OpsItems** collect operational issues from alarms, Config, EventBridge and AWS Health in one place.
- Each OpsItem shows related resources, recent changes, and suggested runbooks to run from it.
- Similar OpsItems are deduplicated, so a flapping alarm does not create hundreds.
- Works across accounts, with a delegated administrator.

> ON THE EXAM
>
> One place to track operational issues and run fixes from them, without a separate ticketing tool: OpsCenter.

The catalogue has moved: incident tooling

SERVICE	STATUS
Systems Manager Incident Manager	Closed to new customers, 7 Nov 2025
AWS Chatbot	Renamed Q Developer in chat applications, Feb 2025
CloudWatch investigations	Generally available June 2025, no extra cost
CloudWatch incident reports	Five Whys analysis added, Nov 2025
AWS DevOps Agent	Preview Dec 2025; generally available Apr 2026

THE RULE

Incident Manager still appears in the exam guide. Answer on the guide's terms; know the reality.

Operations in chat

- **Amazon Q Developer in chat applications** posts notifications to Slack, Microsoft Teams and Chime.
- Notifications arrive through **SNS topics** mapped to channels: alarms, pipelines, Health, GuardDuty.
- Engineers can run commands and runbooks from the channel.
- A channel IAM role plus **guardrail policies** cap what anyone in the channel can do.

> ON THE EXAM
>
> Alarms and failures in the team's Slack channel, with safe commands, least effort: Q Developer in chat applications.

CloudWatch investigations

- An AI agent looks for anomalies, gathers related signals, and proposes **root-cause hypotheses**.
- Suggests remediation: Automation runbooks, re:Post articles, documentation.
- Starts from any CloudWatch widget, from chat, or **automatically from an alarm action**.
- Teams collaborate in the investigation, accepting or discarding findings.

> ON THE EXAM
>
> Start root-cause analysis automatically when a critical alarm fires, AWS-native, no code: an investigation alarm action.

An aside beyond the exam guide: AWS DevOps Agent

- Generally available April 2026: an autonomous agent that investigates incidents as they are raised.
- Builds a map of application resources, then correlates telemetry, deployments and code changes.
- Triggered by CloudWatch alarms or tickets; integrates with third-party observability and Git tools.
- Newer than the exam guide. It is unlikely to be a correct option, but it is where practice is heading.

> ON THE EXAM
>
> Use it at work; do not expect it on the exam. CloudWatch investigations is the likelier exam-era answer.

Closing the loop after an incident

01
Detect
Alarm, event, or Config rule.

›

02
Investigate
Humans, helped by investigations.

›

03
Fix
Runbook, rollback, or change.

›

04
Review
Incident report, Five Whys.

›

05
Prevent
New rule, alarm, test or remediation.

ON THE EXAM

Every incident that was investigated by hand should end with a new automated detection or fix.

> A company has 70 accounts in AWS Organizations. Security groups allowing SSH from 0.0.0.0/0 keep appearing, and must be closed automatically within minutes.
>
> Developers must still be able to change security groups for legitimate reasons. The company wants the least operational overhead.

Which solution meets these requirements?

A. A nightly Lambda function in each account that scans and fixes security groups

B. An organisation conformance pack with the restricted-ssh rule and automatic remediation using AWS-DisablePublicAccessForSecurityGroup

C. Enable GuardDuty in every account

D. An SCP that denies ec2:AuthorizeSecurityGroupIngress

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A **Nightly Lambda**

Hours of exposure, not minutes, and custom code in 70 accounts.

B **Organisation conformance pack**

Managed rule plus AWS-owned runbook, deployed once to every account, fixing within minutes.

C **GuardDuty**

Detects threats. It does not close security groups.

D **SCP denying ingress changes**

Blocks every legitimate change too, which the scenario forbids.

THE SIGNAL

Known misconfiguration, fixed automatically, across an organisation: conformance pack with remediation.

> A Config rule flags S3 buckets without logging, with automatic remediation using an Automation runbook. The rule works, but every remediation fails with an AccessDenied error.
>
> The remediation configuration passes no AutomationAssumeRole parameter.

What should the DevOps engineer do?

A Add permissions to the AWS Config service-linked role

B Grant the engineer who created the rule more permissions

C Increase the maximum automatic remediation attempts

D Create a role trusting Systems Manager with the needed S3 permissions, and pass it as AutomationAssumeRole

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Config service-linked role

Service-linked role permissions are managed by AWS, and the runbook does not run as it.

B Engineer's permissions

Remediation runs later, automatically, not as the person who created it.

C More attempts

Fails with AccessDenied more times.

D AutomationAssumeRole

The runbook needs its own role with the permissions it uses, trusting Systems Manager.

THE SIGNAL

Remediation fails with AccessDenied: the runbook's assume role is missing or under-privileged.

> Auditors need one view of Config rule compliance across 60 accounts in four Regions, including accounts added later. They also want to run SQL queries across the whole inventory.
>
> The company uses AWS Organizations and wants the least operational overhead.

What should the DevOps engineer set up?

A Give auditors read-only roles in every account and Region

B A Config aggregator using Organizations, in a delegated administrator account

C Athena queries over Config snapshots copied from each account

D An organisation conformance pack

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A Roles everywhere

240 places to look. Not one view.

B Organisation aggregator

One view across all accounts and Regions, new accounts included, with SQL advanced queries.

C Athena over snapshots

A copying pipeline to build and maintain.

D Conformance pack

Deploys rules. Does not aggregate or query.

THE SIGNAL

Deploy rules everywhere: conformance pack. See and query them everywhere: aggregator.

> AWS Config costs have tripled. Development accounts run Auto Scaling groups that launch and terminate hundreds of instances daily, each change recorded continuously.
>
> Compliance teams only need a daily view of EC2 instances in development, but continuous recording for everything else.

What should the DevOps engineer do?

A Turn off Config in the development accounts

B Exclude EC2 instances from recording everywhere

C Delete the Config rules that evaluate EC2 instances

D Set daily periodic recording for EC2 instances in development, keeping continuous recording for other types

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Turn off Config

Loses the daily view compliance needs, and everything else too.

B Exclude EC2 everywhere

Loses instance recording in production as well.

C Delete rules

Rules are not the cost here. Recording is.

D Periodic recording for dev instances

One state a day for the churning type; continuous elsewhere. Exactly the requirement.

THE SIGNAL

Config cost driven by churn, daily state sufficient: periodic recording for those resource types.

> An on-call team lives in Slack. It wants CloudWatch alarms, pipeline failures and AWS Health events posted to its incident channel.
>
> Engineers should be able to run safe, read-only diagnostic commands from the channel, and the setup should take the least effort.

What should the DevOps engineer set up?

A. Amazon Q Developer in chat applications, with SNS topics mapped to the channel and guardrail policies on its role

B. A Lambda function that posts every event to a Slack webhook

C. Email notifications to the channel's email address

D. An EventBridge API destination that posts events to a Slack webhook

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A Q Developer in chat applications

Formatted notifications from SNS topics, plus commands limited by guardrail policies.

B Lambda to webhook

Custom formatting code, and no commands from the channel.

C Email to channel

Unformatted, and no commands.

D API destination to webhook

Delivers messages without code, but still no commands, and no formatting per service.

THE SIGNAL

Notifications plus safe commands in chat: Q Developer in chat applications, formerly AWS Chatbot.

> When a critical latency alarm fires, on-call engineers spend an hour correlating metrics, logs, deployments and configuration changes before forming a theory.
>
> The team wants AI-assisted root-cause hypotheses to start automatically when that alarm fires, using AWS-native tooling, with no code.

What should the DevOps engineer configure?

A. A Lambda function on the alarm that queries logs and emails a summary

B. A Contributor Insights rule on the application logs

C. An alarm action that starts a CloudWatch investigation

D. An Incident Manager response plan for the alarm

◆ PAUSE AND DECIDE

What should the DevOps engineer configure?

A Lambda summary

Custom code, and a summary is not correlation or hypotheses.

B Contributor Insights

Finds top contributors in logs. Does not correlate across signals.

C Investigation alarm action

Starts an AI investigation automatically: anomalies, related signals, hypotheses, suggested runbooks.

D Incident Manager

Closed to new customers since November 2025, and it coordinates response rather than finding causes.

THE SIGNAL

Automatic, AI-assisted root-cause hypotheses from an alarm, no code: a CloudWatch investigation.

Module 22 in five lines

- Detect, decide, fix, record. Automate fixes that are understood and reversible.
- Config: managed or Guard rules; periodic recording for churn; remediation needs an assume role.
- Conformance packs deploy rules everywhere; aggregators see and query them everywhere.
- OpsCenter tracks issues; Q Developer in chat applications brings alerts and commands to chat.
- Investigations propose root causes from an alarm. Incident Manager is closed to new customers.

ON THE EXAM

Next, module 23: troubleshooting failed deployments and operations, the last module of Domain 5.

MODULE 23 · DOMAIN 5 - INCIDENT AND EVENT RESPONSE

Troubleshooting Failed Deployments and Operations

A method for diagnosis, where each service records its failures, the error signatures worth recognising, and how to untangle access denied.

DOMAIN 5 of 6 EXAM WEIGHT 14% MODULE 23 of 34

admin@sthithapragna.com

Troubleshooting is **narrowing**: find the layer, find the **first** failure, and read what it **actually says**.

A diagnostic method

01
Place it
Build, deploy, run, or respond?

02
First failure
The earliest error, not the loudest.

03
Read it
The exact message names the cause.

04
What changed?
Deployments, CloudTrail, Config.

05
Fix and prevent
Then add a check so it cannot recur.

ON THE EXAM

Most incidents follow a change. 'What changed just before?' is often the fastest question.

Where each service records its failures

SERVICE	LOOK AT
CodePipeline	Action execution details, linking to the underlying service
CodeBuild	Build logs and phase details
CodeDeploy	Lifecycle events per instance; agent logs on the instance
CloudFormation	Stack events: the first FAILED status reason
ECS	The stopped task's reason; service events
Auto Scaling	Activity history
Lambda	CloudWatch Logs; Errors and Throttles metrics

ON THE EXAM

A pipeline only reports that an action failed. The reason lives in the service the action called.

CloudFormation failure signatures

YOU SEE	IT USUALLY MEANS
Many 'Resource creation cancelled'	Not the cause: find the earlier failure
'already exists'	A fixed name collides with an existing resource
'Received 0 SUCCESS signals'	cfn-signal never reached CloudFormation
'Requires capabilities: CAPABILITY_IAM'	The template creates IAM resources; acknowledge it
Export 'cannot be updated as it is in use'	Another stack imports it
UPDATE_ROLLBACK_FAILED	Fix the cause, then continue rollback, skipping resources

ON THE EXAM

When one resource fails, CloudFormation cancels everything in progress. The cancellations are noise.

Pipeline and build failure signatures

YOU SEE	IT USUALLY MEANS
'Cannot connect to the Docker daemon'	Privileged mode is off
Timeouts downloading packages in a VPC build	No NAT route or endpoints
Secret fetch fails at build start	Service role lacks the fetch or kms:Decrypt permission
Cross-account action 'access denied' on artifacts	Bucket policy or customer managed key policy
Lambda action stuck, then times out	The function never reported a job result
Tests failed, build passed	An exit code was swallowed

ON THE EXAM

Every row here was a scenario in Domain 1. Troubleshooting is recognition of patterns you have already met.

CodeDeploy failure signatures

YOU SEE	IT USUALLY MEANS
No instances found for the deployment group	Tag filter or group name does not match the instances
Every deployment fails at ApplicationStop	The last successful revision's stop script is broken
Too many individual instances failed	Minimum healthy hosts could not be kept
Script timed out at a lifecycle event	The script hangs, or its timeout is too short
'file already exists at location'	Files placed outside CodeDeploy; set file-exists behaviour
Instance never picks up the deployment	Agent not running, or no instance profile access

ON THE EXAM

Read which lifecycle event failed. Its name tells you whether the problem is yours or the environment's.

ECS failure signatures

YOU SEE	IT USUALLY MEANS
'unable to place a task'	No instance has the CPU, memory or free port needed
CannotPullContainerError	Execution role lacks ECR access, no route to ECR, or wrong tag
ResourceInitializationError	Secrets or log setup failed: execution role or network path
Essential container exited	The application crashed: read its logs
Tasks replaced in a loop	Failing health checks, often too short a grace period
Deployment rolled back by itself	The circuit breaker or a deployment alarm acted

ON THE EXAM

Anything that fails before your code runs is the execution role or the network. After, it is your code or the task role.

Task execution role, or task role?

TASK EXECUTION ROLE

Used by ECS, before your code runs

- Pulls images from ECR
- Fetches secrets for environment variables
- Sends logs through the awslogs driver
- Fails as: task never starts

TASK ROLE

Used by your application

- Calls S3, DynamoDB, SQS, and so on
- Credentials appear inside the container
- Nothing to do with starting the task
- Fails as: app runs, then gets access denied

THE TIEBREAKER

Task will not start: execution role. Task runs but the app's AWS calls fail: task role.

Auto Scaling and EC2 failure signatures

ACTIVITY HISTORY SAYS	IT USUALLY MEANS
Insufficient capacity for the instance type	Too narrow a choice: add types and zones
Subnet has no free IP addresses	The subnet is too small for the group
Instance limit or quota exceeded	Request a quota increase
Invalid AMI, key pair or launch template	A reference points to something missing
Instances launched then terminated repeatedly	Health checks fail before the app is ready

ON THE EXAM

Capacity errors for one instance type in one zone: a mixed instances policy across types and zones.

Lambda failure signatures

YOU SEE	IT USUALLY MEANS
429 throttling errors	Concurrency exhausted, or scaling rate exceeded
'Task timed out' calling AWS APIs from a VPC	No NAT route or VPC endpoint
AccessDeniedException in the logs	The execution role lacks the permission
Runtime exited, memory limit reached	Needs more memory
Init errors on every cold start	Failing code outside the handler, or a missing dependency

ON THE EXAM

Attaching a function to private subnets removes its internet path. AWS APIs then need NAT or endpoints.

Untangling access denied

- Most error messages now say **which kind of policy** denied: SCP, boundary, session, identity or resource policy.
- CloudTrail records the failed call, its principal, and the error code.
- The **IAM policy simulator** tests a principal's policies against an action and resource.
- 'Explicit deny in a service control policy': no identity policy change can fix it.

> ON THE EXAM
>
> Read the whole error message first. It usually names the policy type, which tells you where to look.

The layers that must all allow

01
Organisation
SCPs and RCPs: no explicit deny, and an allow.

›

02
Boundaries
Permissions boundary, session policy.

›

03
Identity
The principal's own policies allow it.

›

04
Resource
Bucket, key, queue or endpoint policies agree.

›

05
Network
VPC endpoint policies, and a route at all.

ON THE EXAM

Admin rights inside the account cannot get past a ceiling set above it, or a resource that refuses.

Asking 'what changed?'

- **Deployment history**: pipelines, CodeDeploy and ECS deployments around the start time.
- **CloudTrail**: who changed which resource, and when.
- **Config**: what a resource's configuration was before and after.
- **AWS Health**: whether AWS itself had an event affecting your resources.

> ON THE EXAM
>
> No deployment, sudden failure: look for a manual change in CloudTrail or Config before blaming the application.

> A stack creation fails. The events list shows twelve resources with 'Resource creation cancelled'. Earlier, one event shows a Lambda function failing: 'The role defined for the function cannot be assumed by Lambda'.
>
> The execution role in the template trusts ec2.amazonaws.com.

What should the DevOps engineer fix?

A Change the role's trust policy to trust lambda.amazonaws.com

B Increase the creation timeouts on the twelve cancelled resources

C Add DependsOn attributes to every resource

D Create the stack with rollback disabled and try again

◆ PAUSE AND DECIDE

What should the DevOps engineer fix?

A Trust lambda.amazonaws.com

The first failure says Lambda cannot assume the role; the trust names the wrong service.

B Longer timeouts

The cancellations are consequences, not causes.

C DependsOn everywhere

Ordering was not the problem. The role was never assumable.

D Disable rollback

Keeps the broken state for inspection; the same error recurs.

THE SIGNAL

Twelve loud cancellations, one quiet first failure. Fix the first; the rest follow.

> New ECS tasks on Fargate never start. The stopped reason reads: 'ResourceInitializationError: unable to pull secrets ... AccessDeniedException ... secretsmanager:GetSecretValue'.
>
> The task definition injects a database password from Secrets Manager as an environment variable. The task role allows secretsmanager:GetSecretValue.

What should the DevOps engineer fix?

A. Add secretsmanager:GetSecretValue to the task role again

B. Allow secretsmanager:GetSecretValue, and kms:Decrypt if needed, on the task execution role

C. Open the task's security group to all inbound traffic

D. Increase the task's memory

◆ PAUSE AND DECIDE

What should the DevOps engineer fix?

A **Task role again**

The task role is used by the app after start. Injecting secrets happens before.

B **Task execution role**

ECS fetches injected secrets before the code runs, using the execution role.

C **Open the security group**

Inbound rules do not affect outbound secret retrieval, and the error is access denied.

D **More memory**

The task never started. Memory is irrelevant.

THE SIGNAL

Fails before the code runs: execution role. The planted detail is that the task role already had the permission.

> A CodeDeploy deployment to EC2 fails immediately with 'No instances found for your deployment group'. The deployment group targets instances tagged Env=prod.
>
> Last week the team moved to a new launch template, whose instances are tagged Environment=prod. The agent is running on every instance.

What should the DevOps engineer do?

A. Reinstall the CodeDeploy agent on every instance

B. Lower the deployment configuration's minimum healthy hosts

C. Make the deployment group's tag filter and the instances' tags match

D. Add permissions to the CodeDeploy service role

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A **Reinstall agent**

The scenario says the agent runs. Targeting fails before any agent is involved.

B **Minimum healthy hosts**

There are zero targets. No percentage of zero helps.

C **Match the tags**

Env and Environment are different keys, so the filter matches nothing.

D **Service role**

A permissions problem would say access denied, not no instances found.

THE SIGNAL

'No instances found' plus a recent change to tags or templates: the target filter no longer matches.

> A Lambda function that writes to DynamoDB was attached to private subnets so it could also reach an internal database. Since then, every invocation fails with 'Task timed out after 30.00 seconds'.
>
> The subnets have no NAT gateway. The internal database calls succeed.

What should the DevOps engineer do?

A Increase the function timeout to 5 minutes

B Increase the function's memory

C Set reserved concurrency on the function

D Add a DynamoDB gateway VPC endpoint to the subnets' route tables

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Longer timeout

The call can never succeed without a route. It would just fail more slowly.

B More memory

Speed is not the problem. There is no path.

C Reserved concurrency

Unrelated to network paths.

D DynamoDB gateway endpoint

Gives private subnets a route to DynamoDB, with no NAT needed and no data charge.

THE SIGNAL

Timed out only since joining a VPC, calls to an AWS service: no route. Gateway endpoint for DynamoDB or S3.

> A developer with the AdministratorAccess policy tries to create an RDS database in eu-south-2 and receives: 'with an explicit deny in a service control policy'.
>
> The developer asks for more permissions to be added to their IAM role.

What should the DevOps engineer do?

A. Explain the organisation restricts Regions; use an allowed Region, or request an exception to the SCP

B. Attach an additional policy allowing rds:* to the developer's role

C. Remove the developer's permissions boundary

D. Add the developer to the RDS KMS key's key policy

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A It is the SCP

The message names an explicit deny in an SCP. Only the organisation's policy, or the Region, can change.

B More IAM permissions

The developer already has administrator access. An explicit deny beats any allow.

C Remove boundary

The message names an SCP, not a boundary.

D Key policy

The message names an SCP, not a key.

THE SIGNAL

Read the policy type in the message. 'Explicit deny in a service control policy' is a ceiling, not a missing grant.

> An Auto Scaling group uses one GPU instance type in a single Availability Zone. During a traffic surge, activity history shows repeated 'insufficient capacity' errors, and no instances launch.
>
> The application runs equally well on several similar instance types.

What should the DevOps engineer do?

A Wait and retry the scale-out later

B Use a mixed instances policy with several suitable types, across several Availability Zones

C Request a higher EC2 instance quota

D Switch to a different AMI

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A **Wait**

Surges are exactly when capacity is scarce. Waiting fails users now.

B **More types, more zones**

Many more capacity pools to draw from, and the app runs on any of them.

C **Higher quota**

A quota error says 'limit exceeded'. This is AWS lacking that type in that zone.

D **Different AMI**

The image does not change hardware availability.

THE SIGNAL

Insufficient capacity is not a quota. Widen the choice: instance types and Availability Zones.

> At 14:05, an application's calls to its database started failing with connection timeouts. The pipeline shows no deployment for three days, and the database is healthy.
>
> The on-call engineer wants the fastest way to find the cause.

What should the engineer check first?

A Read the application's debug logs from the last three days

B Enable X-Ray tracing and wait for new traces

C CloudTrail and the Config timeline for changes to the relevant security groups and route tables around 14:00

D Restart the application servers

◆ PAUSE AND DECIDE

What should the engineer check first?

A **Three days of logs**

Slow, and the app did not change. Timeouts suggest the network did.

B **Enable X-Ray**

Tells you where time goes, later. Not what changed at 14:05.

C **CloudTrail and Config around 14:00**

A sudden failure with no deployment points to a manual change; these show who changed what.

D **Restart**

Acting before diagnosing, and it will not fix a changed network rule.

THE SIGNAL

Sudden failure, exact start time, no deployment: ask what changed. Timeouts point to the network.

> An ECS service on EC2 uses bridge networking, with container port 80 mapped to host port 80. Scaling from 4 to 8 tasks leaves 4 tasks pending on a cluster with plenty of spare CPU and memory.
>
> Service events say no container instance met the task's requirements, citing a port already in use.

What should the DevOps engineer change?

A Increase the memory reserved for each task

B Use larger container instances

C Add a placement constraint that spreads tasks across Availability Zones

D Use dynamic host port mapping, or the awsvpc network mode, with the load balancer registering each task

◆ PAUSE AND DECIDE

What should the DevOps engineer change?

A More memory

Memory is plentiful. The port is the constraint.

B Larger instances

Still only one host port 80 per instance, however large.

C Spread across zones

Changes where tasks go, not how many fit per instance.

D Dynamic ports or awsvpc

Each task gets its own port or its own network interface, so many fit per instance.

THE SIGNAL

Spare CPU and memory, tasks pending, 'port in use': a fixed host port allows one task per instance.

Module 23, and Domain 5, in five lines

- Place it, find the first failure, read it, ask what changed, fix and prevent.
- Cancellations follow the real failure. Pipelines point to the service that failed.
- ECS: execution role before your code runs, task role after.
- Access denied messages name the policy type. SCP denies are ceilings, not missing grants.
- VPC timeouts to AWS services: missing routes. Capacity errors: widen types and zones.

> ON THE EXAM
>
> Domain 5 complete. Next, module 24 opens Domain 6: IAM at scale.

MODULE 24 · DOMAIN 6 - SECURITY AND COMPLIANCE

IAM at Scale

How a request is judged, roles and trust, confused deputies, permissions boundaries, session policies and ABAC, Identity Center, keyless workloads, Access Analyzer and root access.

DOMAIN 6 of 6 EXAM WEIGHT 17% MODULE 24 of 34

admin@sthithapragna.com

Every request is judged by a **stack of policies**. Some can grant, some can only cap, and one **explicit deny** anywhere wins.

The policy stack

POLICY TYPE	GRANTS OR CAPS?	ATTACHED TO
Identity-based policy	Grants	Users, groups, roles
Resource-based policy	Grants, including across accounts	Buckets, keys, queues, roles' trust
Permissions boundary	Caps identity-based grants	Users and roles
Session policy	Caps one session	Passed when assuming a role
SCP and RCP	Cap accounts and resources	Organisation, OUs, accounts

ON THE EXAM

Effective permissions are the overlap of every applicable grant and cap, minus any explicit deny.

Same account, or across accounts?

ACROSS ACCOUNTS

Both sides must allow

- Caller's identity policy must allow
- The resource's policy must allow the caller
- Either side alone is not enough
- Plus any organisation policies on each side

SAME ACCOUNT

Either side can allow

- An identity policy alone can be enough
- Or a resource policy alone
- Except KMS key policies and role trust policies
- Those must always allow explicitly

THE TIEBREAKER

Cross-account access denied with a correct resource policy: check the caller's own identity policy.

Roles and trust

- A role's **trust policy** says who may assume it; its **permissions policies** say what it can then do.
- Assuming a role returns temporary credentials from STS.
- Sessions last up to the role's maximum, as long as 12 hours; **role chaining** caps them at one hour.
- A trust policy naming a whole account trusts every principal there with permission to assume it.

> ON THE EXAM
>
> Cannot assume a role: check the trust policy first. Assumed, but cannot act: check the permissions policies.

The confused deputy

- A service acting for many customers could be tricked into using its access for the wrong one.
- For third parties: require an **sts:ExternalId** unique to you in the role's trust policy.
- For AWS services acting for you: condition on **aws:SourceArn** or **aws:SourceAccount**.
- The external ID is not a secret password. It stops one customer's configuration being reused against another.

> ON THE EXAM
>
> A SaaS vendor assumes roles in many customers' accounts: its trust policies need an external ID condition.

A trust policy for a third-party vendor

```
1 { "Version": "2012-10-17",
2   "Statement": [{
3     "Effect": "Allow",
4     "Principal": { "AWS": "arn:aws:iam::999988887777:role/VendorMonitoring" },
5     "Action": "sts:AssumeRole",
6     "Condition": {
7       "StringEquals": { "sts:ExternalId": "acme-7f3c9a21" } }
8   }] }
```

4 Trust one specific role in the vendor's account, not the whole account.

7 The vendor must present the ID it assigned to you.

ON THE EXAM

A vendor-facing role with no ExternalId condition is the confused deputy the exam wants you to spot.

Permissions boundaries

- A **boundary** sets the maximum permissions a user or role's identity policies can grant.
- The classic use: let developers create roles, but only roles that carry the boundary.
- Then no role a developer creates can exceed the boundary, so there is no privilege escalation.
- Also deny developers the ability to remove or change the boundary, or the protection is empty.

> ON THE EXAM
>
> Delegate role creation without allowing escalation: a permissions boundary enforced with iam:PermissionsBoundary.

Delegating role creation safely

```
1 { "Effect": "Allow",
2   "Action": ["iam:CreateRole", "iam:AttachRolePolicy", "iam:PutRolePolicy"],
3   "Resource": "arn:aws:iam::*:role/app-*",
4   "Condition": { "StringEquals": {
5     "iam:PermissionsBoundary": "arn:aws:iam::111122223333:policy/DevBoundary" } } },
6 { "Effect": "Deny",
7   "Action": ["iam:DeleteRolePermissionsBoundary", "iam:PutRolePermissionsBoundary"],
8   "Resource": "*" }
```

5 Roles can only be created with this boundary attached.

7 And the boundary can never be removed or swapped.

ON THE EXAM

Developers self-serve roles; the security team owns only the boundary.

Session policies and session tags

- A **session policy** passed when assuming a role narrows that session below the role's permissions.
- **Session tags** passed on assume or federation become aws:PrincipalTag values for that session.
- **Transitive** session tags survive role chaining.
- Useful when one broad role serves many callers, each needing a narrower view.

> ON THE EXAM
>
> One role, many callers, each limited differently: session policies or session tags, not one role per caller.

Role-based or attribute-based access?

ABAC

Match tags, not names

- One policy: principal's tag must equal resource's tag
- New projects need no new policies
- Tags come from users, roles or sessions
- Scales to hundreds of teams

RBAC

A role per job per project

- Policies list resources explicitly
- Every new project means new policies
- Clear and simple at small scale
- Explodes into hundreds of roles

THE TIEBREAKER

Hundreds of projects, same job functions, tagged resources: ABAC with aws:PrincipalTag and aws:ResourceTag.

IAM Identity Center

- Workforce sign-in to many accounts, with users and groups from your identity provider, synced by SCIM.
- **Permission sets** become roles in each account they are assigned to.
- **Attributes for access control** pass user attributes as session tags, enabling ABAC.
- Short-lived credentials for the console and CLI; no IAM users or long-lived keys.

> ON THE EXAM
>
> Workforce access to many accounts with corporate identities: Identity Center, not IAM users per account.

Workloads without long-lived keys

WORKLOAD	KEYLESS WAY TO GET AWS CREDENTIALS
EC2 instance	Instance profile role
ECS task, Lambda function	Task role, execution role
EKS pod	EKS Pod Identity, or IAM roles for service accounts
GitHub Actions and other CI systems	OIDC federation to an IAM role
On-premises servers	IAM Roles Anywhere, with X.509 certificates

ON THE EXAM

Access keys stored in a CI system's secrets are the answer to replace. OIDC federation replaces them.

IAM Access Analyzer

CAPABILITY	ANSWERS
External access findings	Which resources are shared outside my zone of trust?
Unused access findings	Which roles, keys and permissions are never used?
Policy validation	Is this policy valid and following best practice?
Custom policy checks	Does this change grant new access, or public access?
Policy generation	What does this role actually use, from CloudTrail?

ON THE EXAM

Set the zone of trust to the organisation, run it from a delegated administrator, send findings to Security Hub.

Custom policy checks in a pipeline

- **check-no-new-access**: does the new policy grant anything the reference policy did not?
- **check-access-not-granted**: does it allow specific sensitive actions, such as iam:PassRole on everything?
- **check-no-public-access**: would a resource policy make the resource public?
- Run them in CodeBuild on IaC changes; a failing check fails the build.

> ON THE EXAM
>
> Block risky permission changes before deployment, automatically: custom policy checks in the pipeline.

Centralised root access management

- Since November 2024, root credentials can be **removed** from member accounts entirely.
- New member accounts can be created with no root credentials at all.
- Root-only tasks run as short **privileged root sessions** from the management or a delegated admin account.
- For example: unlocking an S3 bucket policy that denies everyone, or an SQS queue policy.

> ON THE EXAM
>
> No root passwords, MFA devices or keys to manage in member accounts, yet root tasks still possible: centralised root access.

> Developers deploy their own Lambda functions and must create an IAM execution role for each one. The central security team is a bottleneck for role requests.
>
> The company must let developers create roles without being able to grant themselves or their functions more permissions than an approved maximum.

What should the DevOps engineer implement?

A. Allow iam:CreateRole only with the approved permissions boundary attached, and deny removing or changing boundaries

B. Keep all role creation with the central security team

C. Give developers AdministratorAccess and an SCP that denies iam:*

D. Let developers create any role, and review IAM Access Analyzer findings weekly

◆ PAUSE AND DECIDE

What should the DevOps engineer implement?

A Boundary-enforced role creation

Developers self-serve, and no role they create can exceed the boundary.

B Central team keeps it

Keeps the bottleneck the company wants removed.

C Admin plus SCP denying IAM

Blocks all role creation, which developers need.

D Anything, reviewed weekly

Detects escalation a week after it happens. Not prevention.

THE SIGNAL

Delegate IAM safely: permissions boundaries enforced by condition, and protected from removal.

> A company lets a SaaS monitoring vendor read its CloudWatch data by assuming a role in the company's account. The vendor serves thousands of customers from one AWS account.
>
> The security team worries that another vendor customer could trick the vendor into reading this company's data.

What should the DevOps engineer add to the role's trust policy?

A Replace the role with an IAM user and access keys for the vendor

B A condition requiring the sts:ExternalId value the vendor assigned to this company

C A condition limiting access to the vendor's IP address range

D A condition requiring MFA

◆ PAUSE AND DECIDE

What should the DevOps engineer add to the role's trust policy?

A **IAM user and keys**

Long-lived credentials, a worse risk, and it does not address the deputy problem.

B **sts:ExternalId condition**

The vendor must present this company's ID, so another customer cannot redirect it here.

C **IP condition**

Every customer's requests come from the same vendor IPs. It cannot tell them apart.

D **MFA**

An automated vendor system cannot provide MFA, and it still would not tell customers apart.

THE SIGNAL

Third party, many customers, one vendor account: the confused deputy. The answer is an external ID.

> A company has 300 projects, each with developers and data engineers. All resources carry a project tag. Staff sign in through IAM Identity Center, and the directory records each person's project.
>
> Creating roles and policies for every project has become unmanageable. New projects start every week.

Which approach scales with the LEAST operational overhead?

A One permission set per project and job function

B One IAM group per project in every account

C Pass project as a session tag with attributes for access control, and use one permission set per job with aws:ResourceTag/project matching aws:PrincipalTag/project

D Resource-based policies naming each project's users on every resource

◆ PAUSE AND DECIDE

Which approach scales with the LEAST operational overhead?

A Permission set per project

600 permission sets, and more every week. The problem, repeated.

B Groups per project

Still per-project objects in every account.

C ABAC through Identity Center

Two permission sets total; new projects need only tags, not new policies.

D Resource policies per resource

Thousands of policies to keep in step with staff changes.

THE SIGNAL

Many projects, same jobs, tagged resources, attributes in the directory: ABAC, not more roles.

> A deployment pipeline's role has broad permissions granted years ago. The security team wants it reduced to only the actions the pipeline has actually used in the last 90 days.
>
> The team wants the least manual effort.

What should the DevOps engineer use?

A Read 90 days of CloudTrail logs by hand and write a new policy

B AWS Trusted Advisor security checks

C Remove permissions one at a time until the pipeline breaks

D IAM Access Analyzer policy generation from the role's CloudTrail activity

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A Read CloudTrail by hand

Accurate but enormously laborious. Policy generation does it for you.

B Trusted Advisor

Broad account checks. It does not build a least-privilege policy for a role.

C Remove until broken

Causes outages, and still leaves guesswork.

D Access Analyzer policy generation

Builds a policy from the role's actual CloudTrail activity, ready to review and apply.

THE SIGNAL

'Only what it actually used': policy generation from CloudTrail. Unused access findings help spot the excess.

> Teams submit CloudFormation changes that include IAM policies. The security team wants the pipeline to fail automatically if a change grants permissions beyond an approved reference policy, or makes any resource public.
>
> It wants this before deployment, with no manual review.

What should the DevOps engineer add to the pipeline?

A. A CodeBuild step running IAM Access Analyzer custom policy checks: check-no-new-access and check-no-public-access

B. A manual approval where the security team reads each policy

C. An AWS Config rule that evaluates IAM policies after deployment

D. Amazon GuardDuty in the target accounts

◆ PAUSE AND DECIDE

What should the DevOps engineer add to the pipeline?

A Custom policy checks in CodeBuild

Each check answers one requirement, automatically, before anything deploys.

B Manual approval

Ruled out: no manual review.

C Config after deployment

Too late: the permissions already exist.

D GuardDuty

Detects threats in running accounts. It does not review policy changes.

THE SIGNAL

Beyond a reference: check-no-new-access. Public: check-no-public-access. Both in the build, before deploy.

> An organisation has 120 member accounts, each with a root password and MFA device held in a safe. Auditors want no root credentials to exist in member accounts.
>
> The security team must still be able to perform root-only tasks, such as unlocking a bucket policy that denies everyone.

What should the DevOps engineer do?

A. Rotate every root password and move the MFA devices to a second safe

B. Enable centralised root access management, remove member root credentials, and use privileged root sessions when needed

C. Attach an SCP that denies all actions by the root user

D. Close the member accounts and recreate them

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Rotate and re-store

Credentials still exist, 120 times over.

B Centralised root access

Root credentials removed; root-only tasks done as short, scoped privileged sessions.

C SCP denying root

Credentials still exist, and root-only tasks become impossible.

D Recreate accounts

Enormous disruption, and new accounts would still need the same feature.

THE SIGNAL

No root credentials, yet root tasks still possible: centralised root access with privileged sessions.

Module 24 in five lines

- Policies grant or cap; an explicit deny wins. Cross-account needs both sides to allow.
- Trust says who; permissions say what. External IDs stop confused deputies.
- Boundaries make delegation safe; session tags and ABAC make permissions scale.
- Identity Center for people; roles, OIDC and Roles Anywhere for workloads. No long-lived keys.
- Access Analyzer: find, trim, and check in the pipeline. Remove member root credentials.

> ON THE EXAM
>
> Next, module 25: secrets, keys and certificates.

MODULE 25 · DOMAIN 6 - SECURITY AND COMPLIANCE

Secrets, Keys and Certificates

Secrets Manager and Parameter Store, rotation and sharing, KMS key policies, grants and multi-Region keys, CloudHSM, and ACM certificates.

DOMAIN 6 of 6 EXAM WEIGHT 17% MODULE 25 of 34

admin@sthithapragna.com

A secret should be **fetched at run time**, **rotated** without anyone ever seeing it, and protected by a **key whose policy you control**.

Secrets Manager or Parameter Store?

SECRETS MANAGER

Built for secrets

- Automatic rotation, managed or with Lambda
- Replication to other Regions
- Resource policies for cross-account access
- Charged per secret per month

PARAMETER STORE

Built for configuration

- SecureString values encrypted with KMS
- No built-in rotation
- Standard tier free; advanced tier adds policies and RAM sharing
- Can reference Secrets Manager secrets

THE TIEBREAKER

'Must rotate automatically' points to Secrets Manager. Plain configuration, or free and simple: Parameter Store.

How rotation works

01

Create

A new secret value is generated and staged as AWSPENDING.

02

Set

The database or service is updated with the new value.

03

Test

The new value is tried against the service.

04

Finish

AWSPENDING becomes AWSCURRENT; the old becomes AWSPREVIOUS.

ON THE EXAM

Managed rotation handles these steps for RDS, Aurora, Redshift and DocumentDB with no Lambda to maintain.

Rotation in practice

- Schedules use a rate or a cron expression, with a rotation window.
- Applications should fetch the secret, cache it briefly, and fetch again on authentication failure.
- A custom rotation Lambda in a VPC needs a path to both the database and Secrets Manager.
- Hard-coding a secret's value anywhere breaks the moment it rotates.

> ON THE EXAM
>
> Rotation fails with a timeout: the rotation function cannot reach Secrets Manager or the database.

Sharing secrets and parameters

- **Cross-account secret**: a resource policy on the secret, plus the caller's identity policy.
- The secret must use a **customer managed key** whose policy admits the other account.
- **Replicate** secrets to other Regions for disaster recovery and local reads.
- **Advanced-tier parameters** can be shared with other accounts through AWS RAM.

> ON THE EXAM
>
> Cross-account secret denied despite a correct resource policy: the secret uses the AWS managed key.

Three kinds of KMS key

KIND	WHO CONTROLS IT	CROSS-ACCOUNT?
AWS owned	AWS, invisibly, across many accounts	Not applicable
AWS managed (aws/s3, aws/rds...)	AWS; you see it but cannot change its policy	No
Customer managed	You: policy, rotation, deletion	Yes, through the key policy

ON THE EXAM

Anything cross-account, custom rotation, or auditable key control needs a customer managed key.

A key policy, in three parts

```
1 { "Sid": "EnableIAMPolicies", "Effect": "Allow",
2   "Principal": { "AWS": "arn:aws:iam::111122223333:root" },
3   "Action": "kms:*", "Resource": "*" },
4 { "Sid": "KeyAdministrators", "Effect": "Allow",
5   "Principal": { "AWS": "arn:aws:iam::111122223333:role/KeyAdmins" },
6   "Action": ["kms:Create*", "kms:Put*", "kms:ScheduleKeyDeletion"], "Resource": "*" },
7 { "Sid": "KeyUsers", "Effect": "Allow",
8   "Principal": { "AWS": "arn:aws:iam::444455556666:role/Reader" },
9   "Action": ["kms:Decrypt", "kms:DescribeKey"], "Resource": "*" }
```

2 Lets IAM policies in this account grant use of the key.

8 A role in another account may decrypt.

ON THE EXAM

Without the first statement, IAM policies alone can never grant use of the key: the key policy is primary.

Grants

- A **grant** gives a principal permission to use a key, without editing the key policy.
- Grants are created and retired or revoked programmatically, for temporary delegation.
- AWS services such as EBS and RDS use grants to act on your keys for you.
- The condition kms:GrantIsForAWSResource limits grant creation to AWS services.

> ON THE EXAM
>
> Temporary, programmatic, revocable use of a key for a specific principal: a grant, not repeated policy edits.

Rotation and multi-Region keys

- Automatic rotation creates new key material; old material is kept, so old data still decrypts.
- The rotation period is configurable, and rotation can also be done on demand.
- **Multi-Region keys** share key material and ID across Regions: encrypt in one, decrypt in another.
- Keys with imported key material do not rotate automatically. Deleting a key waits 7 to 30 days.

> ON THE EXAM
>
> Data encrypted in one Region must be decrypted in another without re-encrypting: multi-Region keys.

Narrowing key use with conditions

- **kms:ViaService**: the key may only be used through a named service, such as S3 or Secrets Manager.
- **Encryption context**: extra key-value data that must match to decrypt, and appears in CloudTrail.
- **kms:CallerAccount**: limit use to principals from specific accounts.
- Disable a key rather than delete it if you might ever need the data again.

> ON THE EXAM
>
> Allow decryption only when data is read through S3, never directly: kms:ViaService.

CloudHSM and custom key stores

- **CloudHSM**: single-tenant hardware security modules in your VPC; you manage the HSM users.
- For compliance that demands dedicated HSMs, or keys under your exclusive control.
- A **KMS custom key store** backed by CloudHSM keeps KMS integrations with your own HSMs.
- An **external key store** keeps key material outside AWS entirely.

> ON THE EXAM
>
> Dedicated, single-tenant HSMs you control, but still using KMS integrations: a CloudHSM-backed custom key store.

AWS Certificate Manager

- Free public certificates for integrated services: load balancers, CloudFront, API Gateway.
- Renewed automatically; DNS validation lets renewal happen with no human involved.
- Certificates are Regional. **CloudFront needs its certificate in us-east-1**.
- Since February 2026, new certificates last at most **198 days**, and renew 45 days before expiry.

> ON THE EXAM
>
> Imported certificates are not renewed by ACM. Watch their expiry with EventBridge events or a Config rule.

Certificates outside AWS, and private certificates

- **Exportable public certificates** (June 2025) can be exported with their private key, for use anywhere.
- ACM still renews them; an EventBridge event on renewal can trigger redeployment.
- **AWS Private CA** issues private certificates for internal services and devices.
- Certificates issued before 17 June 2025 cannot be exported.

> ON THE EXAM
>
> Public certificate for on-premises servers, renewed automatically by ACM: exportable certificates plus renewal automation.

> An application connects to an Amazon RDS for MySQL database with a password stored in a configuration file. Auditors require the password to rotate every 30 days automatically.
>
> The team wants the least operational overhead, and no rotation code to maintain.

What should the DevOps engineer do?

A Store the password as a Parameter Store SecureString, and write a Lambda function to rotate it

B Have a DBA change the password monthly and update the file

C Store the password in Secrets Manager with managed rotation on a 30-day schedule, and have the app fetch it at run time

D Encrypt the configuration file with a customer managed KMS key

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A **Parameter Store and a Lambda**

Works, but it is exactly the rotation code the team does not want to maintain.

B **Monthly by hand**

Not automatic, and a person sees the password.

C **Secrets Manager managed rotation**

Rotates on schedule with no code; the app always fetches the current value.

D **Encrypt the file**

Protects the file. The password still never rotates.

THE SIGNAL

Automatic rotation, no code, RDS: Secrets Manager managed rotation.

> A Lambda function in account B must read a secret in account A. The secret's resource policy allows the function's role, and the role's identity policy allows secretsmanager:GetSecretValue.
>
> Calls still fail with access denied. The secret is encrypted with the default aws/secretsmanager key.

What should the DevOps engineer do?

A. Add another statement to the function role's identity policy

B. Share the secret through AWS RAM

C. Make the secret's resource policy allow all principals

D. Re-encrypt the secret with a customer managed key whose policy allows the role to decrypt, and grant kms:Decrypt to the role

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A More identity policy

The identity side already allows it. The key is refusing.

B RAM sharing

Secrets are shared by resource policy, not RAM, and the key still refuses.

C Allow everyone

Dangerous, and still blocked by the key.

D Customer managed key

The AWS managed key cannot admit another account. A customer managed key can.

THE SIGNAL

Two locks confirmed open, a default key named: the third lock, the key, is the problem.

> A batch system launches jobs that each need to decrypt data with a customer managed KMS key, using a job-specific role. Permission must exist only while the job runs.
>
> The security team does not want the key policy edited for every job.

What should the DevOps engineer use?

A. Edit the key policy to add and remove each job's role

B. Add kms:Decrypt to every job role's identity policy permanently

C. Create a KMS grant for the job's role when the job starts, and retire it when the job finishes

D. Create a new KMS key for every job

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A Edit the key policy

Ruled out, and risky to edit constantly.

B Permanent permission

Fails 'only while the job runs'.

C Grant, then retire

Programmatic, temporary delegation with no key policy edits: what grants are for.

D A key per job

Data is encrypted under one key. New keys cannot decrypt it.

THE SIGNAL

Temporary, programmatic, revocable key use: grants.

> Application data is encrypted client-side with a KMS key in us-east-1 and replicated to us-west-2 for disaster recovery.
>
> During a failover test, the application in us-west-2 cannot decrypt the replicated data, because the key exists only in us-east-1. The company wants to decrypt locally in either Region, without re-encrypting data.

What should the DevOps engineer use?

A Copy the key to us-west-2

B Create a new key in us-west-2 with the same alias

C A grant that lets us-west-2 principals use the us-east-1 key

D A multi-Region primary key in us-east-1 with a replica key in us-west-2

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A **Copy the key**
Standard KMS keys cannot be copied or exported.

B **Same alias**
A different key underneath. It cannot decrypt the data.

C **Cross-Region grant**
Calls would still go to us-east-1, which fails in a Regional outage.

D **Multi-Region keys**
Same key material and ID in both Regions: decrypt locally, no re-encryption.

THE SIGNAL

Decrypt the same ciphertext in another Region, locally: multi-Region keys.

> A team requests an ACM certificate for www.example.com in eu-west-2, where its application runs, and validates it by DNS.
>
> When configuring a CloudFront distribution in front of the application, the certificate does not appear in the list of choices.

What should the team do?

A. Request a certificate for the domain in us-east-1, and select it in CloudFront

B. Export the eu-west-2 certificate and upload it to CloudFront

C. Switch the certificate from DNS validation to email validation

D. Wait for the certificate to finish propagating to all Regions

◆ PAUSE AND DECIDE

What should the team do?

A Request it in us-east-1

CloudFront only uses ACM certificates from us-east-1.

B Export and upload

Unnecessary effort, and loses ACM's automatic renewal for CloudFront.

C Email validation

Validation method is not the issue, and DNS is the better choice anyway.

D Wait to propagate

ACM certificates are Regional. They never propagate.

THE SIGNAL

CloudFront certificate missing: it is in the wrong Region. CloudFront wants us-east-1.

> A company runs several public-facing web servers on premises. Their TLS certificates, bought from a third party, are renewed by hand and expired twice last year.
>
> The company wants publicly trusted certificates for those servers that renew automatically, with the fewest moving parts.

What should the DevOps engineer do?

A. Issue certificates from AWS Private CA

B. Use ACM exportable public certificates, with an EventBridge rule on renewal that redeploys them through Systems Manager

C. Generate self-signed certificates with a long validity

D. Import the third-party certificates into ACM so that ACM renews them

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Private CA

Private certificates are not trusted by the public's browsers.

B Exportable certificates with renewal automation

Publicly trusted, renewed by ACM, redeployed automatically on each renewal.

C Self-signed

Browsers do not trust them.

D Import into ACM

ACM never renews imported certificates.

THE SIGNAL

Public trust, on premises, automatic renewal: exportable certificates, plus automation on the renewal event.

Module 25 in five lines

- Fetch at run time, rotate without anyone seeing, protect with a key you control.
- Rotation needed: Secrets Manager, managed for RDS. Plain config: Parameter Store.
- Cross-account secrets and data need customer managed keys; AWS managed keys cannot be shared.
- Grants for temporary key use; multi-Region keys for decrypting in another Region.
- ACM: CloudFront needs us-east-1; 198-day certificates; imported ones never auto-renew; exportable since June 2025.

> ON THE EXAM
>
> Next, module 26: network defence in depth.

MODULE 26 · DOMAIN 6 - SECURITY AND COMPLIANCE

Network Defence in Depth

Security groups and network ACLs, WAF and Shield, Network Firewall and DNS Firewall, VPC endpoints, protecting origins, and Firewall Manager across an organisation.

DOMAIN 6 of 6 EXAM WEIGHT 17% MODULE 26 of 34

admin@sthithapragna.com

Defence in depth means every layer assumes the layer **outside it** has already failed.

The layers, from outside in

LAYER	CONTROLS
Edge	CloudFront, Shield, AWS WAF
Application entry	Load balancer or API Gateway, with AWS WAF
VPC perimeter	AWS Network Firewall; Route 53 Resolver DNS Firewall
Subnet	Network ACLs
Instance or task	Security groups
Private paths to AWS	VPC endpoints and their policies

ON THE EXAM

Match the attack to the layer that understands it: HTTP attacks to WAF, domains to Network or DNS Firewall, ports to groups.

Security group or network ACL?

SECURITY GROUP

Stateful, per interface

- Allow rules only
- Return traffic allowed automatically
- Can reference other security groups
- The main, everyday control

NETWORK ACL

Stateless, per subnet

- Allow and deny rules, numbered in order
- Return traffic needs its own rule
- Ephemeral ports must be allowed back out
- A coarse extra layer, or to deny an address

THE TIEBREAKER

Inbound works but responses fail: a stateless network ACL is missing its ephemeral-port rule.

Security groups, used well

- Reference **other security groups** rather than IP ranges: the database allows the app tier's group.
- Use **managed prefix lists** for sets of addresses, such as CloudFront's origin-facing list.
- Security group references now work across VPC peering and Transit Gateway.
- 0.0.0.0/0 on SSH or RDP is the finding every scanner and Config rule looks for.

> ON THE EXAM
>
> Instances scale in and out, so rules based on groups keep working while rules based on IPs go stale.

AWS WAF

- A **web ACL** protects CloudFront, ALB, API Gateway, AppSync, Cognito and more.
- **AWS managed rule groups** cover common exploits, SQL injection, known bad inputs and bad IPs.
- **Rate-based rules** throttle floods; **Bot Control** manages scrapers and bots.
- Start new rules in **count** mode, read the logs, then switch to block.

> ON THE EXAM
>
> SQL injection, scraping, request floods on an HTTP application: AWS WAF with managed rules and rate limits.

Shield Standard or Shield Advanced?

SHIELD ADVANCED

Paid, with a team behind it

- Access to the Shield Response Team
- Cost protection for attack-driven scaling
- Health-based detection and faster response
- Automatic application-layer mitigation with WAF

SHIELD STANDARD

Free, always on

- Network and transport layer protection
- Every AWS customer, automatically
- No configuration
- No response team, no cost protection

THE TIEBREAKER

Expert help during attacks, or protection from the bill an attack causes: Shield Advanced.

Network Firewall or DNS Firewall?

AWS NETWORK FIREWALL

Inspects the traffic itself

- Stateful and stateless rules; Suricata syntax
- Domain allow-lists by TLS server name
- Optional TLS inspection
- Needs routing through firewall subnets

ROUTE 53 RESOLVER DNS FIREWALL

Filters name lookups

- Blocks or allows domain resolution
- Managed lists of malicious domains
- No routing changes
- Bypassed by connecting to an IP directly

THE TIEBREAKER

Restrict outbound traffic to approved domains, robustly: Network Firewall. Block known-bad domains cheaply: DNS Firewall.

Gateway or interface endpoint?

GATEWAY ENDPOINT

S3 and DynamoDB only

- A route in the route table
- No hourly or data charge
- Same Region only
- Controlled with an endpoint policy

INTERFACE ENDPOINT

Most other services

- A network interface with private IPs
- Charged per hour and per GB
- Reachable from on-premises and peered networks
- Security groups plus an endpoint policy

THE TIEBREAKER

Private S3 access at the lowest cost: a gateway endpoint. Private access to Secrets Manager or ECR: interface endpoints.

A bucket that only answers through the endpoint

```
{ "Sid": "OnlyThroughOurEndpoint",
  "Effect": "Deny",
  "Principal": "*",
  "Action": "s3:*",
  "Resource": ["arn:aws:s3:::payroll-data", "arn:aws:s3:::payroll-data/*"],
  "Condition": {
    "StringNotEquals": { "aws:SourceVpce": "vpce-0a1b2c3d4e5f60718" } } }
```

2 An explicit deny, so no other allow can override it.

7 Any request not arriving through this endpoint is refused.

ON THE EXAM

The endpoint policy limits what goes out; the bucket policy limits what comes in. Use both for a tight perimeter.

Protecting origins from being bypassed

- S3 origins: **origin access control**, so the bucket only answers CloudFront.
- ALB, NLB or EC2 origins: **CloudFront VPC origins** (November 2024) keep them in private subnets.
- Older pattern: a public load balancer that checks a secret custom header, plus the CloudFront prefix list.
- A public origin can always be reached directly, around your edge WAF, unless something stops it.

ON THE EXAM

Attackers bypass CloudFront by calling the load balancer directly: make it a VPC origin, with no public endpoint at all.

Stopping exposure before it happens

- **VPC Block Public Access** (November 2024) blocks internet gateway traffic for VPCs and subnets, with exclusions.
- Enforced across an organisation through a **declarative policy**, as in module 12.
- S3 Block Public Access and EBS snapshot block public access do the same for storage.
- **Reachability Analyzer** explains why one resource can or cannot reach another.

> ON THE EXAM
>
> 'Why can't this instance reach that database?': Reachability Analyzer traces the path and names the blocker.

AWS Firewall Manager

- Applies firewall policies across every account in an organisation, from a delegated administrator.
- Covers WAF, Shield Advanced, security groups, Network Firewall and DNS Firewall.
- New accounts and new resources receive the policy automatically; non-compliant ones can be remediated.
- WAF policies can run first and last rule groups, leaving room for each team's own rules.

ON THE EXAM

The same baseline WAF rules on every load balancer in every account, including future ones: Firewall Manager.

> A web application uses CloudFront with AWS WAF in front of an internet-facing Application Load Balancer. Security finds attackers sending requests straight to the load balancer's DNS name, bypassing WAF.
>
> The company wants the strongest fix with the least ongoing operational effort.

What should the DevOps engineer do?

A. Add a secret custom header in CloudFront, check it on the load balancer, and rotate it regularly

B. Restrict the load balancer's security group to the CloudFront managed prefix list

C. Attach a second copy of the WAF web ACL to the load balancer

D. Move the load balancer to private subnets and make it a CloudFront VPC origin

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Secret header

Works, but the secret needs rotating, and the load balancer stays public.

B Prefix list only

Any CloudFront distribution, including an attacker's, can still reach it.

C Second WAF

Double cost and rules; the direct path still exists.

D VPC origin

No public endpoint remains to bypass; CloudFront is the only way in.

THE SIGNAL

Bypass around the edge: remove the path. VPC origins make the load balancer unreachable except through CloudFront.

> A public API behind an Application Load Balancer faces SQL injection attempts, aggressive scraping by bots, and bursts of requests from single addresses.
>
> The team wants protection with the least operational overhead and no custom rule writing.

What should the DevOps engineer deploy?

A. An AWS WAF web ACL on the load balancer with AWS managed rule groups, Bot Control, and a rate-based rule

B. Network ACL deny rules for each attacking address

C. Tighter security group rules on the load balancer

D. AWS Network Firewall in front of the load balancer

◆ PAUSE AND DECIDE

What should the DevOps engineer deploy?

A WAF with managed rules

Managed rules catch injection, Bot Control handles scrapers, and a rate rule throttles bursts.

B NACL denies

Endless manual address lists, a small rule limit, and blind to request contents.

C Security groups

Allow-only, by port and address. They cannot see SQL in a request.

D Network Firewall

A network-layer inspector. HTTP attacks belong to WAF.

THE SIGNAL

Attacks inside HTTP requests: WAF. Every other option works below the layer where the attack lives.

> Build servers in private subnets must only reach a short list of approved domains over HTTPS, such as a package registry and a code host. All other outbound traffic must be blocked, even to raw IP addresses.
>
> The team wants a managed solution.

What should the DevOps engineer use?

A Network ACL outbound rules

B AWS Network Firewall with a stateful domain allow-list, with the subnets routed through it

C Security group outbound rules

D Route 53 Resolver DNS Firewall alone

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A Network ACLs

Addresses and ports only. They cannot match domain names.

B Network Firewall domain allow-list

Matches the TLS server name and drops everything else, including raw IPs.

C Security groups

Addresses and ports only, and addresses behind domains change constantly.

D DNS Firewall alone

Blocks name lookups, but a connection to a raw IP skips DNS entirely.

THE SIGNAL

Egress by domain, robust to direct IPs: Network Firewall. The phrase 'even to raw IP addresses' rules out DNS Firewall.

> A company has 100 accounts in AWS Organizations. Every Application Load Balancer and CloudFront distribution must have a baseline set of WAF rules, including in accounts created later.
>
> Application teams must still be able to add their own WAF rules.

Which solution meets these requirements with the LEAST operational overhead?

A. A StackSet that deploys a web ACL to every account

B. An AWS Config rule that reports load balancers without WAF

C. An AWS Firewall Manager WAF policy from a delegated administrator, with baseline rule groups first and room for team rules

D. An SCP that denies creating load balancers without WAF

◆ PAUSE AND DECIDE

Which solution meets these requirements with the LEAST operational overhead?

A StackSet web ACLs

Creates web ACLs, but does not associate them with every new resource.

B Config rule

Reports the gap. Fixes nothing.

C Firewall Manager

Applies baseline rules to every resource in every account, new ones included, leaving room for team rules.

D SCP

Cannot see whether a load balancer will have WAF attached.

THE SIGNAL

Firewall rules everywhere, including future accounts and resources, with team rules allowed: Firewall Manager.

> Instances in private subnets upload large volumes of data to an S3 bucket through a NAT gateway, and the NAT data charges are high. The bucket must also refuse any request that does not come from this VPC.
>
> The company wants the lowest cost.

What should the DevOps engineer do?

A. Add an S3 gateway endpoint, and a bucket policy denying requests not from that endpoint

B. Add a second NAT gateway

C. Add an S3 interface endpoint, and a bucket policy denying requests not from that endpoint

D. Make the bucket public, with a condition on the NAT gateway's IP address

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Gateway endpoint and bucket policy

No charge for the endpoint or its data, and the policy locks the bucket to it.

B Second NAT gateway

Doubles the charges.

C Interface endpoint

Works and is private, but charges per hour and per GB. Not lowest cost.

D Public bucket

Never. Public exposure for a private workload.

THE SIGNAL

Private S3 or DynamoDB access at the lowest cost: a gateway endpoint. Interface endpoints cost money.

> A team adds an inbound network ACL rule allowing HTTPS on port 443 to a public subnet's web servers. Security groups allow 443 in. Requests reach the servers, but clients never receive responses.
>
> The network ACL's outbound rules allow only port 443.

What should the DevOps engineer change?

A. Add an outbound rule to the instances' security group

B. Add an outbound network ACL rule allowing ephemeral ports 1024-65535 to clients

C. Allow all traffic in both directions in the network ACL

D. Add a route to the internet gateway

◆ PAUSE AND DECIDE

What should the DevOps engineer change?

A **Security group outbound**

Security groups are stateful: responses are already allowed.

B **Ephemeral ports outbound**

Responses go to the client's ephemeral port, which the stateless ACL must allow.

C **Allow everything**

Works by removing the control.

D **Route to the gateway**

Requests already arrive, so the route exists.

THE SIGNAL

Requests arrive, responses vanish, a network ACL is involved: stateless rules need the ephemeral return path.

Module 26 in five lines

- Every layer assumes the outer one failed. Put each attack at the layer that understands it.
- Security groups are stateful and reference groups; network ACLs are stateless and can deny.
- WAF for HTTP attacks; Shield Advanced for DDoS help; Network Firewall for egress by domain.
- Gateway endpoints for cheap private S3 and DynamoDB; aws:SourceVpce locks buckets to them.
- VPC origins remove bypass paths; Firewall Manager applies it all across the organisation.

> ON THE EXAM
>
> Next, module 27: detection and posture at scale. GuardDuty, Security Hub, Inspector, Macie and Detective.

MODULE 27 · DOMAIN 6 - SECURITY AND COMPLIANCE

Detection and Posture at Scale

GuardDuty and Extended Threat Detection, Security Hub CSPM and the new Security Hub, Inspector, Macie, Detective, and organisation-wide CloudTrail.

DOMAIN 6 of 6 EXAM WEIGHT 17% MODULE 27 of 34

admin@sthithapragna.com

Each service has one **verb**. GuardDuty **detects**, Inspector **scans**, Macie **discovers**, Security Hub **aggregates**, Detective **explains**.

One verb each

SERVICE	VERB	LOOKS AT
GuardDuty	Detects threats	CloudTrail, VPC flows, DNS, plus protection plans
Inspector	Scans for vulnerabilities	EC2, ECR images, Lambda, code repositories
Macie	Discovers sensitive data	The contents of S3 objects
Security Hub CSPM	Scores posture, aggregates findings	Controls against standards, via Config
Detective	Explains incidents	A behaviour graph of activity over time
CloudTrail	Records API activity	Every account, every Region

ON THE EXAM

Most of these are Regional, and all support a delegated administrator for the whole organisation.

Amazon GuardDuty

- Foundational sources: CloudTrail management events, VPC Flow Logs and DNS logs, read **independently**.
- You do not need to enable or pay for those logs yourself for GuardDuty to use them.
- Protection plans: S3, EKS, Runtime Monitoring, Malware Protection for EC2 and S3, RDS, Lambda.
- Enable organisation-wide from a **delegated administrator**, with auto-enable for new accounts, in every Region.

> ON THE EXAM
>
> Findings go to EventBridge automatically, so every GuardDuty finding can trigger module 21's responses.

Extended Threat Detection

- GA December 2024: correlates many signals into one **attack sequence** finding, at critical severity.
- Maps to MITRE ATT&CK tactics; covers credential compromise, S3 data compromise, EKS compromise.
- Since May 2026, indicators also come from Inspector, Macie and Security Hub CSPM, if enabled.
- Automatically on, at no extra cost.

> ON THE EXAM
>
> Many related findings, but no single incident view: Extended Threat Detection's attack sequences.

Tuning GuardDuty

- **Suppression rules** archive expected findings automatically, such as a known scanner.
- **Trusted IP lists** and **threat lists** tell GuardDuty which addresses to trust or flag.
- Severity is low, medium, high or critical; route by severity with EventBridge patterns.
- Suppressing findings hides them. Fix the cause where you can.

> ON THE EXAM
>
> A known vulnerability scanner keeps generating findings: a suppression rule, not disabling GuardDuty.

Security Hub CSPM, or the new Security Hub?

SECURITY HUB (NEW, DECEMBER 2025)

Correlates and prioritises

- Correlates GuardDuty, Inspector, Macie and CSPM signals
- Exposure findings and attack paths
- Prioritised, unified security operations
- Includes CSPM as one component

SECURITY HUB CSPM

What 'Security Hub' used to mean

- Standards: FSBP, CIS, PCI DSS, NIST
- Controls evaluated through AWS Config
- Security score and aggregated findings
- What the exam guide means by 'Security Hub'

THE RULE

The exam guide says 'Security Hub'. Answer with the CSPM behaviour: standards, controls, Config, aggregation.

Security Hub CSPM in practice

- Controls depend on **AWS Config** recording in every account and Region. No recorder, no score.
- **Central configuration** from a delegated administrator sets standards and controls organisation-wide.
- A **cross-Region aggregator** brings every Region's findings into one.
- **Automation rules** update findings; **custom actions** send chosen findings to EventBridge.

> ON THE EXAM
>
> Controls show no data in some accounts or Regions: AWS Config is not recording there.

Amazon Inspector

- Scans EC2 instances, ECR images and Lambda functions for software vulnerabilities and network reachability.
- **Rescans automatically** when a new vulnerability is published, not just at deployment.
- Code security (June 2025) scans repositories; findings flow to Security Hub and EventBridge.
- **Inspector Classic** reached end of support in May 2026.

> ON THE EXAM
>
> Continuous vulnerability scanning of instances, images and functions across the organisation: Inspector.

Amazon Macie

- Discovers sensitive data, such as personal data and credentials, inside S3 objects.
- **Automated sensitive data discovery** samples buckets continuously, at low cost, across the organisation.
- Targeted **discovery jobs** scan chosen buckets in depth, with managed and custom data identifiers.
- Also reports bucket security, such as public or unencrypted buckets.

> ON THE EXAM
>
> Which buckets across 200 accounts contain personal data: Macie automated discovery from a delegated administrator.

Macie or GuardDuty S3 Protection?

MACIE

What is in the objects

- Reads object contents
- Finds personal data and secrets
- Answers: where is our sensitive data?
- Posture and compliance

GUARDDUTY S3 PROTECTION

How the objects are accessed

- Watches access behaviour
- Finds unusual reads, exfiltration, disabled logging
- Answers: is someone attacking our data?
- Threat detection

THE TIEBREAKER

Neither answers the other's question. Contents: Macie. Behaviour: GuardDuty.

Amazon Detective

- Builds a **behaviour graph** from CloudTrail, VPC flows, GuardDuty findings and EKS audit logs.
- Shows what a principal, instance or IP did over time, compared with its normal baseline.
- **Finding groups** gather related findings; investigations summarise risky behaviour.
- Detective explains an incident. It does not produce the original finding.

> ON THE EXAM
>
> 'What else did this compromised role touch over the past month?': Detective, not hand-written Athena queries.

CloudTrail across an organisation

- An **organisation trail** logs every account and Region to one bucket in the log archive account.
- **Log file validation** produces digest files that prove logs were not altered.
- Protect the bucket with Object Lock and a KMS key; limit who can read it.
- **CloudTrail Insights** flags unusual API call rates or error rates.

> ON THE EXAM
>
> Prove audit logs were not tampered with: log file validation, plus an immutable, separate log archive bucket.

From finding to response

01
Detect
GuardDuty, Inspector, Macie, CSPM controls.

02
Aggregate
Security Hub gathers every finding.

03
Route
EventBridge rules by type and severity.

04
Respond
Runbooks, workflows, notifications.

05
Investigate
Detective for what happened and how far.

ON THE EXAM

Detection without a routed response is a dashboard nobody reads. Every finding type should have a destination.

> A company with 150 accounts in AWS Organizations wants GuardDuty running in every account and every Region, including accounts created in future.
>
> The security team works in a dedicated security tooling account and wants the least operational overhead.

What should the DevOps engineer do?

A. Enable GuardDuty by hand in each account and Region

B. A StackSet that enables GuardDuty in every account

C. Make the security tooling account GuardDuty's delegated administrator, and turn on auto-enable for all accounts, in each Region

D. An AWS Config rule that reports accounts without GuardDuty

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A **By hand**

Thousands of account-Region pairs, and new accounts are missed.

B **StackSet**

Possible, but reinvents the service's own organisation feature, with member linkage to manage.

C **Delegated admin with auto-enable**

Every existing and future account enrolled, findings central, managed from the tooling account.

D **Config rule**

Reports the gap. Enables nothing.

THE SIGNAL

Organisation-wide security service, future accounts included: delegated administrator plus auto-enable, per Region.

> Over a day, a security team receives dozens of GuardDuty findings: unusual API calls from a role, then S3 reads from a new location, then disabled bucket logging.
>
> Analysts treat them separately and miss that they form one attack. The team wants a single, prioritised finding that ties them together.

What provides this?

A. Aggregating the findings in Security Hub CSPM

B. Amazon Detective finding groups, reviewed by hand

C. A CloudWatch composite alarm over the finding counts

D. GuardDuty Extended Threat Detection attack sequence findings, with S3 Protection enabled

◆ PAUSE AND DECIDE

What provides this?

A CSPM aggregation

Puts the findings in one place. Still dozens of separate findings.

B Detective by hand

Helps investigate once someone suspects, but it is not the automatic single finding.

C Composite alarm

Counts findings. Knows nothing about how they relate.

D Attack sequences

Correlates the signals into one critical finding, mapped to attack tactics.

THE SIGNAL

Aggregating is not correlating. One finding for one attack: Extended Threat Detection.

> Security Hub CSPM is enabled across the organisation with the AWS Foundational Security Best Practices standard. In accounts recently added in eu-central-1, controls show no data and no security score.
>
> GuardDuty works normally in those accounts.

What is the most likely cause?

A GuardDuty is not sending findings to Security Hub

B Macie is not enabled in those accounts

C AWS Config is not recording in those accounts and that Region

D Inspector is not enabled in those accounts

◆ PAUSE AND DECIDE

What is the most likely cause?

A **GuardDuty integration**

GuardDuty findings are separate from control evaluations. Controls need Config.

B **Macie**

Not required for controls to evaluate.

C **Config not recording**

CSPM controls evaluate through Config. No recorder there means no data and no score.

D **Inspector**

Not required for controls to evaluate.

THE SIGNAL

CSPM controls with no data: AWS Config is missing in that account and Region.

> A company runs EC2 instances, container images in ECR, and Lambda functions across 60 accounts. It must know about vulnerable software in all of them, including when a new vulnerability is published for software already deployed.
>
> The company wants the least operational overhead.

What should the DevOps engineer enable?

A ECR basic scanning on every repository

B A third-party scanner run weekly from a pipeline

C Amazon Inspector Classic in each account

D Amazon Inspector for EC2, ECR and Lambda, organisation-wide from a delegated administrator

◆ PAUSE AND DECIDE

What should the DevOps engineer enable?

A ECR basic scanning

Images only, OS packages only, and no continuous rescanning.

B Weekly third-party scan

Up to a week late, and a pipeline to maintain.

C Inspector Classic

End of support in May 2026, and it never covered images or functions.

D Amazon Inspector, organisation-wide

All three resource types, rescanned automatically on new vulnerabilities, centrally.

THE SIGNAL

Instances, images and functions, rescanned on new CVEs, org-wide: Inspector from a delegated administrator.

> A company has thousands of S3 buckets across 200 accounts. A regulator asks which buckets contain personal data, and requires this to be kept up to date continuously.
>
> The company wants the lowest cost and least operational overhead.

What should the DevOps engineer use?

A. Amazon Macie automated sensitive data discovery, organisation-wide from a delegated administrator

B. GuardDuty S3 Protection in every account

C. Athena queries over every bucket's contents

D. Amazon Inspector in every account

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A Macie automated discovery

Samples every bucket continuously, cheaply, and maps where personal data lives.

B GuardDuty S3 Protection

Watches access behaviour. It never reads object contents.

C Athena over everything

Only works on structured data, and scanning everything is costly and custom.

D Inspector

Scans software vulnerabilities, not data.

THE SIGNAL

Where is our personal data: Macie. Automated discovery keeps it continuous and cheap.

> GuardDuty reports that credentials for a CI role were used from an unusual location. The team must find out what else that role did over the past three weeks, and which resources it touched.
>
> It wants a visual answer quickly, without writing queries.

What should the team use?

A Athena queries over the organisation trail

B Amazon Detective, from the GuardDuty finding

C Security Hub CSPM's findings list

D CloudTrail event history in the console, Region by Region

◆ PAUSE AND DECIDE

What should the team use?

A **Athena queries**

Can answer it, but only by writing queries, which the team wants to avoid.

B **Detective**

Opens from the finding into a behaviour graph of what the role did and touched, over time.

C **CSPM findings**

Lists findings. Does not reconstruct a principal's activity.

D **Event history by Region**

Slow, one Region at a time, and no picture of the whole.

THE SIGNAL

Explain what a compromised principal did, visually, without queries: Detective.

Module 27, and the teaching content, in five lines

- GuardDuty detects, Inspector scans, Macie discovers, Security Hub aggregates, Detective explains.
- Delegated administrator plus auto-enable, in every Region, covers future accounts.
- Extended Threat Detection correlates; aggregation alone does not.
- 'Security Hub' in the guide means CSPM behaviour, which needs AWS Config everywhere.
- Contents: Macie. Behaviour: GuardDuty. Retired: Inspector Classic.

> ON THE EXAM
>
> Domain 6 and all teaching modules complete. Next, module 28: confusion pairs.

MODULE 28 · EXAM STRATEGY - ALL DOMAINS

Confusion Pairs

The services and features the exam sets against each other, sorted by the one question that separates each pair.

DOMAIN All six EXAM WEIGHT 100% MODULE 28 of 34

admin@sthithapragna.com

Every confusion pair differs along **one axis**. Find the axis, ask the question, and the pair splits.

admin@sthithapragna.com

Axis 1: before, or after?

PAIR	BEFORE	AFTER
Hook / Config rule	Hook blocks the stack	Rule reports the resource
Proactive / detective control	Stops creation	Finds non-compliance
Deployment / stage rollback	During the traffic shift	When the stage completes
Change set / drift detection	Previews your change	Finds someone else's
Policy check / Access Analyzer	In the pipeline	In the running account

ON THE EXAM

'Ensure' and 'prevent' want the left column. 'Identify' and 'report' want the right.

Axis 2: who, or what, is acting?

PAIR	FIRST	SECOND
SCP / RCP	Your principals	Resources, against outsiders
Execution / task role	ECS, before code runs	Your application
Action / CFN execution role	Starts the operation	Creates the resources
Instance profile / service role	Agent fetches the bundle	CodeDeploy manages ASG, ELB
ExternalId / aws:SourceArn	A third-party vendor	An AWS service

ON THE EXAM

Access denied: name who is actually making the call before touching any policy.

Axis 3: what kind of problem?

PAIR	FIRST	SECOND
Macie / GuardDuty S3 Protection	What is in the objects	How they are accessed
GuardDuty / Inspector	Active threats	Vulnerable software
CloudWatch investigations / Detective	Operational root cause	Security incident scope
Config / CloudTrail	What the resource looked like	Who called which API
Security Hub CSPM / new Security Hub	Posture against standards	Correlated exposure

ON THE EXAM

Read the noun in the requirement: data, threat, vulnerability, outage, configuration, or caller.

Axis 4: copy it, or look at it?

PAIR	COPY	LOOK
Log centralisation / cross-account observability	Retained copy, cross-Region	View in place, same Region
ECR replication / pull through cache	Every push, everywhere	Only what is pulled
Conformance pack / aggregator	Deploys the rules	Sees the results
Backup copy / restore testing	Protects the data	Proves the data restores
Organisation trail / Detective	Records everything	Explains one principal

ON THE EXAM

'Retain for years' means copy. 'Operators need to see' means look.

Axis 5: once, continuously, or on a schedule?

PAIR	FIRST	SECOND
Run Command / State Manager	Once, now	Continuously, including new nodes
Export task / subscription filter	Batch	Real time
ECR basic / enhanced scanning	On push	Continuous rescans
Scheduled rule / Scheduler	UTC cron, recurring	Time zones, one-off runs
Config continuous / periodic recording	Every change	Once a day, cheaper

ON THE EXAM

'Including new instances' and 'as new vulnerabilities appear' both mean continuous.

Axis 6: how much is already running?

PAIR	LESS RUNNING	MORE RUNNING
Pilot light / warm standby	Data live, compute off	Small working copy
Multi-AZ standby / read replica	Failover only, not readable	Serves reads, manual promote
Zonal shift / Region failover	One bad zone	A whole Region lost
Predictive scaling / warm pool	Launches ahead of a pattern	Pre-initialised, for slow starts
Reserved / provisioned concurrency	A guaranteed share	Pre-warmed environments

ON THE EXAM

Tight recovery or start-up times need more already running. Pay only for what the requirement demands.

Axis 7: where does the failure land?

PAIR	FIRST	SECOND
Target DLQ / archive and replay	Could not be delivered	Delivered, then mishandled
DLQ / on-failure destination	The event alone	The event plus the error
Circuit breaker / deployment alarms	Tasks that will not run	Tasks that run badly
notBreaching / breaching	Silence is good	Silence is bad
Retry / rollback	Same code, transient fault	Bad code, go back

ON THE EXAM

Ask what actually went wrong: delivery, processing, starting, running, or the code itself.

Axis 8: which layer, which key, which store?

PAIR	FIRST	SECOND
WAF / Network Firewall	Attacks inside HTTP	Traffic by domain or port
Security group / network ACL	Stateful, allow only	Stateless, can deny
Gateway / interface endpoint	S3 and DynamoDB, free	Most services, charged
AWS managed / customer managed key	Cannot be shared	Cross-account, your policy
Secrets Manager / Parameter Store	Rotation built in	Configuration, free tier

ON THE EXAM

Cross-account anything with encryption: customer managed key. Rotation required: Secrets Manager.

> An RDS for MySQL database uses a Multi-AZ DB instance deployment. Reporting queries saturate the primary's CPU during business hours.
>
> The team expected the standby to absorb those reads, but nothing changed. The database must keep automatic failover.

What should the DevOps engineer do?

A Resize the standby to a larger instance class

B Add a read replica, point the reporting queries at it, and keep the Multi-AZ deployment

C Replace Multi-AZ with a read replica in another Availability Zone

D Put RDS Proxy in front of the database

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A **Bigger standby**

A Multi-AZ instance standby serves no reads, whatever its size.

B **Read replica plus Multi-AZ**

The replica takes reporting reads; Multi-AZ keeps automatic failover.

C **Replica instead of Multi-AZ**

Loses automatic failover, which is required.

D **RDS Proxy**

Pools connections. The problem is CPU from queries.

THE PAIR

Axis 6: a standby is for failover, a replica is for reads. Most production databases want both.

> A company's security policy states that nobody in any member account, including account administrators and the root user, may stop or delete CloudTrail trails.
>
> The company uses AWS Organizations with all features enabled.

What should the DevOps engineer implement?

A. A permissions boundary on every IAM role in every account

B. An IAM policy denying the actions, attached to every user and role

C. A session policy applied whenever administrators assume roles

D. An SCP denying cloudtrail:StopLogging and cloudtrail:DeleteTrail, attached to the root

◆ PAUSE AND DECIDE

What should the DevOps engineer implement?

A **Boundaries everywhere**

Administrators could remove them, and boundaries do not apply to the root user.

B **IAM deny policies**

Account administrators can detach them, and they miss the root user.

C **Session policies**

Only apply when someone chooses to assume a role with one.

D **SCP at the root**

Applies to everyone in member accounts, root user included, and cannot be changed from inside.

THE PAIR

Axis 2: a ceiling nobody inside the account can lift, root included, is an SCP.

> The security team must be notified within seconds every time anyone creates an IAM access key in the production account.
>
> A CloudTrail trail is already logging management events.

What should the DevOps engineer set up?

A An EventBridge rule on the CreateAccessKey API call, targeting an SNS topic

B A periodic AWS Config rule checking for access keys

C A Security Hub CSPM control for IAM access keys

D IAM Access Analyzer unused access findings

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A EventBridge on the API call

Fires on each call within seconds, through the existing trail.

B Periodic Config rule

Evaluates state on a schedule, perhaps hours later.

C CSPM control

Scores posture over time. Not a per-event alert.

D Unused access

Finds keys that are not used. The opposite question.

THE PAIR

Axis 1 again: something just happened means EventBridge; is it out of policy means Config.

> An application uses Aurora PostgreSQL with a single writer instance. It must survive the loss of an Availability Zone, failing over automatically within minutes.
>
> The company has no multi-Region requirement and wants the lowest cost.

What should the DevOps engineer do?

A Convert the cluster to an Aurora Global Database

B Add a cross-Region read replica

C Add an Aurora replica in a different Availability Zone

D Migrate the data to DynamoDB global tables

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Global Database

Protects against Region loss, at higher cost. No such requirement.

B Cross-Region replica

Another Region, not another zone, and promotion is manual.

C Replica in another AZ

Aurora promotes it automatically if the writer's zone fails. Cheapest fit.

D DynamoDB global tables

A re-platform for a requirement one replica meets.

THE PAIR

Axis 6: match the scope of protection to the scope of failure. Zone, not Region.

> An EC2 instance in a production account has started communicating with an IP address associated with cryptocurrency mining.
>
> The security team wants such activity detected and sent to its incident workflow automatically.

Which service detects this?

A Amazon Inspector

B Amazon Macie

C Security Hub CSPM controls

D Amazon GuardDuty, with findings routed through EventBridge

◆ PAUSE AND DECIDE

Which service detects this?

A Inspector

Finds vulnerable software, not active malicious behaviour.

B Macie

Reads S3 object contents. Unrelated to network behaviour.

C CSPM controls

Evaluates configuration against standards, not traffic.

D GuardDuty

Detects threats from flow and DNS activity, including mining, and emits EventBridge events.

THE PAIR

Axis 3: active threat means GuardDuty. A weakness that could be exploited means Inspector.

> Checkout latency tripled for an hour after an unremarkable afternoon. There is no sign of attack. Engineers want help correlating metrics, logs, deployments and configuration changes into likely causes.
>
> Both Detective and CloudWatch are available.

What should the engineers use?

A Amazon Detective

B A CloudWatch investigation

C Amazon GuardDuty

D Security Hub

◆ PAUSE AND DECIDE

What should the engineers use?

A Detective

Scopes security incidents. It does not analyse latency or deployments.

B CloudWatch investigation

Correlates operational signals, including deployments and changes, into hypotheses.

C GuardDuty

Detects threats. There is no attack here.

D Security Hub

Security findings and posture, not operational performance.

THE PAIR

Axis 3: an operational problem goes to CloudWatch investigations; a security incident goes to Detective.

> A service reads about 200 configuration values at start-up, such as endpoints, timeouts and feature settings. None are secrets, and none need rotation or gradual rollout.
>
> The team wants hierarchical names per environment, and the lowest cost.

Where should the values be stored?

A AWS Secrets Manager, one secret per value

B A DynamoDB table read at start-up

C Parameter Store standard parameters, with paths such as /prod/checkout/timeout

D AWS AppConfig with a linear deployment strategy

◆ PAUSE AND DECIDE

Where should the values be stored?

A Secrets Manager

Charged per secret, for rotation nobody needs: 200 monthly charges.

B DynamoDB

Works, but it is a table to design and pay for, with no hierarchy built in.

C Parameter Store standard

Free, hierarchical by path, ideal for configuration read at start-up.

D AppConfig linear

Built for gradual, validated rollout, which is explicitly not needed.

THE PAIR

Axis 8: rotation means Secrets Manager; gradual rollout means AppConfig; plain configuration means Parameter Store.

> A Java API on Lambda shows high p99 latency after idle periods, caused by long cold starts while the framework initialises.
>
> The team wants to cut cold-start time at the lowest cost, without changing application code.

What should the DevOps engineer do?

A. Enable SnapStart on the function's published versions

B. Set reserved concurrency on the function

C. Configure provisioned concurrency sized for peak traffic

D. Increase the function's memory to the maximum

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A SnapStart

Restores from a snapshot taken after initialisation. For Java it adds no charge.

B Reserved concurrency

Controls how much, not how ready. Cold starts continue.

C Provisioned concurrency

Removes cold starts, but charges for warm environments all the time.

D Maximum memory

Somewhat faster initialisation, at a higher price per invocation.

THE PAIR

Axis 6: how ready, cheaply, for Java: SnapStart. How ready, whatever the cost: provisioned concurrency.

Module 28 in five lines

- Two options both sound right? Find the axis they differ on.
- Before or after; who is acting; contents or behaviour; copy or look.
- Once or continuously; how much is running; where the failure lands; which layer.
- Then ask that one question of the scenario. The planted detail usually answers it.
- Match the scope of the answer to the scope of the problem.

> ON THE EXAM
>
> Next, module 29: how DOP-C02 questions are written, and how to read them under time pressure.

MODULE 29 · EXAM STRATEGY - ALL DOMAINS

How DOP-C02 Questions Are Written

The format, the anatomy of a question, qualifiers and distractors, multiple response, catalogue drift, and pacing 75 questions in 180 minutes.

DOMAIN All six EXAM WEIGHT 100% MODULE 29 of 34

admin@sthithapragna.com

Every question is built the same way: a situation with one **planted detail**, a **qualifier**, and options where **more than one works**.

The exam, in facts

ITEM	DETAIL
Questions	75: 65 scored, 10 unscored, and you cannot tell which
Time	180 minutes: about 2.4 minutes per question
Types	Multiple choice, one of four; multiple response, two or more of five or more
Score	Scaled 100 to 1,000; 750 to pass; compensatory across domains
Guessing	No penalty: never leave a question blank
Service names	Short names are used; the Help button lists them

ON THE EXAM

Compensatory means a weak domain can be offset by strong ones. Every question counts the same.

The anatomy of a question

01
Situation
Accounts, services, what exists today.

02
Constraints
Numbers and must-haves: RTO, 'automatically'.

03
Planted detail
One sentence that decides it.

04
Qualifier
LEAST overhead, MOST cost-effective...

05
Options
Two work; one fits everything.

ON THE EXAM

The planted detail is often the last sentence of the situation, and often sounds like background.

A reading order that works

- Read the **question sentence** and qualifier first, so you know what you are looking for.
- Then read the situation, noting numbers, 'automatically', 'existing', 'future accounts', 'without code changes'.
- Look for the sentence that sounds like background but rules options in or out.
- Only then read the options, and eliminate before you compare.

> ON THE EXAM
>
> Reading options first plants an answer in your head before you know the constraints.

What each qualifier really asks for

QUALIFIER	REALLY MEANS	USUALLY WINS
LEAST operational overhead	Least to run and maintain afterwards	Managed feature over custom code
MOST operationally efficient	Fewest moving parts over time	Native integration
MOST cost-effective	Cheapest that meets every requirement	Not simply the cheapest option
LEAST development effort	Configuration, not code	A setting or managed service
MOST secure	Strongest control that still meets needs	Preventive, least privilege, no long-lived keys
LEAST downtime	Users keep being served	Blue/green, traffic shifting

ON THE EXAM

Cost-effective never means violating a requirement. Eliminate on requirements first, then apply the qualifier.

Seven kinds of wrong answer

DISTRACTOR FAMILY	WHAT IT LOOKS LIKE
Custom code for a native feature	A scheduled Lambda rebuilding a built-in setting
A person in the loop	Manual approval or review where 'automatically' was asked
Retired or legacy service	OpsWorks, Inspector Classic, a polling source
Wrong scope	Region-wide fix for a zone problem, or the reverse
Right service, wrong setting	Recover on an instance check; DLQ for mishandled events
Over-engineered	Multi-Region active-active for an internal tool
Works, but breaks a constraint	Correct technically, fails one stated must-have

ON THE EXAM

Name the family and you can discard the option without fully understanding it.

Multiple response questions

- Read the count: 'Choose TWO' or 'Choose THREE'. There is no partial credit.
- Judge each option as true or false on its own, against every requirement.
- Correct options often form **two halves** of one solution: prevent plus fix, permission plus network.
- Two options that do the same job are rarely both right. Pick the better one and look elsewhere.

> ON THE EXAM
>
> In our question bank analysis, about one question in five was multiple response.

Catalogue drift on the day

- The exam guide predates many changes: retired services may still appear as options.
- Answer on the **guide's terms**: a guide-era correct design is still correct.
- If a newer native feature appears as an option and fits every requirement, it is likely the answer.
- Do not reject an option only because the service has since been renamed.

> ON THE EXAM
>
> Module 30 lists every gap between the guide and today, with dates.

Spending 180 minutes

01

Pass one

Answer every question in about 2 minutes. Flag doubts.

02

Checkpoint

At about 120 minutes, all 75 answered.

03

Pass two

Revisit flagged questions with fresh eyes.

04

Final check

No blanks. Every answer has a guess at least.

ON THE EXAM

Non-native English speakers can request 30 extra minutes. Arrange it before booking the exam.

When you are stuck between two

- Find the axis they differ on, from module 28, and ask that question of the situation.
- Reread the last sentence of the situation: it is usually the planted detail.
- Prefer the option that satisfies every constraint over the one that is most impressive.
- Do not change a first answer without a concrete reason you can name.

> ON THE EXAM
>
> The sophisticated option is often the over-engineered distractor. Sufficient beats impressive.

> A Lambda function calls a partner API with a key that the partner requires to be rotated every 30 days. Rotating it means calling the partner's API to issue a new key.
>
> Today an engineer rotates it by hand and updates an environment variable. The company wants rotation automated with the LEAST operational overhead.

What should the DevOps engineer do?

A. Store the key in Secrets Manager with a rotation function on a 30-day schedule, and fetch it at run time

B. Store the key in Parameter Store, and build an EventBridge Scheduler job and Lambda function to replace it

C. Have the deployment pipeline generate a new key and update the environment variable monthly

D. Encrypt the environment variable with a customer managed KMS key

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Secrets Manager rotation

Scheduling, staging labels and retries are built in; you only write the partner call.

B Parameter Store plus Scheduler

Works, but you build the scheduling, versioning and failure handling yourself.

C Pipeline updates the variable

Redeploys to rotate a secret, and keeps it in an environment variable.

D Encrypt the variable

Protects it at rest. Still never rotates.

THE METHOD

Anatomy: both A and B work. The qualifier chooses the managed rotation framework.

> Compliance requires one year of VPC Flow Logs for 40 VPCs. The logs are queried a few times a year during investigations, and minutes of query latency are acceptable.
>
> Flow logs currently go to CloudWatch Logs with one-year retention, and the bill is high.

Which solution is the MOST cost-effective?

A. Keep CloudWatch Logs, and switch the log groups to the Infrequent Access class

B. Stream flow logs into an Amazon OpenSearch Service domain

C. Load flow logs into Amazon Redshift through Firehose

D. Deliver flow logs to S3, move them to a cheaper storage class after 30 days, and query with Athena

◆ PAUSE AND DECIDE

Which solution is the MOST cost-effective?

A Infrequent Access logs

Cheaper ingestion, but a year in CloudWatch still costs far more than S3.

B OpenSearch

A running cluster all year, for a few queries.

C Redshift

A warehouse to run, for rare, simple queries.

D S3, lifecycle, Athena

Cheapest storage, pay-per-query analysis, and minutes of latency is accepted.

THE METHOD

Anatomy: 'a few times a year' and 'minutes acceptable' are the planted details that make S3 and Athena fit.

> An organisation with 90 accounts must stop new public S3 buckets from being created, and fix any bucket policies that are already public. Both must happen automatically.

Which combination of steps meets these requirements? (Choose TWO.)

A Enable GuardDuty S3 Protection in every account

B Enable account-level S3 Block Public Access everywhere, with an SCP denying changes to it

C Have the security team review bucket policies weekly

D An organisation conformance pack with a public-bucket rule and automatic remediation

E Enable Amazon Macie in every account

◆ PAUSE AND DECIDE

Which combination of steps meets these requirements? (Choose TWO.)

A GuardDuty S3 Protection

Detects suspicious access. Neither prevents nor fixes public policies.

B Block Public Access, locked by SCP

The preventive half: new public access is blocked, and cannot be turned off.

C Weekly review

Manual, and a week late. 'Automatically' rules it out.

D Conformance pack with remediation

The corrective half: existing public policies are found and fixed.

E Macie

Finds sensitive data and reports bucket posture. It does not fix anything.

THE METHOD

Two requirements, 'stop new' and 'fix existing': expect one preventive and one corrective answer.

> EC2 instances in private subnets with no internet access must be managed through Session Manager. The instances have no instance profile, and none appear as managed nodes.

Which combination of steps will make the instances managed? (Choose TWO.)

A Create interface VPC endpoints for ssm, ssmmessages and ec2messages

B Add a NAT gateway to the private subnets

C Attach an instance profile with the AmazonSSMManagedInstanceCore policy

D Open port 22 in the instances' security group

E Launch a bastion host in a public subnet

◆ PAUSE AND DECIDE

Which combination of steps will make the instances managed? (Choose TWO.)

A Three interface endpoints

The network half: a private path to Systems Manager, with no internet.

B NAT gateway

Also a network path, but it gives internet access, which the situation rules out.

C Instance profile

The permission half: the agent can now register. Default host management would also do it.

D Port 22

Session Manager needs no inbound ports at all.

E Bastion host

An SSH pattern Session Manager exists to replace.

THE METHOD

Module 13's checklist: agent, permissions, network path. Two were missing, so two answers.

Module 29 in five lines

- 75 questions, 180 minutes, 750 to pass, no penalty for guessing: never leave a blank.
- Read the question and qualifier first; find the planted detail; eliminate, then compare.
- Name the distractor family to discard options quickly.
- Multiple response: judge each option alone; correct answers are often two halves.
- Answer on the guide's terms; pass one by two hours, then review flags.

> ON THE EXAM
>
> Next, module 30: the revision gap. Everything the exam guide says that has since changed.

MODULE 30 · EXAM STRATEGY - ALL DOMAINS

The Revision Gap

Everything the DOP-C02 exam guide describes that has since been retired, renamed or overtaken, with dates, and how to answer when the guide and today disagree.

DOMAIN All six EXAM WEIGHT 100% MODULE 30 of 34

admin@sthithapragna.com

The guide describes AWS as it **was**. Answer in the **guide's** terms, and know the **reality** for your job.

Retired or closed: build, deploy and configure

IN THE EXAM GUIDE	WHAT HAPPENED	DATE
AWS OpsWorks, all editions	End of life; Systems Manager replaces it	March to May 2024
AWS CodeStar	Discontinued	31 July 2024
AWS Copilot CLI	End of support	12 June 2026
AWS Proton	End of support	7 October 2026
AWS App Runner	Closed to new customers; ECS Express Mode	30 April 2026
CodeGuru Reviewer and Security	Closed; Security discontinued	November 2025

ON THE EXAM

Chef cookbooks run through State Manager now. Code review moved to Inspector code security and Q Developer.

Retired or closed: monitor, respond and secure

SERVICE OR FEATURE	WHAT HAPPENED	DATE
Systems Manager Incident Manager	Closed to new customers	7 November 2025
Systems Manager Change Manager	Closed to new customers	7 November 2025
CloudWatch Evidently	Discontinued; AppConfig covers flags	17 October 2025
X-Ray SDKs and daemon	Maintenance; end of support February 2027	25 February 2026
Amazon Inspector Classic	End of support	20 May 2026
ARC readiness check	Closed to new customers	30 April 2026

ON THE EXAM

CloudTrail Lake is also no longer open to new customers. Query trails in S3 with Athena instead.

Renamed, split or reversed

OLDER NAME OR STATUS	TODAY
Kinesis Data Firehose	Amazon Data Firehose
Fault Injection Simulator	Fault Injection Service
CodeStar Connections	CodeConnections (provider type still says CodeStarSourceConnection)
AWS Chatbot	Amazon Q Developer in chat applications (February 2025)
Security Hub	Security Hub CSPM, plus a new correlating Security Hub (December 2025)
CodeCommit closed to new customers	Reopened to general availability, 24 November 2025

ON THE EXAM

A renamed service in an exam option is still the same service. Do not reject it for its old name.

New since the guide: pipelines and builds

FEATURE	DATE	MODULE
CodePipeline V2 execution modes: QUEUED, PARALLEL	February 2024	2
Stage conditions; CodeBuild and Commands rules	2024; March 2025	2
Manual approval timeout configurable, 5 minutes to 60 days	2024	2
CodeBuild Lambda compute and reserved capacity fleets	2023 to 2024	3
Inspector code security for repositories	June 2025	4
CodePipeline Lambda deploy action with canary and linear	May 2025	7

ON THE EXAM

Many 'least overhead' answers moved from Lambda glue to these built-in features.

New since the guide: images and deployments

FEATURE	DATE	MODULE
ECR-to-ECR pull through cache	March 2025	5
ECR tag immutability exclusion patterns	July 2025	5
ECR managed signing; archive storage class	November 2025	5
CodeDeploy zonal configuration; termination hooks	2024	6
ECS native blue/green	July 2025	7
ECS native linear and canary	October 2025	7

ON THE EXAM

CodeDeploy blue/green for ECS is still valid. ECS-native is now AWS's recommendation for new services.

New since the guide: infrastructure as code

FEATURE	DATE	MODULE
CloudFormation IaC generator	February 2024	9
Custom resource ServiceTimeout	June 2024	9
Hooks with Guard and Lambda; managed proactive controls	November 2024; September 2025	10
Stack refactoring	February 2025	9
Drift-aware change sets	November 2025	9
CDK refactor command, preview	September 2025	11

ON THE EXAM

Drift-aware change sets and stack refactoring replace several older multi-step workarounds.

New since the guide: organisations and fleets

FEATURE	DATE	MODULE
Resource control policies	November 2024	12
Centralised root access management	November 2024	24
Declarative policies	December 2024	12
Systems Manager just-in-time node access	April 2025	13
SCPs support the full IAM policy language	19 September 2025	12
Control Tower landing zone 4.0; controls-only option	November 2025	12

ON THE EXAM

Older material saying SCP Allow statements cannot use conditions is now wrong.

New since the guide: resilience

FEATURE	DATE	MODULE
Attached EBS status checks; Auto Scaling EBS health checks	August 2024	20
Aurora Serverless v2 scales to zero	November 2024	15
EKS Auto Mode	December 2024	15
Backup multi-party approval for air-gapped vaults	June 2025	16
DynamoDB global tables with strong consistency	June 2025	14
ARC Region switch	August 2025	14

ON THE EXAM

Zero-RPO multi-Region data is now possible with DynamoDB, but only across exactly three Regions.

New since the guide: observability and events

FEATURE	DATE	MODULE
X-Ray OpenTelemetry endpoint and Transaction Search	November 2024	19
Logs Insights SQL and PPL	December 2024	18
EventBridge direct cross-account targets	January 2025	21
CloudWatch investigations generally available	June 2025	22
CloudWatch Logs centralisation across accounts and Regions	September 2025	17
AWS DevOps Agent generally available	April 2026	22

ON THE EXAM

New tracing work should use OpenTelemetry. Existing X-Ray SDK answers still reflect the guide.

New since the guide: security

FEATURE	DATE	MODULE
IAM Access Analyzer custom policy checks, incl. no public access	2023; July 2024	24
CloudFront VPC origins	November 2024	26
VPC Block Public Access	November 2024	26
GuardDuty Extended Threat Detection	December 2024	27
ACM exportable public certificates	June 2025	25
ACM public certificates limited to 198 days	February 2026	25

ON THE EXAM

CloudFront VPC origins replace the secret-header pattern for load balancer origins.

Answering when the guide and today disagree

- If the only option that fits is a retired service, choose it: the exam still marks it right.
- If a newer native feature fits every requirement, it is likely the intended answer.
- Treat renamed services as the same service under either name.
- Never talk yourself out of a correct guide-era answer because it is no longer fashionable.

> ON THE EXAM
>
> The exam rewards the design that meets every stated requirement, not the newest one.

What has not changed

- IAM evaluation: explicit deny wins; both sides must allow across accounts.
- CodeDeploy lifecycle hooks on EC2, and the previous-revision ApplicationStop rule.
- CloudFormation fundamentals: change sets, policies, cfn-init, cfn-signal, cfn-hup.
- Auto Scaling policies, lifecycle hooks, and the release loop from module 1.

> ON THE EXAM
>
> The foundations the exam tests most are stable. The drift sits mostly at the edges.

Module 30 in five lines

- Answer in the guide's terms; know the reality for your job.
- Retired: OpsWorks, CodeStar, Copilot, Proton, CodeGuru, Evidently, Inspector Classic.
- Renamed: Data Firehose, CodeConnections, Q Developer in chat, Security Hub CSPM.
- New: native ECS deployments, stage conditions, drift-aware change sets, RCPs, and more.
- The foundations are stable. The drift is at the edges.

> ON THE EXAM
>
> Next, modules 31 to 34: four practice papers, 20 questions each, weighted like the real exam.

MODULE 31 · EXAM STRATEGY - ALL DOMAINS

Practice Exam 1 of 4

Twenty new questions, weighted like the real exam, including four multiple-response questions.

QUESTIONS 20 PASS MARK 15 of 20 HOLD 9 seconds

admin@sthithapragna.com

How to use this paper

- Pause after each question and commit to an answer before the solution appears.
- Write down your letters. Multiple-response questions need every correct letter.
- Score yourself by **domain** at the end, not only in total.
- For each miss, revisit the module named on the scoring slide.

> ON THE EXAM
>
> The answer teaches the fact. The module teaches the discriminator you missed.

A Maven project builds in CodeBuild a few times a day. Every build spends eight minutes downloading the same dependencies.

Builds are infrequent and land on different build hosts. The team wants faster builds with the least effort.

What should the DevOps engineer configure?

A Local custom cache for the Maven repository directory

B An S3 cache for the Maven repository directory

C A larger compute type

D Publish the dependencies to CodeArtifact

◆ PAUSE AND DECIDE

What should the DevOps engineer configure?

A Local custom cache for the Maven repository directory

Local caches are best effort and host-bound. Infrequent builds on different hosts rarely hit them.

B An S3 cache for the Maven repository directory

Shared by every build host and persistent between infrequent builds. The right cache for this pattern.

C A larger compute type

The time is spent downloading, not computing.

D Publish the dependencies to CodeArtifact

Still downloads every dependency on every build, just from a different place.

REVISIT MODULE 3

Infrequent builds on different hosts: S3 cache. Frequent builds on warm hosts: local cache.

A pipeline in a tooling account deploys to EC2 instances in a production account with CodeDeploy. Artifacts are encrypted with a customer managed KMS key.

The artifact bucket policy already allows the production account to read. Instances fail to download the revision.

Which steps will fix the deployment? (Choose TWO.)

A Allow the production instance role to decrypt in the key's policy

B Grant the instance profile s3:GetObject on the bucket and kms:Decrypt on the key

C Grant the CodeDeploy service role s3:GetObject

D Open outbound port 443 in the instances' security group to 0.0.0.0/0

E Switch the artifact bucket to the AWS managed key for S3

◆ PAUSE AND DECIDE

Which steps will fix the deployment? (Choose TWO.)

A Allow the production instance role to decrypt in the key's policy

The key is in the tooling account, so its policy must admit the production role.

B Grant the instance profile s3:GetObject on the bucket and kms:Decrypt on the key

Cross-account needs both sides: the role's own policy must allow the calls too.

C Grant the CodeDeploy service role s3:GetObject

The agent downloads the bundle using the instance profile, not the service role.

D Open outbound port 443 in the instances' security group to 0.0.0.0/0

The error is access denied, not a network timeout.

E Switch the artifact bucket to the AWS managed key for S3

An AWS managed key can never be used by another account.

REVISIT MODULE 8

Bucket already allows it: the key policy and the caller's own policy are the two locks left.

A V2 pipeline builds and releases a library from GitHub through CodeConnections. It currently runs on every push to main.

The team wants releases only when a version tag such as v2.3.0 is pushed, with no custom code.

What should the DevOps engineer do?

A Add a push trigger with a tag filter that includes v*

B Switch the source to polling every five minutes

C Create an EventBridge rule on CodeCommit tag events

D Use a Lambda function behind a GitHub webhook to start the pipeline on tags

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Add a push trigger with a tag filter that includes v*

V2 triggers filter Git tags natively. No code.

B Switch the source to polling every five minutes

Polling still runs on every change and cannot filter tags.

C Create an EventBridge rule on CodeCommit tag events

The repository is on GitHub, not CodeCommit.

D Use a Lambda function behind a GitHub webhook to start the pipeline on tags

Works, but it is the custom code the team ruled out.

REVISIT MODULE 2

Filter on branches, tags or paths, from a connection source: V2 triggers.

> An Elastic Beanstalk application must send 10% of traffic to each new version for 15 minutes, then shift the rest if healthy.
>
> It must stay in the same environment and roll back automatically if the new version is unhealthy.

Which deployment policy meets these requirements?

A Rolling

B Immutable

C Traffic splitting, 10% for 15 minutes

D Blue/green by swapping environment URLs

◆ PAUSE AND DECIDE

Which deployment policy meets these requirements?

A **Rolling**

Updates batches of existing instances. No traffic percentage or evaluation period.

B **Immutable**

A new group takes traffic without a 10% canary phase.

C **Traffic splitting, 10% for 15 minutes**

A canary share for an evaluation period, then the rest, with automatic rollback.

D **Blue/green by swapping environment URLs**

Uses two environments and moves all traffic at once.

REVISIT MODULE 7

A percentage for a period inside one Beanstalk environment: traffic splitting.

admin@sthithapragna.com

> Developers want to see which unit tests fail, and how the failure rate changes over time, without reading raw build logs.
>
> Tests already produce JUnit XML files during the CodeBuild build phase.

What should the DevOps engineer do with the LEAST effort?

A Upload the XML files to S3 and build a QuickSight dashboard

B Parse the build logs with Logs Insights

C Run the tests in AWS Device Farm

D Add a reports section to the buildspec, sending the XML to a report group

◆ PAUSE AND DECIDE

What should the DevOps engineer do with the LEAST effort?

A Upload the XML files to S3 and build a QuickSight dashboard

A custom reporting pipeline for something CodeBuild does natively.

B Parse the build logs with Logs Insights

The requirement is to avoid reading logs, and parsing is fragile.

C Run the tests in AWS Device Farm

For mobile and browser device testing, not unit tests.

D Add a reports section to the buildspec, sending the XML to a report group

Report groups show each test case and trends over time, from the files already produced.

REVISIT MODULE 3

Test results and trends from CodeBuild: a report group. No custom tooling.

> A stack contains a production RDS database. A future template change could force replacement.
>
> The company must block any update that would replace the database, and keep a snapshot if a replacement is ever forced deliberately.

Which steps meet these requirements? (Choose TWO.)

A Set DeletionPolicy: Delete on the database

B A stack policy denying Update:Replace on the database

C Enable termination protection on the stack

D Set UpdateReplacePolicy: Snapshot on the database

E Set UpdateReplacePolicy: RetainExceptOnCreate

◆ PAUSE AND DECIDE

Which steps meet these requirements? (Choose TWO.)

A Set DeletionPolicy: Delete on the database

The opposite of protection.

B A stack policy denying Update:Replace on the database

Blocks replacement for everyone until deliberately overridden.

C Enable termination protection on the stack

Protects the stack from deletion, not the resource from updates.

D Set UpdateReplacePolicy: Snapshot on the database

If a replacement is forced, the old database is snapshotted.

E Set UpdateReplacePolicy: RetainExceptOnCreate

Not valid for UpdateReplacePolicy; that option exists only for DeletionPolicy.

REVISIT MODULE 9

Block the update: stack policy. Protect data if it happens anyway: UpdateReplacePolicy.

> Every EC2 instance, including instances launched in future, must run the CloudWatch agent with a configuration stored in Parameter Store.
>
> If someone stops the agent, it must be restored automatically.

What should the DevOps engineer use?

A Run Command, once, against all current instances

B State Manager associations that install and configure the agent on a schedule

C User data in every launch template

D Bake the agent into a new AMI

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A Run Command, once, against all current instances

Misses future instances, and never restores a stopped agent.

B State Manager associations that install and configure the agent on a schedule

Applies to new instances and re-applies continuously, correcting drift.

C User data in every launch template

Runs once at launch; a stopped agent stays stopped.

D Bake the agent into a new AMI

Helps new instances start with it, but nothing restores a stopped agent.

REVISIT MODULE 13

'Including future' and 'restored automatically': State Manager.

> Developers in the Sandbox OU may only launch t3 and t4g instance types. They launch through the console, the CLI and CloudFormation.
>
> The company wants a preventive control across every Sandbox account with the least overhead.

What should the DevOps engineer implement?

A. A CloudFormation Guard Hook checking instance types

B. An AWS Config rule for approved instance types

C. An SCP on the Sandbox OU denying ec2:RunInstances unless ec2:InstanceType matches t3.* or t4g.*

D. A Service Catalog portfolio of approved instances

◆ PAUSE AND DECIDE

What should the DevOps engineer implement?

A A CloudFormation Guard Hook checking instance types

Only covers CloudFormation. Console and CLI launches bypass it.

B An AWS Config rule for approved instance types

Detective: the instance already exists when it is flagged.

C An SCP on the Sandbox OU denying ec2:RunInstances unless ec2:InstanceType matches t3.* or t4g.*

Applies to every API call, however made, in every account in the OU.

D A Service Catalog portfolio of approved instances

Offers approved products but does not stop direct launches.

REVISIT MODULE 12

'Console, CLI and CloudFormation' rules out a Hook. Every API call, preventive: an SCP.

> A legacy application runs on EC2 with its data on EBS volumes and cannot be re-architected.
>
> After a Regional failure it must lose no more than one minute of data and be running within four hours, at the lowest cost.

Which solution meets these requirements?

A AWS Elastic Disaster Recovery replicating to a second Region

B Hourly AWS Backup copies to a second Region

C A full-size warm standby fleet in a second Region

D Multi-Region active-active

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A. AWS Elastic Disaster Recovery replicating to a second Region

Seconds of RPO with a cheap staging area; recovery well within four hours.

B. Hourly AWS Backup copies to a second Region

Up to an hour of data lost. Fails the one-minute RPO.

C. A full-size warm standby fleet in a second Region

Meets the targets, at far higher cost than needed.

D. Multi-Region active-active

The most expensive option, and needs re-architecture.

REVISIT MODULE 16

The one-minute RPO rules out backups; the four-hour RTO rules out paying for running copies.

> A web tier on an Auto Scaling group behind an ALB serves report requests lasting up to two minutes.
>
> During scale-in, users see 502 errors when instances are removed mid-request.

What should the DevOps engineer change?

A Add a launch lifecycle hook

B Turn off scale-in

C Use larger instances

D Set the target group's deregistration delay above two minutes

◆ PAUSE AND DECIDE

What should the DevOps engineer change?

A Add a launch lifecycle hook

Acts at launch, not while an instance is being removed.

B Turn off scale-in

Stops the errors by giving up scaling, and the cost savings with it.

C Use larger instances

Requests are cut off on removal whatever the instance size.

D Set the target group's deregistration delay above two minutes

In-flight requests finish before the instance is terminated.

REVISIT MODULE 14

Requests cut off on removal: deregistration delay longer than the longest request.

> A web application runs active-passive in two Regions. Static assets are in S3 and user data in DynamoDB.
>
> If the primary Region fails, static content must fail over automatically and user data must already be in the secondary Region.

Which steps meet these requirements? (Choose TWO.)

A. S3 replication, with a CloudFront origin group across both buckets

B. A nightly job copying S3 objects to the second Region

C. A DynamoDB global table across both Regions

D. Daily DynamoDB backups copied to the second Region

E. Route 53 simple routing to the primary Region

◆ PAUSE AND DECIDE

Which steps meet these requirements? (Choose TWO.)

A S3 replication, with a CloudFront origin group across both buckets

Content is copied, and CloudFront retries the secondary bucket automatically.

B A nightly job copying S3 objects to the second Region

Up to a day stale, and nothing fails over automatically.

C A DynamoDB global table across both Regions

User data is already present in the secondary Region.

D Daily DynamoDB backups copied to the second Region

Data must be restored first, and up to a day is lost.

E Route 53 simple routing to the primary Region

Simple routing has no failover.

REVISIT MODULE 14

Two halves: static content fails over at the edge; data is already replicated.

> An application already writes a log line containing LOGIN_FAILED for each failed sign-in to CloudWatch Logs.
>
> Security wants an alarm when failed sign-ins exceed 50 in five minutes. The code cannot change.

What should the DevOps engineer do?

A. A metric filter on the log group, and an alarm on the metric

B. Rewrite the logging to use the embedded metric format

C. A subscription filter to a Lambda function that counts failures

D. A Logs Insights query run by hand every five minutes

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A A metric filter on the log group, and an alarm on the metric

Turns existing log lines into a metric, with no code change.

B Rewrite the logging to use the embedded metric format

A code change, which is ruled out.

C A subscription filter to a Lambda function that counts failures

Custom code for what a metric filter does natively.

D A Logs Insights query run by hand every five minutes

Manual, and not an alarm.

REVISIT MODULE 17

Value already in the logs, no code change: metric filter.

> A service pages on-call when CPU is high, and again when latency is high. Most pages are false alarms from one or the other alone.
>
> The team wants a page only when high CPU and high latency happen together.

What should the DevOps engineer configure?

A Send both alarms to the same SNS topic

B An anomaly detection alarm on CPU

C A composite alarm with an AND rule, carrying the only notification

D A metric math alarm on CPU plus latency

◆ PAUSE AND DECIDE

admin@sthithapragna.com

What should the DevOps engineer configure?

A Send both alarms to the same SNS topic

Still pages for each alarm alone.

B An anomaly detection alarm on CPU

Changes one threshold; still pages on CPU alone.

C A composite alarm with an AND rule, carrying the only notification

Fires only when both child alarms are in ALARM.

D A metric math alarm on CPU plus latency

Adding unrelated units produces a meaningless number.

REVISIT MODULE 18

Page only when conditions coincide: composite alarm with AND.

admin@sthithapragna.com

> A team runs many services on ECS with Fargate. It needs CPU, memory and network metrics per service and per task, with ready-made dashboards.
>
> It wants the least operational effort.

What should the DevOps engineer enable?

A. A CloudWatch agent sidecar in every task definition

B. CloudWatch Container Insights for the cluster

C. AWS X-Ray tracing

D. A self-managed Prometheus server

◆ PAUSE AND DECIDE

What should the DevOps engineer enable?

A. A CloudWatch agent sidecar in every task definition
Changes every task definition to rebuild what is built in.

B. CloudWatch Container Insights for the cluster
Per-service and per-task metrics with automatic dashboards.

C. AWS X-Ray tracing
Traces requests; does not report resource metrics.

D. A self-managed Prometheus server
A server to run, for metrics available natively.

REVISIT MODULE 17

Container resource metrics with dashboards, least effort: Container Insights.

> The team wants an alert when any EC2 instance tagged env=prod is stopped.
>
> An EventBridge rule on EC2 state-change events with a pattern on the tag never matches.

Why, and what is the fix?

A The pattern is case-sensitive; fix the case of the tag key

B State-change events are only sent for Auto Scaling instances

C The rule needs a trail to receive state-change events

D The event does not carry tags; match state 'stopped' and have a Lambda target check the tag

◆ PAUSE AND DECIDE

Why, and what is the fix?

A The pattern is case-sensitive; fix the case of the tag key

Case is not the problem. The tag is not in the event at all.

B State-change events are only sent for Auto Scaling instances

Every instance emits them.

C The rule needs a trail to receive state-change events

State changes come from EC2 directly; a trail is for API-call events.

D The event does not carry tags; match state 'stopped' and have a Lambda target check the tag

Enrich the event: look up the tag, then notify only for production.

REVISIT MODULE 21

Events carry what the service puts in them. Instance tags are not in state-change events.

> All new EBS volumes in every account must be encrypted, without changing any team's templates or scripts.
>
> Existing unencrypted volumes must be reported for follow-up.

Which steps meet these requirements? (Choose TWO.)

A An SCP denying ec2:CreateVolume unless encryption is requested

B Amazon Macie in every account

C Turn on EBS encryption by default in every account and Region

D Amazon GuardDuty in every account

E An AWS Config rule reporting unencrypted volumes, through a conformance pack

◆ PAUSE AND DECIDE

admin@sthithapragna.com

Which steps meet these requirements? (Choose TWO.)

A An SCP denying ec2:CreateVolume unless encryption is requested

Breaks every template that does not request encryption: the thing ruled out.

B Amazon Macie in every account

Macie examines S3 objects, not EBS volumes.

C Turn on EBS encryption by default in every account and Region

New volumes are encrypted automatically, with no template changes.

D Amazon GuardDuty in every account

Detects threats, not unencrypted volumes.

E An AWS Config rule reporting unencrypted volumes, through a conformance pack

Reports existing unencrypted volumes across accounts.

REVISIT MODULE 22

'Without changing templates' rules out a deny. Encryption by default fixes new; Config reports old.

A CodeBuild project was moved into private subnets with no NAT gateway, to reach an internal database.

Builds now fail at start-up with a timeout fetching a Secrets Manager secret. The service role's permissions are unchanged and correct.

What should the DevOps engineer do?

A Enable privileged mode

B Add kms:Decrypt to the service role

C Add a Secrets Manager interface endpoint with private DNS to the VPC

D Add an S3 gateway endpoint

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Enable privileged mode

For Docker builds. Unrelated.

B Add kms:Decrypt to the service role

A timeout, not access denied; permissions are correct.

C Add a Secrets Manager interface endpoint with private DNS to the VPC

Gives the build a private path to Secrets Manager.

D Add an S3 gateway endpoint

Secrets Manager is not reached through S3.

REVISIT MODULE 23

Timeout after moving into a VPC, permissions fine: missing network path. Add the service's endpoint.

> A GitHub Actions workflow deploys to AWS using an IAM user's access keys stored as GitHub secrets.
>
> Security wants no long-lived keys, and only the repository's main branch able to deploy.

What should the DevOps engineer do?

A. An IAM OIDC provider for GitHub, and a role whose trust allows only this repository's main branch

B. Rotate the access keys every 30 days

C. IAM Roles Anywhere with a certificate stored in GitHub

D. An IAM Identity Center user for the workflow

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A An IAM OIDC provider for GitHub, and a role whose trust allows only this repository's main branch

Short-lived credentials per run, scoped by the token's subject claim.

B Rotate the access keys every 30 days

Still long-lived keys, just younger.

C IAM Roles Anywhere with a certificate stored in GitHub

For on-premises workloads; storing a certificate is another long-lived secret.

D An IAM Identity Center user for the workflow

For people, not CI systems.

REVISIT MODULE 24

CI system, no keys: OIDC federation. The subject condition limits it to one repo and branch.

> EBS snapshots encrypted with the AWS managed aws/ebs key must be shared with a disaster recovery account.
>
> Sharing them fails.

What should the DevOps engineer do?

A Share the snapshots through AWS RAM

B Make the snapshots public

C Add the DR account to the aws/ebs key policy

D Copy each snapshot re-encrypted with a customer managed key shared with the DR account, then share the copy

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Share the snapshots through AWS RAM

The key is still the AWS managed one, which the other account cannot use.

B Make the snapshots public

Never, and encrypted snapshots cannot be public anyway.

C Add the DR account to the aws/ebs key policy

AWS managed key policies cannot be edited.

D Copy each snapshot re-encrypted with a customer managed key shared with the DR account, then share the copy

The copy uses a key the DR account is allowed to use.

REVISIT MODULE 25

Cross-account plus AWS managed key: re-encrypt with a customer managed key.

> A login endpoint behind CloudFront faces credential stuffing from many addresses, and the business serves only three countries.
>
> The team wants to block other countries and slow any single address hammering /login.

What should the DevOps engineer configure?

A Network ACL rules for each attacking address

B A WAF web ACL with a geographic match rule and a rate-based rule scoped to /login

C Security group rules on the origin

D AWS Network Firewall in front of the origin

◆ PAUSE AND DECIDE

What should the DevOps engineer configure?

A Network ACL rules for each attacking address

Endless manual lists, and blind to countries and paths.

B A WAF web ACL with a geographic match rule and a rate-based rule scoped to /login

Blocks by country, and limits each address on the login path only.

C Security group rules on the origin

Addresses and ports only; no countries or paths.

D AWS Network Firewall in front of the origin

A network-layer inspector; this is an HTTP problem at the edge.

REVISIT MODULE 26

Countries and request paths are HTTP-level ideas: WAF.

Answer key

- **Answer key:** 1 B, 2 AB, 3 A, 4 C, 5 D, 6 BD, 7 B, 8 C, 9 A, 10 D
- **Answer key:** 11 AC, 12 A, 13 C, 14 B, 15 D, 16 CE, 17 C, 18 A, 19 D, 20 B
- Multiple response (2, 6, 11, 16) score only if both letters are right.
- 15 or more: on track. 13 or 14: close. 12 or fewer: revisit weak domains first.

> ON THE EXAM
>
> Each solution slide named the module to revisit. Use it for every miss.

Scoring by domain

DOMAIN	QUESTIONS	MODULES TO REVISIT
D1 SDLC Automation	1, 2, 3, 4, 5	2, 3, 7, 8
D2 Configuration Management and IaC	6, 7, 8	9, 12, 13
D3 Resilient Cloud Solutions	9, 10, 11	14, 16
D4 Monitoring and Logging	12, 13, 14	17, 18
D5 Incident and Event Response	15, 16, 17	21, 22, 23
D6 Security and Compliance	18, 19, 20	24, 25, 26

ON THE EXAM

Two misses in one domain matter more than three spread across six.

MODULE 32 · EXAM STRATEGY - ALL DOMAINS

Practice Exam 2 of 4

Twenty new questions, weighted like the real exam, including multiple-response questions.

QUESTIONS 20 PASS MARK 15 of 20 HOLD 9 seconds

admin@sthithapragna.com

How to use this paper

- Pause after each question and commit to an answer before the solution appears.
- Write down your letters. Multiple-response questions need every correct letter.
- Score yourself by **domain** at the end, not only in total.
- For each miss, revisit the module named on the solution slide.

> ON THE EXAM
>
> The answer teaches the fact. The module teaches the discriminator you missed.

A V2 pipeline's deploy stage sometimes fails because a downstream API briefly throttles. Re-running the failed action always succeeds.

Engineers retry by hand several times a week. The team wants failed actions retried automatically, with no custom code.

What should the DevOps engineer configure?

A An On Failure stage condition with a Retry result

B A manual approval before the stage

C An EventBridge rule on failures invoking a Lambda function that retries

D Change the pipeline to QUEUED mode

◆ PAUSE AND DECIDE

What should the DevOps engineer configure?

A An On Failure stage condition with a Retry result
Retries the failed actions automatically. Configuration only.

B A manual approval before the stage
Adds a person; retries nothing.

C An EventBridge rule on failures invoking a Lambda function that retries
Custom code for a built-in feature.

D Change the pipeline to QUEUED mode
Changes ordering of runs, not retries.

REVISIT MODULE 2

Transient failure, same code: retry. Built into stage conditions since 2024.

> Python builds in CodeBuild run in private subnets with no internet access. They need packages from the public PyPI registry.
>
> Security also wants a record and control of which package versions enter the company.

What should the DevOps engineer set up?

A. A NAT gateway so builds can reach PyPI directly

B. A nightly job that copies all of PyPI into an S3 bucket

C. A CodeArtifact repository with an external connection to PyPI, reached through CodeArtifact VPC endpoints

D. Developers download packages and commit them to the repository

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A — A NAT gateway so builds can reach PyPI directly

Gives internet access, which the design forbids, and records nothing.

B — A nightly job that copies all of PyPI into an S3 bucket

Enormous, custom, and not a package repository.

C — A CodeArtifact repository with an external connection to PyPI, reached through CodeArtifact VPC endpoints

Packages are fetched and retained centrally; builds stay private.

D — Developers download packages and commit them to the repository

Manual, bloats the repository, and uncontrolled.

REVISIT MODULE 5

Private builds needing public packages: CodeArtifact external connection plus its endpoints. Python needs no S3 endpoint.

> A team deploys container images to ECS. Twice last month, a deployment picked up the wrong image because the latest tag had moved.
>
> The team wants every deployment traceable to an exact commit, with images that can never be silently replaced.

Which changes meet these requirements? (Choose THREE.)

- A Deploy using the latest tag, pulled at deployment time
- B Tag each image with the commit ID from the build
- C Enable tag immutability on the ECR repository
- D Expire all images older than one day
- E Pass the exact tag to the deploy action through an exported variable

◆ PAUSE AND DECIDE

Which changes meet these requirements? (Choose THREE.)

A. Deploy using the latest tag, pulled at deployment time

The exact cause of the incidents.

B. Tag each image with the commit ID from the build

Makes every image traceable to its source.

C. Enable tag immutability on the ECR repository

A tag can never be pointed at a different image.

D. Expire all images older than one day

Deletes images you may need to roll back to.

E. Pass the exact tag to the deploy action through an exported variable

The deployment names the precise image the build produced.

REVISIT MODULE 5

Traceable, immutable, exact: commit tag, immutability, and passing that tag to the deploy.

admin@sthithapragna.com

> A shared Python library must be tested against Python 3.11, 3.12 and 3.13 on every commit, from a single CodeBuild project.
>
> The team wants the three test runs in parallel, with the least configuration.

What should the DevOps engineer use?

A Three separate CodeBuild projects

B A loop in the buildspec that installs each version in turn

C A Step Functions workflow starting three builds

D A batch build with a build matrix over the three versions

◆ PAUSE AND DECIDE

admin@sthithapragna.com

What should the DevOps engineer use?

A Three separate CodeBuild projects

Triples the configuration to maintain.

B A loop in the buildspec that installs each version in turn

Sequential, not parallel, and slower.

C A Step Functions workflow starting three builds

Custom orchestration for a built-in feature.

D A batch build with a build matrix over the three versions

One project; every combination runs in parallel.

REVISIT MODULE 3

Same project, several runtime versions, in parallel: a build matrix.

> A CDK pipeline adds a new target account. Deployment to it fails with an error that the bootstrap version parameter cannot be found.
>
> The app deploys correctly to every other account.

What should the DevOps engineer do?

A Run cdk synth again and redeploy

B Bootstrap the new account and Region, trusting the pipeline account

C Grant the pipeline role administrator access in the new account

D Delete the cdk.out folder

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Run cdk synth again and redeploy

The templates are fine; the account is not prepared.

B Bootstrap the new account and Region, trusting the pipeline account

Creates the bootstrap stack and roles the pipeline expects.

C Grant the pipeline role administrator access in the new account

There is still no bootstrap stack or role to assume.

D Delete the cdk.out folder

Local build output is not the problem.

REVISIT MODULE 11

Works everywhere except a new account, bootstrap missing: bootstrap it with --trust.

> Developers in 20 accounts need approved ElastiCache clusters with encryption and set node types.
>
> They must not hold ElastiCache permissions themselves. The platform team manages one catalogue centrally.

Which steps meet these requirements? (Choose TWO.)

A Share the Service Catalog portfolio with the developers' OU through Organizations

B Grant developers ElastiCache full access

C Deploy the cluster template with a StackSet

D Add a launch constraint role that can create the clusters

E An AWS Config rule for unencrypted clusters

◆ PAUSE AND DECIDE

Which steps meet these requirements? (Choose TWO.)

A Share the Service Catalog portfolio with the developers' OU through Organizations

One central catalogue, available in every account.

B Grant developers ElastiCache full access

The permission that is ruled out.

C Deploy the cluster template with a StackSet

Pushes clusters out; not self-service.

D Add a launch constraint role that can create the clusters

Service Catalog creates the cluster; developers need no ElastiCache rights.

E An AWS Config rule for unencrypted clusters

Detects afterwards; enables nothing.

REVISIT MODULE 10

Central catalogue in many accounts, no underlying permissions: share the portfolio, plus a launch constraint.

admin@sthithapragna.com

> Engineers sometimes edit CloudFormation-managed resources by hand in 60 accounts.
>
> The compliance team wants stacks with drift detected daily and reported centrally, with no custom code.

What should the DevOps engineer set up?

A. A scheduled Lambda function in each account calling drift detection

B. Drift-aware change sets on every stack

C. The cloudformation-stack-drift-detection-check Config rule through an organisation conformance pack, with an aggregator

D. CloudTrail Insights

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A. A scheduled Lambda function in each account calling drift detection
Custom code in sixty accounts.

B. Drift-aware change sets on every stack
Restores drift during a deployment; does not detect and report it daily.

C. The cloudformation-stack-drift-detection-check Config rule through an organisation conformance pack, with an aggregator
Managed detection everywhere, reported in one place.

D. CloudTrail Insights
Flags unusual API volumes, not drift.

REVISIT MODULE 9

Detect and report drift everywhere: the managed Config rule. Restore it on deploy: drift-aware change sets.

A Systems Manager Automation runbook must run in 50 accounts and three Regions to update a configuration value.

The operations team works from a delegated administrator account and wants one execution with rate control.

What should the DevOps engineer do?

A Start a multi-account, multi-Region Automation execution targeting the OUs and Regions

B A script that loops through each account and Region

C A StackSet with a custom resource that runs the change

D Run Command separately in each account

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Start a multi-account, multi-Region Automation execution targeting the OUs and Regions

One execution, fanned out with concurrency and error limits.

B A script that loops through each account and Region

Custom code doing what Automation does natively.

C A StackSet with a custom resource that runs the change

Misuses infrastructure deployment for an operation.

D Run Command separately in each account

One hundred and fifty separate executions.

REVISIT MODULE 13

Same runbook everywhere, one execution, rate control: multi-account, multi-Region Automation.

A Lambda function consumes an SQS queue and writes to a database that handles only 20 concurrent writers.

During bursts, Lambda scales up and overloads the database. The team wants to cap it without throttling errors or extra retries.

What should the DevOps engineer configure?

A Reserved concurrency of 20 on the function

B A batch size of 1

C A shorter visibility timeout

D Maximum concurrency of 20 on the SQS event source mapping

◆ PAUSE AND DECIDE

admin@sthithapragna.com

What should the DevOps engineer configure?

A Reserved concurrency of 20 on the function

Caps it, but pollers keep delivering and get throttled, causing retries.

B A batch size of 1

More invocations, not fewer.

C A shorter visibility timeout

Causes duplicate processing.

D Maximum concurrency of 20 on the SQS event source mapping

Pollers stop at 20, so nothing is throttled.

REVISIT MODULE 15

Cap a queue consumer cleanly: maximum concurrency on the event source mapping, not reserved concurrency.

> An Aurora PostgreSQL cluster serves read-heavy reporting whose volume swings unpredictably through the day.
>
> The team wants reader capacity added and removed automatically, with no manual steps.

What should the DevOps engineer configure?

A Add Aurora replicas by hand each morning

B An Aurora Auto Scaling policy for replicas, tracking reader CPU

C Convert to a Multi-AZ DB instance deployment

D Convert to an Aurora Global Database

◆ PAUSE AND DECIDE

What should the DevOps engineer configure?

A Add Aurora replicas by hand each morning
Manual, and the swings are unpredictable.

B An Aurora Auto Scaling policy for replicas, tracking reader CPU
Adds and removes replicas as load changes.

C Convert to a Multi-AZ DB instance deployment
For failover; its standby serves no reads.

D Convert to an Aurora Global Database
Cross-Region protection, not read scaling.

REVISIT MODULE 15

Unpredictable read load: replica auto scaling with target tracking.

> An API runs in two Regions, active-passive. The primary can be up while its database connection is broken.
>
> Traffic must move to the secondary automatically whenever the primary cannot serve real requests.

Which steps meet these requirements? (Choose TWO.)

A Simple routing to the primary Region

B Failover routing records, with a health check on the primary

C A one-day TTL on the records

D Weighted routing, 50 to each Region

E Point the health check at a deep endpoint that verifies the database

◆ PAUSE AND DECIDE

Which steps meet these requirements? (Choose TWO.)

A Simple routing to the primary Region

Simple routing has no failover.

B Failover routing records, with a health check on the primary

Moves traffic when the primary is unhealthy.

C A one-day TTL on the records

Slows failover for a day.

D Weighted routing, 50 to each Region

Active-active, not failover.

E Point the health check at a deep endpoint that verifies the database

The check then fails when real requests would.

REVISIT MODULE 14

Failover needs a routing policy and a check that tells the truth.

> A hundred Lambda functions in production write large volumes of debug logs through the runtime's standard logger. Ingestion costs are high.
>
> The team wants debug lines dropped before ingestion, with no code changes.

What should the DevOps engineer do?

A. Set JSON log format and an application log level of WARN in each function's logging configuration

B. Switch the log groups to the Infrequent Access class

C. A subscription filter that drops debug lines

D. Shorten retention to one day

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Set JSON log format and an application log level of WARN in each function's logging configuration

Lambda filters lower-level lines before they are sent. No code change.

B Switch the log groups to the Infrequent Access class

Cheaper per GB, but the debug lines are still ingested.

C A subscription filter that drops debug lines

Subscriptions copy logs after ingestion; they drop nothing.

D Shorten retention to one day

Storage cost falls; ingestion cost does not.

REVISIT MODULE 17

Stop paying to ingest noise, no code change: Lambda's log level controls.

> The team needs an alarm on the fault rate of one API path, /checkout, which is traced with X-Ray.
>
> Other paths should not affect the alarm.

What should the DevOps engineer do?

A. A Contributor Insights rule on the application logs

B. A CloudWatch Synthetics canary on /checkout

C. An X-Ray group with a filter expression for /checkout, and an alarm on its fault metric

D. A metric filter on the load balancer access logs

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A A Contributor Insights rule on the application logs

Ranks top contributors; not a fault-rate metric for one path.

B A CloudWatch Synthetics canary on /checkout

Tests synthetic requests, not real traffic's fault rate.

C An X-Ray group with a filter expression for /checkout, and an alarm on its fault metric

Groups publish metrics for only the matching traces.

D A metric filter on the load balancer access logs

Access logs go to S3, where metric filters do not apply.

REVISIT MODULE 19

One path's traced fault rate: an X-Ray group, which publishes its own metrics.

> Analysts run the same Logs Insights queries many times a day, each filtering a huge log group by requestId.
>
> Queries are slow and scan costs are rising.

What should the DevOps engineer do?

A Increase the log group's retention

B Switch the log group to the Infrequent Access class

C Export the logs to S3 every day

D Create a field index on requestId

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Increase the log group's retention

More data, not less scanning.

B Switch the log group to the Infrequent Access class

Changes ingestion price, not query scanning.

C Export the logs to S3 every day

Moves the problem and adds a pipeline.

D Create a field index on requestId

Filtered queries scan only matching events: faster and cheaper.

REVISIT MODULE 18

Repeated filters on one field: a field index cuts what each query scans.

admin@sthithapragna.com

> AWS schedules EC2 instances for retirement across 40 accounts. Each notice has a deadline, and missing it means an unplanned stop.
>
> The company wants each affected instance stopped and started automatically, at a quiet time before the deadline.

What should the DevOps engineer do?

A Email the notices to the owning teams

B An EventBridge rule on AWS Health retirement events that starts a stop-and-start Automation runbook

C An alarm that reboots the instances

D An AWS Config rule for scheduled retirements

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Email the notices to the owning teams

Manual, and easy to miss.

B An EventBridge rule on AWS Health retirement events that starts a stop-and-start Automation runbook

Acts on every notice automatically; stop and start moves the instance to new hardware.

C An alarm that reboots the instances

A reboot stays on the same host.

D An AWS Config rule for scheduled retirements

Config does not see Health events.

REVISIT MODULE 21

Announced failures: AWS Health event, rule, runbook. Stop and start moves hosts; reboot does not.

> When any production pipeline fails, the on-call team wants a message in its Slack channel and an OpsItem opened for tracking.
>
> No custom code is allowed.

Which steps meet these requirements? (Choose TWO.)

A An EventBridge rule on failed pipeline executions targeting an SNS topic mapped in Q Developer in chat applications

B A Lambda function that polls pipeline status every minute

C The same EventBridge rule, also targeting OpsCenter to create an OpsItem

D CloudTrail data events for CodePipeline

E Email the Slack channel's address

◆ PAUSE AND DECIDE

Which steps meet these requirements? (Choose TWO.)

A An EventBridge rule on failed pipeline executions targeting an SNS topic mapped in Q Developer in chat applications

Formatted Slack messages, no code.

B A Lambda function that polls pipeline status every minute

Custom code, and polling.

C The same EventBridge rule, also targeting OpsCenter to create an OpsItem

EventBridge can create OpsItems directly.

D CloudTrail data events for CodePipeline

Records API calls; notifies nobody.

E Email the Slack channel's address

Unformatted, and no OpsItem.

REVISIT MODULE 22

One event, two targets: chat notification and an OpsItem. No code needed.

> A new ECS service on Fargate fails to start. The stopped reason is CannotPullContainerError with an authorisation failure from ECR.
>
> The image exists, and the task role has full ECR permissions.

What should the DevOps engineer fix?

A Add more ECR permissions to the task role

B Enable privileged mode

C Increase the task's memory

D Give the task execution role ECR pull permissions, such as the AmazonECSTaskExecutionRolePolicy

◆ PAUSE AND DECIDE

What should the DevOps engineer fix?

A Add more ECR permissions to the task role

The task role is used by the application, after the image is pulled.

B Enable privileged mode

Not available on Fargate, and unrelated.

C Increase the task's memory

The task never started.

D Give the task execution role ECR pull permissions, such as the AmazonECSTaskExecutionRolePolicy

ECS pulls images with the execution role, before your code runs.

REVISIT MODULE 23

Fails before the code runs: execution role. The task role already had permissions: that is the planted detail.

> A developer's role has an identity policy allowing dynamodb:*. A call to CreateTable fails with an explicit deny in a permissions boundary.
>
> The developer asks for the identity policy to be widened.

What should the DevOps engineer do?

A Widen the identity policy further

B Add an allow to an SCP

C Review the permissions boundary, and allow CreateTable there if it is appropriate

D Add a resource-based policy to the table

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Widen the identity policy further

It already allows the action. The boundary caps it.

B Add an allow to an SCP

The message names a boundary, not an SCP.

C Review the permissions boundary, and allow CreateTable there if it is appropriate

The boundary is the ceiling the message names.

D Add a resource-based policy to the table

The table does not exist yet, and the boundary still caps it.

REVISIT MODULE 24

Read the policy type in the message. A boundary deny is a ceiling, not a missing grant.

admin@sthithapragna.com

> An audit finds customer managed KMS keys whose key material has not changed in years.
>
> Policy now requires key material to rotate automatically at least yearly, without re-encrypting stored data.

What should the DevOps engineer do?

A Create a new key each year and re-encrypt all data

B Enable automatic rotation on the keys

C Switch to AWS managed keys

D Import new key material each year

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Create a new key each year and re-encrypt all data

Re-encryption is what the policy wants to avoid.

B Enable automatic rotation on the keys

New material on schedule; old material kept, so old data still decrypts.

C Switch to AWS managed keys

Loses control of the key policy, and cross-account use.

D Import new key material each year

Imported material cannot rotate automatically.

REVISIT MODULE 25

Rotation keeps old material: nothing needs re-encrypting.

> A shared S3 bucket must be readable by any principal in the company's organisation, currently 300 accounts, and by nobody else.
>
> New accounts join every week.

What should the DevOps engineer put in the bucket policy?

A An allow for s3:GetObject conditioned on aws:PrincipalOrgID matching the organisation

B A list of all 300 account ARNs

C Make the bucket public and restrict it with an SCP

D Share the bucket through AWS RAM

◆ PAUSE AND DECIDE

What should the DevOps engineer put in the bucket policy?

A An allow for s3:GetObject conditioned on aws:PrincipalOrgID matching the organisation

Covers every current and future account in one condition.

B A list of all 300 account ARNs

Needs editing every week, and grows unwieldy.

C Make the bucket public and restrict it with an SCP

SCPs cannot stop outsiders reading a public bucket.

D Share the bucket through AWS RAM

S3 buckets are not shared through RAM.

REVISIT MODULE 26

'Our organisation, including new accounts': aws:PrincipalOrgID.

Answer key

- **Answer key:** 1 A, 2 C, 3 BCE, 4 D, 5 B, 6 AD, 7 C, 8 A, 9 D, 10 B
- **Answer key:** 11 BE, 12 A, 13 C, 14 D, 15 B, 16 AC, 17 D, 18 C, 19 B, 20 A
- Multiple response (3, 6, 11, 16) score only if every letter is right.
- 15 or more: on track. 13 or 14: close. 12 or fewer: revisit weak domains first.

> ON THE EXAM
>
> Each solution slide named the module to revisit. Use it for every miss.

Scoring by domain

DOMAIN	QUESTIONS	MODULES TO REVISIT
D1 SDLC Automation	1, 2, 3, 4	2, 3, 5
D2 Configuration Management and IaC	5, 6, 7, 8	9, 10, 11, 13
D3 Resilient Cloud Solutions	9, 10, 11	14, 15
D4 Monitoring and Logging	12, 13, 14	17, 18, 19
D5 Incident and Event Response	15, 16, 17	21, 22, 23
D6 Security and Compliance	18, 19, 20	24, 25, 26

ON THE EXAM

Two misses in one domain matter more than three spread across six.

MODULE 33 · EXAM STRATEGY - ALL DOMAINS

Practice Exam 3 of 4

Twenty new questions, weighted like the real exam, including multiple-response questions.

QUESTIONS 20 PASS MARK 15 of 20 HOLD 9 seconds

admin@sthithapragna.com

How to use this paper

- Pause after each question and commit to an answer before the solution appears.
- Write down your letters. Multiple-response questions need every correct letter.
- Score yourself by **domain** at the end, not only in total.
- For each miss, revisit the module named on the solution slide.

> ON THE EXAM
>
> The answer teaches the fact. The module teaches the discriminator you missed.

> A CodeDeploy in-place deployment to EC2 fails on most instances during the Install event. The error says a file already exists at the destination.
>
> An engineer had copied a hotfix onto the servers by hand. The team wants the new revision's files to win.

What should the DevOps engineer do?

A Reinstall the CodeDeploy agent

B Set ignoreApplicationStopFailures

C Lower minimum healthy hosts

D Redeploy with the file-exists behaviour set to OVERWRITE

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Reinstall the CodeDeploy agent

The agent is working; it is refusing to overwrite by default.

B Set ignoreApplicationStopFailures

For broken stop scripts, not existing files.

C Lower minimum healthy hosts

Changes how many fail at once, not why.

D Redeploy with the file-exists behaviour set to OVERWRITE

Replaces files that the last deployment did not place.

REVISIT MODULE 6

'File already exists' after manual changes: set fileExistsBehavior to OVERWRITE.

A V2 pipeline pauses at a manual approval before production. Approvals left pending over a weekend later release stale changes.

The team wants any approval not given within four hours to fail automatically, with no code.

What should the DevOps engineer configure?

A Set the approval action's timeout to 240 minutes

B A Lambda function that rejects approvals after four hours

C A DeploymentWindow rule on the stage

D An EventBridge schedule that stops the pipeline nightly

◆ PAUSE AND DECIDE

What should the DevOps engineer configure?

A Set the approval action's timeout to 240 minutes

Approval timeouts are configurable per action, from 5 minutes to 60 days.

B A Lambda function that rejects approvals after four hours

Custom code for a setting.

C A DeploymentWindow rule on the stage

Controls when deployments may run, not approval age.

D An EventBridge schedule that stops the pipeline nightly

Blunt, and stops healthy runs too.

REVISIT MODULE 2

Approval timeout is no longer fixed at seven days. Set it on the action.

> A V2 pipeline deploys a Lambda function. Each release must receive 10% of traffic for ten minutes before taking the rest.
>
> It must roll back automatically if the function's error alarm fires during that time.

Which steps meet these requirements? (Choose TWO.)

A. Route 53 weighted records across two function URLs

B. Use the CodePipeline Lambda deploy action with a canary of 10% for 10 minutes

C. Increase reserved concurrency

D. Name the error alarm in the deploy action for automatic rollback

E. An API Gateway stage canary

◆ PAUSE AND DECIDE

Which steps meet these requirements? (Choose TWO.)

A Route 53 weighted records across two function URLs

DNS weighting is imprecise and has no alarm rollback.

B Use the CodePipeline Lambda deploy action with a canary of 10% for 10 minutes

The action shifts alias traffic in the stated shape.

C Increase reserved concurrency

Controls capacity, not traffic shifting.

D Name the error alarm in the deploy action for automatic rollback

A firing alarm returns traffic to the previous version.

E An API Gateway stage canary

Splits at the API, without automatic promotion or alarm rollback.

REVISIT MODULE 7

Canary plus alarm rollback in a pipeline: the Lambda deploy action, with both configured.

> A team's GitHub Actions workflows need larger machines and access to AWS. Today they use GitHub-hosted runners and AWS access keys stored as repository secrets.
>
> The team wants to keep its workflow files unchanged in structure, remove stored keys, and run jobs on AWS compute.

What should the DevOps engineer do?

A Rewrite every workflow as a CodePipeline pipeline

B Use CodeBuild-hosted GitHub Actions runners, with jobs running under the project's service role

C Run self-managed runners on an EC2 fleet with keys in user data

D Rotate the stored keys weekly

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Rewrite every workflow as a CodePipeline pipeline

Abandons the workflows the team wants to keep.

B Use CodeBuild-hosted GitHub Actions runners, with jobs running under the project's service role

Workflows stay; jobs run on CodeBuild compute with no stored keys.

C Run self-managed runners on an EC2 fleet with keys in user data

A fleet to run, and keys still stored.

D Rotate the stored keys weekly

Still long-lived keys, and no bigger machines.

REVISIT MODULE 3

Keep GitHub Actions, run in AWS, no stored keys: CodeBuild-hosted runners.

A platform team publishes a shared npm library to CodeArtifact. Six application pipelines depend on it.

Whenever a new library version is published, every dependent pipeline must start automatically.

What should the DevOps engineer do?

A Have each pipeline poll CodeArtifact every five minutes

B Rebuild every application nightly

C An EventBridge rule on the CodeArtifact package version event, targeting the six pipelines

D Ask the platform team to message each team after publishing

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Have each pipeline poll CodeArtifact every five minutes

Polling is the legacy pattern; wasteful and delayed.

B Rebuild every application nightly

Up to a day late, and rebuilds when nothing changed.

C An EventBridge rule on the CodeArtifact package version event, targeting the six pipelines

Publishing emits an event; the rule starts every consumer.

D Ask the platform team to message each team after publishing

Manual.

REVISIT MODULE 5

Publishing a package version is an event. React to it with EventBridge.

> Instances in a stack are configured by cfn-init from AWS::CloudFormation::Init metadata. A stack update changed a configuration file in that metadata.
>
> The update succeeded, but running instances still have the old file.

What should the DevOps engineer do?

A Configure cfn-hup on the instances with a hook that re-runs cfn-init when metadata changes

B Add a CreationPolicy to the instances

C Set DeletionPolicy: Retain

D Run drift detection

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Configure cfn-hup on the instances with a hook that re-runs cfn-init when metadata changes
Running instances pick up metadata changes in place.

B Add a CreationPolicy to the instances
Waits for signals at creation; does nothing for updates.

C Set DeletionPolicy: Retain
Unrelated to configuration updates.

D Run drift detection
Would not detect file contents on the instance, nor fix them.

REVISIT MODULE 9

cfn-init runs once at launch. cfn-hup applies later metadata changes.

> A company requires that no member account can leave the organisation, and that nobody in a member account can disable or disassociate GuardDuty.
>
> This must hold even for account administrators.

Which steps meet these requirements? (Choose TWO.)

A. An SCP denying organizations:LeaveOrganization

B. A permissions boundary on administrator roles

C. An AWS Config rule that reports GuardDuty status

D. An RCP on GuardDuty detectors

E. An SCP denying GuardDuty delete, disassociate and stop actions

◆ PAUSE AND DECIDE

Which steps meet these requirements? (Choose TWO.)

A An SCP denying organizations:LeaveOrganization

Blocks leaving, for everyone in member accounts.

B A permissions boundary on administrator roles

Administrators could change it, and it misses the root user.

C An AWS Config rule that reports GuardDuty status

Detects after the fact; prevents nothing.

D An RCP on GuardDuty detectors

RCPs protect resources from outsiders; here the actors are insiders.

E An SCP denying GuardDuty delete, disassociate and stop actions

Blocks disabling GuardDuty, for everyone in member accounts.

REVISIT MODULE 12

Insiders, administrators included, must be stopped: SCPs.

> A team has 400 resources created by hand over several years across VPCs, load balancers and databases.
>
> It wants them managed by CloudFormation without recreating anything, and without writing templates by hand.

What should the DevOps engineer use?

A Write templates by hand, then import the resources

B Recreate everything with CloudFormation and migrate the data

C Export an AWS Config snapshot

D The IaC generator: scan, generate a template, then import the resources into a stack

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A Write templates by hand, then import the resources

Ruled out: no hand-written templates.

B Recreate everything with CloudFormation and migrate the data

Ruled out: nothing may be recreated.

C Export an AWS Config snapshot

Describes resources; does not create a stack.

D The IaC generator: scan, generate a template, then import the resources into a stack

Templates from what exists, adopted in place.

REVISIT MODULE 9

Existing resources, no hand-written templates, no recreation: IaC generator plus import.

admin@sthithapragna.com

A DynamoDB table in provisioned mode with auto scaling throttles during sudden flash sales, because scaling reacts too slowly.

Traffic is unpredictable, and the team wants no throttling and no capacity planning.

What should the DevOps engineer do?

A Raise the auto scaling target utilisation

B Add a DAX cluster

C Switch the table to on-demand capacity mode

D Create a global table

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Raise the auto scaling target utilisation
Leaves less headroom: more throttling.

B Add a DAX cluster
Helps reads; flash-sale writes still throttle.

C Switch the table to on-demand capacity mode
Serves sudden spikes with no capacity to plan.

D Create a global table
Multi-Region, not burst capacity.

REVISIT MODULE 15

Unpredictable spikes, no capacity planning: on-demand.

> Objects written to an S3 bucket must appear in a second Region within 15 minutes, with a service commitment and metrics to prove it.
>
> Existing objects are already replicated.

What should the DevOps engineer configure?

A Batch Replication every night

B Cross-Region Replication with Replication Time Control

C Cross-Region Replication without Replication Time Control

D AWS DataSync on a 15-minute schedule

◆ PAUSE AND DECIDE

What should the DevOps engineer configure?

A Batch Replication every night

Up to a day late.

B Cross-Region Replication with Replication Time Control

99.99% within 15 minutes, with replication metrics and events.

C Cross-Region Replication without Replication Time Control

Usually fast, but no commitment or metrics.

D AWS DataSync on a 15-minute schedule

Scheduled copying, with no replication commitment.

REVISIT MODULE 14

'Within 15 minutes, with a commitment and metrics': Replication Time Control.

> An application behind AWS Global Accelerator is moving from us-east-1 to eu-west-1. Both Regions now run healthy endpoint groups.
>
> The team wants to move traffic gradually, 10% at a time, reversible instantly, without DNS caching delays.

What should the DevOps engineer adjust?

A The traffic dial on the us-east-1 endpoint group

B Route 53 weighted records

C A CloudFront origin group

D Cross-zone load balancing

◆ PAUSE AND DECIDE

What should the DevOps engineer adjust?

A The traffic dial on the us-east-1 endpoint group

Turning it down sends that share to the other group, instantly, with no DNS involved.

B Route 53 weighted records

DNS caching delays the shift; the requirement rules it out.

C A CloudFront origin group

Fails over on errors; does not shift percentages.

D Cross-zone load balancing

Within one Region only.

REVISIT MODULE 14

Gradual Regional shift, instant, no DNS: Global Accelerator traffic dials.

admin@sthithapragna.com

> A legacy daemon on 200 EC2 instances sometimes exits silently. The instances stay healthy, so nobody notices for hours.
>
> The team wants an alarm on any instance where the daemon's process is not running.

What should the DevOps engineer do?

A. An alarm on the instances' CPU utilisation

B. An alarm on EC2 status checks

C. The CloudWatch agent's procstat plugin for the process, with an alarm when its process count drops to zero

D. X-Ray tracing

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A An alarm on the instances' CPU utilisation

A stopped daemon may barely change CPU.

B An alarm on EC2 status checks

The instances stay healthy; status checks pass.

C The CloudWatch agent's procstat plugin for the process, with an alarm when its process count drops to zero

Measures the process itself.

D X-Ray tracing

The daemon serves no traced requests.

REVISIT MODULE 17

Watch the thing that fails: a per-process metric from the agent.

> A company uses a third-party monitoring platform. It wants CloudWatch metrics for several namespaces delivered there continuously, within minutes.
>
> It wants no custom code and no API polling.

What should the DevOps engineer set up?

A. A scheduled Lambda function calling GetMetricData

B. A log subscription filter to the partner

C. Daily metric exports to S3

D. A CloudWatch metric stream through Firehose to the partner, filtered by namespace

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A A scheduled Lambda function calling GetMetricData
Custom polling code.

B A log subscription filter to the partner
Subscriptions carry logs, not metrics.

C Daily metric exports to S3
Not continuous, and there is no such export.

D A CloudWatch metric stream through Firehose to the partner, filtered by namespace
Continuous delivery of chosen metrics, no code.

REVISIT MODULE 17

Metrics out, continuously, no polling: metric streams. Logs use subscription filters.

> Customers report slow page loads in some countries, but server-side metrics look normal. The company also wants to know immediately if the sign-up page breaks, even at night with no traffic.
>
> It wants AWS-native tools and the least effort.

Which steps meet these requirements? (Choose TWO.)

A CloudWatch RUM on the web application

B VPC Flow Logs

C A CloudWatch Synthetics canary scripting the sign-up flow

D Contributor Insights on the server logs

E X-Ray tracing on the backend

◆ PAUSE AND DECIDE

Which steps meet these requirements? (Choose TWO.)

A CloudWatch RUM on the web application

Captures real users' page load times from their browsers.

B VPC Flow Logs

Network flows, not page experience.

C A CloudWatch Synthetics canary scripting the sign-up flow

Tests the page on a schedule, even with no traffic.

D Contributor Insights on the server logs

Server-side data, which already looks normal.

E X-Ray tracing on the backend

Backend only; the slowness is on the client side.

REVISIT MODULE 18

Real users' experience: RUM. Breakage with no traffic: a synthetic canary.

> A stack update failed, and the automatic rollback also failed, leaving the stack in UPDATE_ROLLBACK_FAILED.
>
> The rollback cannot restore a queue that someone deleted by hand. Every other resource is fine.

What should the DevOps engineer do?

A Delete the stack and create it again

B Continue the update rollback, skipping the deleted queue

C Run drift detection

D Recreate the queue by hand with a new name

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Delete the stack and create it again

Destroys every healthy resource to fix one.

B Continue the update rollback, skipping the deleted queue

Completes the rollback; the stack becomes usable again.

C Run drift detection

Reports the difference; does not unstick the stack.

D Recreate the queue by hand with a new name

The stack still cannot roll back.

REVISIT MODULE 23

UPDATE_ROLLBACK_FAILED: fix the cause, or skip the resource, and continue the rollback.

> A DynamoDB table's stream carries every order change. Only changes where status becomes FAILED matter; each needs customer details added before starting a Step Functions workflow.
>
> The team wants the least custom code.

What should the DevOps engineer use?

A. A Lambda function that reads the stream, filters, looks up customers and starts the workflow

B. An EventBridge rule on DynamoDB item changes

C. Kinesis Data Firehose to S3, then a nightly job

D. EventBridge Pipes: stream source, a filter on FAILED, enrichment, and a Step Functions target

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A A Lambda function that reads the stream, filters, looks up customers and starts the workflow
Works, but all of it is custom code.

B An EventBridge rule on DynamoDB item changes
Item changes are not published to the default bus.

C Kinesis Data Firehose to S3, then a nightly job
Delayed, and still custom.

D EventBridge Pipes: stream source, a filter on FAILED, enrichment, and a Step Functions target
Point to point with built-in filtering and enrichment.

REVISIT MODULE 21

One source, filter, enrich, one target: Pipes. Only the enrichment needs code.

> EC2 instances in private subnets with no internet access must read a Secrets Manager secret.
>
> The secret must also be unreadable from anywhere except through that VPC's private path.

Which steps meet these requirements? (Choose TWO.)

A Add a NAT gateway

B A Secrets Manager interface endpoint with private DNS

C Assign public IP addresses to the instances

D A gateway endpoint for Secrets Manager

E A secret resource policy denying access unless aws:SourceVpce is that endpoint

◆ PAUSE AND DECIDE

admin@sthithapragna.com

Which steps meet these requirements? (Choose TWO.)

A Add a NAT gateway

Gives internet access, which the design rules out.

B A Secrets Manager interface endpoint with private DNS

A private path from the subnets to Secrets Manager.

C Assign public IP addresses to the instances

Exposes the instances; wrong direction entirely.

D A gateway endpoint for Secrets Manager

Gateway endpoints exist only for S3 and DynamoDB.

E A secret resource policy denying access unless aws:SourceVpce is that endpoint

Locks the secret to the private path.

REVISIT MODULE 26

A private path, and a policy that insists on it: interface endpoint plus aws:SourceVpce.

> The security team's own vulnerability scanner runs weekly from known addresses. GuardDuty raises dozens of expected findings each time.
>
> The team wants those findings archived automatically, while every other finding stays visible.

What should the DevOps engineer configure?

A. A GuardDuty suppression rule matching the scanner's findings

B. Disable GuardDuty during the scan

C. Lower every finding's severity with an EventBridge rule

D. Delete the findings by hand after each scan

◆ PAUSE AND DECIDE

What should the DevOps engineer configure?

A A GuardDuty suppression rule matching the scanner's findings

Archives only the expected findings, automatically.

B Disable GuardDuty during the scan

Blinds the company to real threats during that window.

C Lower every finding's severity with an EventBridge rule

Affects all findings, and is not how severity works.

D Delete the findings by hand after each scan

Manual, every week.

REVISIT MODULE 27

Expected noise from a known source: a suppression rule, never disabling detection.

A company wants Security Hub CSPM's foundational best practices standard enabled in all 80 accounts and every Region, with three controls turned off everywhere because they do not apply.

New accounts must receive the same configuration automatically.

What should the DevOps engineer use?

A Configure each account and Region by hand

B A StackSet deploying Security Hub settings

C A central configuration policy from the Security Hub delegated administrator

D An AWS Config conformance pack

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A Configure each account and Region by hand

Hundreds of settings, and new accounts are missed.

B A StackSet deploying Security Hub settings

Reinvents the service's organisation feature.

C A central configuration policy from the Security Hub delegated administrator

Standards and controls set once, applied to all accounts, Regions and new accounts.

D An AWS Config conformance pack

Deploys Config rules, not Security Hub standards and controls.

REVISIT MODULE 27

Standards and controls across the organisation: Security Hub central configuration.

> Several load balancers use certificates imported into ACM from a third-party authority. One expired last month and caused an outage.
>
> The team wants warnings well before any imported certificate expires, with no custom code.

What should the DevOps engineer do?

A Rely on ACM's automatic renewal

B Route ACM's approaching-expiration events, or the acm-certificate-expiration-check Config rule, to an SNS topic

C A monthly review of the certificate list

D CloudTrail event history

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Rely on ACM's automatic renewal

ACM never renews imported certificates: the cause of the outage.

B Route ACM's approaching-expiration events, or the acm-certificate-expiration-check Config rule, to an SNS topic

Native warnings in advance, for imported certificates too.

C A monthly review of the certificate list

Manual, and it missed one already.

D CloudTrail event history

Records API calls, not upcoming expiry.

REVISIT MODULE 25

Imported certificates never auto-renew. Watch their expiry with native events or a Config rule.

admin@sthithapragna.com

Answer key

- **Answer key:** 1 D, 2 A, 3 BD, 4 B, 5 C, 6 A, 7 AE, 8 D, 9 C, 10 B
- **Answer key:** 11 A, 12 C, 13 D, 14 AC, 15 B, 16 D, 17 BE, 18 A, 19 C, 20 B
- Multiple response (3, 7, 14, 17) score only if every letter is right.
- 15 or more: on track. 13 or 14: close. 12 or fewer: revisit weak domains first.

> ON THE EXAM
>
> Each solution slide named the module to revisit. Use it for every miss.

Scoring by domain

DOMAIN	QUESTIONS	MODULES TO REVISIT
D1 SDLC Automation	1, 2, 3, 4, 5	2, 3, 5, 6, 7
D2 Configuration Management and IaC	6, 7, 8	9, 12
D3 Resilient Cloud Solutions	9, 10, 11	14, 15
D4 Monitoring and Logging	12, 13, 14	17, 18
D5 Incident and Event Response	15, 16	21, 23
D6 Security and Compliance	17, 18, 19, 20	25, 26, 27

ON THE EXAM

Two misses in one domain matter more than three spread across six.

MODULE 34 · EXAM STRATEGY - ALL DOMAINS

Practice Exam 4 of 4

Twenty new questions, weighted like the real exam, including multiple-response questions.

QUESTIONS 20 PASS MARK 15 of 20 HOLD 9 seconds

admin@sthithapragna.com

How to use this paper

- Pause after each question and commit to an answer before the solution appears.
- Write down your letters. Multiple-response questions need every correct letter.
- Score yourself by **domain** at the end, not only in total.
- For each miss, revisit the module named on the solution slide.

> ON THE EXAM
>
> The answer teaches the fact. The module teaches the discriminator you missed.

> A V2 pipeline validates pull requests. When several are opened together, each waits for the one before it, and feedback takes an hour.
>
> Each pull request deploys to its own isolated test stack, and runs share nothing.

What should the DevOps engineer change?

A Set the execution mode to QUEUED

B Set the execution mode to SUPERSEDED

C Set the execution mode to PARALLEL

D Add more CodeBuild compute

◆ PAUSE AND DECIDE

admin@sthithapragna.com

What should the DevOps engineer change?

A Set the execution mode to QUEUED

Queued is what makes them wait in line.

B Set the execution mode to SUPERSEDED

Newer runs would replace older ones, skipping pull requests.

C Set the execution mode to PARALLEL

Isolated runs proceed independently, so every pull request gets fast feedback.

D Add more CodeBuild compute

The runs are waiting in line, not short of compute.

REVISIT MODULE 2

Isolated runs, fast independent feedback: PARALLEL. Order matters: QUEUED.

> An ECS service uses CodeDeploy blue/green with a test listener on port 8443. Integration tests must run against the green tasks before any production traffic.
>
> If the tests fail, the deployment must roll back automatically.

Where should the tests run?

A In a Lambda function on the AfterAllowTestTraffic hook, reporting failure to CodeDeploy

B In the AfterAllowTraffic hook

C In a CodeBuild stage after the deployment completes

D In a BeforeInstall hook

◆ PAUSE AND DECIDE

Where should the tests run?

A In a Lambda function on the AfterAllowTestTraffic hook, reporting failure to CodeDeploy

Runs once green is reachable on the test listener; a failure rolls back.

B In the AfterAllowTraffic hook

Production traffic has already moved by then.

C In a CodeBuild stage after the deployment completes

Customers already reach green, and CodeDeploy has finished.

D In a BeforeInstall hook

Green is not running or reachable yet.

REVISIT MODULE 7

Test green on the test listener, before production: AfterAllowTestTraffic.

> Builds pull public base images from Docker Hub and hit its rate limits. Security also wants those images scanned inside AWS.
>
> The team wants the least operational overhead.

What should the DevOps engineer set up?

A. A nightly job copying every needed image into ECR

B. A NAT gateway with more IP addresses

C. Build base images from source in every build

D. An ECR pull through cache rule for Docker Hub, with credentials in Secrets Manager

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A. A nightly job copying every needed image into ECR
Custom, and misses newly needed images.

B. A NAT gateway with more IP addresses
Rate limits follow the account, and nothing is scanned.

C. Build base images from source in every build
Slow and wasteful.

D. An ECR pull through cache rule for Docker Hub, with credentials in Secrets Manager
Images are cached in ECR after the first pull, and ECR scanning applies.

REVISIT MODULE 5

Public registry limits, and scanning in AWS: pull through cache.

> A buildspec sets a database password as a plaintext environment variable, visible to anyone who can view the project.
>
> The password already lives in Secrets Manager, encrypted with a customer managed key.

Which steps fix this? (Choose TWO.)

A Encrypt the buildspec file in the repository

B Echo the value in the build log to confirm it works

C Reference the secret in the buildspec's secrets-manager section

D Move the value into a project environment variable of type PLAINTEXT

E Allow secretsmanager:GetSecretValue and kms:Decrypt on the service role

◆ PAUSE AND DECIDE

Which steps fix this? (Choose TWO.)

A Encrypt the buildspec file in the repository

The build needs to read it; the value is still plain.

B Echo the value in the build log to confirm it works

Exposes it further.

C Reference the secret in the buildspec's secrets-manager section

Resolved at build time; masked in logs; never stored in the project.

D Move the value into a project environment variable of type PLAINTEXT

Still visible to anyone who can view the project.

E Allow secretsmanager:GetSecretValue and kms:Decrypt on the service role

The build runs as the service role, which must be able to fetch and decrypt.

REVISIT MODULE 3

Reference, do not store. And the service role, not the developer, must be able to read it.

> A StackSet deploys a template to 30 accounts in two Regions. It succeeds in the first Region, then fails in the second with 'already exists' errors.
>
> The template gives an IAM role and an S3 bucket fixed names.

What should the DevOps engineer change?

A Increase the failure tolerance

B Include the Region in the names, or let CloudFormation generate them

C Deploy the Regions in parallel

D Switch to self-managed permissions

◆ PAUSE AND DECIDE

admin@sthithapragna.com

What should the DevOps engineer change?

A Increase the failure tolerance

Lets more stacks fail; they still collide.

B Include the Region in the names, or let CloudFormation generate them

IAM names are account-wide and bucket names global; unique names stop the collision.

C Deploy the Regions in parallel

Collides sooner.

D Switch to self-managed permissions

Permissions are not the problem.

REVISIT MODULE 10

Second Region fails with 'already exists': a globally unique name is repeated.

admin@sthithapragna.com

A central team maintains the approved AMI ID in a Parameter Store parameter in a shared services account.

Launch templates in 40 workload accounts must read that one parameter directly, always getting the current value.

What should the DevOps engineer do?

A Copy the parameter into each account with a scheduled Lambda

B Store the value in a public S3 object

C Make it an advanced-tier parameter and share it through AWS RAM

D Move the value into Secrets Manager with a resource policy

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Copy the parameter into each account with a scheduled Lambda

Copies can drift; not the one parameter.

B Store the value in a public S3 object

Public, and launch templates cannot reference it.

C Make it an advanced-tier parameter and share it through AWS RAM

Other accounts read the one shared parameter directly.

D Move the value into Secrets Manager with a resource policy

Not a secret, and launch templates resolve parameters, not secrets.

REVISIT MODULE 25

One parameter read by many accounts: advanced tier, shared with RAM.

> A service-managed StackSet targets the organisation root with a security baseline. Every member account received it.
>
> The management account did not, and auditors require the baseline there too.

What should the DevOps engineer do?

A Deploy the template to the management account as a separate stack

B Retry the StackSet operation

C Move the management account into an OU

D Increase maximum concurrent accounts

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Deploy the template to the management account as a separate stack

Service-managed StackSets never deploy to the management account, by design.

B Retry the StackSet operation

It will skip the management account again.

C Move the management account into an OU

It is still the management account, and still skipped.

D Increase maximum concurrent accounts

Speed is not the problem.

REVISIT MODULE 10

Missing only in the management account: expected behaviour. Deploy there separately.

A company with 70 accounts needs daily backups of all resources tagged backup=daily, kept 35 days, and copied to a central vault in a separate backup account.

New accounts must be covered automatically.

What should the DevOps engineer use?

A A backup plan created by hand in each account

B A Lambda function in each account taking snapshots

C Data Lifecycle Manager policies for EBS only

D An AWS Organizations backup policy with a cross-account copy rule to the central vault

◆ PAUSE AND DECIDE

What should the DevOps engineer use?

A. A backup plan created by hand in each account
Seventy set-ups, and new accounts are missed.

B. A Lambda function in each account taking snapshots
Custom, per service, and per account.

C. Data Lifecycle Manager policies for EBS only
EBS only, and no cross-account vault copy.

D. An AWS Organizations backup policy with a cross-account copy rule to the central vault
Applied to every account by tag, including new ones, with copies to the central vault.

REVISIT MODULE 16

Same backup plan everywhere, including new accounts, with central copies: an organisation backup policy.

> An application on Amazon RDS for PostgreSQL Multi-AZ suffers several minutes of errors after each failover, although the failover itself completes in about a minute.
>
> Investigation shows the application keeps using stale connections and cached DNS.

Which steps reduce the impact of failover? (Choose TWO.)

A Put RDS Proxy in front of the database

B Move to a larger instance class

C Disable Multi-AZ

D Use a short DNS cache time, and retry with backoff on connection errors

E Add a read replica

◆ PAUSE AND DECIDE

Which steps reduce the impact of failover? (Choose TWO.)

A Put RDS Proxy in front of the database

Clients stay connected to the proxy while it reconnects to the new primary.

B Move to a larger instance class

Size does not affect stale connections.

C Disable Multi-AZ

Removes automatic failover altogether.

D Use a short DNS cache time, and retry with backoff on connection errors

Clients find the new primary quickly and recover without a stampede.

E Add a read replica

Serves reads; does not help writers reconnect.

REVISIT MODULE 15

The database recovered in a minute; the clients took minutes. Fix the clients' path back.

> A team ran an AWS FIS experiment that stopped instances in one Availability Zone. Customer errors spiked, but the experiment kept running for its full 30 minutes.
>
> Future experiments must halt automatically if customers are affected.

What should the DevOps engineer add?

A A shorter experiment duration

B A stop condition using a CloudWatch alarm on the customer error rate

C A manual approval before each experiment

D Run experiments only at night

◆ PAUSE AND DECIDE

What should the DevOps engineer add?

A. A shorter experiment duration
Still runs regardless of harm, just for less time.

B. A stop condition using a CloudWatch alarm on the customer error rate
Halts the experiment as soon as customers are affected.

C. A manual approval before each experiment
Approves the start; stops nothing mid-run.

D. Run experiments only at night
Fewer customers, but still no automatic halt.

REVISIT MODULE 16

Halt on harm: an FIS stop condition tied to an alarm.

> An API's latency alarm uses the Average statistic and never fires. Yet a steady share of customers complain that requests take several seconds.
>
> Most requests are fast, so the average stays low.

What should the DevOps engineer change?

A Alarm on the p99 latency percentile

B Lower the average threshold

C Use the Sum statistic

D Use a longer period

◆ PAUSE AND DECIDE

admin@sthithapragna.com

What should the DevOps engineer change?

A **Alarm on the p99 latency percentile**
Reflects the slowest requests that averages hide.

B **Lower the average threshold**
Starts firing on normal traffic while still blurring the slow tail.

C **Use the Sum statistic**
Sums latency, which grows with traffic, not slowness.

D **Use a longer period**
Smooths even more of the slow tail away.

REVISIT MODULE 18

Averages hide the tail. Alarm on a high percentile for user experience.

> Containers on ECS with Fargate must send logs to CloudWatch Logs and, filtered to errors only, to a third-party log platform.
>
> The team wants a managed pattern without changing application code.

What should the DevOps engineer use?

A The awslogs driver alone

B A metric stream to the partner

C FireLens with Fluent Bit routing to both destinations, filtering the partner output

D Have the application write to both platforms

◆ PAUSE AND DECIDE

admin@sthithapragna.com

What should the DevOps engineer use?

A The awslogs driver alone

Sends to CloudWatch only; no second destination or filtering.

B A metric stream to the partner

Carries metrics, not logs.

C FireLens with Fluent Bit routing to both destinations, filtering the partner output

A sidecar router with multiple outputs and filters, configured in the task definition.

D Have the application write to both platforms

A code change, which is ruled out.

REVISIT MODULE 17

Several log destinations, with filtering, from containers: FireLens.

admin@sthithapragna.com

A company needs every application log from 50 accounts kept for five years in a central account. Operators also want to search recent logs across all accounts from a monitoring account, in the same Region.

It wants the least operational overhead.

Which steps meet these requirements? (Choose TWO.)

A Nightly export tasks from every log group

B CloudWatch Logs centralisation rules copying to the central account

C Cross-account observability links to the monitoring account

D A metric stream from every account

E Subscription filters on every log group, streaming to Kinesis

◆ PAUSE AND DECIDE

Which steps meet these requirements? (Choose TWO.)

A Nightly export tasks from every log group
Batch jobs to schedule everywhere.

B CloudWatch Logs centralisation rules copying to the central account
The retained copy, organisation-wide, with no code.

C Cross-account observability links to the monitoring account
Operators search logs in place, without copying.

D A metric stream from every account
Metrics, not logs.

E Subscription filters on every log group, streaming to Kinesis
Works, with far more to build and run.

REVISIT MODULE 17

Retain: copy with centralisation. Search in place: cross-account observability. Two needs, two tools.

> Workloads run in us-west-2 and eu-west-1. The central operations team's automation listens on an event bus in us-east-1.
>
> GuardDuty findings from both Regions must reach that bus with the least effort.

What should the DevOps engineer set up?

A. A Lambda function in each Region that re-publishes findings

B. Move all workloads to us-east-1

C. Poll GuardDuty in each Region every minute

D. In each Region, a rule on GuardDuty findings targeting the us-east-1 event bus

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A A Lambda function in each Region that re-publishes findings

Custom code for a native feature.

B Move all workloads to us-east-1

Absurd scope for routing events.

C Poll GuardDuty in each Region every minute

Polling instead of events.

D In each Region, a rule on GuardDuty findings targeting the us-east-1 event bus

EventBridge can send events to a bus in another Region directly.

REVISIT MODULE 21

Events from many Regions to one bus: a rule in each Region targeting that bus.

> A remediation must snapshot an EBS volume, wait until the snapshot completes, which can take hours, then detach and delete the volume.
>
> It must be triggered automatically from a Config rule and retry failed steps.

What should implement the remediation?

A. A single Lambda function that waits for the snapshot

B. A Systems Manager Automation runbook with a wait step, used as the Config remediation action

C. An EventBridge rule that deletes the volume immediately

D. A cron job on an instance

◆ PAUSE AND DECIDE

What should implement the remediation?

A — A single Lambda function that waits for the snapshot

Lambda stops after 15 minutes; snapshots can take hours.

B — A Systems Manager Automation runbook with a wait step, used as the Config remediation action

Runbooks can wait for a resource state for hours, retry steps, and are Config's native remediation target.

C — An EventBridge rule that deletes the volume immediately

Deletes before the snapshot exists.

D — A cron job on an instance

A server to run, and not triggered by Config.

REVISIT MODULE 22

Long waits, retries, triggered by Config: an Automation runbook as the remediation.

admin@sthithapragna.com

> A Lambda function in private subnets with no NAT gateway must read objects from S3 and send messages to SQS. Both calls time out.
>
> Permissions are correct, and the company will not add internet access.

Which steps fix both calls? (Choose TWO.)

A An S3 gateway endpoint on the subnets' route tables

B Increase the function timeout

C Move the function into public subnets

D Set reserved concurrency

E An SQS interface endpoint with private DNS

◆ PAUSE AND DECIDE

Which steps fix both calls? (Choose TWO.)

A An S3 gateway endpoint on the subnets' route tables

A free private route to S3.

B Increase the function timeout

There is no route; calls just fail more slowly.

C Move the function into public subnets

Lambda gets no public IP there either.

D Set reserved concurrency

Unrelated to network paths.

E An SQS interface endpoint with private DNS

A private path to SQS, which has no gateway endpoint.

REVISIT MODULE 23

Two services, two private paths: a gateway endpoint for S3, an interface endpoint for SQS.

A CloudTrail trail in account A delivers logs to a bucket in a log archive account. The bucket policy allows the CloudTrail service principal to write.

Security wants to ensure only that specific trail can write, so no other account's trail could use the bucket.

What should the DevOps engineer add to the bucket policy?

A An sts:ExternalId condition

B A condition requiring MFA

C A condition on aws:SourceArn matching the trail's ARN

D A condition on aws:SourceIp

◆ PAUSE AND DECIDE

What should the DevOps engineer add to the bucket policy?

A An sts:ExternalId condition

External IDs are for third-party role assumption, not service principals.

B A condition requiring MFA

A service principal cannot use MFA.

C A condition on aws:SourceArn matching the trail's ARN

The service may write only on behalf of that trail: no confused deputy.

D A condition on aws:SourceIp

Service requests do not come from your addresses.

REVISIT MODULE 24

An AWS service acting for you: aws:SourceArn or aws:SourceAccount. A third party: ExternalId.

> A new customer managed KMS key protects payroll data. Security requires that key administrators can manage the key but never decrypt, and that the payroll application can decrypt but never change the key.
>
> Both groups work in the same account.

How should the key policy be written?

A Separate statements: management actions for the admin role, and Decrypt for the application role

B kms:* for both roles

C An AWS managed key instead

D Grant both roles through IAM policies only, with no key policy statements

◆ PAUSE AND DECIDE

How should the key policy be written?

A Separate statements: management actions for the admin role, and Decrypt for the application role

Each principal gets only its own set of actions.

B kms:* for both roles

Gives each group the other's powers.

C An AWS managed key instead

Its policy cannot be customised at all.

D Grant both roles through IAM policies only, with no key policy statements

Works only if the key policy enables IAM, and then IAM admins could grant themselves decrypt.

REVISIT MODULE 25

Separation of duties on a key: separate key policy statements for administrators and users.

> Security wants to know which EC2 instances are reachable from the internet on any open port, and which of those also run vulnerable software.
>
> It wants this continuously, across many accounts, with no scanning agents to deploy beyond what is already there.

What should the DevOps engineer enable?

A VPC Flow Logs analysed with Athena

B Amazon Inspector, organisation-wide, for EC2 vulnerability and network reachability findings

C GuardDuty Runtime Monitoring

D Security groups reviewed monthly

◆ PAUSE AND DECIDE

What should the DevOps engineer enable?

A VPC Flow Logs analysed with Athena

Shows traffic that happened, not reachability or software.

B Amazon Inspector, organisation-wide, for EC2 vulnerability and network reachability findings

Reachability and vulnerabilities, combined and continuous.

C GuardDuty Runtime Monitoring

Detects active threats, not exposure or vulnerable packages.

D Security groups reviewed monthly

Manual, and ignores software.

REVISIT MODULE 27

Exposed and vulnerable: Inspector's reachability plus vulnerability findings.

> Auditors require that CloudTrail logs can be proven unaltered, and cannot be deleted by anyone for seven years. And no member account may stop the organisation trail.
>
> The company uses Organizations with a log archive account.

Which steps meet these requirements? (Choose THREE.)

A Enable CloudTrail log file validation

B Enable CloudTrail Insights

C S3 Object Lock in compliance mode with seven-year retention on the log bucket

D An SCP denying cloudtrail:StopLogging and DeleteTrail

E Amazon Macie on the log bucket

◆ PAUSE AND DECIDE

Which steps meet these requirements? (Choose THREE.)

A Enable CloudTrail log file validation
Digest files prove whether logs were altered.

B Enable CloudTrail Insights
Flags unusual activity; proves nothing about integrity.

C S3 Object Lock in compliance mode with seven-year retention on the log bucket
Nobody, including root, can delete the logs early.

D An SCP denying cloudtrail:StopLogging and DeleteTrail
No member account can stop the trail.

E Amazon Macie on the log bucket
Finds sensitive data; protects nothing.

REVISIT MODULE 27

Proven, undeletable, unstoppable: validation, Object Lock, and an SCP.

Answer key

- **Answer key:** 1 C, 2 A, 3 D, 4 CE, 5 B, 6 C, 7 A, 8 D, 9 AD, 10 B
- **Answer key:** 11 A, 12 C, 13 BC, 14 D, 15 B, 16 AE, 17 C, 18 A, 19 B, 20 ACD
- Multiple response (4, 9, 13, 16, 20) score only if every letter is right.
- 15 or more: on track. 13 or 14: close. 12 or fewer: revisit weak domains first.

> ON THE EXAM
>
> Each solution slide named the module to revisit. Use it for every miss.

Scoring by domain

DOMAIN	QUESTIONS	MODULES TO REVISIT
D1 SDLC Automation	1, 2, 3, 4	2, 3, 5, 7
D2 Configuration Management and IaC	5, 6, 7	10, 25
D3 Resilient Cloud Solutions	8, 9, 10	15, 16
D4 Monitoring and Logging	11, 12, 13	17, 18
D5 Incident and Event Response	14, 15, 16	21, 22, 23
D6 Security and Compliance	17, 18, 19, 20	24, 25, 27

ON THE EXAM

Two misses in one domain matter more than three spread across six.